

ANNUAL REPORT

2023

www.gdpd.it

Pasquale Stanzione, President

Ginevra Cerrina Feroni, Vice President

Agostino Ghiglia, Member

Guido Scorza, Member

Fabio Mattei, Secretary General

Piazza Venezia, 11

00187 Rome

Tel. 06 696771

e-mail: protocollo@gdpd.it

www.gdpd.it

Annual Report

2023

Table of Contents

VII

Table of ContentsANNUAL REPORT 2023TABLE OF CONTENTS

Collegial measures 634

1,595

IMI Procedures

263

59

Decisions on complaints

Opinions on regulatory and administrative acts

2,037

Notified personal data breaches

and reports

9,281

Responses to complaints

and reports

506

Responses to inquiries

€ 7,977,343

Fines collected

144

Inspections

The numbers

of 2023

7

Communications

to the judicial authority

235

International meetings

15,048

SRP contacts

79

Press releases and

Newsletters

4,263,357

Accesses to

the website

I - STATUS OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION

1. Introduction

2. The regulatory framework on personal data protection

2.1. The laws

2.2.

2.3.

Decrees-law

Legislative decrees

3. Relations with Parliament and other institutions

3.1. The advisory activity of the Guarantor

3.1.1. The consultation of the Guarantor in the legislative procedure or in the exercise of the knowledge, guidance, and control functions of the Chambers

3.1.2. The consultation of the Guarantor on primary state regulatory acts: opinions to the Government on draft laws and legislative decree drafts

3.1.3. Opinions on regulatory or administrative acts in general

3.1.4. The consultation of the Guarantor on regional or autonomous province regulatory acts

3.1.5. Reports

3.1.6. Inquiries

3.2. Consultation through the IMI platform

3.3.

3.4. Examination of regional laws for constitutional scrutiny by the Government

Contribution to the Government for responses to acts of inspection oversight

II - THE ACTIVITY CARRIED OUT BY THE GUARANTOR

4. The Guarantor and public administrations

4.1. Tax, fiscal, and anti-money laundering activities

4.1.1. The pre-filled tax return

4.1.2. Anti-money laundering

4.2. Social security, social assistance, and other economic benefits

4.3. The protection of personal data in the school and university sectors

4.4. Transparency and publicity of administrative action

4.4.1. The publication of personal data online by public administrations

4.4.2. Civic access

4.5. Processing of personal data carried out by central administrations, regions, and local authorities

4.5.1. Processing of personal data carried out by central administrations

4.5.2. Processing of personal data carried out by regions and local authorities

4.5.2.1. Environment

4.5.2.2. Mobility and transport

4.5.3. Exercise of rights

4.6. Processing for administrative purposes

4.7. Online services and security measures

4.8.

4.9. Professional orders

The DPO in the public sector

3

16

16

19

23

26

26

26
27
27
29
30
30
30
31
31
35
35
35
37
38
39
42
42
43
47
47
49
49
50
50
51
52
53
53
VII

Table of ContentsANNUAL REPORT 2023TABLE OF CONTENTS

4.10. Digitalization of public administration

4.11. The demographic and electoral matters

4.12. Processing of personal data in the public sector through video devices

5. Health

5.1. Digital health

The electronic health record

The health dossier

5.1.1.

5.1.2.

5.1.3. Telemedicine

5.2. The use of artificial intelligence in health

5.3. Processing of personal data within central health information systems

5.4. Processing for care purposes and administrative matters related to care

5.4.1. Measures resulting from data breaches

5.4.2. Measures resulting from complaints and reports

5.4.3. Measures resulting from office-initiated investigations

5.4.4. Measures relating to the processing of personal data carried out in the context of the health emergency

5.5. Processing for purposes other than care and/or administrative matters related to care

5.6. Exercise of rights

6. Scientific research

6.1. Measures adopted pursuant to Article 110 of the Code	
6.2. Clarifications regarding Article 110-bis, paragraph 4, of the Code	
6.3. Other measures concerning processing for scientific research purposes	
7. Statistics	
7.1. Official statistics	
8. Processing in the judicial and security sectors	
8.1. Processing in the judicial sector	
8.2. Processing by law enforcement agencies	
8.3. Opinions provided on draft decrees in the judicial sector or in relation to	
8.4.	
8.5. police activities	
Control over the CED of the Department of Public Security	
Control over the Schengen Information System	
8.5.1. Follow-up of the Schengen evaluation concerning Italy	
8.5.2. The control and monitoring activity on SIS II	
9. Journalistic activity	
9.1. Statistical data and procedural aspects	
9.2. Processing of data in the exercise of journalistic activity	
Unlawful dissemination of health data	
9.2.1. Judicial data	
9.2.2.	
9.2.3. Data relating to minors	
9.2.4. Data of public figures	
9.2.5. News of significant public interest and respect for the essentiality of information	
9.2.6. Requests for deletion addressed to publishers	
9.3. Processing of data by search engines	
VIII	
54	
57	
58	
60	
60	
60	
63	
64	
65	
67	
70	
70	
74	
79	
80	
81	
84	
86	
86	
92	
93	
96	
96	
99	
99	

101
101
103
103
103
104
105
105
106
106
106
107
108
109
111
112

Table of ContentsANNUAL REPORT 2023TABLE OF CONTENTS

10. Cyberbullying and Revenge Porn

11. Marketing and Processing of Personal Data

11.1. The phenomenon of unwanted telemarketing and counteraction

11.1.1. Illegal telemarketing in the telecommunications sector

11.1.2. Illegal telemarketing in the energy sector

11.1.3. Illegal activation of telephone cards

11.1.4. Use of call centers located outside the European Union

11.1.5. Evolving scenarios in the illegal telemarketing sector: the code of conduct

11.1.6. Marketing and profiling

11.1.7. Marketing through dark patterns and illegal databases

11.1.8. Activities carried out in the context of consumer protection in electronic communication services

12. Electronic Communication Services and the Internet

12.1. Meta Election Day Information (EDI)

12.2. Retention of traffic data

12.3. Data retention for judicial purposes

12.4. Cookies and other tools for tracking personal data

12.5. Processing of personal data online

12.6. Processing of personal data through connected devices

12.7. Activities regarding data processing through artificial intelligence systems

12.8. Final decision schemes pursuant to Art. 60, paras. 7 or 8, of the GDPR

12.9. European cooperation procedures regarding cross-border processing of personal data carried out by information society service providers

13. The Protection of Personal Data in Private and Public Employment

13.1. Processing of data via email

13.2. Exercise of rights

13.3. Processing of biometric data

13.4. Processing of health data

13.5. Video surveillance in private sector workplaces

13.6. Publication of data on the internet

13.7. Processing of data through technological devices

13.8. Processing of data in the context of acquisition procedures and management of reports of wrongdoing (so-called whistleblowing)

13.9. The protection of data in the context of public employment

13.9.1. Processing of data for the purpose of establishing and managing the employment relationship

13.9.1.1. Processing of data in the context of competitive procedures

- 13.9.1.2. Processing of data carried out during the verification of vaccination requirements for healthcare professionals
- 13.9.1.3. Communication of data to third parties and circulation of information in workplace contexts
- 13.9.1.4. Online dissemination of employee data
- 13.9.2. Personal data of employees in public databases
- 14. Economic Activities
 - 14.1. Processing of data in the insurance sector
 - 14.2. Processing of data in the banking-financial sector and credit information systems
 - 14.3. Enterprises
 - 14.4. Public service concessionaires
 - 14.5. IMI procedures related to data processing in the economic-productive sector
- 15. Other Processing in the Private Sector
 - 15.1. Processing of personal data in the context of condominiums
 - 15.2. Processing of data by associations and foundations
 - 15.3. Video surveillance in the private sector
- 16. Artificial Intelligence and the Right to Personal Data Protection
- 17. Personal Data Breaches
- 18. The Transfer of Personal Data Abroad
- 19. Inspection Activities
 - 19.1. Inspection activities between programming and contingencies
 - 19.2. Online checks on so-called guidelines regarding cookies
 - 19.3. Collaboration with the Financial Police
- 20. Jurisdictional Litigation
 - 20.1. General considerations
 - 20.2. Objections to the measures of the Guarantor and the most significant judicial decisions
 - 20.3. The contribution of the Guarantor in proceedings regarding data protection
- 21. Community and International Relations
 - 21.1. Cooperation between data protection authorities in the European Economic Area: the European Data Protection Board
 - 21.2. Cooperation of data protection authorities in the area of freedom, justice, and home affairs
 - 21.2.1. Coordinated control committee
 - 21.2.2. Supervisory group of the EUODAC system
 - 21.2.3. Coordination group for the supervision of the Customs Information System
 - 21.3. The Authority's participation in the Council of Europe, the OECD, and other international working groups
 - 21.4. International and European Conferences
 - 21.5. Preliminary questions before the Court of Justice of the European Union
 - 21.6. Projects for the application of the GDPR funded by the European Union
- 22. International and National Technical Standardization Activities
- 23. Communication, Information, and Public Relations Activities
 - 23.1. The Guarantor's communication: general profiles
 - 23.2. Informational products
 - 23.3. The institutional website, multimedia products, and publications
 - 23.4. Events and conferences
 - 23.5. International activities
 - 23.6. Public assistance and the preparation of new informational tools
- III - THE OFFICE OF THE GUARANTOR
 - 24. Study and Documentation Activities
 - 25. Administrative Management and Information Systems
 - 25.1. The budget and economic-financial management of the Authority
 - 25.2. Contractual activities, logistics, and maintenance of the property
 - 25.3. Organization of the Office

25.4. "Transparent administration" and compliance with anti-corruption regulations

25.5. The IT-technological sector and digital transition

IV - STATISTICAL DATA

List of the most common abbreviations and acronyms

ARERA

AGCM

AGCOM

AgID

annex

ANAC

art.

BCR

c.c.

cf.

considering

C.d.S.

c.p.

c.p.c.

c.p.p.

CAD

cap.

CDFUE

so-called

CEDU

Regulatory Authority for Energy, Networks and Environment

Antitrust Authority

Authority for Communications Guarantees

Agency for Digital Italy

attached document

National Anti-Corruption Authority

article

Binding Corporate Rules

Civil Code

compare

considering

Council of State

Criminal Code

Code of Civil Procedure

Code of Criminal Procedure

Digital Administration Code

chapter

Charter of Fundamental Rights of the European Union

so-called

European Convention on Human Rights and Fundamental Freedoms

EDPB or European Data Protection Board

cf.

CJEU

cited

Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC (Legislative Decree June 30,

2003, No. 196, as amended by Legislative Decree August 10, 2018, No. 101)

European Court of Human Rights

Constitution

draft law

decree-law

legislative decree

ministerial decree

decree of the President of the Council of Ministers

decree of the President of the Republic

document

ECHR

Constitution

d.d.l.

d.l.

d.lgs.

d.m.

d.P.C.M.

d.P.R.

doc.

XII

2023 REPORT

e.g.

FAQ

EHR

EDPB

Article 29 Working Party

G.U.

OJEU

AI

IMI

IVASS

IWGDPT

law

letter

Ministry of Economy and Finance

number

page

public administration/public administrations

paragraph

certified electronic mail

National Recovery and Resilience Plan

provision of the Guarantor

royal decree

regulation

Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016,

concerning the protection of natural persons with regard to the processing of personal data, as well as

the free movement of such data and repealing Directive 95/46/EC (General Data Protection

Regulation)

Data Protection Officer

Public Opposition Register

Head of the Prevention and Protection Service

European Economic Area

Section

Public Digital Identity System

National Health Service

table

Advisory Committee of the Council of Europe Convention No. 108/1981

consolidated text

Treaty on the Functioning of the European Union

European Union

Uniform Resource Locator

see

XIII

2023 REPORT

State of implementation of the Code

regarding the protection

of personal data

ANNUAL REPORT

2023

I - State of implementation

of the Code regarding

the protection of personal data

1

Introduction

1 Executive Summary

The activity of the Guarantor in 2023 took place in a context characterized by elements with a strongly innovative component, but it also continued along a line of continuity. Three are the most representative among the first, in summary: digitalization, artificial intelligence, National Recovery and Resilience Plan. These are elements that have led, at the national level, to a significant push to accelerate all processes, including administrative ones, and therefore also the response of the Guarantor to requests from public and private entities that, each in their own part, have been involved in such processes. However, some constants characterized the Authority's work last year, thus confirming themselves as essential features of the national data protection scenario; in this case, we can identify a triad: combating marketing up a direct dialogue between parliamentarians and the Garante on highly relevant issues; the hearings held by the President of the Authority before the competent Committees of the Chamber and Senate, as well as the submissions made in relation to exploratory inquiries, covered a wide range of significant topics – from the annual law for the market and competition to the use of wiretaps, and even initiatives to counter the challenges posed by resistance in online social networks. Furthermore, the Authority did not fail to highlight, through its reports to the Government, certain gaps in secondary legislation that have long awaited rectification, particularly concerning the recognition of personal data processing in judicial and police activities, also for the purpose of exercising rights by the data subjects (see para. 3.1.5).

If it is true that the processes of digitalization have long characterized the landscape of data protection, it is equally true that they have brought about new challenges that require constant attention and adaptation. The Garante has sought to address these challenges through various initiatives aimed at ensuring that the principles of data protection are upheld in the face of rapid technological advancements.

In conclusion, the Garante remains committed to its mission of protecting personal data and ensuring compliance with data protection regulations, while also advocating for the necessary resources to effectively carry out its duties in an increasingly complex and dynamic environment.

****STATE OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION****

up a dialogue directly between MPs and the Garante on very topical issues. The President of the Garante was heard by the competent Committees at both the Chamber of Deputies and the Senate, and briefings were submitted as part of fact-finding inquiries carried out by Parliament on highly diverse as well as important topics – from the annual market and competition law to the use of wiretapping records, up to measures aimed at countering challenges on social media. On the other hand, the Garante did not fail to draw the Government's attention to loopholes in secondary legislation that have long been in need of being cured – with particular regard to processing operations in law enforcement activities, also in order to regulate the exercise of data subject rights (see para. 3.1.5).

Digitalisation has become since long a feature in Italy's economic and social landscape; however, it is unquestionable that the pace of its development gained momentum over the past year due to several concurrent reasons – first and foremost, the need to make use of the funds made available through the national recovery and resilience plan along with the pervasive reliance on technology that partakes, generally speaking, of 'artificial intelligence'. Within this framework, the Garante played the advisory role it is called upon to discharge as for the introduction of new functions in delivering online services to citizens. Those functions are basically intended to simplify and streamline access to public administration services, which raises, in turn, several questions as to proportionality and necessity of the processing of personal data as well as regarding allocation of competence. By way of example, reference can be made to the centralised management of digital identity credentials (CIEId), the single digital gateway (SDG) enabling cross-border transfer of evidence, and the unified platform for the digital service of administrative instruments (see para. 4.10). Still from this perspective, the Garante continued working on processing activities by the Italian Revenue Agency, which are grounded generally speaking in the once-only principle and accordingly envisage the exchange of information between public administrative bodies to ensure that pre-completed tax returns contain accurate as well as complete information (see para. 4.1.1); the national Index of residents including its multiple components was also the subject of in-depth assessment.

It is worth mentioning here that the Garante imposed a reprimand along with corrective measures on ISTAT, the Italian statistics agency (see para. 7.1), since it was found not to have implemented some of the measures the Garante had previously set out in a decision of 2020 concerning the national census survey. Those measures were aimed at having pseudonymisation techniques in place that could ensure compliance with data minimisation and purpose limitation requirements in handling the huge.

****Limitation of Purpose in the Management****

of the enormous amount of information entrusted to the Institute.

Even in the health sector, the reform of the electronic health record 2.0 and the implementation of the national telemedicine system, which are part of the actions for the implementation of Mission 6 (Health) of the PNRR and presuppose the interconnection between health information systems in a perspective of digitalization, have led the Garante to reiterate the necessity of coordinating the technical and organizational measures to be introduced to protect fundamental rights and general principles of processing. Also significant is the publication of a decalogue for the realization of national health services through artificial intelligence systems (see para. 5.2), which provided guidance on the legal and ethical profiles to be considered in the realization of national health services that involve the use of AI solutions (see Chapter 16). The Garante reminded that AI applications involve profiling activities and can generate decisions based on fully automated processes that, in a public interest context such as that characterizing health care, require a legal basis in national law that ensures respect for the rights and freedoms of the data subjects. Moreover, these same principles have also been recalled concerning some of the projects included in the national statistical program (see para. 7.1) on which the Garante has expressed the required opinion, as they foresee the use of machine learning techniques for data analysis that cannot disregard, in particular, a qualified human intervention for the supervision of algorithmic results and must not lead to forms of discrimination by these latter.

In light of the constant attention paid by the Garante to vulnerable subjects and the protections that

must be afforded, particular relevance is given to the indications provided regarding some government-initiated initiatives undertaken.

****STATE OF IMPLEMENTATION OF THE CODE REGARDING PERSONAL DATA PROTECTION****

involving women who had undergone a termination of pregnancy, identifying them on students' platforms, which is aimed to provide ad-hoc digital services to uphold the right to education and simplify the granting of benefits to families and students, or the newly introduced benefits for people in need of financial support (i.e., the 'assegno di inclusione' and 'supporto per la formazione e il lavoro') which superseded the so-called 'citizenship income' and 'citizenship pension' minimum income schemes (see para. 4.3). Consistently with previous decisions, the Garante stepped in to lay out such adjustments and improvements as were found to be necessary in the individual cases to ensure compliance with fundamental proportionality and necessity requirements as to the information to be processed along with adequate data governance measures; the latter included a more granular allocation of responsibilities among the many stakeholders that are involved in the processes to grant those benefits to individuals deserving protection and support. In this connection, one of the areas the Garante has consistently covered is related to transparency and openness of administrative activities with particular regard to FOIA-type access requests and the increasing number of opinions issued to ombudspersons and managers of anti-corruption measures. In those opinions, indeed throughout those activities, the Garante has aimed to strike a balance between administrative openness requirements and protection of the right to privacy in its multifarious configurations (see para. 4.4.2) – in line with the guidelines that were published jointly by the Garante and ANAC (the national anti-corruption authority) in 2016. Reference should also be made to a few decisions in which the Garante addressed especially heinous as well as serious infringements of data protection legislation which had been committed by public bodies and administrative agencies to the detriment of highly vulnerable individuals. This is particularly the case with the decisions issued following dissemination of information.

****Labels Affixed to the Burials of Fetuses****

(see paras. 4.6 and 5.5), as well as the many cases of data breaches in the healthcare sector that have led to the dissemination of substantial volumes of particularly sensitive information due to the flawed or negligent implementation of adequate technical and organizational security measures (see para. 5.4.1). On the other hand, a considerable number of proceedings were closed in 2023 regarding complaints and reports made by individuals over fifty who had been subject to administrative sanctions for failing to comply with vaccination obligations related to the COVID-19 pandemic, identifying suitable methods to prevent, both towards the Revenue Agency and the Ministry of Health, the communication of excessive information regarding the health status of the complainants (see para. 5.4.4).

****Protection of Personal Data in the Workplace****

Also very relevant in this same area, focused on vulnerable subjects, is the activity aimed at ensuring the protection of personal data in both public and private workplaces. Numerous measures, as in the past, were taken regarding processing activities carried out in the preparatory phases for establishing an employment relationship as well as during the duration of such a relationship, especially concerning the use of email in the workplace and the deployment of video surveillance systems (see para. 13.1); in all these cases, the Authority intervened taking into account the close connection between the performance of work activities and the development of the worker's personality, as well as the difficulties in tracing, especially in light of the pervasiveness of the use of digital technologies in public and private sectors, a clear boundary between the professional/work environment and the strictly private sphere. On this basis, the Garante indicated the necessity for employers to carefully consider the principles of accountability and necessity of processing, especially where remote monitoring of workers may be configured.

****1STATO DI ATTUAZIONE DEL CODICE IN MATERIA DI PROTEZIONE DEI DATI PERSONALI****

worker. It is worth recalling in this context two guiding documents developed during the year – one dedicated to the management of electronic mail in the workplace and the processing of metadata (see para. 13.7), the other drafted in collaboration with ANAC and dedicated to the management of

procedures related to so-called whistleblowing (see para. 13.8) – as both combine attention to the protection of vulnerable subjects (such as employees) with the correct use of digital tools. Furthermore, once again from the perspective of digital innovation, the opinion issued by the Authority (on an urgent basis) regarding the operational modalities of the unified recruitment portal that all public administrations are required to use starting in 2023 (see para. 13.9.2) allowed the Garante to indicate a series of specific technical and organizational measures capable of mitigating the high risks to the rights and freedoms of data subjects that the use of the portal entails, given that it may also include data belonging to special categories or relating to criminal convictions and offenses.

Despite a certain fragmentation of cases regarding the many complaints and reports concerning processing carried out by companies and private entities in general, it is still possible to identify some constants in this field as outlined in the initial paragraphs. In many cases, the complaints have concerned, according to a well-established tradition, the partial or denied response to access requests made by data subjects, particularly in the banking and insurance sectors, sometimes also in relation to inheritance issues or various types of litigation – responses that turned out to be erroneous because the grounds for limiting access often proved to be non-existent (see paras. 14.1, 14.2). Moreover, the Garante has had the opportunity to examine complex issues related to the difficult interaction between the legislation protecting financial interests and combating money laundering and that protecting privacy (see para. 14.2); here the Garante reaffirmed the importance of striking the right balance between preventing money laundering in accordance with due diligence requirements and ensuring the protection of personal data.

****par. 14.2)****, reiterating the importance of finding a proper balance between the interest in preventing money laundering within the logic of due diligence and the interests underlying the fundamental rights to data protection and privacy – in this case, applying an identical degree of diligence through cross-checks and precise verifications in ascertaining the relevance of publicly available negative information to a specific data subject. Significant, then, from a broader perspective, are the numerous interventions by the Authority, including inspection assessments, against public service concessionaires in the energy market, during a historical phase characterized by the transition to the free market and, for this reason, by the emergence of illicit practices by some suppliers for the acquisition of unsolicited contracts through the processing of inaccurate and outdated personal data (see para. 14.4). In many cases, the Garante was able to highlight that the phenomenon was the result of the inadequacy of the technical and organizational measures adopted by suppliers to ensure compliance with the instructions given to their respective data processors – that is, the failure to comply with the accountability requirements set out in the GDPR.

This same line of persistent non-compliance with the regulations protecting data subjects is reflected in the activity to combat aggressive telemarketing, which, even in 2023, has not shown significant reductions. The Authority intervened on multiple fronts and at various levels (see para. 11.1), analyzing the activities of intermediaries and call centers as essential, and sometimes weak, links in a chain where the absence of control mechanisms that prevent companies from using contacts acquired in violation of the regulations has proven to be one of the primary causes of the violations found. However, two positive elements in this landscape are represented on one hand by the approval of the code of conduct for telemarketing and tele-selling activities, which aims to promote the accountability of the actors involved, along with the full deployment of the automated system to report unlawful telemarketing via the...

****1STATO DI ATTUAZIONE DEL CODICE IN MATERIA DI PROTEZIONE DEI DATI PERSONALI**** sector; on the other hand, from the full operation of the automated reporting system regarding telemarketing implemented through the web portal of the Authority (see 2022 Report), which allowed for the extraction of valuable information by cross-referencing the data collected with other data from inspection activities or of another nature, and therefore to promote even more targeted and comprehensive investigations (see para. 11.1.5). The multiple investigations conducted by the Authority in this area also concerned subjects operating in a cross-border context and, consequently, required cooperation activities within the framework of the one-stop-shop mechanism under Article 60

of the GDPR (see para. 12.5).

The level of international cooperation required in managing cases, some of high profile, concerning the protection of personal data in electronic communications and, in general, online, proved to be even more significant. In a substantial percentage of these cases, it was possible to reach a resolution of the interests at stake through more streamlined procedures that allowed for effective remedies for complainants within relatively short timeframes (see para. 12.9). On the other hand, in 2023, there were some significant interventions by the Authority against major international players, including those not established in the European Union, which raised important questions regarding the use of artificial intelligence techniques in their various forms and, at the same time, spurred reflection at the European level on coordinated and effective approaches aimed at achieving balanced and timely protection (see para. 12.7).

As recalled on several occasions in the preceding pages, it is precisely the search for a balance between innovation and regulation that has always characterized, and especially in recent years, the activity of the Garante. In no area is this more necessary than in the one related to artificial intelligence, and in this sense, 2023 saw the achievement of a significant milestone at the supranational level with the pre-finalization of the EU regulation on AI, which aims to ensure the aforementioned reconciliation. Work also continued relentlessly within the Council of Europe to lay down a framework Convention, which

****Important Result at the Supranational Level****

with the substantial definition of the EU regulation aimed at ensuring precisely such balance, as well as with the ongoing work within the Council of Europe for the definition of a Framework Convention significantly dedicated to AI and “human rights, democracy, and the rule of law” (see Chapter 16). In this context, while expressly preserving the regulations concerning the protection of personal data, it must be noted that the future European regulation on AI leaves open the question (largely entrusted to national legislators) of the competent national authorities and their coordination in supervisory functions. For some time, the Garante (see 2022 Report) has represented the reasons for the primacy of the Authority in this area in light of the close connection between the operation of AI systems and the use of personal data, as well as the necessity of having a fully independent controller (such as the Garante) for effective supervision of these systems.

The issues of AI and digitalization have been the subject and impetus for numerous activities in European and international forums to which the Garante has consistently and actively participated. It is no coincidence that the G7 of data protection authorities (including the Garante), held in Tokyo in 2023, adopted a joint statement precisely on the topic of AI and the need for privacy by design approaches in this area (see para. 21.4), and that new technologies and cross-border data flows feature prominently in the work program of this consensus (which will be hosted in Rome in 2024 and chaired by the Garante). The same applies to the activities of the Garante within the OECD and the Council of Europe and, above all, for cooperation activities at the EU level, through the work of the European Data Protection Board (EDPB). The latter has repeatedly addressed the implications of the Union's digital strategy over the past year, considering the many instruments involved (from the DMA to the DGA); additionally, the EDPB, through its many subgroups, dealt with the increasingly frequent interactions between the data protection legal framework and other legal domains including, in particular, consumer protection and the risks arising.

****1. STATE OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION****

multiple facets (from the DMA to the DGA), all of which have impacts on data protection issues; furthermore, through the work of the many subgroups it comprises, the EDPB has addressed the increasingly frequent instances of interaction between the legal framework on data protection and other areas such as, in particular, consumer protection and the risks associated with the use of digital tools (including social media). Regarding the flows of personal data, it is worth mentioning here the contribution provided by the Garante to the EDPB's work on the draft adequacy decision for data transfers between the EU and the USA, which was subsequently adopted by the European Commission concerning the new Data Privacy Framework (see para. 21.1). On the other hand, 2023

also saw the proposal from the European Commission (2023/348) for a new regulation intended to supplement the GDPR in order to enhance and facilitate cooperation among supervisory authorities in cases of cross-border processing (see para. 21.1). The proposal was the subject of a significant joint opinion by the EDPB and the European Data Protection Supervisor, drafted under the coordination of the Italian Garante, and represents a sign of the increasing willingness for harmonization and European and international cooperation that, as mentioned, characterizes the activities of data protection authorities and, primarily, also of the Garante.

From this perspective, it is also necessary to observe that the past year has seen a substantial increase in the interpretative interventions of the Court of Justice of the EU following requests for preliminary rulings regarding provisions of the GDPR and the law enforcement directive (see para. 21.5). With these interventions, for which the Garante has consistently provided briefs and analytical contributions to the competent national bodies, the Court has effectively outlined important implementing elements regarding, for example, compensation for non-material damage resulting from the processing of personal data, the exercise of access rights, controllership and joint controllership, and the exercise of the powers conferred on data protection authorities.

Two areas where the trends mentioned in the above paragraphs are especially prominent include the handling of cases related to journalism and freedom of expression (see Chapter 9), on the one hand, and to revenge porn, on the other.

****State of Implementation of the Code on Personal Data Protection****

of personal data, of the exercise of the right of access, of ownership and co-ownership of processing, and of the exercise of powers by the same authorities.

Two areas in which the aforementioned trends emerge with particular clarity are those concerning cases related to journalism and freedom of expression (see Chapter 9), on one hand, and those concerning revenge porn for which, as is known, Article 144-bis of the Code grants the Authority specific powers (see Chapter 10). For the former, the constant balancing between freedom of information and respect for personal identity has been manifested in the examination of a high number of complaints and reports alleging violations due to the dissemination of news online and on social media, almost evenly divided between requests addressed to search engines for the de-indexing mainly of content deemed obsolete (in accordance with the so-called right to be forgotten) and requests directed at media outlets, the latter primarily aimed at obtaining the removal of data considered excessive and not compliant with the principle of materiality of the information to be published. While in this regard the Authority has acted according to principles of equitable balancing of the interests at stake, as established by a wealth of national and supranational case law, in the case of interventions concerning revenge porn, the Garante has acted, as required by

the regulations, to prevent and counter a phenomenon of particular violence and hatred, also through the implementation of a specific online reporting procedure that has resulted in a significant increase in the reports received during the year. In almost half of such reports, an urgent managerial determination was adopted to obtain the preventive blocking of sexually explicit content that was feared to be disseminated. These are measures that have a para-emergency nature and that cannot, evidently, constitute the only institutional response to the problem. Regarding the latter, it should be recalled that Section 144-a of the data protection Code does confer specific powers on the Garante (see Chapter 10). As to the former, the balancing exercise between freedom of the press and respect for an individual's identity was carried out by dealing with a substantial number of complaints and alerts alleging violations due to the dissemination of information on the Internet and social media. Those cases involved, to an almost identical extent, delisting requests to search engines mainly in respect of allegedly obsolete information – in accordance with the so-called right to be forgotten – and requests submitted to media outlets mostly in order to have contents removed because of their being allegedly excessive and in breach of the principle of materiality of the information to be published. In all these instances, the Garante pursued the equitable balancing of the interests at issue, also in the light of the wealth of case law on this subject matter; conversely, as for revenge porn, the Garante took action as required by the law in order to prevent and counter an especially violent as well as disreputable crime. To that end, an ad-hoc online alerting procedure was implemented, which resulted in a steep increase in the number of alerts received over the past year. In almost half of those cases, an urgent decision by the competent department was issued to block the sexually explicit contents that were allegedly about to be disseminated. Needless to say, these steps are taken in an emergency situation and they are certainly not enough to tackle the issue from a public interest perspective. Key importance should be attached in this context also to the information and

awareness-raising initiatives by the Garante, which included both an information campaign addressing consumers and citizens in general (see para. 23.1) and targeted awareness-raising actions concerning aggressive marketing, the risks of generative AI, or the measures to protect children online.

such as the '2023 State of Privacy' conference organized by the Garante (see para. 23.1) had a large audience discussing ways to ensure that public authorities and citizens work jointly and knowledgeably as required in order to devise innovative, creative solutions to navigate digitalization and new technologies – which is ultimately aimed to uphold the human-centered approach underpinning the whole European legal framework on privacy and data protection.

Recital 4 GDPR states that 'the processing of personal data should be designed to serve mankind.' This is certainly no chance statement. Indeed, this is the objective the Garante has consistently pursued, and this has taken on further significance and importance over the past few years. The Report contained in the following sections is supported by detailed statistical information providing – as is customary – in-depth numerical evidence in tabled format of the work carried out by the Garante. Our work is a complex, at times a daunting task – however, it is work performed with passion, and this short executive summary has barely scratched its surface by pointing to key trends and highlights in the past year.

In this sense, the communication and awareness-raising activities conducted by the Authority continue to hold primary importance, which have seen both a general institutional information campaign aimed at consumers and citizens in general (see para. 23.1), as well as targeted activities to raise awareness on issues such as invasive marketing, the risks of generative artificial intelligence, and measures to protect minors in online activities. Public events with wide participation, such as the "State of Privacy 2023" (see para. 23.1), have allowed for the message of the necessary synergy and awareness of institutions and citizens to be conveyed as widely as possible in order to identify even innovative and creative solutions that allow for navigating the world of digitalization and innovative technologies without losing sight of that human-centered approach that characterizes the entire European discipline on data protection and privacy.

It is certainly no coincidence that the GDPR states in its Recital 4 that "the processing of personal data should be at the service of man." This is the objective that the Garante has always pursued, and which has gained further relevance and resonance in recent times. The following Report, supported by detailed statistical information that, as usual, provides a precise numerical account in tabular form, accounts for the work carried out, a complex, at times difficult, but always passionate work, of which this brief introduction has sought to outline the trends and main contents.

15

REPORT 2023

2

The regulatory framework on personal data protection

In 2023, numerous relevant legislative measures were approved (albeit to varying degrees) in terms of personal data protection. In the impossibility of describing them all, the following analyzes the regulatory acts that have the most significant impact on the matter.

2.1. The laws

Law No. 213 of December 30, 2023, concerning the State budget for the year 2024 and the multi-year budget for the three-year period 2024-2026, includes some provisions of interest in the field of personal data protection, among which the following are particularly noteworthy:

- Paragraph 60 of Article 1, which, in order to combat evasion in the domestic work sector, legitimizes the Revenue Agency and INPS to realize – with methods defined by agreement – the full

interoperability of databases for the exchange and analysis of data, including through the use of advanced digital technologies;

- Paragraph 86 of Article 1, concerning changes in the status of real estate, which legitimizes the Revenue Agency and the collection agency to verify, based on specific selective lists developed using modern interoperability technologies and database analysis, the submission, where required, of the declaration of change of assets (Article 1, paragraphs 1 and 2, Ministerial Decree of April 19, 1994, No. 701), for any effects on the income of the property present in the land registry;
- Paragraph 100 of Article 1, which, in preparing measures to combat evasion and rationalize the procedures for offsetting credits, provides for amendments to Presidential Decree No. 602/1973, containing provisions on the collection of income taxes. In particular, Article 75-ter is added to the decree, which, in order to ensure maximum efficiency of the collection activity, legitimizes the collection agent to use, before initiating the enforcement action, telematic methods of application cooperation and IT tools to acquire all necessary information, held by anyone. The opinion of the Garante is required on the definition, by the Ministry of Economy and Finance (MEF), of the technical solutions capable of ensuring the use of such IT tools for access to the information necessary for collection.

The annual law for the market and competition, No. 214 of December 30, 2023, includes various provisions particularly relevant from the perspective of personal data protection. These have been analyzed by the Garante in the...

****Minutes of the hearing held before the 9th Commission of the Senate on September 5, 2023, as well as in the memorandum sent to the 10th Commission of the Chamber of Deputies on November 29, 2023 (see par. 3.1.1). ****

The Guarantor emphasized in these venues that the regulation established by the law concerns data protection from a dual perspective; on one hand, it intervenes in the increasingly close relationship between data protection and consumer protection (art. 2); on the other hand, by aligning the domestic legal framework with the Digital Markets Act, it outlines a regulatory framework rich in interrelations between data protection and the regulation of digital markets (art. 18).

****2024 Budget Law****

****Competition Law****

****STATUS OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION****

The Guarantor then focused on the provisions of art. 2, which, in regulating the use of second-generation smart meters, govern access to consumption data through the Integrated Information System. In particular, art. 2 – amending Legislative Decree No. 102 of July 4, 2014, which implements Directive 2012/27/EU – provides that Acquirente Unico S.p.A., as the manager of the Integrated Information System, makes the supply meter data available to the final customer or, upon their formal request, to a uniquely designated third party, in a format that is easily understandable and can be used to compare comparable offers or for the provision of services by such third parties. This will occur through the Energy and Natural Gas Consumption Portal and "in compliance with the regulations on personal data protection." The same article also establishes that an electronic register shall be set up at Acquirente Unico S.p.A. listing the third parties that access the final customer's data, aimed at ensuring free access for final customers to any information concerning access to data by third parties, including their history and the types of data consulted.

In his remarks, the Guarantor, after recalling the involvement of the Guarantor in the establishment, in 2019, by ARERA, of the Consumption Portal, suggested some clarifications to be introduced in the text – however not adopted by the legislator – aimed at defining the objective and subjective limits of access to the Portal, specifying the scope of "third parties" authorized to access the consumption data of final customers, as well as the types of data "related to the input" and "withdrawal" of electricity and natural gas. The Consumption Portal indeed contains a multitude of personal data (e.g., personal data, POD and PDR, switching practices, contractual data, etc.) whose broad availability to parties other than the data subject could have significant implications for privacy (consider the widespread phenomenon of fraudulent activation of utilities in the free energy market).

Furthermore, the need to identify the purposes of access in a more detailed manner was emphasized, with a formulation more circumscribed than that relating to the comparison of "comparable offers" or "the provision of services by the aforementioned third parties," which is inadequate in itself to exclude further purposes (e.g., customer profiling, statistical data processing, etc.) beyond those more closely related to assessing the energy footprint of the final customer or the comparison of comparable offers pursued by the regulation (see also Directives 2019/944/EU and 2012/27/EU).

Further considerations addressed art. 18, which aligns the domestic legal framework with Regulation (EU) 2022/1925 (the so-called Digital Markets Act), identifying the AGCM as the designated authority for enforcement. The provision correctly preserves the general supervisory and control powers of the Guarantor, particularly concerning some of the profiles regulated by the regulation, which are of greater relevance for the protection of personal data (art. 18, paragraph 8). The explicit mention of this safeguard clause, although derivable from the supranational legal framework, is necessary – as emphasized by the Guarantor in preliminary discussions with the Government on the matter – to avoid potential conflicts and overlaps of competencies among the involved authorities at the domestic level.

As also recalled during the hearing, the need for adequate coordination and, therefore, for fair collaboration between competition authorities and data protection authorities has been generally affirmed by the CJEU in its judgment of July 4, 2023 (C-252/21), noting that the former must consult the latter where, in the context of their own investigations, issues affecting data protection arise.

****Oncological Oblivion****

****Tax Delegation****

Particularly relevant is the law of December 7, 2023, no. 193, which, in laying down provisions for the prevention of discrimination and the protection of the rights of individuals cured of oncological diseases, incorporates the requests of the European Parliament resolution of February 16, 2022, on strengthening Europe in the fight against cancer – towards a global and coordinated strategy (2020/2267(INI)). In defining its object and purposes, Article 1 of the law makes an express reference to Articles 2 (recognition of the inviolable rights of man), 3 (equality and equal social dignity), and 32 (fundamental right to health protection) of the Constitution and to Articles 7 (respect for private and family life), 8 (protection of personal data), 21 (non-discrimination), 35 (health protection), and 38 (consumer protection) of the Charter of Fundamental Rights of the European Union, as well as to Article 8 (right to respect for private and family life) of the European Convention for the Protection of Human Rights and Fundamental Freedoms. Additionally, paragraph 2 of the aforementioned article defines the right to oncological oblivion as "the right of individuals cured of an oncological condition not to provide information or undergo inquiries regarding their previous pathological condition."

The second article of the law regulates access to financial, banking, investment, and insurance services, as well as in the context of entering into any other type of contract, even exclusively between private parties, when health information may influence conditions and terms. This article thus establishes that the consumer is not required to provide information related to previous health conditions concerning oncological diseases ten years after the end of therapeutic treatment, or five years if the diagnosis was made before the age of eighteen, and that financial operators, in all phases of consumer access to such services, including pre-contractual negotiations and the conclusion or renewal of contracts, must provide the counterparty with adequate information regarding this right. The same article also provides that information about health status cannot be obtained from sources other than the contracting party and, if it is nonetheless available to the operator or intermediary, it cannot be used to determine contractual conditions.

Paragraph 7 of Article 2 stipulates that opinions from the Guarantor must be obtained on measures (CICR resolution and IVASS provision) aimed at identifying the methods for implementing confidentiality guarantees concerning financial and insurance companies.

Similar confidentiality guarantees are then provided in Article 4, which prohibits requesting – for the purposes of accessing bankruptcy procedures – information regarding the health status of the interested parties concerning oncological diseases if ten or five years have passed, depending on age. Finally, particular interest is given to Article 5 of the law, which sets forth transitional and final

provisions, assigning the Guarantor the function of overseeing the correct application of the provisions of the relevant measure (paragraph 4).

Law no. 111 of August 9, 2023, containing legislative delegation for tax reform, has particularly indicated, among the directive criteria for exercising the delegation, the preparation of tools to prevent, combat, and reduce tax evasion and avoidance, also through:

- 1) the full utilization of data flowing into the tax registry information system, the enhancement of risk analysis, the use of digital technologies and artificial intelligence solutions, in compliance with EU regulations on personal data protection, as well as the strengthening of the collaborative compliance regime or the updating and introduction of institutions, including incentives, aimed at promoting forms of collaboration between the tax administration and taxpayers;
- 2) the full utilization of data made available by electronic invoicing and the telematic transmission of receipts as well as the full realization of the interoperability of databases, in compliance with EU regulations on personal data protection.

Article 16 of the law indicates, among the principles and directive criteria related to the general review of tax obligations, the introduction of measures for the simplification of declarative and payment obligations. In this context, it provides that the use of pre-filled declarations is incentivized, with incentive systems, expanding the categories of taxpayers involved and facilitating access to telematic services for individuals with less aptitude for using IT tools (letter g); that the methods of access for taxpayers to the services provided by the tax administration are simplified (letter h), also increasing the number of digital services available to citizens (letter i).

The provision also establishes that tools and organizational models that facilitate the sharing of data and documents, electronically, between the Revenue Agency and the competent municipal offices are to be enhanced, also in order to facilitate and accelerate the identification of non-registered properties and illegal properties.

Article 17, finally, indicates specific principles and guidelines for the review of the activities of assessment, adherence, and voluntary compliance. Specific measures for the simplification of the assessment procedure are foreseen, including the use of digital technologies, resulting in a reduction of administrative burdens on taxpayers, as well as a generalized application of the adversarial procedure. It is also provided that the rules regarding the analysis of tax risk positions and the increasing use of digital technologies (also supported by artificial intelligence) will be rationalized and reorganized in accordance with the regulations on data protection and access, in order to obtain, through full interoperability between databases, the availability of the necessary information to prevent taxpayer errors and the consequent assessments.

2.2. Decrees-Law

Law No. 159 of November 13, 2023, converted, with amendments, Decree-Law No. 123 of September 15, 2023, containing urgent measures to combat youth distress, educational poverty, and juvenile delinquency, as well as for the safety of minors in the digital environment. The text contains numerous provisions of interest, among which the following are particularly noteworthy:

- Article 12 reorganizes the regulations regarding the supervision of compliance with the obligation of education as per Article 114 of Legislative Decree No. 297 of April 16, 1994 (consolidated text of the legislative provisions in force regarding education, relating to schools of all levels), redefining the tasks of the mayor and the school principal. In particular, it is provided that the mayor, through access to the National Education Registry (ANIST), can identify minors who are not in compliance with this obligation, proceeding to warn the "responsible party" "without delay" and inviting them to comply (paragraph 2). In this context, pending the activation of ANIST, the provision allows school principals to transmit data regarding the aforementioned minors to the mayor, delegating to implementing acts, after consulting the Guarantor, the indication of the necessary procedures and protections for this purpose;
- Article 13 introduces provisions—whose correct application will be monitored by AGCOM—aimed at ensuring parents free access to parental control applications on electronic communication devices. Paragraph 6 of Article 13 further provides that personal data collected or generated during the activation of the applications cannot be used for commercial and profiling purposes;

- Article 13-bis prescribes a general prohibition for minors to access pornographic content and imposes on website operators with such content the obligation to verify the age of users through technical methods to be identified by AGCOM, after consulting the Guarantor;

- Article 15 designates AGCOM as the coordinator of digital services pursuant to Article 49, paragraph 2, Regulation (EU) 2022/2065, also providing that AGCOM, the Guarantor, and any other competent national authority ensure all necessary cooperation for the exercise of their respective functions. It is also provided that the authorities may regulate the application and procedural aspects of mutual cooperation through memoranda of understanding (Article 15, paragraph 2).

Law No. 137 of October 9, 2023, contains the conversion, with amendments, of Decree-Law No. 105 of August 10, 2023, containing urgent provisions regarding criminal procedure, civil procedure, combating forest fires, recovery from drug addiction, health, and culture, as well as regarding the personnel of the judiciary and public administration. Of particular relevance in the provision are the provisions regarding interceptions.

Article 1 extends the scope of application of the discipline referred to in Article 13 of Decree-Law No. 152/1991, derogating from the codified regulations, to proceedings for crimes committed or attempted, of organized activities for the illicit trafficking of waste and kidnapping for extortion purposes, or committed with terrorist intent, or by availing oneself of the conditions provided for in Article 416-bis of the Penal Code or for the purpose of facilitating the activities of the associations referred to in the same article. As a result of this provision, interceptions may also be ordered for these proceedings when necessary (and not absolutely indispensable) for the conduct of investigations, in relation to a crime for which there are sufficient (instead of serious) indications of guilt. This provision also includes in its paragraphs from 2-bis to 2-quinquies certain significant amendments to the Code of Criminal Procedure, concerning in particular:

- the amendment of Article 267 of the Code of Criminal Procedure, aimed at specifying that the authorization decree for environmental interceptions through a technical device must state with clarity...

****Assessment of the specific reasons that make it necessary in practice, for the conduct of investigations, to resort to such a method (paragraph 2-bis);****

- The amendment of Article 268 of the Code of Criminal Procedure (c.p.p.), according to which the minutes must also summarize the content of the intercepted communications that are relevant for the investigations, including for the benefit of the person under investigation. The content that is not relevant for the investigation will not be transcribed, even summarily, and no mention of it will be included in the minutes and notes of the judicial police, which will bear the express wording "the omitted conversation is not useful for the investigations" (paragraph 2-ter);

- The further amendment of the same Article 268, concerning the exclusion from the minutes of facts and circumstances relating to the private life of the interlocutors, if not relevant (paragraph 2-ter);

- The amendment of Article 270 c.p.p., which limits the possibility of using the results of interceptions in proceedings other than those in which they were ordered, allowing it only in cases where they are relevant and indispensable for the ascertainment of crimes for which arrest in flagrance is mandatory (paragraph 2-quater).

****STATE OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION****

Article 2 provides for the establishment of specific inter-district digital infrastructures aimed at achieving higher and uniform levels of security for interception activities, adequate technological updates, greater efficiency, cost-effectiveness, and energy-saving capabilities of information systems.

Paragraph 4 then establishes that the technical requirements of the infrastructures guarantee the autonomy of the functions of the Public Prosecutor regarding the direction, organization, and supervision of interception activities and related data, as well as access and operations performed on the data itself.

While maintaining investigative secrecy and guarantees of confidentiality and data security, it is reiterated that the Ministry of Justice, even within the scope of the aforementioned activities, cannot have access to unencrypted data.

Paragraph 5 delegates to a decree from the Minister of Justice the provision for the activation of the digital archive referred to in Articles 269, paragraph 1, c.p.p. and 89-bis of the implementing provisions of the c.p.p.; thus, paragraph 6 authorizes the migration of data from individual prosecutors and the conferment of new data.

Paragraph 9 provides that the implementing decrees of Article 2 are adopted after consulting the Superior Council of the Judiciary, the Guarantor, and the Interministerial Committee for Cybersecurity.

Law No. 112 of August 10, 2023, converting Decree Law No. 75 of June 22, 2023, concerning the organization of public administrations, agriculture, sports, labor, and the organization of the Jubilee of the Catholic Church for the year 2025, establishes in Article 21 the platform "Families and Students."

As provided in paragraph 4-ter, the Ministry of Education and Merit promotes the design, development, and implementation of the aforementioned platform as a single access channel to the information assets held by the Ministry itself and by state educational institutions. It consists of a technical infrastructure that enables the interoperability of existing information systems functional to the activities of the Ministry, in order to simplify access and use. The Ministry of Education and Merit and the state educational institutions use the data present on the platform only for treatments strictly related to the purposes of the latter and for the pursuit of their respective institutional objectives.

Paragraph 4-quater establishes that, in order to simplify the provision of services for families and students, optimize the activities of the Ministry and state educational institutions, and feed the platform, the Ministry is authorized to acquire from INPS (previously transmitted for the identification of students) aggregated data devoid of identifying elements, divided by brackets, relating to the Equivalent Economic Situation Indicator (ISEE) of the families of which students enrolled in the aforementioned institutions are part, in order to allocate resources among them. It also provides that, always in compliance with data protection regulations, state educational institutions, as service providers, through the platform, also carry out checks on the ISEE information system regarding the truthfulness of the substitute declarations concerning the data of families that have requested recognition of the contribution.

Finally, paragraph 4-quinquies delegates the definition of the digital services included in the platform (paragraph 4-ter), the technological standards, and the criteria for security, accessibility, availability, and interoperability, the limits and conditions of access aimed at ensuring the correct and lawful use of data to one or more non-regulatory decrees of the Minister of Education, after consulting the Guarantor.

Law No. 85 of July 3, 2023, converting Decree Law No. 48 of May 4, 2023, within the framework of urgent measures concerning social inclusion and access to the labor market, introduced, as a national measure to combat poverty, the inclusion allowance: a supplement to the income of family units that...

****Organization of Public Administrations****

****Access to the Labor Market****

****REPORT 2023****

include a person with a disability, a minor, or a person over sixty years of age, and who meet certain requirements. The regulation provides that the monthly benefit is to be disbursed by INPS through an electronic payment instrument, for a maximum period of 18 consecutive months, with the possibility of renewal for an additional 12 months (art. 1). Among the provisions of interest, in addition to art. 2 which identifies the pool of beneficiaries of the allowance, is the subsequent art. 3 which outlines the activation process of the measure, implemented through the automatic sending, via a platform, of the family unit data to the social services of the municipality of residence for the purposes of analysis, the taking charge of members with complex needs, and the activation of any supports.

Art. 4 regulates the methods of requesting the allowance. In particular, it is provided that the application be submitted electronically to INPS, which may grant the benefit after verifying the possession of the requirements, based on the information available in its databases or through those provided by the municipalities, the Ministry of the Interior via the National Register of the Resident Population, the Ministries of Justice, Education and Merit, the Tax Register, the PRA, and other public authorities holding the necessary data for the verification of the requirements, through interoperability systems. The same article provides in its first paragraph that INPS inform the applicant that, in order to receive the economic benefit, they must register with the Information System for Social and Labor Inclusion (SIISL), which will allow them to sign a digital activation pact and that they must expressly authorize the transmission of data related to the application to employment centers, labor agencies, and authorized entities for intermediation activities.

Paragraph 3 specifies that, through the platform, the activation process is implemented through the automatic sending of the family unit data to the social services of the municipality of residence for the purposes of analysis, the taking charge of members with complex needs, and the activation of any supports. Finally, paragraph 7 of this article provides that the entire procedure for requesting the measure shall be defined by one or more decrees of the Minister of Labor and Social Policies, after consulting the Guarantor and the National Agency for Active Labor Policies.

Art. 5 provides for the establishment, at the Ministry of Labor and Social Policies, of the SIISL, created by INPS to enable the activation of personalized pathways for beneficiaries, as well as for analysis, monitoring, evaluation, and control purposes of the allowance. This information system will allow the interoperability of all digital platforms of the entities accredited to the social system, as provided for by one or more decrees of the Minister of Labor and Social Policies, after consulting the Guarantor, INPS, and ANPAL.

Art. 7, on the other hand, regulates the inspection controls on the inclusion allowance, carried out by the inspection staff of the National Labor Inspectorate (INL) and the Carabinieri Command for Labor Protection, by the inspection staff of INPS, as well as by the Guardia di Finanza within the scope of ordinary economic and financial police functions. The provision states in its paragraph 2 that, in order to allow for effective oversight, the inspection staff of INL and the Guardia di Finanza shall have access to all information and databases, both in analytical and aggregated form, processed by INPS, already available to the inspection staff dependent on the same Institute and, in any case, to the information and databases containing information related to the requirements and conditions for accessing and maintaining the benefit. The same paragraph 2 also provides that INPS and the Guardia di Finanza, after consulting the Guarantor, shall enter into a specific agreement for the achievement of the aforementioned purposes.

22

STATUS OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION

Paragraph 3 delegates to a decree of the Minister of Labor and Social Policies, after consulting the Guarantor, the identification of the categories of data, the access methods, the measures to protect the interested parties, and the retention times of the aforementioned data.

Art. 12 then establishes support for training and work consisting of a monthly allowance granted to individuals aged between 18 and 59 who participate in active labor policy projects or projects beneficial to the community, also in this case delegating to a specific decree of the Minister of Labor and Social Policies, after consulting the Guarantor and ANPAL, the identification of its procedures and the measures for its activation.

Finally, with art. 15, regarding oversight, public and private entities are required to share free of charge the information they possess – identified after consulting the Guarantor, pursuant to art. 2-ter, paragraph 1, of the Code – with INL and the Guardia di Finanza, to better guide their inspection activities, particularly towards companies that show risk factors in terms of health and safety in the workplace, irregular work, or contribution evasion or omission.

2.3. Legislative Decrees

Among the numerous legislative decrees adopted in 2023 that are relevant, to varying degrees, in the field of personal data protection, the following are particularly noteworthy:

The legislative decree of July 26, 2023, No. 106, implements the delegation referred to in Article 2 of Law No. 118 of August 5, 2022, for the mapping and transparency of the concession regimes of public goods. The decree, on which the Guarantor provided a favorable opinion on November 10, 2022, establishes, at the Ministry of Economy and Finance (MEF), the information system for the detection of public goods concessions, in order to promote maximum publicity and transparency of the main data and information related to all concession relationships, taking into account security needs. This information system is fed by the information related to the concession of public goods held by public administrations that own or manage the asset (which must belong to the State's public domain or unavailable assets). Among the minimum information that feeds the system are also those relating to the personal details of the concessionaire. Among the publicity obligations provided in compliance with the delegation criterion, the publication of the data communicated and detected by the administrations on a dedicated section of the MEF website is included, also in aggregated form and in compliance with data protection regulations, unless it concerns assets intended for national defense or there are justified needs for the protection of public safety and public order by the competent administration.

The legislative decree of March 10, 2023, No. 24 implements Directive (EU) 2019/1937 of the European Parliament and of the Council, of October 23, 2019, regarding the protection of persons who report violations of Union law and containing provisions concerning the protection of persons who report violations of national regulatory provisions. The decree, on which the Guarantor provided an opinion on January 11, 2023 (see par. 3.1.2), was adopted in the exercise of the legislative delegation conferred to the Government by Article 13 of Law No. 127 of August 4, 2022 (European Delegation Law 2021), which, among the principles and directive criteria, provides for the need to make the necessary adjustments to the existing provisions in order to align national legislation with European legislation, also in relation to violations of domestic law attributable to crimes or improper behaviors that compromise the impartial care of the public interest or the regular organization and management of the entity.

Mapping and Transparency of Concession Regimes

Whistleblowing

REPORT 2023I2

The objective scope of application is extended, by Article 1, to reports concerning violations of domestic law, by virtue of the faculty provided for in Article 2, paragraph 2, of the directive. Conversely, the same Article 1 regulates the cases of exclusion from the application of the new discipline, among which are particularly included disputes or claims of a personal nature in individual employment or public employment relationships and reports of violations concerning national security or contracts related to aspects of national defense or security, unless such aspects are attributable to Union derived law. Article 3 identifies the subjective scope of application of the discipline, identifying as subjects interested in the protection for reporting unlawful acts, susceptible to possible retaliatory acts, all workers in the public and private sectors as employees or collaborators, subordinate and self-employed workers, freelancers, and other categories, including volunteers and interns, even if unpaid, shareholders, and persons with functions of administration, direction, control, supervision, or representation, even where such roles are exercised in a de facto manner. Articles 4 and 5, which introduce Chapter II (internal reports, external reports, obligation of confidentiality, and public disclosures), respectively regulate the methods of submitting internal reports, aimed at ensuring the confidentiality of the whistleblower's identity and the procedural process following the report. Articles 7 and 8 regulate the characteristics of the external reporting channel activated at ANAC concerning both the public and private sectors, with an obligation to guarantee (also through the use of encryption) the confidentiality of the whistleblower, the persons involved and mentioned in the report, as well as the content of the same. Even in these cases, reports are made through an IT platform provided by ANAC, or in written or oral form (through telephone lines and other voice messaging systems), as well as, if

the person requests it, also through a direct meeting. Article 8 establishes, in ANAC's responsibility, in addition to the obligation to provide feedback to the whistleblower, also the obligation to transmit reports concerning violations outside its own responsibilities to the competent authorities, administrative or judicial – including the entities of the European Union – which are also required, in the subsequent activity, to ensure the confidentiality of the interested parties. Article 9 regulates the information on external reports and their follow-up, establishing in ANAC the obligation to illustrate the confidentiality regime applicable to the reports. Article 10 entrusts ANAC with the adoption – subject to the Guarantor's opinion – of guidelines regarding the procedures for submission and...

****Management of External Reports****

which also promotes the use of encryption tools to ensure the confidentiality of the data subjects and the content of the reports.

Article 12, under the heading "Obligation of Confidentiality," establishes the general principle that reports may only be used for follow-up purposes, with an express prohibition on disclosure to persons other than those specifically authorized pursuant to Articles 29 and 32, paragraph 4, of the GDPR and 2-quaterdecies of the Code, of the identity of the whistleblower, in the absence of their express consent.

Article 13 regulates the processing of personal data, indicating the subjective roles and specifying that the rights enshrined in Articles 15 to 22 of the GDPR may be exercised within the limits set out in Article 2-undecies of the Code.

Article 14 allows for the retention of internal and external reports and related documentation for the time necessary for their resolution and, in any case, for no more than five years from the date of communication of the final outcome of the reporting procedure. The article provides an additional clarification on the methods of documenting the report, due to its being made using telephone lines or other systems of recorded or unrecorded voice messaging, or during a face-to-face meeting.

****REPORT 2023****

****3****

****Relations with Parliament and Other Institutions****

****3.1. The Advisory Activity of the Authority****

The provision for the mandatory opinion of the Authority on legislative acts, including those of primary rank, with profiles of interest in the field of personal data protection has led to a significant increase, both qualitatively and quantitatively, in the advisory activity of the Authority (Articles 36, paragraph 4, and 57, paragraph 1, letter c), Recital 96, GDPR Article 28, paragraph 2, EU Directive 2016/680; Article 24, paragraph 2, Legislative Decree No. 51/2018).

Through this enhanced consultation of the Authority, a more appropriate balance between rights (often in opposition) has generally been achieved in relation to the ever-increasing regulations that provide for the processing of personal data.

****3.1.1. The Consultation of the Authority in the Legislative Procedure or in the Exercise of the Knowledge, Guidance, and Control Functions of the Chambers****

There have been numerous cases of consultation of the Authority on primary legislative acts, including during the conversion of legislative decrees, particularly in relation to the measures adopted to counter the current international, economic, and energy crisis. The use of the particularly flexible tool of parliamentary hearings is becoming increasingly frequent in this area, which also offers the possibility of direct dialogue, through the subsequent debate following the report, between individual parliamentarians and the Authority.

Among the hearings (or, in any case, requests for contributions) of the Authority within the legislative procedure, the following are particularly noteworthy for the reference period:

- a) Hearing before the 9th Commission of the Senate in the context of the examination of the legislative decree implementing EU Directive 2019/2161, which amends Directive 93/13/EEC and Directives 98/6/EC, 2005/29/EC, and 2011/83/EU for better application and modernization of Union rules regarding consumer protection - January 12, 2023 (web doc no. 9843160);
- b) Hearing before the 9th Commission of the Senate in the context of the examination of the bill AS

795, concerning the annual law for the market and competition 2022 - September 5, 2023 (web doc no. 9921332);

c) Hearing before the 2nd Commission of the Senate in the context of bill no. 808, concerning amendments to the penal code, the code of criminal procedure, the judicial system, and the military code - September 6, 2023 (web doc no. 9926529);

d) Memorandum submitted to the 10th Commission of the Chamber of Deputies in the context of the examination, in the second reading, of bill AC 1555, concerning the annual law for the market and competition 2022 - November 29, 2023 (web doc no. 9997290).

Requests for contributions have also been received in the context of the exercise of the knowledge, guidance, and control functions of the Chambers, demonstrating a widespread sensitivity to the protection of personal data and its demands.

Among the hearings or contributions made during the year, the following are particularly noteworthy:

a) Hearing before the 2nd Commission of the Senate, in the context of the exploratory investigation on the topic of interceptions - January 24, 2023 (web doc no. 9855910);

b) Hearing before the 7th Commission of the Chamber of Deputies, in the context of the examination of resolution no. 7-00055, concerning initiatives to counter the...

****Dissemination of Resistance Challenges (Challenge) in Telecommunication Social Networks - April 26, 2023 (web doc no. 9880951);****

c) Hearing before the 2nd Commission of the Senate as part of the inquiry into the topic of defamation, also in relation to new technological communication tools - July 18, 2023 (web doc no. 9911932).

****3.1.2. Consultation of the Guarantor on State Normative Acts of Primary Rank: Opinions to the Government on Draft Laws and Legislative Decrees****

Significant contributions have been offered by the Guarantor regarding legislative initiatives or acts with the force of law, of governmental origin, affecting the subject matter. Among the main opinions rendered in this context, the following are particularly noteworthy:

a) Opinion of January 11, 2023, rendered to the Presidency of the Council of Ministers on a draft legislative decree implementing Directive (EU) 2019/1937 of the European Parliament and of the Council of October 23, 2019, concerning the protection of persons who report violations of Union law and the protection of persons who report violations of national regulatory provisions (web doc no. 9844945);

b) Opinion of August 3, 2023, on the draft law, of governmental initiative, AS 808, containing amendments to the Penal Code, the Code of Criminal Procedure, the Judicial System, and the Military Code (web doc no. 9927390);

c) Opinion of August 31, 2023, rendered to the Presidency of the Council of Ministers on the draft legislative decree concerning the simplification of controls on economic activities in implementation of the delegation to the Government referred to in Article 27, paragraph 1, Law No. 118 of August 5, 2022 (web doc no. 9929069);

d) Opinion of December 21, 2023, rendered to the Presidency of the Council of Ministers on a draft legislative decree containing supplementary and corrective provisions of Legislative Decree No. 150 of October 10, 2022, implementing Law No. 134 of September 27, 2021, containing delegation to the Government for the efficiency of the criminal process as well as in matters of restorative justice and provisions for the swift resolution of judicial proceedings (web doc no. 9974918).

In this opinion, the Guarantor expressed a recommendation regarding the publicity regime of procedural acts subject to video recording. The "Cartabia reform," in order to ensure a more accurate representation of the acts in question, has significantly expanded the use of audiovisual and phonographic reproduction: specifically, as a general method of documentation, intended to accompany the minutes for the acts of the proceeding (Article 134 of the Code of Criminal Procedure) as well as a preferred method of documenting the guarantee interrogation of the accused in custody (Article 141-bis of the Code of Criminal Procedure) and as a form of documentation of the evidentiary hearing (Article 510, paragraph 2-bis, of the Code of Criminal Procedure). In relation to this innovation—due to its impact on the processing of personal data of the parties and third parties

involved, in various capacities, in the proceeding—the Guarantor suggested the introduction of a special publicity regime for the procedural acts thus documented, so as to balance the needs for publicity, an expression of the principle referred to in Article 101, paragraph 1, of the Constitution, the right to privacy, and the principle of minimization referred to in Article 5, paragraph 1, letter c), of the GDPR.

****3.1.3. Opinions on Regulatory or Administrative Acts in General****

In exercising the consultative function regarding regulatory norms (or general administrative acts) likely to affect the protection of personal data, the Guarantor has rendered numerous opinions.

During the period considered, in particular, opinions were rendered on the following acts:

- a) Draft decree concerning the regulation on the processing of personal data by restorative justice centers, pursuant to Article 65, paragraph 3, Legislative Decree No. 150 of October 10, 2022, implementing Law No. 134 of September 27, 2021, containing delegation to the Government for the efficiency of the criminal process, as well as in matters of restorative justice and provisions for the swift resolution of judicial proceedings (Opinion of May 17, 2023, No. 215, web doc no. 9899898);
- b) Draft decree concerning the regulation on the functioning of the database related to judicial auctions, pursuant to Article 26, paragraph 6, Legislative Decree No. 149 of October 10, 2022 (Opinion of May 17, 2023, No. 216, web doc no. 9897618);
- c) Draft decree containing the regulation concerning the identification of further categories of the register of technical consultants and the sectors of specialization of each category, the requirements for registration in the register, and the formation, maintenance, and updating of the national list referred to in Article 24-bis of the provisions for the implementation of the Code of Civil Procedure and transitional provisions, pursuant to Article 13, paragraph 4, of the same provisions for implementation, as added by Article 4, paragraph 2, letter a), Legislative Decree No. 149 of October 10, 2022 (Opinion of May 17, 2023, No. 217, web doc no. 9897647);
- d) Draft regulation concerning the methods of establishment and functioning of the conciliation commissions for the amicable resolution of disputes referred to in Article 17, paragraph 4, Law No. 46/2022 (Opinion of June 8, 2023, No. 239, web doc no. 9913578);
- e) Draft decree of the Minister of Enterprises and of...
made in Italy in implementation
of Article 4, paragraph 6, Legislative Decree No. 219 of November 25, 2016, concerning the definition of the terms and operational modalities for the feeding of the business electronic file,
as per Article 43-bis, paragraph 1, letter b), Presidential Decree No. 445 of December 28, 2000, and Article 2,
paragraph 2, letter b), Law No. 580 of December 29, 1993,
as well as the modalities and limits
of access to the related information by the
interested public and private entities
(opinion of June 22, 2023, No. 282, web document No. 9919882);
- f) draft regulation concerning the determination
of the criteria and modalities
for the registration and maintenance of the register of mediation bodies and the list of
training entities, the approval of the indemnities
due to the bodies, pursuant to
Article 16 of Legislative Decree No. 28 of March 4, 2010, and concerning
the establishment of the list of
ADR bodies designated to manage
national and cross-border disputes, as well as
the procedure for the registration of ADR bodies
pursuant to Article 141-decies,
Legislative Decree No. 206 of September 6, 2005, concerning the consumer code, in accordance with
Article 7, Law
No. 229 of July 29, 2003 (opinion of July 6, 2023, No. 305,

web document No. 9920527);

g) draft inter-ministerial decree, presented by the Minister of Enterprises and Made in Italy, concerning the regulation of the professional activity of the family mediator, provided for by Article 4, Legislative Decree No. 149 of October 10, 2022 (opinion of July 18, 2023, No. 331, web document No. 9920162);

h) draft regulation of the Minister of Culture, in agreement with the Minister of Economy and Finance, concerning the criteria and modalities for the attribution and use of the Youth Culture Card and the Merit Card, as per Article 1, paragraphs 357 and following of Law No. 234 of December 30, 2021, and subsequent amendments, accompanied by a draft decree of the Secretary General, concerning the regulation of the modalities and timing of the management and conservation of personal data (opinion of August 31, 2023, No. 386, web document No. 9929134);

i) draft decree amending the decree of the Minister of Infrastructure and Transport No. 146 of July 29, 2008, concerning the implementation regulation of Article 65, decree No. 171 of July 18, 2005, concerning the code of pleasure boating (opinion of September 14, 2023, No. 417, web document No. 9938721);

j) draft regulation of the Ministry of Infrastructure and Transport concerning the regulation of nautical education centers (opinion of September 28, 2023, No. 458, web document No. 9946342);

k) draft decree of the Minister of Justice regarding digital infrastructures for interceptions (opinion of September 28, 2023, No. 460, web document No. 9942101);

l) draft decree of the Ministry of Infrastructure and Transport concerning the determination of the tools and procedures for assessing the state of intoxication due to the use of alcoholic beverages by the operators of pleasure craft, pursuant to Article 53-bis, paragraph 7, Legislative Decree No. 171 of July 18, 2005, concerning the code of pleasure boating (opinion of November 30, 2023, No. 596, web document No. 9970897);

m) draft decree of the Minister of Justice concerning the regulation to be adopted pursuant to Article 87, paragraphs 1 and 3, Legislative Decree No. 150 of October 10, 2022, and in implementation of the provisions regarding digital justice in civil proceedings introduced by Legislative Decree No. 149 of October 10, 2022, and Article 36, Legislative Decree No. 13 of February 24, 2023, converted,

with amendments, by Law No. 41 of April 21, 2023 (opinion of November 30, 2023, No. 554, web document No. 9973320);

n) draft regulation defining the transitional provisions for the military telematic criminal process pursuant to Article 87, paragraph 7, Legislative Decree No. 150 of October 10, 2022 (opinion of December 7, 2023, No. 593, web document No. 9976701);

o) draft decree of the Minister of Justice pursuant to Article 2, paragraph 3, Decree Law No. 105 of August 10, 2023, converted with amendments by Law No. 137 of October 9, 2023, concerning the specific technical requirements for the management of data at inter-district digital infrastructures (opinion of December 28, 2023, No. 637, web document No. 9978591).

The opinions referred to in letters m) and n) concerned recent procedural reforms that introduced "framework" norms and deferred, for implementation, in detail, to the technical specifications for which the opinion of the Guarantor is required. No particular critical issues were noted regarding the examined texts, with only suggestions made both from the drafting perspective (replacing the expression "sensitive data" with "data referred to in Article 9 of the GDPR," as for ordinary proceedings), and in relation to the normative parameters of compliance of the military process (i.e., the reference to data protection regulations within the reference norms and the eIDAS regulation for digital identification, as well as the provisions on data breaches within the regulations on site malfunctions).

3.1.4. Consultation of the Guarantor on regional or autonomous province legislative acts

The Guarantor was requested to express its opinion on certain draft laws or regulatory schemes from regions or autonomous provinces. In this regard, the following are noted:

- 1) opinion on the draft law of the Autonomous Province of Trento concerning interventions to support the Trentino economic system (opinion of February 9, 2023, No. 46, web document No. 9868127);
- 2) Opinion on the draft regulation of the Autonomous Province of Trento concerning the operation of the congenital anomalies register, in implementation of Article 14, paragraph 5-bis, Provincial Law of July 23, 2010, No. 16 (Provincial Law on Health Protection) (Opinion July 6, 2023, No. 307, web doc No. 9920921);
- 3) Opinion on the proposed law of the Autonomous Region of Friuli Venezia Giulia and the related implementing regulation, aimed at regulating the methods of processing personal data for the performance of activities assigned within the tasks attributed to the Regional Single Point (PUR) (Opinion August 31, 2023, No. 361, web doc No. 9928773);

4) Opinion on the draft regulation of the Autonomous Province of Trento containing rules on the protection of personal data in implementation of Article 29 of the Provincial Law on interventions in favor of the economy (Opinion October 12, 2023, No. 470, web doc No. 9997275);

5) Opinion on the draft implementing regulation of Article 40, paragraph 11-bis, Provincial Law of December 27, 2010, No. 27, concerning the processing of personal data belonging to special categories under Article 9 of the GDPR in the performance of cadastral functions delegated by the State to the Autonomous Province of Trento regarding land and urban cadastre (Opinion November 16, 2023, No. 595, web doc No. 9974277).

3.1.5. Reports

In 2023, two reports were submitted to the Government, aimed at urging the adoption of three measures (two ministerial decrees for the Minister of Justice and one for the Minister of the Interior), all of which, for various reasons, are of considerable importance for the complete definition of the regulatory framework regarding data protection.

These include, in particular, the ministerial decree on justice, which has a regulatory nature, aimed at regulating the processing of judicial data by private entities, in cases not already provided for by legislative or regulatory norms; the ministerial decree on justice that will have to carry out the inventory, also by category, of the processing of personal data carried out in the field of criminal justice, their essential characteristics, and the methods of exercising the rights of the data subjects, pursuant to Article 5, Legislative Decree No. 51/2018; the ministerial decree on the interior which, mirroring the one mentioned above, will have to carry out the inventory, also by category, of the processing of personal data carried out in the context of police activities, their essential characteristics, and the methods of exercising the rights of the data subjects, pursuant to Article 5, Legislative Decree No. 51/2018.

3.1.6. Questions

In the reference year, the Authority responded to a question submitted by a chauffeur service company regarding the application of the regulation concerning the content of the chauffeur service sheet as per Article 11, paragraph 4, Law of January 15, 1992, No. 21. In this circumstance, the report to the Government of May 16, 2019, was recalled, in which the questionable compatibility with the principle of proportionality of the requirement to indicate, within the service sheet, the data of the service user and the route taken (letters e) and c) of the aforementioned paragraph 4) was highlighted.

The Authority reminded the company that, on that occasion, it had urged the Government to take corrective legislative action – which has not yet been realized – regarding the contested provision, in order to amend the highlighted critical aspects.

3.2. Consultation through the IMI platform

In the reference year, there was a significant increase in cooperation procedures at the European level, through which primary issues regarding data protection were addressed.

In particular, the requested feedback was provided in relation to seven IMI procedures for mutual assistance under Article 61 of the GDPR, on important topics such as: the inventory of internal regulations governing the processing of special data by sports entities and associations for purposes related to the assessment of athletes' physical performance; the inventory of internal regulations on the processing of personal data within the employment relationship; the status of transposition in Italy of the NIS2 Directive; the designation of the supervisory authority for the purposes of the Data Governance Act (DGA) – Regulation (EU) 2022/868 of May 30, 2022.

30

STATUS OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION

3.3. Contribution to the Government for the Response to Acts of Inspectorial Oversight

In 2023, the Authority provided, at the request of the Government, informational elements for the drafting of the response to acts of inspectorial oversight concerning issues related to the protection of personal data.

With particular reference to the immediate response inquiry no. 5-01008, presented by Hon. Mari, regarding the use of automated decision-making systems in the workplace (June 20, 2023), the

Authority provided observations regarding the legitimacy criteria to be respected in monitoring workers in smart working through software that controls activity logs to verify the amount of work performed by the employee.

In this context, the Authority recalled the provisions that have aimed to protect the privacy of workers since Law No. 300/1970 against employer controls that could reach, also thanks to technology, particular levels of invasiveness. Thus, it indicated the rules on the prohibition of investigation into the opinions of workers (Article 8), the limits on monitoring their activities (Article 4), and the penalties provided for in case of violation of these limits (Article 171, Legislative Decree No. 196/2003).

The Authority also stated that the same EU data protection regulation recognizes, in the workplace context, a margin of flexibility for "interstitial" internal rules (Article 88 of the GDPR), due to the peculiarities of this regulatory sector and the consequent balancing that this requires between the protection of personal data and employer needs, with the possibility of different modulations at the internal level.

Among the internal provisions on the matter, it indicated Article 4 of Legislative Decree No. 104/2022, which implements Directive (EU) 2019/1152 of the European Parliament and of the Council of June 20, 2019, concerning transparent and predictable working conditions in the European Union. This, in amending Legislative Decree No. 152/1997, introduced a specific informational obligation for the employer (limited by the recent Legislative Decree No. 48/2023 to cases of full automation) regarding the use of automated decision-making or monitoring systems "designed to provide relevant indications for the purposes of hiring or assigning tasks, managing or terminating the employment relationship, assigning duties or tasks as well as indications affecting surveillance, evaluation, performance, and compliance with the contractual obligations of workers."

The Authority also recalled that this informational obligation (additional and more specific than that referred to in Article 13 of the GDPR regarding the processing of personal data) does not affect the provisions of Article 4 of Law No. 300/1970, according to which, indeed, the tools from which the possibility of remote monitoring of workers' activities may derive can be used exclusively for organizational and productive needs, for workplace safety, and for the protection of company assets, and can be installed subject to a collective agreement concluded by the unitary trade union representation or by the company trade union representations or upon administrative authorization. In this regulatory framework, it finally recalled that to verify the compliance of the tools used for the performance of work with the provisions of the GDPR, it will be necessary to conduct a risk analysis and an impact assessment of the same treatments, proceeding with prior consultation of the Authority.

3.4. Examination of Regional Laws for Constitutional Review by the Government

In the reference year, the resumption of the Authority's examination of regional laws is noted, in order to provide the Presidency of the Council of Ministers with any evaluation elements regarding their compatibility with the provisions on the protection of personal data, for the purposes of Article 127 of the Constitution.

In particular, the Authority examined, transmitting its evaluations and observations to the Presidency of the Council, the law of the Puglia Region No. 13/2023, containing provisions to prevent and combat mistreatment or abuse, including psychological abuse, against the elderly and persons with disabilities, and amending the regional law of August 9, 2006, No. 26.

In a note dated July 11, 2023, the Authority reported to the Presidency of the Council questionable compatibility profiles of the law with the data protection regulations (Legislative Decrees Nos. 196/2003 and 51/2018), in relation to the exclusive legislative power of the State in the matter of civil law (to which the Constitutional Court, with ruling No. 271/2005, has referred the data protection regulations), as well as to the "constraints arising from community law" concerning the provisions of the GDPR (cf. Article 117, paragraphs one and two, letter I), Constitution, as well as Constitutional Court, ruling No. 271/2005).

The note, in particular, highlighted that in regulating an activity such as video surveillance in residential facilities, which has a significant impact on privacy guarantees (both for guests and for the workers involved), the law seemed to intervene beyond its competences, in an area reserved for the state legislator, pursuant to Article 117, paragraphs one and two, letter I), of the Constitution.

The Authority also responded with a note dated July 20, 2023, to the Region's objections regarding the arguments provided, reiterating...

as noted in the memorandum to the Presidency of the Council regarding the possible misalignment of the regional law with the principles and the same regulation on data protection. The regional law was subsequently challenged by the Presidency of the Council of Ministers (with a decision made in the meeting of August 3 of the Council of Ministers) for violation of the allocation of legislative powers concerning certain matters such as, indeed, data protection (pursuant to Article 117, paragraphs 1 and 2, letter i), of the Constitution) before the Constitutional Court, which with the recent ruling of April 23, 2024, no. 69 declared the constitutional illegitimacy of Article 3 of the aforementioned regional law Puglia no. 13 of 2023 for conflict with Article 117, first paragraph, of the Constitution, in relation to the GDPR and Directive 2016/680/EU, and with Article 117, second paragraph, letter l), of the Constitution, concerning the matter of "civil law."

32

STATUS OF IMPLEMENTATION OF THE CODE ON PERSONAL DATA PROTECTION

Activities carried out by the Guarantor
ANNUAL REPORT
2023

II - Activities carried out
by the Guarantor

4

The Guarantor and public administrations

4.1. Tax, fiscal, and anti-money laundering activities

4.1.1. The pre-filled tax return

Also in 2023, the Guarantor was called to express an opinion regarding the so-called pre-filled tax return, both on the methods of access to the declaration by the interested parties and authorized subjects, as well as on the types of data to be transmitted to the Revenue Agency. The Authority was presented with the draft provision from the Director of the Revenue Agency concerning access to the pre-filled 730 declaration by the taxpayer and other authorized subjects, starting from the tax year 2022, in which the list of deductible expenses and related reimbursements, transmitted by third parties, was particularly integrated, which are used by the Revenue Agency for the processing of the declaration, with data transmitted by state institutions of higher education and artistic and musical specialization related to expenses for state courses following the attainment of the diploma. In this context, the Revenue Agency represented that it considered the experimental phase already initiated to be concluded, based on the positive outcome of the control activities requested by the Authority on the correct management of delegations by the CAFs, and therefore wished to allow all CAFs that deem it appropriate to sign the agreement to access the pre-filled declaration in cooperative application with a security framework. On this basis, the Authority expressed a favorable opinion, considering that the set of measures and guarantees provided in the draft is compliant with the regulations on personal data protection and adequately takes into account the high risks to the rights and freedoms of the interested parties that the processing in question entails (provision of April 13, 2023, no. 116, web doc no. 9888129).

Regarding the collection of data for the purpose of processing the pre-filled tax return, first of all, the Guarantor expressed a favorable opinion on the draft decree of the Minister of Economy and Finance which provides for the telematic transmission to the Revenue Agency of data concerning expenses for the purchase of subscriptions to local, regional, and interregional public transport services (provision of February 23, 2023, no. 45, web doc no. 9869626). Consequently, the Guarantor gave its favorable opinion on the draft provision of the Director of the Revenue Agency that regulates the transmission of the aforementioned data, as the measures aimed at ensuring the protection of the rights and fundamental freedoms of the interested party were deemed adequate, such as, for example, the guarantee of opposition to the use of the data (provision of August 31, 2023, no. 360, web doc no.

9928753). A favorable opinion was also rendered on the draft provision of the Director of the Agency concerning the methods and terms of communication to the Tax Registry of data relating to reimbursements granted for the purchase of prescription glasses or corrective contact lenses – within the framework of the so-called vision bonus regulated by the decree of the Minister of Health, in agreement with the Minister of Economy and Finance, of October 21, 2022 (on which the Guarantor had expressed its opinion with provision of October 6, 2022, no. 319, web doc no. 9817038) – taking into account that the processing concerns the personal data necessary for the pursuit of the purposes related to the submission and management of the pre-filled tax return, including those of formal control thereof, and that the flows occur through the provision of an encrypted file, directly within the information systems of SOGEI S.p.A., responsible for the processing both of the Ministry of Health and of the Revenue Agency (provision of October 26, 2023, no. 494, web doc no. 9953525).

A positive ruling from the Guarantor was also given on the draft decree of the Minister of Economy and Finance which provides for the transmission to the Health Card System (Sistema TS) of data relating to health expenses by subjects registered in the Register of Pediatric Nurses and the identification of the National Federation of Orders of the Health Profession of Physiotherapists and the National Federation of...

****National Orders of Biologists as Subjects Required to Make Available to the TS System the Lists of Registered Members of the Relevant Registers (Provision April 27, 2023, No. 161, Web Document No. 9894458). ****

At the same time, the Guarantor has expressed a favorable opinion on the draft decree of the MEF – General Accountant of the State, which consequently provides for the adjustment of the technical specifications and operational methods of the data flows related to healthcare expenses for the purpose of processing the pre-filled income tax return, within the framework of transmission to the TS System, in order to implement the aforementioned innovations related, in particular, to pediatric nurses (Provision April 27, 2023, No. 162, Web Document No. 9894499).

In this context, the Guarantor has also endorsed the draft provision of the Director of the Revenue Agency that regulates the technical methods for using the data of healthcare expenses incurred for services provided by members of the professional registers of pediatric nurses, referring to the regulations contained in the relevant provisions, which have already been favorably evaluated by the Guarantor, regarding the measures and guarantees contained therein deemed adequate to protect the rights and freedoms of the interested parties (Provision June 22, 2023, No. 258, Web Document No. 9913892).

The Guarantor was consulted by the Revenue Agency on the draft provision of the Director concerning the methods of transmission to the Agency of the data contained in the form regarding the choices for the allocation of the eight, five, and two per thousand of the IRPEF by the withholding agents providing tax assistance. In issuing the opinion, it was preliminarily noted that the collection and transmission to the Revenue Agency as well as the retention of the forms, by employers (as withholding agents) and the Agency itself, of particular categories of personal data of employees related to the aforementioned choices, in the delicate work and professional context, are safeguarded, in addition to the specific guarantees provided by the regulations on personal data protection, also by the relevant regulatory framework, which provides protections aimed at preventing discriminatory effects, including indirect ones, against workers.

That said, the Guarantor noted that the measures identified in the draft for the dematerialization of the methods of presenting the aforementioned forms did not offer an equivalent level of protection regarding the confidentiality of the choices of the interested workers, compared to that provided for by the previous regulations, as they were not sufficient to prevent the employer from knowing the content. A favorable opinion was therefore issued, on the condition of introducing measures such as the encryption of the electronic document containing the choices made by the worker, directly by the worker before delivering the document to the withholding agent, through tools and cryptographic keys made available by the Agency, as well as the collection of the aforementioned choices by the Agency directly from the worker, or in any case through a channel different from the withholding agent

(Provision March 23, 2023, No. 79, Web Document No. 9879234).

The MEF submitted to the Guarantor's consultation two draft decrees aimed at regulating the purposes and methods of use, by the Revenue Agency, of tax data, the methods and terms of data acquisition, the security measures for the protection of the rights and freedoms of the interested parties, and the use of data for the purpose of monitoring overall public and private healthcare spending, with reference to the data contained in electronic invoices and the payments related to healthcare services transmitted to the TS System (pursuant to, respectively, Article 10-bis, Decree Law October 23, 2018, No. 119, and Article 2, paragraph 6-quater, Legislative Decree August 5, 2015, No. 127). A favorable opinion was expressed in this regard due to the identification of appropriate and specific measures to protect the fundamental rights and interests of the interested parties, such as the limitation of the use for tax purposes of only the data transmitted to the TS System that are actually indispensable for the pursuit, by the Revenue Agency and the Guardia di Finanza, of the purposes provided by law, excluding data related to the health of the interested parties (Provision December 7, 2023, No. 581, Web Document No. 9974159).

4.1.2. Anti-Money Laundering

The Agents and Brokers Organization (OAM) has submitted to the Authority the draft of the Technical Specifications for the registration, accreditation, and consultation procedures related to the register of contracted subjects and agents of payment service providers and electronic money issuing institutions, pursuant to Article 45 of Legislative Decree No. 231 of November 21, 2007 (the so-called anti-money laundering decree) and, in its implementation, the decree of the Minister of Economy and Finance of May 31, 2022 (on which the Guarantor had expressed an opinion with provision No. 77 of February 24, 2022, web document No. 9751958). A favorable opinion was issued considering that the draft, in addition to taking into account what has already been defined in the past regarding the register of gold buying operators (see the opinion issued with provision No. 447 of July 26, 2018, web document No. 9025512), has incorporated, as far as compatible and adapting them to the specific context, the observations provided regarding virtual currency operators (provision No. 449 of December 21, 2022, web document No. 9856315). It is noted that these indications particularly concerned the identification of the types of personal data and documents subject to processing both in the user registration phase and in the accreditation and transmission phases, the delimitation of the types of personal data subject to consultation both in the publicly accessible section of the register and in the reserved access section, the adoption of measures aimed at adequately informing contracted subjects and agents about the processing of their personal data (also with reference to those involving public accessibility), the introduction of a mechanism for mutual and timely information among the data controllers involved in case of security breaches or other threats that pose a risk to the security and to the rights and freedoms of the data subjects (provision No. 141 of April 13, 2023, web document No. 9894521). Also in the field of anti-money laundering, the Authority has reviewed, at the request of InfoCamere S.c.p.A., the draft Addendum to the technical regulation on the security of data processing regarding beneficial ownership, as provided for by Article 11, paragraph 3, of the regulation pursuant to the decree of the Minister of Economy and Finance, in agreement with the Minister of Economic Development, No. 55 of March 11, 2022, already adopted by InfoCamere following the opinion of the Guarantor (provision No. 316 of October 6, 2022, web document No. 9817361). The Authority, in particular, had reserved the right to evaluate the technical and organizational measures concerning access to information on beneficial ownership. In this regard, the Guarantor, after highlighting the intervening judgment of the Court of Justice of the European Union of November 22, 2022, joined cases C-37/20 and C-601/20 – which declared invalid the provision of the European anti-money laundering directive allowing States to provide for public accessibility of information on the beneficial ownership of companies and other legal entities – issued a favorable opinion also considering that the draft Addendum, following the indications provided by the Authority during the discussions, has coordinated the provisions concerning access to information on beneficial ownership by the so-called legitimate subjects, limiting its scope more clearly to holders of a relevant and differentiated legal interest, thus ensuring compliance with what was established in the ruling of the Court of Justice (provision No. 397 of September 14, 2023, web document No. 9938499).

4.2. Social Security, Social Assistance, and Other Economic Benefits

The year 2023 has seen regulatory changes regarding the recognition of economic support measures for people in difficulty, with the transition from the citizenship income (RDC) and citizenship pension (PDC) (regulated by Decree-Law No. 4/2019) to the inclusion allowance (ADI) and support for training and work (SFL) (introduced by Decree-Law No. 48/2023).

Regarding citizenship income and pension, the Guarantor has provided a favorable opinion on the draft application form for the benefit, which modifies those adopted by INPS in 2019 and 2022 (following the Guarantor's opinion) pursuant to Article 5, paragraph 1, of Decree-Law No. 4/2019, in order to follow up on the changes that have occurred in the sector regulations which have defined the gradual exhaustion of the provision of the measure, the cessation of which has become effective as of January 1, 2024 (provision No. 241 of June 8, 2023, web document No. 9913623).

In order to implement the new support measures of the ADI and SFL, introduced by Decree-Law No. 48/2023, the Ministry of Labor and Social Policies has submitted to the Authority's consultation two draft decrees concerning, respectively, the establishment and functioning of the Information System for Social and Labor Inclusion (SIISL) and the establishment and implementation of the SFL. In its opinion, the Guarantor preliminarily observed that the SIISL – established at the Ministry of Labor and Social Policies and implemented by INPS, through which the interoperability of all digital platforms of the subjects accredited to the social and labor system for the provision of ADI and SFL is ensured – is also realized through the reuse of components already developed within the Information System of the RDC pursuant to Decree-Law No. 4/2019, within which guarantees vetted by the Authority have been ensured (provision No. 138 of June 20, 2019, web document No. 9817361).

web n. 9122428). For this reason, as well as for the incorporation of the indications provided by the Office during the discussions – such as those concerning the identification of the subjects involved and the roles assumed by each in relation to the processing of personal data carried out, the types of personal data subject to the feeding of the SIISL and the related sources, the tasks of the accredited subjects competent for the provision of active policy measures within the SFL, the guarantees contained in the regulations on the processing of personal data, including automated processing carried out for profiling purposes within the activities of training, qualification, and professional requalification, guidance, and job placement (cf. Guarantee Program for the Employability of Workers (GOL), on which the Guarantor has expressed a favorable opinion with provision of October 20, 2022, n. 353, doc. web n. 9827428) – a favorable opinion has been issued (provision of August 3, 2023, n. 354, doc. web n. 9918937).

38

ACTIVITIES CARRIED OUT BY THE GUARANTOR

ACTIVITIES CARRIED OUT BY THE GUARANTOR

II4

ADI

Families and Students Platform

In the process of implementing d.l. n. 48/2023, the Ministry of Labor and Social Policies has drafted the regulations for the specific measure of ADI, requesting the required opinion from the Guarantor on the related draft decree. In its opinion, the Guarantor noted the improvements made to the text following the acceptance of the indications provided by the Office, particularly concerning: the identification of the role played by patronage institutions and CAF in relation to the processing of personal data carried out in the context of the ADI application; the definition of the personal data subject to processing by INPS for the purpose of verifying eligibility requirements and the related methods; the reference to the guarantees of the GOL Program in case of profiling as well as on periodic checks; the adoption by INPS of appropriate measures of transparency and information regarding the obligations and duties to which beneficiaries are subject. In any case, the opinion includes a remark regarding the necessity that the processing carried out in the context of checks on the possession of requirements, where not already regulated by other normative sources, be initiated after identifying adequate measures to protect the rights and fundamental freedoms of the data subjects, following a data protection impact assessment, in a provision of INPS to be adopted after consulting the Guarantor (provision of

4.3. The protection of personal data in the educational and university context

Also in 2023, the Guarantor interacted with the Ministry of Education and Merit, universities, and educational institutions during meetings and contacts aimed at providing clarifications and indications on the correct application of the regulations regarding personal data protection. In this context, particular importance was given to the provision of October 10, 2023, n. 468 (doc. web n. 9953443), with which the Guarantor expressed, urgently, a favorable opinion, subject to conditions, pursuant to Articles 36, paragraph 4, and 58, paragraph 3, letter b), of the GDPR, as well as Article 21, paragraph 4-quater, d.l. n. 75/2023, on the draft decree of the Minister of Education and Merit concerning the regulations on the processing of personal data within the Families and Students Platform. The draft establishes that the Platform represents a single access channel to the information assets held by the Ministry and educational institutions, interoperable with the related information systems, interconnected with the ANS and, when operational, with the ANIST, with the aim of providing specific digital services to ensure support for the right to education and effective support for students in their growth and skills development, as well as simplifying the provision of services for families and students and optimizing the work of the Ministry and institutions. The Platform consists of a public area and a private area, the latter accessible, following an identification and authentication procedure, to various categories of users (students of lower and upper secondary schools, parents/legal guardians, teachers, tutors, school principals, ATA staff, etc.). Through it, it is possible to access optional digital services, such as the so-called e-portfolio (a service that allows viewing data and information related to the educational path of students, in order to support them in their educational and professional choices), the tutor teacher (a service aimed at facilitating the performance of tasks assigned to the teacher who holds the role of tutor), school trips (a service aimed at enabling the widest participation of students in educational trips and visits, through the recognition of economic contributions or other types of benefits for families in greater need).

39

REPORT 2023

The draft decree and the related technical annex take into account the observations provided by the Office to the representatives of the Ministry during informal discussions in order to make the treatments compliant with the regulations on the protection of personal data, in accordance with the principle of privacy by design and by default. These observations particularly concerned the identification of the subjects involved and the roles assumed by each in relation to the processing of personal data carried out and the institutional purposes pursued; the methods through which the Ministry aggregates personal data, in order to reduce the risk of re-identification of the data subjects, for its own purposes of monitoring and general governance of the Platform; with specific reference to the digital teacher tutor service, the optional nature of the provision of information by users and the limitation of the purposes for which access to this service is permitted; with specific reference to the digital school trips service, the description of the planned treatments and, in relation to each of these, the identification of roles, the types of personal data processed, and the operations performed, as well as the specification of the related informational obligations, as well as the aggregation of the information exchanged between the Ministry and INPS; the retention periods for the various types of personal data processed within the Platform; the identification of technical and organizational measures to be adopted in order to ensure compliance with the principles of the GDPR and security obligations (computer authentication procedures, categories of persons authorized to access the Platform for the performance of the institutional purposes pursued by the entity of belonging, methods of data exchange with INPS, and others).

Since the personal data directly provided by users in the Platform may also include those belonging to the categories referred to in Articles 9 and 10 of the GDPR, the Authority expressed a favorable opinion on the draft decree on the condition that it be supplemented with the indication of the types of data that may be processed, the operations that can be performed, and the appropriate and specific measures to protect the fundamental rights and interests of the data subject, as established by Article

2-sexies of the Code, to be identified based on an adequate risk assessment.

The Authority also urgently expressed a favorable opinion on the draft decree of the Minister of Education and Merit concerning the criteria and methods related to the section of the National Education Registry (ANIST) regarding students enrolled in ITS Academy programs for the quantitative and qualitative monitoring of the tertiary technological education system through the specific national database, pursuant to Articles 12, paragraphs 1 and 2, and 14, paragraph 6, Law No. 99/2022.

In this case as well, the draft decree takes into account the observations of the Office provided during informal discussions and meetings with the representatives of the Ministry, in order to ensure that the treatments regulated therein comply with the regulations on the protection of personal data, in respect of the principles of data protection from the design stage and by default. These observations particularly concerned the specification of the purposes pursued by the ITS Academy Section of ANIST and the identification of the subjects authorized to access the personal data contained therein in implementation of the tasks defined by law; the identification of the roles assumed by the ITS Academy and the Ministry in relation to the processing of personal data carried out within the ITS Academy section of ANIST; the general definition of the types of personal data contained in the ITS Academy section of ANIST; the use by the Ministry, for the purposes of monitoring the tertiary technological education system, of information related to the employment outcomes of enrolled students and graduates exclusively in aggregated form.

The Authority provided its opinion on the assumption that, in any case, the full operation of the ITS Academy section of ANIST and the initiation of the consequent treatments.

****Processing of Personal Data of Students****

The processing of personal data of students will only take place following the complete definition of the legal framework through the issuance of a subsequent implementing decree, which will be subject to the opinion of the Data Protection Authority and aimed at identifying further detailed elements of the processing, such as, in particular, the specific types of personal data subject to processing and their respective sources; the operations that can be performed on the data and the related processing methods, as well as the specific technical and organizational measures to ensure the protection of the rights and freedoms of the data subjects; the guarantees to ensure the issuance of certifications, including those related to educational qualifications by the ITS Academy, which has been assigned the certification function by the sector regulations; the retention periods of personal data within the new section; the connection between the latter and the national database referred to in Article 13 of the Prime Ministerial Decree of January 25, 2008, including the characteristics of the processing carried out in this context and the methods of interaction between them (provision of November 16, 2023, no. 525, web document no. 9966592).

Also during the current year, complaints and reports have been defined concerning the publication, on the websites of educational institutions, of personal data of students as well as regarding the communication of such data to third parties, in the absence of a suitable legal basis and in violation of the principles applicable to data processing.

In this context, the Authority has criticized the behavior of a school that published, in the transparent administration section of the institutional website, a note from the school principal containing the names of students admitted to full-time attendance at the primary school in one of the institution's locations and the indication of their assigned class. In this regard, it was recalled that a specific processing of personal data can only be lawfully carried out by a public entity if it is necessary for the fulfillment of a legal obligation by the data controller or for the execution of a task of public interest or related to the exercise of public powers; moreover, the processing must find its basis in a provision that has the characteristics referred to in Article 2-ter of the Code. The Authority also reminded that the Data Protection Authority, in collaboration with the Ministry of Education, intervened by referring to a specific FAQ regarding the publication, on the websites of educational institutions, of lists of names related to the composition of classes (see FAQs regarding the processing of personal data in the school context within the framework of the health emergency, web document no. 9337010, and, in

particular, FAQ no. 10). With the aforementioned FAQ, it was clarified that the dissemination of data related to the composition of classes on the websites of educational institutions is not permitted as such processing is lawful only in the cases provided for by Article 2-ter of the Code.

The Authority thus established that the publication on the school's website had resulted in the unlawful dissemination of personal data, in violation of Articles 5 and 6 of the GDPR, as well as Article 2-ter of the Code, and proceeded to admonish the educational institution (provision of April 13, 2023, no. 185, web document no. 9902516; see also provision of July 6, 2023, no. 288, web document no. 9920274). Similarly, the Authority admonished an educational institution following a complaint regarding a contested email sent by a teacher to all parents of the students in the class, containing information related to the inappropriate behavior of the complainants' child and another student. The Authority, after recalling that "in circulars, resolutions, or other communications not addressed to specific recipients, personal data that can identify students cannot be included" (see FAQ no. 7 School and Privacy – frequently asked questions and The school privacy-proof - Vademecum ed. 2023.pdf, see the entry "School Communications" on p. 28) deemed that the sending of the communication in question by the educational institution had effectively made information regarding the aforementioned students known.

also from third parties not authorized (all the parents of the class recipients of the emails other than the parents of the two interested boys), thereby resulting in a communication of personal data in violation of Articles 5 and 6 of the GDPR and Article 2-ter of the Code (provision of September 28, 2023, no. 421, web document no. 9946323). The Authority also censured with a warning the behavior of a school institution that, following a request for access to administrative documentation submitted to the institution pursuant to Law No. 241/1990, sent to the interested parties, identified pursuant to Article 3 of Presidential Decree No. 184/2006, a copy of the access request containing, in addition to the name of the complainant, further personal data such as the phone number and a copy of the identity document of the interested party. In this regard, the Authority clarified that the objection raised concerned not so much the communication of the identity of the complainant to the interested parties in the access to documents procedure—conduct not subject to censure under the regulations on access to administrative documents—nor the transmission of the mere access request, but rather the sending of the complete copy of the complainant's identity document as well as the personal information contained in the access request, such as the phone number and email address. Such communication was not functional to the purpose of the regulation (i.e., to present a possible opposition to access) and lacked suitable regulatory grounds, thus proving disproportionate in relation to the purpose of processing, in violation of the principle of data minimization (Articles 5, paragraph 1, letter a) and c); 6, paragraph 1, letters c) and e), paragraph 2 and paragraph 3, letter b), of the GDPR and Article 2-ter of the Code) (provision of September 28, 2023, no. 422, web document no. 9947479).

4.4. Transparency and publicity of administrative action

During the year, the Authority examined numerous issues concerning the theme of personal data protection with reference to the needs for transparency and publicity of administrative action, which, for clarity of exposition, will be divided in relation to the publication of personal data online and access to information and documents held by the public administration through the institute of civic access (Article 5 of Legislative Decree No. 33/2013).

4.4.1. The publication of personal data online by public administrations

There have been various interventions, which have also led to the adoption of specific warnings or sanctions against public entities responsible for processing, for having disseminated personal data online in the absence of an appropriate legal basis in violation of Article 2-ter, paragraphs 1 and 3, of the Code and Article 6, paragraph 1, letters c) and e); paragraph 2 and paragraph 3, letter b), of the GDPR, as well as the principle of minimization referred to in Article 5, paragraph 1, letter c), of the GDPR. This particularly concerned the publication of data and personal information on institutional websites of a ministry, a port authority, and two municipalities related to:

- an individual mentioned in a municipal council resolution published online, who was identifiable from the relevant initials and contextual information, also considering the indications regarding the period of

work performed, professional qualification, and the procedural events reported (provision of March 2, 2023, no. 65, web document no. 9874480; see also provision of July 18, 2023, no. 311, web document no. 9920562, where the Authority declared the illegitimacy of the dissemination of information concerning a complainant that could indirectly identify him even though the name and surname had been obscured);

- a person who had reported a building abuse to a municipality, whose personal data were contained in the order of the entity related to a demolition order that also clearly reported the personal data of the subject recipient of the administrative provision (including personal data, place and date of birth, residence address) and of the professionals in charge, indicating, among other things, the disciplinary report made to the College of Surveyors (provision of April 27, 2023, no. 166, web document no. 9896450);

- various individuals through the erroneous online publication of their identification documents and health cards (provision of May 17, 2023, no. 193, web document no. 9907862).

4.4.2. Civic access

Regarding the right of civic access and the protection of personal data, the Authority intervened by adopting numerous opinions addressed to the Heads of Corruption Prevention (RPCT) or to civic defenders pursuant to Article 5, paragraphs 7 and 8, Legislative Decree No. 33/2013. In this regard, the general principles were reiterated.

principles and the criteria for the mutual balancing of the two rights outlined in the ANAC determination of December 28, 2016, no. 1309, adopted in agreement with the Guarantor, "Guidelines containing operational indications for the definition of exclusions and limits to civic access referred to in Article 5, paragraph 2 of Legislative Decree 33/2013," to which reference is made for a more detailed examination.

In this context, it is worth noting the civic access to sensitive data such as that held by the Ministry of Health regarding vaccinated individuals. In the specific case, the request for disclosure concerned data related to the deaths of individuals who had received the first dose of any type of Covid-19 vaccine. In particular, information was requested for each individual, excluding their name and surname, but including date of birth, date of possible death, date of the first dose, date of any second dose, date of any third dose, and date of any fourth dose. The Guarantor highlighted that the individual information contained in the National Vaccination Registry in the case at hand has particularly sensitive nature and, therefore, any potential disclosure could alter the regime and security measures adopted by the Ministry of Health pursuant to Article 32 of the GDPR, as well as the rules regarding accountability and the risk assessments for re-identification carried out by the aforementioned Ministry through the impact assessment provided for in Article 35 of the GDPR for high-risk processing. The data indeed refers to vaccinated individuals treated on a large scale and to the administered vaccine doses, the number of which may be suitable to reveal – in the case, for example, of receiving only one dose or failing to complete the vaccination cycle – the existence of possible subsequent exemptions or deferrals related to morbidity situations, past or present, temporary or permanent (with the consequent attribution to the "special categories of personal data" referred to in Article 9 of the GDPR) or other personal beliefs.

Therefore, after highlighting that the state legislation in the sector contained in the decree of the Ministry of Health of September 17, 2018, concerning the establishment of the National Vaccination Registry provides for access to the data of such Registry only under certain conditions and in an aggregated and anonymous form, it was represented that the data requested through civic access in the case at hand, even if devoid of the name and surname, were neither aggregated data nor had they been adequately anonymized even if devoid of the name and surname of the assisted individual. In this regard, it was reiterated that a process of anonymization cannot be deemed effective if it does not prevent anyone from using such data, in combination with "reasonably available" means, to: 1. isolate a person in a group (single-out); 2. link an anonymized data to data referable to a person present in a distinct dataset (linkability); 3. deduce new information referable to a person from an anonymized data (inference). In the case at hand, it was necessary to take into account the risk of re-identifiability of the individuals concerned arising from the request for disclosure of individual data in disaggregated form

(administered vaccine, dates of administration of the different doses, dates of birth and possibly of death) and from the possibility for the requesting party (but, in light of the publicity regime inherent to civic access, also for third parties) to cross-reference and compare the obtained data with other auxiliary information already known or contained in further databases or in statistical data (provisions of November 27, 2023, no. 552, web doc no. 9967883; October 12, 2023, no. 469, web doc no. 9956589; October 5, 2023, no. 466, web doc no. 9953563).

Also regarding sensitive data, in 2023 the Guarantor expressed itself on the existence of cases of exclusion of civic access or so-called absolute exceptions with specific reference to requests concerning health data, with respect to which the administration is required to refuse access, without the need to carry out further merit evaluations regarding the existence of any concrete prejudice to the interests of the individuals concerned. This specifically refers to requests for civic access concerning documents related to a request for clarification made by the ASL to a nursing home, including the response provided by it, which reported in...

clear the name or initials of the interested party, with detailed information regarding the related hospitalization, healthcare services, treatment path, treatments and specialist visits, pathologies and health conditions, relationships with healthcare personnel, patient discharge (provision December 15, 2023, no. 598, web doc no. 9976123).

In other cases, however, the Guarantor has provided opinions on requests for generalized civic access, expressing itself on the existence of the limit arising from the protection of personal data as per Article 5-bis, paragraph 2, letter a), Legislative Decree no. 33/2013, under which generalized civic access must be denied. This particularly refers to:

- declarations of objection/non-objection of conscience issued by employees working in counseling facilities, in the obstetrics and gynecology departments of hospitals, and in health companies issued pursuant to Article 9 of Law April 19, 1978, divided by professional figure and with precise indication of the structures to which the declarations pertain. In this regard, it has been highlighted that the personal data contained in the aforementioned declarations of healthcare personnel and auxiliary staff fall within the "special categories of personal data" as per Article 9 of the GDPR, as they are data capable of revealing personal beliefs of the interested parties, including religious or philosophical beliefs. The disclosure of such data may cause, in relation to the cases and the context in which they may be used by third parties, taking into account also the particular publicity regime of the data subject to generalized civic access, the concrete prejudice to the protection of personal data provided for by Article 5-bis, paragraph 2, letter a), Legislative Decree no. 33/2013. Therefore, even when providing aggregated data, a careful assessment regarding the risk of re-identification of objectors and non-objectors of conscience must be carried out (provision June 22, 2023, no. 267, web doc no. 9919260);

- written papers in a public competition. The Guarantor has highlighted that the issue of generalized civic access to copies of the written papers of public competitions has been examined more than once, under different profiles (see provisions November 7, 2019, no. 200, web doc no. 9196072; October 26, 2017, no. 433, web doc no. 7156158; May 24, 2017, no. 246, web doc no. 6495600; November 7, 2017, no. 366, web doc no. 7155171). In this regard, it recalled that the CJEU has also stated that the content of the answers provided by a candidate in a competitive examination reflects the relative level of knowledge and competence in a given field, as well as their reflection processes, judgment, and critical spirit, also indicating multiple aspects of a personal nature regarding the individual characteristics related, for example, to professional preparation, culture, expression abilities, or the character of the person (which constitute evaluable aspects in the selection of participants) (CJEU December 20, 2017, C-434/16; see also point no. 23 of the conclusions of the Advocate General, case C-434/16, cited). Therefore, it has been observed that the use of such information may have an effect on the rights and interests of the interested parties, as it may determine or influence, for example, the possibilities of accessing the desired profession or employment. In the case at hand, it has been reiterated that, even if civic access must be denied, the possibility remains that the same written papers may be made accessible if a qualified interest is demonstrated pursuant to Law no. 241/1990 (provisions January 29, 2023, no. 36, web doc no. 9867345; April 27, 2023, no. 177, web doc no.

9895517);

- notes sent to employees regarding the assignment of specific responsibilities with an indication of the amount of the annual allowance due, to which the individual score allocation sheets and compensation determination were attached. In this case, it was noted that the aforementioned notes contained personal data of the interested employees of various natures and types, such as: the name and... surname; the qualification of provincial employee with indication of the category (e.g., C or D), level (from 1 to 6), area; the amount of the annual allowance assigned based on the weighting sheet; the specific duties and responsibilities assigned in addition to the normal institutional tasks; the scores assigned for the duties performed during the reference period. It was represented, among other things, that the allowance was assigned based on evaluative elements of the activity carried out and that the generalized disclosure of the notes would expose employees to prejudices or disturbances regarding the regular performance of public functions or activities of public interest exercised. Therefore, it was deemed that the entity had correctly rejected the request for civic access to the aforementioned notes (provisions July 13, 2023, no. 308, web doc no. 9990570; August 3, 2023, no. 343, web doc no. 9925408; September 29, 2023, no. 461, web doc no. 9953581);

- preparatory acts related to an inquiry for the coverage of 84 managerial positions not general at a public administration. In this case, it was noted that the requested documentation contained substantive observations, including comparative ones, regarding the "spendability" / "suitability" of the candidacy of a certain manager for a specific office rather than another, based on the complexities (including managerial) of the office to be directed and in light of the preferences indicated by the candidate (in several cases disregarded by the Commission during the assignment of the position). The minutes of the commission also included the individual evaluation sheets related to the managers who participated in the inquiry, which contained the individual and total scores regarding numerous factors related to aptitudes and professional skills or specific competencies and experiences of the candidates as well as their respective declarations of availability. In this regard, it was emphasized that the aforementioned data and information did not constitute public data and that the related disclosure had to be evaluated in light of the rules and limits provided by the state regulations in the sector regarding civic access, also considering a certain sensitivity of the requested information, as well as the fact that the generalized disclosure of the aforementioned personal information through the institute of civic access could well be a source of possible negative repercussions on a professional or relational level, even within the work environment, so that it would configure for the interested parties, depending on the hypotheses and the context in which the data was provided, and the information could be used by third parties, precisely that concrete prejudice to the protection of personal data provided for by Article 5-bis, paragraph 2, letter a), Legislative Decree no. 33/2013 (provision August 3, 2023, no. 353, web doc no. 9921143);

- final report of an internal administrative investigation ordered following a report concerning the work environment and carried out through the distribution of some questionnaires to employees. In this regard, it was highlighted that the report contained personal data of various nature and type that identified multiple persons and provided indications on a specific incident and on the working relationships between colleagues belonging to the same office, with a description of the facts and the report made. Consequently, it was deemed that the related disclosure would have determined an unjustified and disproportionate interference in the rights and freedoms of the interested parties, with possible negative repercussions on a social, relational, and professional level (Article 5-bis, paragraph 2, letter a), Legislative Decree no. 33/2013; Article 5, paragraph 1, letters b) and c), of the GDPR) (provision October 26, 2023, no. 492, web doc no. 9953599);

- landscape authorizations and evaluations of a municipality with particular reference to projects, photographic reproductions, illustrative technical reports, graphic tables, and graphic elaborations, as well as information and documents concerning a sanctioning procedure for the absence of the landscape authorization later remedied (provision January 29, 2023, no. 37, web doc no. 9870805);

- data and/or documents concerning an extraordinary maintenance intervention according to the CILA procedure (certified notification of commencement of works), provided for by Article 6-bis of

Presidential Decree no. 380/2001. Also in this case, in accordance with previous orientations in the matter, it was recalled that the information and data, including personal data, to be presented to the competent authority and contained in the aforementioned building permit are multiple and of different types and nature. It was therefore confirmed that, even in this case, the general knowledge of the data and personal information contained in the CILA, considering the quantity and quality of the personal data involved, would have determined an unjustified and disproportionate interference in the rights and freedoms of the interested party – in violation of the aforementioned principle of data minimization (Article 5, paragraph 1, letter c), of the GDPR) – with possible negative repercussions on a personal and social level. The latter had, in particular, represented, in the opposition to civic access, that with the potential display of the requested documentation would provide "indications regarding the configuration of [one's] main residence" that could compromise the related right to privacy and create a prejudice to personal security (provision of September 22, 2023, no. 418, web doc no. 9953858);

- cemetery concessions issued by the municipality. Such documents contained sensitive personal data and information, as they pertained to the holders of the cemetery concessions, the decision to renew the concession or to proceed with the exhumation of a loved one or to move the remains to another site, as well as the specification of what was paid to the administration for such operations (provision of November 16, 2023, no. 550, web doc no. 9965679).

The Authority also expressed itself in cases where civic access could not be denied for reasons of personal data protection. The reference is to a case where the subject of civic access was the "expressions of interest" sent to the mayor by the current members of the Advisory Commission on Mobility established by a municipality. In particular, such documents contained personal data (such as personal details, citizenship, enjoyment of civil and political rights) with an attached curriculum certifying the "knowledge of the functioning of the Commission and the acquired experience and competence." Unlike the previous cases examined by the Authority regarding expressions of interest (cf. provision of March 30, 2017, no. 162, web doc no. 6393422), the case in question was characterized by the circumstance that the request for generalized civic access did not concern all those who had submitted applications and had not been selected, but exclusively the expressions of interest sent by the members of the Advisory Commission on Mobility appointed by the mayor and who were in office. Therefore, the municipality receiving the request for civic access was asked to reconsider the denial, allowing access to the data and curricula of the current members of the Advisory Commission on Mobility, for whom mandatory publication obligations are provided for under Article 15, Legislative Decree no. 33/2013, ensuring, however, that personal information that could be deemed disproportionate, excessive, and irrelevant to the purpose of transparency was selected and obscured (e.g.: residence, contact details, tax codes, handwritten signatures, or also – after involving the interested parties – possible information on qualities and experiences that may be contained in the curricula that are not relevant because they do not pertain to the specific competencies required to participate in the selection) (provision of June 1, 2023, no. 222, web doc no. 9908447).

Similarly, it was specified that it was not possible to invoke the limit of personal data protection provided for by Article 5-bis, paragraph 2, letter a), Legislative Decree no. 33/2013 in relation to requests concerning information and data referring not to natural persons, but to companies or legal entities, for which it was once again reiterated that it is necessary to assess the existence of different limits (e.g. Article 5-bis, paragraph 2, letter c), Legislative Decree no. 33/2013) (provision of February 20, 2023, no. 40, web doc no. 9872995, cf. on the topic of access to corporate data and legal entities: provisions of April 13, 2023, no. 149, web doc no. 9888170; August 10, 2023, no. 355, web doc no. 9990602; August 14, 2023, no. 356, web doc no. 9929110).

4.5. Processing of personal data carried out by central administrations, regions, and local authorities

4.5.1. Processing of personal data carried out by central administrations

Central administrations, as also represented in the paragraph relating to the digitalization of public administration (cf. par. 4.10), consulted the Authority on the initiatives undertaken in the context of the digitalization process, stimulated by the implementation of the PNRR. The Authority exercised the

powers attributed to it by the GDPR and the Code in order to ensure respect for the rights and freedoms of the data subjects in such contexts, often characterized by high risks due to the characteristics presented by the processing proposed by the involved administrations.

In 2023, the Authority continued its monitoring activity on large public databases by verifying the security measures adopted and the legitimacy of accesses made by authorized subjects. The Authority expressed a favorable opinion on the drafts of two ministerial decrees from the Ministry of Enterprises and Made in Italy, implementing the decree of the Ministry of Economic Development of May 7, 2019, concerning, respectively, the definition of the methods and deadlines for submitting applications for registration in the list of qualified managers and consulting firms authorized to carry out managerial assignments, and the model of application for admission to the contribution and the definition of the deadlines for submission, as well as the evaluation criteria for applications and for the priority allocation of available resources. In the context of the discussions that took place, the Ministry had accepted the indications provided by the Office concerning, in particular, the roles held by the involved actors, the types of personal data subject to processing (also distinguishing between the information provided mandatorily by applicants, the registration in the ministerial list, and those provided).

Data transfer from

CONSOB to the

U.S. oversight body for

auditors

Access to

information for the

search of assets to

be seized

Tax credit

in mediation

proceedings

(optionally) and the retention periods (both in relation to consultation by businesses and to the request for the voucher and the phase of enjoying the benefit). The opinion also recalled that the data controller must take into account what is indicated in the report “2022 Coordinated Enforcement Action - Use of cloud-based services by the public sector” adopted by the EDPB on January 17, 2023, in order to ensure compliance with the GDPR when a public entity, in the exercise of its institutional functions, uses cloud services (provision March 23, 2023, no. 80, web doc no. 9875280).

With a complex procedure submitted for preliminary examination by the EDPB, the Guarantor authorized CONSOB, pursuant to Articles 46, paragraph 3, letter b) and 58, paragraph 3, letter i), of the GDPR, to enter into the draft administrative agreement for the transfer of personal data to the Public Company Accounting Oversight Board (PCAOB, i.e., the non-governmental U.S. authority overseeing auditors), aimed at facilitating the fulfillment of their respective functions of control, inspection, and investigation of auditors that fall under the supervision of both authorities, in light of what is provided for by Article 33 of Legislative Decree No. 39 of January 27, 2010, and Article 4, paragraphs 3 and 5-bis, of Legislative Decree No. 58 of February 24, 1998. For the purposes of the authorization, the Guarantor took into account the fact that the contents of the draft agreement were aligned with those of the draft administrative agreement for the transfer of personal data between the French oversight authority for auditors (H3C) and the same U.S. body, endorsed by the EDPB with opinion 5/2021 of February 2, 2021. In any case, in order to ensure an adequate level of protection in the event of data transfer to a third country, the Guarantor deemed it essential to condition the authorization on compliance with all the clauses provided in the draft agreement, reiterating that the latter does not prejudice its supervisory duties (provision May 17, 2023, no. 196, web doc no. 9904047).

The Ministry of Justice submitted to the Authority a draft agreement with the Revenue Agency, aimed at regulating the methods of access to databases containing information useful for the search, by judicial officers and through electronic means, of assets to be seized, in implementation of what is

provided for by Article 492-bis of the Code of Civil Procedure, for the purpose of acquiring the opinion required by Article 155-quater of the implementing provisions of the Code of Civil Procedure. The Guarantor expressed a favorable opinion, also in light of the reception of the indications provided during the preliminary discussions (such as those concerning the identification of categories of subjects who may have access to personal data held in the Tax Registry or the retention of personal data), but imposed some conditions regarding the tracking and control activities carried out by the Ministry of Justice and the Revenue Agency on the accesses made, such as the need to specify that the data subject to tracking will also be used by the Revenue Agency to verify the lawfulness of the processing, ensure the security of the processing, and, in the event of a personal data breach, fulfill the obligations set forth in Articles 33 and 34 of the GDPR (provision May 17, 2023, no. 219, web doc no. 9907989).

A positive opinion was also issued on two draft decrees from the Minister of Justice, in agreement with the Minister of Economy and Finance, concerning, respectively, the determination, liquidation, and payment, also through the recognition of a tax credit, of the fees due to the lawyer of the party admitted to legal aid at the expense of the State (pursuant to Article 15-octies of Legislative Decree No. 28/2010 and Article 11-octies of Law Decree No. 132/2014) and the tax incentives, in the form of a tax credit, in civil and commercial mediation and assisted negotiation proceedings (pursuant to Article 20, paragraph 5, of Legislative Decree No. 28/2010 and Article 21-bis, paragraph 2, of Law Decree No. 83/2015). The Ministry took into account the indications offered by the Office during the preliminary discussions, which particularly concerned,

THE ACTIVITIES CARRIED OUT BY THE GUARANTOR

THE ACTIVITIES CARRIED OUT BY THE GUARANTOR

the identification of the subjects involved in the processing of personal data, and their respective roles, in relation to the activities of competence of each, appropriate methods for correctly providing information to the data subjects, the identification of personal data acquired during the submission of the application for access to the aforementioned benefits, the processing of personal data carried out in the context of checks on the possession of the necessary requirements to access tax benefits as provided for by d.P.R. n. 445/2000, compliance with the principle of integrity and confidentiality and security obligations in the context of the transmission of personal data between the Ministry of Justice and the Revenue Agency, the regulation of personal data processing for statistical purposes (provision of June 22, 2023, n. 257, web doc n. 9917836).

4.5.2. Processing of personal data carried out at regions and local authorities

4.5.2.1. Environment

A communication has been received by the Authority, pursuant to art. 2-ter of the Code, regarding the start of personal data processing by an Optimal Territorial Area (ATO), the company managing the water service, and the municipalities of an integrated water basin, in order to define an agreement regulating the communication to the data manager of the personal data held by the municipalities. The purposes underlying this communication are the correct census of users of the water service, the prevention of abuse, and the correct allocation of the tariff based on the intended use (commercial or residential).

During the investigation, the public nature of the subjects involved, the role played by each in the processing, the specific purposes pursued related to the performance of a public interest task, and the relevant legal bases were analyzed in particular. Following in-depth investigations conducted by the entities involved in the agreement, the types of processing necessary for carrying out activities that require the acquisition of data from the municipalities and the types of personal data requested from local authorities (personal details, holders of active supply contracts, subjects residing in the municipality, etc.) were detailed, and compliance with the applicable principles for processing was ensured, with particular regard to transparency towards the data subjects (lawfulness, fairness, and transparency), the identification of purposes, and the selection of data to be communicated (purpose limitation), the adequacy and relevance of the data concerning the declared purposes (data minimization), and the appropriate measures for the security of processing (integrity and

confidentiality), pursuant to art. 5, par. 1, lett. a), b), c) and f), of the GDPR. As a result of the evaluation of the elements provided by the parties to the agreement, considering that the communication of personal data concerns a selection of information extracted from the TARI database, necessary and relevant for controlling the users by the water service manager, and that such communication is not systematic and on a large scale, the Authority has favorably acknowledged the notification received pursuant to art. 2-ter of the Code (note of July 3, 2023).

A query has been received by the Authority from a municipality regarding the correct identification of the role of the urban waste collection service manager as an independent data controller, joint controller, or data processor. In this regard, the Authority, recalling the figure of the data controller (art. 4, par. 1, point 7), of the GDPR, and guidelines 07/2020 of the EDPB), with specific regard to the conditions of lawfulness, has stated that the processing of personal data by public subjects or managers of public services is lawful if “it is necessary for the execution of a task carried out in the public interest or connected to the exercise of public powers” (art. 6, par. 1, lett. e) and par. 2 and 3, of the GDPR; 2-ter of the Code) and must take place in compliance with the principles established by art. 5 of the GDPR. The management of urban waste falls within the institutional activities entrusted to local authorities, which cannot, therefore, “disengage” from this purpose and task, but can choose to entrust its management to third parties, regulating the relationship pursuant to art. 28 of the GDPR. On this point, the Authority had already expressed itself, stating that “the management of urban waste is, according to the relevant regulations, a public interest activity carried out, in particular, by municipalities that, with their own regulations, establish the methods of separate collection, conferment, and transport of the various fractions of waste, to facilitate their separate management and promote their recovery, in compliance with the principles of efficiency, effectiveness, and economy” (provision of July 14, 2005, web doc n. 1149822).

That said, the Authority has invited the municipality to evaluate, in any case, considering the conditions, context, and circumstances related to the assignment of the urban waste service, the correct framing of the relationship with the manager, also for the purpose of fair distribution of responsibilities for the processing of personal data (note of December 5, 2023).

4.5.2.2. Mobility and transport

Complaints and reports continue to be received regarding the notification of a sanction for violation of the road code, through PEC related to the work and professional activities of the data subjects (e.g., professional studios). The Authority reiterated that, with circular 300/STRAD/1/10060.U/2021 of the 17...

November 2021, the Ministry of the Interior clarified that “the possibility of using PEC addresses related to professional firms to notify violations committed with a vehicle registered to the professional is excluded, as they are also visible to personnel collaborating with the holder of the PEC.” In order to balance the aspect of personal data protection with the needs for speed and certainty in the notification process, it is necessary to distinguish, however, the cases in which the address used in the work context is not directly and easily attributable to a professional firm (e.g., because it refers to a natural person and not to a firm or an association of professionals). In these cases, the Authority clarified that there is no automatic risk of communication of the personal data of the data subject (the individual professional) to third parties (collaborators, secretaries, associates, etc.), since access to this PEC address could only be granted to individuals other than the registered professional with the express authorization of the latter (notes of May 15, June 10, and July 17, 2023).

PEC and Notification of Violations of the Road Code

4.5.3. Exercise of Rights

Numerous complaints have been received regarding the exercise of rights under Articles 15 et seq. of the GDPR, which, however, are often improperly used in place of other institutions recognized by specific sector regulations that may be applicable (such as the so-called banking access and the so-called documentary access). In this regard, the Authority clarified that the rights under Articles 15 et seq. of the GDPR aim to make the data subject aware of the data processing concerning them, but cannot be used as a substitute for other tools nor to contest the merits of administrative measures or

aspects of a contractual nature that can only be challenged before the competent judicial authority. In particular, it was reiterated that pursuant to Article 15 of the GDPR, the data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning them is being processed and, in that case, access to the personal data and the information referred to in paragraphs 1 (letters a) to h)) and 2 of the same article as well as “a copy of the personal data undergoing processing” (paragraph 3), but not necessarily a copy of the documents in which such data is recorded.

THE ACTIVITY CARRIED OUT BY THE GUARANTOR

Following a complaint, the Authority became aware of a lack of response to the exercise of the right of access under Article 15 of the GDPR presented by a citizen against a municipality and a territorial residential construction company. The data subject, in particular, had exercised this right in order to understand which entity was the data controller, as well as the owner of the apartment of which they were a tenant. The lack of response to the exercise of the right of access under Article 15 of the GDPR had prevented the data subject from correctly identifying the entity that owned the property and, therefore, had resulted in the inability to benefit from the right of first refusal for the purchase of the assigned housing. For these reasons, the Authority sanctioned the municipality, as the data controller, for violation of Articles 5, 12, 15 of the GDPR and 157 of the Code (provision of June 1, 2023, no. 224, web doc no. 9916670). The Authority, on the other hand, admonished the territorial company which, as emerged during the investigation, although not being the owner of the property, had nevertheless taken measures to mitigate the damage suffered by the data subject, collaborating with the municipality, the data controller, in providing feedback to the data subject (provision of June 1, 2023, no. 225, web doc no. 9917702).

In a similar case, the Authority admonished a municipality for failing to respond to the request for the exercise of rights made by the data subject under Articles 17, 18, and 21 of the GDPR. In particular, the municipality had not provided feedback to the data subject under the mistaken belief that the unfoundedness of the request meant that a formal response was unnecessary. The Authority reminded, in this regard, that Article 12, paragraph 3, of the GDPR establishes that the data controller must respond – even negatively – to the request of the data subject without undue delay and, in any case, no later than one month from the receipt of the request. If the data controller does not comply with the request of the data subject, they must, in any case, inform the data subject without delay, and at the latest within one month from the receipt of the request, of the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority and of seeking judicial remedy (recital 59 and Article 12, paragraph 4, of the GDPR). Considering in any case that the lack of response within the time limits established by the GDPR had not resulted in any consequence for the data subject, as their requests for deletion, limitation, and opposition could not have been accepted anyway, it was deemed sufficient to admonish the municipality for the violation of Articles 5 and 12 (in conjunction with Articles 17, 18, and 21) of the GDPR (provision of December 7, 2023, no. 586, doc. 9970880).

4.6. Processing for Administrative Purposes

Following a complex investigation, which also included urgent inspection activity initiated as a result of press reports, the Authority adopted a sanctioning measure against a municipality and a municipal company (in-house company) responsible for managing cemetery services, for having disseminated the data...

of women who had undergone an abortion, indicated on plaques affixed to the burials of the fetuses. The data of the women, in addition to being on the plaques, had been subject to further processing by the cemetery services and the municipality related to the maintenance of cemetery records and the archiving of documentation received from the ASL, consisting of the authorization for transport and burial and the forensic medical certificate (see par. 5.5).

Considering that the indication of the women's data on the plaques affixed above the burials was carried out in the absence of a legal basis (Articles 5, par. 1, lett. a) and 9 of the GDPR; Article 2-sexies of the Code) and in violation of the specific prohibition of dissemination of health data (Article 2-septies, paragraph 8, of the Code) and that the processing of such data was carried out inaccurately

and incongruously to mark a burial that did not concern the woman (Article 5, par. 1, lett. d), of the GDPR) and, in any case, lacking a legitimate purpose, given that the need to identify the burial of a fetus could have been satisfied by reporting simple codes (Article 5, par. 1, lett. b), of the GDPR), a corrective measure was adopted against the municipality, as the data controller, for the violation of the aforementioned provisions.

Furthermore, considering that the aforementioned processing was carried out by the municipal company managing cemetery services, designated as the data processor, to which the data controller had not given any specific instructions for the cases in question, with the same measure the municipality was deemed responsible for the violation of Articles 28 and 29 of the GDPR (provision of April 27, 2023, no. 163, web document no. 9900808).

At the conclusion of the investigation, two additional corrective measures were adopted. The first against the aforementioned municipal company responsible for the processing, following the violation of Article 29 of the GDPR, for not having requested specific instructions from the data controller, despite the alleged gaps in the regulatory framework, and Articles 28, 29, and 32 of the GDPR and 2-quaterdecies, in relation to the implementation, partly incomplete and partly inadequate, of the instructions and technical organizational measures provided by the data controller, subsequent to the initiation of the investigation, in order to overcome the contested criticalities (provision of April 27, 2023, no. 164, web document no. 9900826). The second corrective measure was adopted against the ASL for having transmitted to the cemetery services of the municipality data related to health, directly identifying the women involved in an abortion (whether spontaneous or voluntary), in violation of the basic principles of processing set forth in Article 5, par. 1, lett. c) and f), of the GDPR (provision of April 27, 2023, no. 165, web document no. 9900503; see par. 5.5).

4.7. Online Services and Security Measures

Following a report, an investigation was initiated against a data processing service company, wholly owned by a municipality, which provides in-house services related to IT support, assistance and consulting, software development and maintenance, as well as administration activities of the entity's information systems. The investigation found that access from a public network to the corporate intranet of the aforementioned company was possible using the HTTP communication protocol, thus rendering the user-server communication unprotected and lacking guarantees for the confidentiality and integrity of the data exchanged between the user's browser and the server hosting the company's intranet, as well as inadequate to allow users to verify the authenticity of the displayed website. The use of cryptographic techniques, at present, is one of the commonly adopted measures to protect, in particular, the authentication credentials of users of an online site/service during their transmission over the internet, considering the high risks presented by the processing of such data that may arise from unauthorized access to them or their disclosure, also due to the tendency of many users to reuse the same password, or at least a very similar password, for access to different online services. For these reasons, considering that the failure to use cryptographic techniques for data transmission constituted a violation of Article 5, par. 1, lett. f) and Article 32 of the GDPR, the Authority adopted a corrective measure against the company for having processed the data in violation of the GDPR (provision of August 31, 2023, no. 362, web document no. 9935548; see par. 4.8 for further aspects of non-compliance by the same company).

****Designation and Position of DPOs****

****Supervision on DPO Issues****

4.8. The DPO in the Public Sector

2023 was characterized by the initiation of the second coordinated action for the implementation of the GDPR (Coordinated Enforcement Framework - CEF 2023) promoted by the EDPS, in which European data protection authorities, including the Garante, participated, focusing on the designation and position of DPOs (see par. 21.1).

The Authority also initiated an investigation against large local authorities to verify compliance with the obligation to communicate the contact details of the DPO as per Article 37, paragraph 7, of the GDPR, ordering the initiation of specific proceedings aimed at adopting corrective and sanctioning measures

against some of these non-compliant entities. This supervisory activity was then extended to other local authorities (see Newsletter May 26, 2023, web doc. no. 9890504).

The Garante sanctioned a municipality for having designated as DPO an individual who was in a position of conflict of interest, in violation of Article 38, paragraph 6, of the GDPR, as he was the administrative director of the company owned by the same municipality for which the latter provided, in-house and in the capacity of data processor, instrumental IT services. In this way, the role fulfilled by the DPO within the organization of the company led him to participate in decisions regarding the processing carried out by the company on behalf of the municipality, the data controller of such processing; this occurred in a context where the company itself, as the data processor, and the individuals acting under its authority (including its administrative director) received instructions from the data controller. Furthermore, the measure—which also sanctions the municipality for failing to communicate to the Authority the contact details of the DPO designated to replace the previous one—warns data controllers against including clauses in the contracts for the assignment of the DPO role that could create conditions for behaviors undermining the decision-making autonomy of the data controller in the choice of subsequent DPOs (decision August 31, 2023, no. 363, web doc. no. 9936094).

In the same matter, the Garante sanctioned the aforementioned company for failing to designate a new DPO following the resignation of the previously designated one, as well as for not updating the relevant contact details, concerning both the obligation to publish the contact details and the obligation to communicate them to the Authority (decision August 31, 2023, no. 362, web doc. no. 9935548). Following a report, the Authority also learned that a municipality had used video surveillance systems to verify the correct disposal of urban waste within the municipal territory in a manner not compliant with data protection regulations. Among other violations, it emerged that the municipality had delayed the designation of the DPO and had published the contact details of the designated DPO late on its institutional website, approximately one month after the date of the designation. For these reasons, the Authority sanctioned the municipality for violating Article 37, paragraphs 1 and 7, of the GDPR (decision July 18, 2023, no. 313, web doc. no. 9920578).

Finally, a university was sanctioned, among other things, for failing to communicate the contact details of the DPO to the Authority (decision May 17, 2023, no. 195, web doc. no. 9908484).

4.9. Professional Orders

The Authority's activity also concerned certain processing of personal data carried out by professional orders. Following a complaint, the Garante criticized the conduct of a territorial order of lawyers, which—for the purpose of activating a profile on a web portal set up to allow the submission of applications for legal aid on behalf of its clients—had requested lawyers to provide both their PEC (certified email) and the access password. The Garante noted that although the order did not retain the data in question, it had nonetheless processed them, both at the time of user registration on the portal (when the password, in clear text, was collected, encrypted, and stored within an alleged technical cookie) and at the time of submitting an application (when the password, stored in encrypted form within the aforementioned technical cookie, was collected, decrypted, and used by the portal to send, on behalf of the lawyer, the PEC message containing the application). In this regard, the Garante clarified that the cookies in question could not be considered so-called technical cookies (for which Article 122, paragraph 1, of the Code provides an exemption from the obligation to obtain prior informed consent), as they were not strictly necessary for the provision of the service; in fact, each lawyer could independently send the digitally signed application from their PEC mailbox without having to provide the order with access credentials. It was also established that the order had not provided the interested parties, at the time of registration on the portal, with information regarding the processing of personal data carried out therein. The overall processing was deemed non-compliant with the GDPR. principle of data protection by design and by default, as the order did not adopt adequate technical and organizational measures aimed at mitigating risks to the rights and freedoms of data subjects and ensuring processing in accordance with the principles of data protection. Noting the violation of Articles 5, 6, 13, and 25 of the GDPR, as well as Article 122 of the Code, the Authority adopted a sanctioning measure against the order (provision of April 13, 2023, no. 121, web document no. 9889644).

In another case, a territorial order of lawyers had forwarded to the president and a manager of the local court a report that the complainant had submitted to the order, in her capacity as a lawyer, to inform them that both she and a defendant she was defending believed they had contracted the SARS-CoV-2 virus during a hearing held at that court. The Authority, taking into account all the specific circumstances that emerged during the investigation, deemed it sufficient to admonish the data controller for having communicated to third parties personal data, some of which related to health status, in the absence of a legal basis, in violation of Articles 5, paragraph 1, letter a), 6, and 9 of the GDPR, as well as Articles 2-ter and 2-sexies of the Code, in the text prior to the amendments made by Legislative Decree no. 139/2021 (provision of March 2, 2023, no. 57, web document no. 9873294; in relation to a different case involving a provincial order of surgeons and dentists in the context of proceedings to verify the vaccination requirement against SARS-CoV-2, see paragraph 13.9.1.2).

4.10. Digitalization of Public Administration

Throughout 2023, the process of digitalization of the public administration continued, also driven by the implementation of the PNRR. In this context, the Authority exercised the advisory function attributed to it by the GDPR, the Code, and the law on schemes of acts promoted by government institutions and central administrations, aimed, in particular, at introducing new functionalities in the landscape of online service delivery to citizens. Furthermore, monitoring and control activities on the operations of service providers continued, aimed at verifying the processes of issuance and management of certificates and digital identities (SPID) as well as violations of data protection regulations and identity thefts committed.

CIEId

Single Digital Gateway

The Ministry of the Interior submitted to the Authority the data protection impact assessment in order to obtain authorization to carry out the processing of personal data concerning the creation, use, and management of digital identity credentials CIE (CIEId) – as a tool for accessing online services integrating an electronic identification regime pursuant to Regulation (EU) 910/2014 (eIDAS Regulation) – in accordance with the decree of the Minister of the Interior, the Minister for Technological Innovation and Digital Transition, and the MEF of September 8, 2022 (on which the Authority had expressed an opinion with provision of July 7, 2022, no. 247, web document no. 9803398). The Authority authorized the aforementioned processing, considering that the impact assessment had incorporated the indications provided to make the processing compliant with the data protection regulations. These indications particularly concerned the identification of measures aimed at protecting data subjects during the management phase of the CIEId digital identity (such as the autonomous management of the user's digital identity through the relevant portal, with the possibility to modify and certify their contacts and view the related logs; sending the user a notice regarding the certified contacts during the operations of modifying them or changing the credentials); the registration, in specific log files, of information related to activation and revocation operations as well as management and use of the digital identity and its preservation; information to data subjects about the attributes made available by the CIEId manager to service providers following the authentication process; the introduction of a mechanism for timely information between the Ministry of the Interior and service providers/aggregators in case of security breaches or other threats that pose a risk to the security and rights and freedoms of data subjects. Furthermore, with particular reference to the use of CIEId by minors, considering that the aforementioned decree provides that, with a specific provision, after consulting the Authority, the Ministry identifies the necessary functionalities and measures to protect data subjects – also to facilitate parental control aimed at verifying the correct use of online services by minors under their care – it is highlighted that, pending the identification of adequate guarantees, such use is allowed even by minors (excluding those aged 0 to 5 years) for access to services of educational institutions of all levels, taking into account what is provided in the specific guidelines adopted by AgID for SPID (provision of March 23, 2023, no. 81, web document no. 9880472).

The Authority provided an opinion on the draft regulation for the operation of the national infrastructure

of the Single Digital Gateway (SDG), to be adopted by a determination of the Head of the Department for Digital Transformation of the Presidency of the Council of Ministers, in implementation of the commitments made within the framework of the PNRR.

SDG is the “Technical system for the automated cross-border exchange of evidence” as referred to in Regulation (EU) 2018/1724 and Regulation (EU) 2022/1463, through which the exchange of requests and related “evidence” (documents or data) between the competent authorities of the EU is permitted within specific administrative procedures, possibly at the explicit request of the interested party. The Authority has preliminarily highlighted that the processing of personal data and the related technical and operational specifications are specifically regulated by the aforementioned European regulations and that discussions are still ongoing in the competent European forums regarding the definition of the profiles concerning the implementation and management of the components of the SDG by the Commission, which limits the margins of decision-making autonomy left to national regulation. In this context, the Authority has expressed a favorable opinion, emphasizing that the administrations responsible for the processing concerning the services provided by them in this area can adhere to the SDG, in accordance with the relevant operational regulation, without obtaining the opinion of the Authority, unless a prior consultation is necessary following a potential data protection impact assessment conducted by such adhering administrations (provision of December 7, 2023, no. 579, web document no. 9974086).

On the same topic, the Authority has simultaneously expressed a favorable opinion on the draft decree of the Minister of the Interior referred to in Article 62, paragraph 6-bis, Legislative Decree no. 82/2005, concerning the provision, through the National Registry of the Resident Population (ANPR), of the procedures related to the request for proof of birth registration and the registration of a change of address, which pursuant to the aforementioned Regulation (EU) 2018/1724 must be carried out through the SDG (provision of December 7, 2023, no. 580, web document no. 9974134, see paragraph 4.11).

The Authority has also granted a conditional authorization to PagoPA S.p.A. for the processing of personal data within the Digital Notifications Platform, governed by Article 26 of Legislative Decree no. 76/2020 and by the decree of the Minister for Technological Innovation and Digital Transition no. 58/2022 (on which it had previously ruled with provision of October 14, 2021, no. 369, web document no. 9716841). The Authority has positively evaluated the incorporation of its indications concerning the definition of the roles assumed by the various parties involved, the identification of measures aimed at ensuring that the operator sends the notification (based on the nature of the act) to the digital domicile specifically designated to receive personal or professional communications, and the identification of suitable measures to ensure that the acquisition, by the recipients, of the paper copy of the documents subject to notification, at the designated counters, occurs only after communication of the details of the recipient's identity document instead of the copy of the identity document. However, the Authority deemed it necessary to prescribe the adoption of further measures aimed at ensuring compliance with the principles of the Regulation, and in particular to: limit the visibility of the reason to cases where the notification is certain to be in the hands of the recipient of the act subject to notification; prevent the counter operator, where the recipient approaches to acquire the documents notified in paper form, from downloading or making copies of the same documents; not allow the same operator to view the documents subject to notification and the reasons related to them; report, on the blank page produced by the printer before the printed documents, the number of pages as well as information that allows the same operator to correctly identify the subject to whom to deliver the act (provision of December 21, 2023, no. 604, web document no. 9976614).

Following the issuance of the favorable opinion of the Authority regarding the draft implementing regulation of the Province of Bolzano on linguistic census which, in implementation of Article 18, paragraph 2, Presidential Decree no. 752/1976, introduced the possibility of conducting data collection also electronically (provision of October 6, 2022, no. 318, web document no. 9825838), the Authority has expressed its opinion on the impact assessment prepared by the municipalities of the Autonomous Province of Bolzano and by the Provincial Institute of Statistics of the Province of Bolzano (ASTAT).

This assessment had taken into account the indications provided by the Office during informal discussions aimed, in particular, at identifying adequate measures to anonymize the data related to a person's affiliation/aggregation to the linguistic group, in such a way as to prevent or not allow the re-identification of the interested parties. On this basis, the processing was therefore authorized pursuant to Articles 36, paragraph 5, and 58, paragraph 3, letter c), of the GDPR (provision of March 23, 2023, no. 97, web document no. 9879199).

The Authority has expressed its opinion on the guidelines developed by AgID containing technical rules for the opening of data and the reuse of public sector information referred to in Article 12, Legislative Decree no. 36/2006 pursuant to Article 71, Legislative Decree no. 82/2005 (provision of July 6, 2023, no. 333, web document no. 9925342). In this regard, the Authority intervened to remind that documents, or parts of them, whose access, pursuant to the provisions of the Regulation, the Code as well as Legislative Decree no. 56 do not fall within the application of the same.

****Data of Information****

****Public Sector****

****ACTIVITY CARRIED OUT BY THE GUARANTOR****

****ACTIVITY CARRIED OUT BY THE GUARANTOR****

****14****

51/2018, must be excluded or limited, or must not be detrimental to the protection of the private life and integrity of individuals. This is in line with the previous guidelines of the Guarantor on the reuse of personal data, according to which, regarding further uses of personal data, and therefore also reuse, as provided for by Article 6, paragraph 4, of the GDPR, the processing of personal data for a purpose different from that for which the personal data were initially collected must be – in any case – “compatible” with the original purpose of the processing, with particular reference to cases where such assessment concerns personal data published online to fulfill transparency and publicity obligations of administrative action. The indications of the Authority have been followed in the guidelines, which do not impose further obligations for online publication of personal data beyond those provided by the current regulations and, in particular, do not foresee that every obligation of online publication established by the current regulations translates, by that very fact, into an obligation to publish personal data as “open data” and, as such, by definition, freely reusable for further purposes, in accordance with what is also provided for by the CAD (Article 52, paragraph 2). For this reason, the entity called to implement the obligations of publication on its institutional website – if it intends to make the data reusable – must determine whether, for what purposes, and under what limits and conditions any further uses of the publicly disclosed personal data can be considered lawful in light of the “purpose principle” and other principles regarding the protection of personal data.

4.11. **The Registration and Electoral Matter**

By decree of the Ministry of the Interior, the procedures have been regulated to ensure access and the execution of the procedures referred to in Annex II of Regulation (EU) 2018/1724; these are the telematic methods for requesting and issuing birth certificates through the ANPR, in favor of the citizen of the European Union, born in Italy, no longer registered in the ANPR at the date of the request, but still registered in the municipal registry at the time of the municipality's entry into the ANPR or subsequently, and the telematic methods by which the citizen of the European Union requests, pursuant to Articles 3 and 9 of Legislative Decree No. 30/2007, registration in the registry through the ANPR and, consequently, can obtain a residency certification pursuant to the decree of the Minister of the Interior of November 3, 2021. In this regard, a favorable opinion was expressed in the absence of critical profiles regarding the protection of personal data, as the indications provided by the Office during informal discussions that took place during the investigation were taken into account, with particular reference to the need to better clarify the integration methods between the services provided by ANPR and the national SDG node, as well as the role of the Ministry of the Interior regarding the automated exchange of proofs (provision of December 7, 2023, No. 580, web document No. 9974134, see paragraph 4.10). The Authority also expressed a favorable opinion on the draft decree of the Ministry of the Interior concerning the provision of the ANPR certificate service by the counters of the

postal offices within the Polis-Case project of digital citizenship services (as per Article 1, paragraph 2, letter f), No. 1, Decree Law No. 59/2021, converted, with amendments, by Law No. 101/2021 and Article 38 of Decree Law No. 50/2022, converted, with amendments, by Law No. 91/2022). The operator of Poste Italiane, having identified the requesting citizen, carries out the necessary registry checks to verify the possibility of proceeding with the issuance of the certificate, which can be issued for the requester and for the members of the respective family unit. In this regard, a favorable opinion was expressed as no critical profiles regarding the protection of personal data were detected, and the indications provided by the Office during informal discussions that took place during the investigation were taken into account, particularly regarding the requirements and criteria for identifying the responsible personnel, as well as the technical and organizational measures aimed, also from a perspective of accountability, at minimizing the risk of unauthorized processing, in compliance with the provisions of Article 5, paragraphs 1, letter f) and 2, as well as Articles 24, 25, and 32 of the GDPR (provision of October 26, 2023, No. 493, web document No. 9954092).

The Ministry of the Interior submitted to the Authority the draft ministerial decree pursuant to Article 62, paragraph 6-bis, Legislative Decree No. 82/2005 concerning the update of the services made available by the ANPR, in order to allow lawyers to request, for purposes related to the execution of the professional mandate, the registry certificates in telematic mode made available through the ANPR. The examined draft took into account the indications provided by the Guarantor during discussions with the Ministry of the Interior, concerning, in particular, the need for the issuance of certificates requested by lawyers on behalf of their clients to be assisted by particular guarantees, aimed at ensuring that such certificates are actually used for purposes related to a specific professional mandate, while respecting the sector regulations (Articles 33 et seq., Presidential Decree No. 223/1989; Law No. 1064/1955).

consideration of the identified critical issues, some prescriptions have been formulated aimed at aligning the treatments in question with the regulations regarding personal data protection. In particular, it was deemed necessary to prescribe the identification of a suitable criterion for determining the sample of lawyers to be subjected to verification regarding their registration in the bar, the reformulation of certain phrases in order to clarify that the personal data of clients are not subject to processing, as well as the introduction of a control mechanism (to be entrusted to the competent bar associations) regarding the existence of a specific professional mandate and its relevance to the requested certificate, in accordance with the principles of lawfulness, fairness, and transparency, purpose limitation, and data minimization (art. 5, par. 1, lett. a), b), and c), of the GDPR). Furthermore, the Ministry of the Interior was instructed to transmit to the Authority, six months after the start of processing, a report on the effectiveness of the criteria and measures adopted, highlighting any critical issues encountered, taking into account the outcomes of the verification activities carried out by the Ministry itself and by the competent bar associations (provision of June 22, 2023, no. 279, web document no. 9919862).

The Authority examined the draft ministerial decree of the Ministry of the Interior, pursuant to art. 3, par. 1, ministerial decree of December 23, 2015, concerning the update of the characteristics of the Electronic Identity Card provided for by the model referred to in Annex A of the ministerial decree and aimed at adapting the current model of CIE to the new numbering of civil status acts, introducing the new format of the birth act number reported in the CIE (so-called national unique identifier). In this regard, a favorable opinion was expressed as no critical issues regarding personal data protection were identified (provision of July 6, 2023, no. 306, web document no. 9920897).

4.12. Processing of personal data in the public sector through video devices

Following a report, the Authority ascertained that a municipality had used video surveillance systems to verify the correct disposal of urban waste in the municipal territory in a manner not compliant with the regulations on personal data protection. In particular, the municipality had not provided adequate information on the processing of personal data, in violation of the principles of lawfulness, fairness, and transparency, nor had it defined the retention periods for the collected images, in violation of the principles of data minimization, storage limitation, accountability, and data protection by design and by

default.

In order to install and maintain such video surveillance systems, the municipality had initially relied on a company without ever having regulated the relationship with it pursuant to art. 28 of the GDPR (or, for the period prior to May 25, 2018, pursuant to art. 29 of the Code, in the text prior to the amendments made by Legislative Decree no. 101/2018 and in force during the period related to the issue raised in the report) and subsequently on a sole proprietorship, regulating the relationship with it, pursuant to art. 28 of the GDPR, only after the processing of personal data had begun. Lastly, it emerged that the municipality had delayed the designation of the DPO, whose contact details it published on its institutional website about a month after the date of designation. For these reasons, the Authority sanctioned the municipality for violation of arts. 5, par. 1, lett. a), c), and e), and par. 2 (in conjunction with art. 24), 12, par. 1, 13, 25, 28, and 37, pars. 1 and 7, of the GDPR (provision of July 18, 2023, no. 312, web document no. 9920578).

Furthermore, as the aforementioned company had not entered into a data protection agreement with the municipality before the start of processing, and no other grounds were identified by it that could legitimize the processing of the personal data in question, the Authority sanctioned the company for violation of arts. 5, par. 1, lett. a) and 6 of the GDPR for having carried out personal data processing in a manner not compliant with the principle of lawfulness, fairness, and transparency.

transparency and in the absence of a suitable regulatory basis (provision of July 18, 2023, no. 314, web doc no. 9920664). Similarly, the individual enterprise was sanctioned for violating Articles 5, paragraph 1, letter a) and 6 of the GDPR for not having entered into a data protection agreement with the municipality before the commencement of processing, and no other bases were identified by it that could legitimize the processing of the personal data in question (provision of July 18, 2023, no. 313, web doc no. 9920645).

The Authority then addressed a project implemented by a national agency and a municipal museum institution, which involved the use of video devices placed near works of art, with the aim of measuring the level of appreciation of the same through an artificial intelligence system based on convolutional neural networks, capable of detecting the faces of visitors (face detection) and interpreting their behavior during the enjoyment of the works. Following the investigation, which originated from a report, the Authority clarified that, although the captured images resided on the system for a very short period, it still constituted a processing of personal data, consisting of the acquisition and temporary storage of the image of the faces of museum visitors (cf. provision of December 21, 2017, no. 551, web doc no. 7496252). The two public entities, qualified as joint controllers of the processing, did not prove that the processing could be based on an appropriate legal basis, nor was a joint controller agreement established, and visitors to the museum were not provided with comprehensive information regarding the processing of personal data. The Authority, having assessed all the specific circumstances of the case, therefore adopted a warning measure against each joint controller for the violation of Articles 5, paragraph 1, letter a), 6, 12, 13, and 26 of the GDPR, as well as Article 2-ter of the Code, in the text prior to the amendments made by Legislative Decree no. 139/2021 (provisions of April 13, 2023, nos. 122 and 123, web docs no. 9896412 and no. 9896808).

5

Health

5.1. Digital Health

During 2023, there were numerous interventions by the Authority on the topics of digital health, originating both from requests for opinions on regulatory acts and from reports and complaints. The main areas of intervention concerned the reform of the Electronic Health Record (EHR) 2.0 and the establishment of the national telemedicine system, which are part of the implementation actions of Mission 6 (health) of the PNRR. In these interventions, the Authority strongly reiterated the necessary regulatory coordination of the implementation provisions of the various digital health tools, considering that the planned interconnection between health information systems and the EHR makes it necessary for the technical and organizational measures to be introduced in the implementation of the provisions to protect the fundamental rights of the data subject and the general principles of processing to be

coherent with each other, especially with regard to the ownership of the processing, the identification of responsibilities, and the tasks of the various parties involved (cf. point 3.2, opinion of June 8, 2023, no. 256, web doc no. 9900433).

In the field of digital health, the Office also intervened concerning the processing of health data carried out through the information systems of public and private health facilities used for managing clinical data and documents, and, in particular, in relation to those carried out through the health dossier and the business and regional components of the EHR.

5.1.1. The Electronic Health Record

Following the unfavorable opinions of August 22, 2022 (web docs no. 9802729 and no. 9802752), the Ministry of Health submitted a new draft decree to the Authority regarding the regulation of the EHR 2.0, the realization of which is linked to achieving the objectives of the EHR sub-investment of the PNRR (provision of June 8, 2023, no. 256, web doc no. 9900433 and press release of January 20, 2020, web doc no. 9516732). Overall, the transmitted draft was found to be profoundly modified as, in order to overcome the numerous observations made at the time, all aspects of the processing of personal data related to the realization of the new EHR 2.0 system were deepened, integrated, and regulated.

The corrective interventions concerned, among other things:

- the scope of application of the decree, which partially repeals the Prime Ministerial Decree no. 178/2015, which remains fully in force for pursuing through the EHR the purposes of research and health governance;
- data and documents that can be consulted through the EHR, for which an exhaustive listing was ensured and it was specified, for example, that information related to income exemptions and the related exemption codes must be consultable only by the interested party;
- access to the EHR in emergencies, providing, as requested by the Authority, that, in compliance with the principle of proportionality, in cases of physical impossibility, incapacity to act, or incapacity to understand or will, and of serious, imminent, and irreparable risk to the health or physical safety of the interested party who has not expressed consent to the consultation of their EHR for care purposes, healthcare professionals may prioritize access to the section of the EHR called ****Synthetic Health Profile (PSS)**** and, where necessary, to the additional data and documents of the ****FSE****, except for those for which the interested party has requested obscurity, for the time strictly necessary to ensure essential care or until the interested party is again able to express their will in this regard;
- the rights of the interested parties, with particular reference to the identification of uniform measures across the national territory for the exercise of the right to obscurity and the right to know the accesses made to their own ****FSE****;
- the synthetic health profile (PSS) and the personal notebook (TP), indicating the ownership of the processing and the responsibilities connected to security profiles;
- the consent of the interested party, ensuring, in particular, the requirement of specificity regarding the different purposes pursued (care, prevention, and international prophylaxis);
- access to the ****FSE**** by the interested party, regulating the institution of delegation both for subjective profiles (delegable subjects, number of allowed delegations) and objective profiles (delegable activities);
- treatments for care purposes, through a precise definition of the different profiles of authorization for access to the ****FSE****, specifying, for each of them, the conditions and limits of access in line with the principles of minimization, necessity, and relevance;
- treatments for prevention purposes, defining the roles of processing and introducing measures aimed at limiting access to data from both a subjective and objective perspective;
- treatments for international prophylaxis purposes, indicating the types of subjects bound by

"professional secrecy" who may process the data and documents of the **FSE** based on specific and valid consent from the interested party, as well as the measures suitable to prevent the risk of re-identification.

The draft decree, accompanied by the impact assessment as requested by the **Garante** in August 2022, has led to the provision of specific security measures aimed at ensuring homogeneous minimum security levels at the national level, identifying the criteria for encryption and for the separation of data capable of revealing health status and sexual life from other personal data, the subject required to carry out authorization activities, management of privileges, and profiling of authorized subjects in relation to the different architectural models provided, the technical measures adopted concerning data subject to so-called greater protection of anonymity, and the possibility for healthcare personnel to access by default only the **FSE** of interested parties who have already expressed consent. Particular attention has also been paid to pseudonymization mechanisms, the effectiveness of which must be constantly verified in light of the evolution of the state of the art in technology and the recommendations and guidelines adopted from time to time at the European level (e.g., **EDPB**, **ENISA**) and at the international level (e.g., **NIST**, **ISO**).

The draft decree, in addition to overcoming all the critical issues identified by the **Garante** in 2022, has also presented significant new aspects regarding which, for the aspects of personal data protection, it is worth highlighting:

- the possibility for regions and autonomous provinces to choose between two architectural models of **FSE**, with consequences regarding the identification of the ownership of processing, the associated attribution of roles in the processing of healthcare subjects involved in various capacities, and therefore also the different technical and organizational measures to be adopted to minimize the risks specific to each model;
- the provision that a regional determination, following an impact assessment and the opinion of the **Garante**, may introduce the conduct of "specialized data management" of the **FSE** in a perspective of specifying the methods and logics of organization and processing that are identified – by express provision of law – with the decrees adopted pursuant to paragraph 7 of Article 12 of **Decree Law No. 179/2012**, in accordance with the principles of proportionality, necessity, and indispensability in the processing of personal data (cf. Article 12, paragraph 6, **Decree Law No. 179/2012**).

With the aforementioned opinion of June 8, 2023, the **Garante** then addressed the delicate issue concerning the right of the interested party to oppose the feeding of the **FSE** with data and health documents related to healthcare services provided before May 18, 2020 (cf. opinion April 7, 2022, web document No. 9773977). The **Garante** indeed acknowledged that the decree on **FSE 2.0** confirms the burden on the Ministry of Health and the regions and autonomous provinces to carry out information campaigns highlighting the possibility of opposition by the interested party (Article 27, paragraph 1 of the draft decree). This provision was not deemed sufficient, so the **Garante** prescribed that the draft decree be supplemented with the indication of a deadline within which to carry out the aforementioned information campaign (point 3.3). In this regard, the decree of **FSE 2.0** (adopted – subsequent to the June opinion – on September 7, 2023) was supplemented with the indication of a deadline – 6 months from the entry into force of the decree, then published in the **G.U.** on October 24, or by April 24, 2024 – within which the Ministry of Health, the regions, and the autonomous provinces must carry out the aforementioned information campaigns (cf. transitional provisions - No. 1).

In the aforementioned opinion of June 8, 2023, the **Garante** has... further conditions regarding the information to be provided to the data subjects concerning the data processing carried out through the **FSE**. In particular, acknowledging the provision of a single national information model, the Authority requested to integrate the draft decree with the provision for the opinion of the Guarantor on this model and with the indication of a reasonable deadline within which the Ministry of Health, the regions, and the autonomous provinces must provide the data subjects with

information regarding the personal data processing carried out through the FSE in relation to the architectural model adopted by them. In this regard, the FSE 2.0 decree in question has been further integrated by providing for the opinion of the Authority on the information model (art. 7, paragraph 4) and the obligation to provide such information to the data subject by the Ministry of Health and the regions and autonomous provinces within 3 months from the entry into force of the decree, that is, by January 24, 2024 (see art. 7, paragraph 1). In compliance with what was requested by the aforementioned decree, on December 21, 2023, the Guarantor expressed its favorable opinion on the information model for the personal data processing carried out through the FSE 2.0, which was previously shared with the Health Commission of the Conference of Regions and Autonomous Provinces (provision of December 21, 2023, no. 600, web doc no. 9976886). This model, which will be used throughout the national territory, illustrates, as requested by the Authority, the prerequisites for the lawfulness of the multiple processing activities that can be carried out through the FSE, as well as the different architectural models that can be implemented by regions/autonomous provinces and that significantly affect the attribution of processing roles. Particular attention has also been paid to the methods by which the data subject can make use of the delegation for access to the FSE, as well as exercise the rights recognized by the GDPR and the specific sector regulations, even concerning the so-called data with greater anonymity protection, including the consequences in case of withdrawal of consent.

With specific reference to reports, complaints, and notifications of violations related to the processing of personal data carried out through the FSE, particular attention is drawn to the sanctioning measures adopted against an autonomous province and two companies designated by it as data processors, related to unauthorized access to the health documents of certain patients due to the vulnerability of the service related to the FSE of the province (see provision of March 23, 2023, no. 86, web doc no. 9883731). In these measures, it was highlighted that, although considering that the multiple processing activities carried out within the FSE fall under the ownership of multiple subjects pursuing different purposes, the processing activities subject to the violation fell within the sphere of ownership of the autonomous province and not of the health company. Specifically, the violation was found to have been caused by an incorrect functioning of the system that allowed access, without specific limitations, to the documents contained in the FSE of the autonomous province, which indeed falls under the ownership of the latter.

In this context, the Authority sanctioned the province and the two designated companies responsible for the processing for failing to implement, from the design phase of the processing carried out within the FSE, adequate technical and organizational measures aimed at effectively implementing the principles of data protection and integrating the necessary guarantees into the processing in order to meet the requirements of the GDPR and protect the rights of the data subjects, in violation of Article 25 of the latter.

5.1.2. The health dossier

In 2023, the Guarantor continued to address the processing of health data carried out through the health dossier, with reference to which the indications provided in the guidelines of June 4, 2015 (web doc no. 4084632) remain fully in force. These latter specify that

The health dossier, constituting the set of personal data generated by current and past clinical events concerning the data subject, represents a specific and additional processing of personal data compared to that carried out by the healthcare professional based on the information acquired during the treatment of the individual clinical event. Regarding the aforementioned processing, it is worth highlighting two measures related to the use of this tool during the period of the Covid-19 health emergency.

In the measure dated October 12, 2023, no. 473 (web doc no. 9954220), the Authority sanctioned a healthcare company for violating numerous provisions regarding the protection of personal data through the use of the health dossier that did not respect, among other things, the expression of will of the data subject and allowed its use outside the purposes of patient care. The Authority reiterated that, in cases where the condition of lawfulness is represented, as in this case, by the consent of the data

subject, this must be given through a positive act whereby the data subject expresses a free, specific, informed, and unequivocal will regarding the processing of personal data concerning them (cons. 32, 42, and 43, arts. 5, 6, par. 1, lett. a) and 7 of the GDPR and guidelines 5/2020 on consent under the GDPR, adopted by the EDPB on May 4, 2020), thus not considering the holder's thesis that the consent of the data subject could be inferred from conclusive behaviors ("implicit consent" and "unequivocal positive actions") as admissible.

In the sanctioning measure, it was then highlighted that the dossier, given its optional nature and structural informational incompleteness (cf. right to erasure), cannot be used for purposes related to the management of organizational and administrative needs of the holder, even in cases where, as in this case, the holder assumes both the role of employer and the health authority caring for the data subject (cf. also measure dated May 26, 2022, web doc no. 9791909). More specifically, the processing of data related to the health of employees can only be legitimately carried out when necessary to fulfill the obligations and exercise the specific rights of the data controller or the data subject in the field of labor law and social security and social protection, to the extent that it is authorized by Union law or the laws of Member States or by a collective agreement under the laws of Member States, in the presence of appropriate safeguards for the fundamental rights and interests of the data subject (art. 9, paras. 2, lett. b) and 4 of the GDPR; see also art. 88 and cons. 51-53 of the GDPR). In this context, in the absence of express prior regulatory provisions, it is therefore not permitted for the employer to collect and process, directly from the data subjects or, as in this case, from other sources, personal data even relating to the health status of the worker (cf. FAQ on "Data Processing in the Context of Public and Private Employment during the Health Emergency," web doc no. 9337010 and measure dated May 26, 2022, web doc no. 9788986).

The Authority, while recognizing the critical issues related to the organization of hospital shifts for healthcare personnel and the delicate situation linked to the pandemic context, noted that the company should have processed the claimant's data in compliance with the aforementioned sector regulations that constitute its legal basis and establish limits and prerequisites. With the same measure, moreover, the Authority requested the company to adopt corrective measures related to the systems for monitoring any anomalies that may constitute unlawful processing, as well as the operations carried out on the dossier, through procedures that provide for the automatic recording in specific log files of all accesses and operations performed.

In this regard, reference is also made to a measure adopted by the Authority against a healthcare company following access, via the health dossier, to the Covid-19 report of a data subject by a healthcare worker who was not caring for them (measure dated December 7, 2023, no. 587, web doc no. 9978342).

The investigation revealed that the company had configured the health dossier in such a way as to allow all healthcare personnel to access this informational tool regarding any patient present in the company's wards or in the emergency room. This corporate choice, made in relation to the Covid-19 emergency, did not only concern patients affected by this pathology, but all those pertaining to the company from March 2020 to 2023, and therefore well beyond the end of the state of health emergency (March 31, 2022). The Authority therefore noted that the choice made by the company had effectively made the health dossiers of all patients accessible, regardless of the involvement of the healthcare operator in the care pathway and the circumstance that the healthcare service was actually provided to a Covid-19 patient, and without even providing for different levels of access to the dossier by the various authorized figures (OSS, nurses, emergency personnel).

Considering that at the time of the adoption of the aforementioned measure, it was still foreseen for hospital nurses and doctors the possibility of accessing the health dossier "without specific limitations," the Authority ordered the company to adopt corrective measures aimed at limiting access to only those healthcare personnel who are likely to be involved over time in the patient's care process, also based on the services provided and the clinical pathways activated, while maintaining the possibility of access to health dossiers in the occurrence of specific events (including emergencies). An additional corrective measure concerned the necessity for the company to adopt a system for detecting any

anomalies that may constitute unlawful processing, or the use of anomaly indicators (so-called alerts) aimed at identifying abnormal or risky behaviors related to the operations performed by the subjects authorized to process, useful for guiding subsequent audit interventions.

5.1.3. Telemedicine

In the referenced opinion of June 8, 2023, on FSE 2.0, the Authority intervened on the topic of telemedicine noting the need to update the guidelines for telemedicine services approved by decree of the Ministry of Health on September 21, 2022 (on which the expected opinion of the Authority was not acquired) (point 3.2). The decree of September 21, 2022, indeed provided for data interconnections between the FSE and national and regional telemedicine infrastructures through functionalities and systems, including the EDS and the Gateway, which were described in the draft decrees on which the Authority issued the aforementioned negative opinions on August 22, 2022, and which are instead absent in the new regulation of FSE 2.0. For the aspects related to the protection of personal data, the Authority therefore deemed it necessary that what is provided in the aforementioned decree on telemedicine be aligned with the characteristics and functionalities of the FSE, as well as with the measures to guarantee the rights and fundamental freedoms of the interested parties present in the decree on the FSE adopted on September 7, 2023. At the same time, the Authority noted that in the guidelines on telemedicine, where there is no reference to the regulation on the processing of personal data, the essential elements of the processing of health data carried out through telemedicine systems had not been identified, as required by the GDPR and the Code (Articles 6 and 9 of the GDPR and Article 2-sexies of the Code).

In light of these observations, the Authority requested the Ministry, in the aforementioned opinion of June 8, 2023, to promptly communicate the initiatives taken or that it intended to take in order to align the aforementioned guidelines with what is provided in the draft decree (then adopted on September 7, 2023) as well as in the regulation on the processing of personal data. Following what was observed in the aforementioned opinion, some discussions were initiated with the Ministry of Health and with AGENAS regarding the definition of the data protection aspects mentioned above and the realization of the national telemedicine platform subject to investments from the PNRR. The realization of the platform indeed presupposes a processing of data on the

****Large-Scale Salutation to Vulnerable Stakeholders****

This can only occur in full compliance with the regulations on personal data protection. The Authority has revisited this topic in its opinion dated June 22, 2023, No. 284 (web doc No. 9919981) regarding the information system for monitoring rehabilitative assistance (SIAR), in which it acknowledged that the reference to telemedicine contained in an earlier draft of the decree had been removed in the version submitted for opinion. This explicit (and suppressed) reference was linked to informal observations made by the Office regarding the necessity to consider that the integration of rehabilitative assistance activities with telemedicine systems requires data controllers to conduct a prior impact assessment to introduce measures suitable for reducing the risks associated with such processing, which is carried out on a large scale concerning vulnerable individuals through the use of new technologies. Similar considerations were expressed by the Office and accepted by the Ministry in the opinion dated July 6, 2023, No. 259 (web doc No. 9918016) on the information system for monitoring home assistance (SIAD).

With regard to telemedicine services provided by individual healthcare facilities (tele-diagnosis apps, teleconsultation, tele-assistance, and telemonitoring used by medical personnel), the Authority reiterated in 2023 that the provision of diagnoses or therapies remotely does not require specific consent for the processing of personal data of the interested party, as it constitutes a different mode of conducting the doctor-patient relationship (see in particular Article 9, paragraphs 2, letters h) and 3, of the GDPR). The data controller must, in any case, carry out the impact assessment (Article 35 of the GDPR), provide the interested party with complete information regarding the processing of data carried out through the aforementioned apps, and ensure compliance with the principles of integrity, confidentiality, and accuracy of the data being processed.

****5.2. The Use of Artificial Intelligence in Healthcare****

In the context of promoting awareness regarding the obligations set forth by the GDPR (Article 57, paragraph 1, letter d)), the Authority adopted a ten-point guideline in September 2023 for the implementation of national healthcare services through artificial intelligence systems (web doc No. 9938038), in order to provide some preliminary indications regarding the legal profiles related to the protection of personal data and the associated ethical aspects to be considered in this area (see Chapter 16).

In the ten-point guideline, the Authority highlighted that the processing of health data through AI techniques invokes the concepts of profiling and decisions based on automated processes, and that, where such processing is carried out for reasons of public interest, the use of such tools is permitted only if expressly provided for by the law of the Member States, in compliance with adequate measures to protect the rights, freedoms, and legitimate interests of the data subjects (Recital 71 and Article 22, paragraph 4, of the GDPR) (Point 1).

Based on the principle of "data protection by design" (Article 25, paragraph 1, of the GDPR), the Authority clarified that in the development of AI systems in the healthcare sector, appropriate technical and organizational measures must be adopted to implement the principles of data protection (Article 5 of the GDPR) and integrate the necessary safeguards to meet the requirements of the GDPR and protect the rights and freedoms of the data subjects (Point 2). Such measures must ensure—by default—the proportionality of the processing concerning the public interest pursued, aiming to achieve a real protective effect.

The third point of the guideline addressed the definition of roles in processing, considering it necessary, also from a data governance perspective, to have a comprehensive view of the ownership of processing that takes into account that access to a national AI system in the healthcare sector could be granted to multiple parties based on different legal grounds and for different purposes.

The Authority then recalled the three cornerstone principles that must govern the use of algorithms and AI tools in carrying out tasks of significant public interest, based on the provisions of the GDPR and in light of recent case law from the Council of State: the principle of transparency, the principle of non-discrimination in algorithms, and the principle of non-exclusivity (Point 4).

In the fifth point of the guideline, the Authority drew attention to the necessity of conducting an impact assessment pursuant to Article 35 of the GDPR prior to the establishment of a centralized national system through which healthcare services would be provided using AI tools, as this would result in systematic, large-scale processing of special categories of personal data as referred to in Article 9 of the GDPR concerning vulnerable individuals, through the use of new technologies and with a high risk to the rights and freedoms of the data subjects.

Particular emphasis was placed on the need to ensure high-quality data standards, considering that the use of outdated or inaccurate information could also affect the effectiveness and correctness of the services provided by the aforementioned AI systems, which indeed rely on the reprocessing of such data.

****6.**** They intend to implement (point 6).

In recalling the necessary respect for the principles of integrity and confidentiality, the Guarantor has highlighted the need to ensure a precise description of the algorithmic logics used to "generate" the data and services through the aforementioned AI systems, the metrics used to train and evaluate the quality of the adopted analysis model, the checks carried out to detect the presence of any biases, and the corrective measures subsequently adopted, as well as the appropriate measures to verify, even retrospectively, the operations performed by each authorized subject and the inherent risks in deterministic and stochastic analyses (point 7).

It has also been represented, in line with international documents and administrative jurisprudence, that transparency and fairness in decision-making processes based on automated processing constitute one of the fundamental pillars to be established at the base of the development and use of AI systems in light of the related risks, including discriminatory ones, that may arise from the use of such tools (point 8).

In the ninth point of the decalogue, it has been recalled that the GDPR, the European Guarantor, and the Guarantor himself have emphasized the centrality of the concept of human oversight contained in the proposed regulation on AI, highlighting that the actual involvement of human beings should be based on highly qualified supervision and the lawfulness of processing, in order to ensure respect for the right not to be subjected to a decision based solely on automated processing.

In the last point, the ethical and deontological aspects of the processing of personal data through AI tools have been recalled, emphasizing that the validation of algorithms should ensure the improvement of the quality of services of the National Health Service without negative repercussions in social, deontological, or ethical terms for the individual or regarding professional responsibility.

The decalogue has been transmitted to central and local health governance bodies in order to align ongoing projects with the principles mentioned therein.

On the topic of AI, the investigation initiated following some press reports regarding a pilot regional project aimed at creating support for the diagnosis of rare diseases through AI is also mentioned.

****5.3. Processing of personal data within central health information systems****

Also in 2023, the Guarantor continued to provide opinions on matters of competence regarding the aspects of personal data protection related to the implementation of central health information systems.

In particular, the Guarantor returned to address the issue of the processing of personal data carried out through medical devices with the opinion issued on the draft decree containing provisions regarding the methods of providing information concerning the identifying data of the manufacturer and the list of types of custom medical devices made available in the national territory (provision of April 27, 2023, no. 186, web document no. 9896484). In this opinion, acknowledging the retention period identified by the Ministry of Health, the Guarantor reiterated the necessity for the same Ministry to ensure that access to the personal and anamnesis data of the patient is prohibited within the activities functional to the provision or maintenance of the devices, except when indispensable for the provision of maintenance and tele-diagnosis/tele-intervention services, ensuring that every operation of intervention/access is traceable, also in order to fully comply with the previous opinion on the matter dated May 26, 2022, no. 189 (web document no. 9782450).

The same reminder was reiterated in the opinion issued on the draft decree concerning the retention times of personal data possibly provided in connection with communications of incidents involving in vitro medical devices, implementing Article 13, paragraph 9, of Legislative Decree August 5, 2022, no. 138 (provision of May 17, 2023, no. 192, web document no. 9897587).

In relation to the numerous individual-based national information systems that feed into the New Health Information System (NSIS) owned by the Ministry of Health, the Office has preliminarily requested the aforementioned Ministry to verify, with technical scientific justifications, the necessity of retaining data for thirty years from the death of the patient. The Ministry has represented that, for the evaluation of care pathways, the data must encompass the entire life of the patients, including the event of death, from which a period of time should commence that, on one hand, ensures a uniform retention period for all interested parties, regardless of the duration of their life, and on the other hand, allows for a sufficient database for the various analytical purposes underlying each information system.

The adjustment of the

****SIAR****

****SICOF****

****SIAD****

The NSIS flows for this period of preservation have also become necessary based on the regulation establishing the National Registry of Assistants (ANA), which provides for the retention of data of the assisted individuals for thirty years from the date of death (art. 4, paragraph 4, d.P.C.M. June 1, 2022), as the procedure for interconnection referred to in art. 3 of the decree of the Ministry of Health no. 262/2016 stipulates that ANA provides the Ministry of Health with the service of verifying the validity of the identification code and updating the data.

In relation to the favorable opinions rendered in this area, it is worth noting the one on the draft decree aimed at establishing the Information System for Monitoring Rehabilitation Assistance (SIAR) and its

related technical annex (prov. June 22, 2023, no. 259, doc. web no. 9918016). The SIAR is implemented in the context of semi-residential and residential assistance, of an intensive, extensive, and maintenance nature, as per art. 34 of d.P.C.M. January 12, 2017, and is aimed at collecting information from regions and autonomous provinces regarding rehabilitation treatments, following a multidimensional assessment of the assisted individual and taking charge, and the individual rehabilitation project (PRI). The SIAR allows, on one hand, regions and autonomous provinces to conduct comparative analyses regarding rehabilitation treatments, based on indicators calculated following the aggregation of data at the company level on an annual basis, and, on the other hand, enables the Ministry of Health to consult the information made available by the System. The SIAR includes non-directly identifiable information related to the provider of rehabilitation assistance services and the assisted individual, to whom the interconnection procedure referred to in d.m. no. 262/2016 applies, according to the rules indicated in the technical disciplinary scheme that also defines the methods, frequency, and timing of the collection and transmission of the same. Another important opinion regarding central health systems concerned the draft decree aimed at establishing the Information System for Monitoring Activities Provided by Family Counseling Centers (SICOF) (prov. June 22, 2023, no. 260, doc. web no. 9918033). This information system, whose management is entrusted to the Ministry of Health, as the data controller, is implemented concerning the services provided by family counseling centers, established by law no. 405/1975. The SICOF allows regions and autonomous provinces to monitor the services provided by family counseling centers, as well as the essential and uniform levels of assistance, through comparative analyses in the field of health and social-healthcare assistance, based on indicators calculated following the aggregation of data at the company level on an annual basis. The System also allows the Ministry of Health to consult the information made available in the same form by the System. The non-directly identifiable information, related to the provider of the healthcare and social-healthcare services offered by the counselors and the assisted individual, is transmitted by the regions and autonomous provinces and subjected to verification by the Ministry regarding completeness and quality. The interconnection procedure referred to in d.m. no. 262/2016 also applies to SICOF. In this context, the opinion rendered on the draft decree of the Minister of Health modifying the decree of the Minister of Labor, Health, and Social Policies of December 17, 2008, establishing the Information System for Monitoring Home Assistance (SIAD) is also relevant (prov. July 6, 2023, no. 284, doc. web no. 9919981). The modification arises from the need expressed by the Ministry of Health to integrate the existing SIAD flow with data related to home palliative care and basic home care, in order to have a homogeneous information base among the regions usable for calculating the indicators of the PNRR for home assistance provided in Investment 1.2 "Home as the First Place of Care and Telemedicine" of Mission 6, Component 1 of the PNRR.

****MONITORING EMERGENCY-URGENT SERVICES****

****SIND****

It is also noted, in this context, the opinion rendered on the draft decree of the Minister of Labor, Health, and Social Policies, modifying the decree of December 17, 2008, establishing the Information System for Monitoring Services Provided in Emergency-Urgent Healthcare (prov. July 6, 2023, no. 283, doc. web no. 9919963). During the investigation initiated by the Office, the Ministry substantiated with technical-scientific reasons the necessity to assign to the information system the purpose of allowing rapid alerts related to respiratory syndromes, based on emergency room admissions. The draft decree and the related technical disciplinary took into account the observations made by the Office during informal discussions that particularly concerned the need to indicate in the draft decree the regulatory references that assign to the Ministry of Health specific competencies in combating any health emergency, as well as any initiative aimed at treating emerging epidemic-pandemic diseases, to specify the levels of data aggregation contained in the system provided for access by the Ministry's management, and to indicate in the disciplinary that the system does not allow access to entities external to the Ministry, except for the Higher Institute.

****Health Authority as Data Controller.****

The Authority has therefore expressed, in the terms provided, a favorable opinion of competence without making observations, highlighting that it was issued on a text under revision and that, should

modifications regarding the type of data collected or the operations carried out be introduced, it would be necessary to amend the draft decree under examination and obtain a new opinion from the Authority.

Lastly, reference is made to the opinion on the draft decree of the Minister of Health concerning the National Information System for Addictions (SIND), which repeals and replaces the decree of the Minister of Health dated June 11, 2010, included among the information systems of the National Health Service interconnected pursuant to Ministerial Decree No. 262/2016 (provision dated October 12, 2023, No. 471, web document No. 9947458).

In particular, in this opinion, the Guarantor highlighted that the processing of personal data of detainees through the aforementioned System, as it relates to criminal convictions and offenses referred to in Article 10 of the GDPR, is permitted only if authorized by a legal provision or, in cases provided for by law, by regulation, which provides appropriate guarantees for the rights and freedoms of the data subjects. In the absence of the aforementioned legal or regulatory provisions, the processing of such data and the related guarantees are identified by decree of the Minister of Justice; however, in relation to the specific case, the aforementioned decree has not been adopted, although the Guarantor, on June 24, 2021, adopted the opinion on a draft regulation identifying the processing of personal data relating to criminal convictions and offenses and the related appropriate guarantees pursuant to Article 2-octies, paragraph 2, of the Code (web document No. 9682603, see also opinion dated June 30, 2022, No. 237, web document No. 9794929).

In this regard, the Guarantor also emphasized that the detection in the SIND of the condition of being a detainee could not be considered legitimized by the reform legislation on prison health (Law No. 418/1998, Legislative Decree No. 230/1999, and Prime Ministerial Decree of April 1, 2008), which provides for the establishment of the National Information System on the health of detainees and minors subject to criminal measures, within the NSIS of the Ministry of Health, as the aforementioned legal provision provides for the collection of judicial data within the information system on the health of detainees and not also in the SIND, which concerns addictions.

During the discussions, including informal ones, the Ministry took into account the observations made by the Office, removing the variable related to the detained patient from the data collected by the SIND and providing assurances regarding the track named "HIV Monitoring," which only collects aggregated data related to the execution of the HIV serological test by users of the Addiction Services (SerD), in which there are no demographic variables. It was also clarified that the production of statistical analyses and statistical indicators on the phenomenon of healthcare assistance to people with addictions or at-risk behaviors is the responsibility of the statistical office of the Ministry of Health, in accordance with the ethical rules for treatments for statistical or scientific research purposes carried out within the National Statistical System adopted by the Guarantor's provision dated December 19, 2018, No. 514 (web document No. 9069677) and reported in Annex A of Legislative Decree No. 196/2003.

Alongside the aforementioned favorable opinions, a negative opinion was also expressed on the draft decree of the Ministry of Health, to be adopted in concert with the Ministry of Economy and Finance (MEF), concerning the definition of the characteristics and contents of prescriptions for medicines issued in Italian territory at the request of a patient who intends to use them in a Member State pursuant to Article 12, paragraph 9, Legislative Decree No. 38/2014 (so-called cross-border prescription) (provision dated January 26, 2023, No. 24, web document No. 9856677). In this opinion, the Guarantor noted significant critical issues regarding the identification of the ownership of the treatments following the generation of the cross-border prescription made by the prescribing physician, concerning the activities necessary for the use of the prescription abroad and the control of its regularity.

Further critical issues have been identified in the information to be provided to the data subject, as well as in the absence of the identification of appropriate and specific measures to protect the fundamental rights and interests of the data subjects, the operations that can be carried out, and the relevant public interest pursued. The provisions examined have also been found to be inconsistent with the regulations on the FSE and in light of the observations already made in this regard in the aforementioned opinion of August 22, 2022. Additional observations have concerned the lack of

guarantees regarding compliance with the parameters related to the quality of the processed data and the indeterminate duration of the related retention period, as well as the security aspects of the processing connected to the absence of a prior impact assessment.

5.4. Processing for healthcare purposes and administrative activities related to healthcare

5.4.1. Measures resulting from data breaches

Numerous investigations initiated by the Authority have concerned, in 2023, behaviors of which the Guarantor became aware upon receiving notifications of personal data breaches, communicated by the data controllers pursuant to Article 33 of the GDPR. In a considerable number of cases, the investigations resulted in sanctioning measures.

One of these concerned the conduct of a healthcare company and, in particular, the cardiac surgery unit, which had sent an email, in carbon copy, to patients awaiting heart transplants, in the context of obtaining informed consents for participation in a clinical study, through forms to be filled out and signed. In examining the matter, the Authority recalled that email addresses fall under the notion of personal data, even if devoid of references to the first and last name or otherwise to other directly identifying information of the data subjects; it also highlighted that from the context of the communication, it could be inferred that the recipients of the email were patients awaiting heart transplants, so that the described processing concerned health data as it related to information regarding healthcare services, which reveal information about health status (Article 4, paragraph 1, number 15 of the GDPR). It was therefore emphasized that such sending had, in fact, without justified reason and in the absence of a legal basis, resulted in a communication of personal data and health-related data of the data subjects (to whom the email addresses pertain), in violation of the basic principles set forth in Articles 5, paragraph 1, letter f) and 9 of the GDPR.

The Authority consequently adopted a sanctioning measure against the company, considering a series of elements in this regard, including the fact that it became aware of the event following the notification of the data breach made by the data controller, the number of data subjects (19), and the absence of intentional behaviors on the part of the company; the violation had indeed occurred due to an error made by an employee in the phase of entering the recipients in the specific field of the email, within the framework of a temporary procedure adopted during the pandemic period to avoid, for the delivery of documentation, the in-person summons of the fragile patients who were the recipients of the email (provision of January 11, 2023, no. 7, web document no. 9861356).

Another data breach case involved the unlawful communication of health data carried out by a healthcare company for having unintentionally included a patient's health documentation in a clinical file related to a different patient — and delivered to the latter — in the absence of an appropriate legal basis. The company was sanctioned by the Guarantor for violating the basic principles of processing set forth in Articles 5 and 9 of the GDPR and the obligations regarding security set forth in Article 32 of the same GDPR (provision of January 26, 2023, no. 26, web document no. 9861289).

The Guarantor, following two notifications of data breaches made by a healthcare company, the data controller, within a few days and concerning both the incorrect delivery of radiological reports, after having ordered the joining of the proceedings considering the analogy between the two cases, adopted a sanctioning measure against this company. Specifically, the company had — due to the operator's error in the phase of enveloping the reports — delivered some reports (referring, in total, in the two cases, to no. 4 patients) to third parties (two in the first case of data breach and two in the second case) not authorized to receive them. This conduct constituted an unlawful communication of health data, as it occurred in the absence of a legal basis that legitimized the knowledge of the aforementioned information by the recipients, in violation of the basic principles set forth in Article 5, letter f) and Article 9 of the GDPR, as well as the obligations of security of personal data set forth in Article 32 of the same GDPR (provision of October 26, 2023, no. 500, web document no. 9964729).

In another case, a territorial social-health company notified the Authority of three violations of personal data, concerning the communication of health data to unauthorized subjects on separate occasions. In

particular, in the first case, the communication contained a summons for a visit by the company's commission for the evaluation of civil disability, in addition to the authorized subject, also to two other people; in the second, it was included, in the field...

denominated copy knowledge, the address of 198 recipients, in the sending of an email from the multiple sclerosis center of the company and having as its subject the "updated recommendations on Covid in patients affected by multiple sclerosis"; in the third, health documentation containing the result of an examination carried out by a third party had been delivered to a patient.

Considering that the violations subject to notification pursuant to Article 33 of the GDPR concerned the same data controller in relation to similar cases, the consolidation of the 3 investigative proceedings was ordered. The Authority clarified that the data subject to communication concerned, in all cases, information about the health of the data subjects, highlighting that, in light of the described traceability of the email addresses to the notion of personal data, the circumstance whereby it could be inferred from the context of the communications that the recipients were patients under treatment at the multiple sclerosis center resulted in the processing of information related to health, according to the definition of Article 4, paragraph 1, number 15 of the GDPR, even if no indication had been provided regarding the severity or illness of the patient (cf., in this sense, provisions of May 13, 2021, no. 206, web doc no. 9688020; September 16, 2021, no. 328, web doc no. 9722297; April 28, 2022, no. 164, web doc no. 9779057; July 7, 2022, no. 242, web doc no. 9809998; January 11, 2023, no. 7, web doc no. 9861356). This conclusion also applied in relation to the summons for a visit by the company commission for the evaluation of civil disability, based on the health documentation produced by the data subjects.

In adopting the corrective measure, the Authority took into account the number of data subjects involved (about 200); the fact that no complaints or reports had been received regarding the incident, having become aware of the events following the notifications of personal data breaches made by the data controller; the introduction of measures aimed at reducing the replicability of the events that occurred. It was also considered that the facts had occurred, in one case, in the context of the vaccination campaign and the need to provide, immediately and as easily as possible, the information related to the updated recommendations on Covid-19 in patients affected by multiple sclerosis; in another, in the context of activities aimed at increasing, after the state of emergency from Covid-19, the volumes of activities and work rhythms, in order to address the long waiting lists that had arisen following the suspension and slowdown of activities during the pandemic period (provision of July 18, 2023, no. 316, web doc no. 9935484).

In another circumstance, the investigation was initiated following a notification of a personal data breach by an entity that had stated it had mistakenly managed an invoice related to psychiatric services both in the heading phase and in the sending phase, both carried out towards a subject different from the data subject, with the same name. In the illustrated case, the Authority intended to assess the violation as minor, considering certain elements, including: the absence of previous violations committed by the entity, the high degree of cooperation promptly demonstrated throughout the entire investigative and procedural phase, the circumstance that the communication of health data concerned only one data subject and that the violation was caused by an error of an employee, who was nonetheless subject to disciplinary proceedings. The Authority therefore limited itself to admonishing the data controller, believing that this type of measure could serve a proportional corrective function, also being an effective and deterrent measure (provision of September 14, 2023, no. 399, web doc no. 9939623).

In many circumstances, the data breaches reported by the data controllers were due to inadequate security measures. In particular, a company notified a breach concerning the communication made via ordinary mail to a very large number of beneficiaries (39,852) of documentation addressed to them, but containing the certificate, concerning a third party, of exemption from participation in healthcare costs for income reasons issued by the region.

**On the same issue, the Authority also received some complaints from the same beneficiaries. On this occasion, the Authority, in adopting a sanctioning measure for the described processing

concerning only common data and occurring in violation of Articles 5, 6, and 32 of the GDPR, did not foresee corrective measures, considering that the company had sent the correct exemption certificate to the involved beneficiaries by ordinary mail and had requested the destruction of the previously received one; the Authority also considered the high degree of cooperation during the investigative and procedural phase, the circumstance that the processing had concerned a very large number of data subjects, but had involved the communication of the data of one data subject to a single different subject and, in any case, that the choice to proceed with the mass sending to the homes of the beneficiaries of the exemption certificates was...**

State of Affairs, in the emergency context of the Covid-19 pandemic, in order to avoid user access on-site and thereby prevent gatherings at the company's counters (provision of May 17, 2023, no. 197, web document no. 9899929).

Another front on which the Authority has been heavily engaged concerning data breach notifications has been that of cybersecurity. In particular, a healthcare company reported a health data breach following a ransomware attack that, through a virus, limited access to the healthcare facility's database and for which a ransom was demanded to restore the functionality of the systems.

Several critical issues were identified by the Authority during the investigation into the incident, during which an inspection was also necessary to verify the technical and organizational measures adopted by the company both before and after the attack. In particular, from the examination of the information and elements acquired as well as the documentation provided by the company, it emerged that the processing had been carried out in violation of the regulations on the protection of personal data, touching on multiple aspects.

Firstly, there was inadequate management of the alarms aimed at detecting the incident, which did not allow the company to become promptly aware of the personal data breach that occurred. This constituted a violation of the provisions of Article 5, paragraph 1, letter f) and Article 32, paragraph 1, of the GDPR, also in light of the guidelines 9/2022 on the notification of personal data breaches under the GDPR, adopted by the EDPB on March 28, 2023 (point no. 41).

It also emerged that the company had not adopted adequate measures to segment and segregate the networks on which the workstations of its employees were located, as well as the systems (servers) used for processing, and that, at the time the personal data breach occurred, remote access to the company's network via VPN had occurred through a computer authentication procedure based solely on the use of a username and password.

The failure to adopt adequate measures to ensure the security of the networks, both in relation to the lack of segmentation and segregation, which had caused the propagation of the virus throughout the entire IT infrastructure, and concerning remote access via VPN, was found not to be compliant with the provisions of Articles 5, paragraph 1, letter f) and 32, paragraph 1, of the GDPR, according to which the data controller and the processor must implement measures to ensure on a permanent basis the confidentiality, integrity, availability, and resilience of the systems and services of processing.

Finally, in light of what emerged and, in particular, the failure to adopt adequate measures and guarantees to effectively implement the principle of "data integrity and confidentiality" and to protect against unauthorized or unlawful processing, the elements of a violation of the principle of "data protection by design," as per Article 25, paragraph 1, of the GDPR, were also identified, considering the risks to the rights and freedoms of the data subjects arising from the processing in question, in relation to the nature, scope, context, and purposes of the processing.

In sanctioning the unlawful act, the Authority took into account the fact that the data breach involved data capable of revealing health information of a very significant number of data subjects (842,000 among patients and employees), but also the unintentional and extremely cooperative attitude of the company at every stage of the investigation, including the inspection phase. After the incident, the company adopted a diversified series of measures aimed not only at mitigating the damage suffered by the data subjects but also at reducing the replicability of the event itself, including the activation of a network access procedure via VPN with two-factor authentication (provision of September 28, 2023,

no. 426, web document no. 9941232).

It is also noted that, during the year, in terms of security, several inspections were carried out at other healthcare companies that had reported personal data breaches following ransomware attacks (see Chapter 17).

****REPORT 2023****

****Data Breaches****

****Dissemination of Health Data****

****5.4.2. Measures Arising from Complaints and Reports****

Even in the reference year, the Authority initiated numerous investigations following specific complaints and reports, some of which concerned violations of the basic principles of processing and concluded with the adoption of corrective measures.

In one case subject to reporting, the Authority sanctioned a Calabrian hospital company for violating Articles 5, paragraph 1, letters a) and f) and 9 of the GDPR and the security obligations under Article 32 of the same GDPR, as well as Article 75 of the Code, which preserves specific sector provisions. It was indeed established, at the end of the investigation, the company's responsibility for having sent, via email and in violation of the measures indicated in Annex A of the Prime Ministerial Decree of August 8, 2013, a report concerning a patient to an unauthorized third party and, therefore, in the absence of a legal basis justifying such communication of health-related data (provision of January 26, 2023, no. 25, web document no. 9863050).

It is noted that, following a complaint from a patient, an investigation was initiated against a local social-health company that, intending to transmit a...

e-mail to the complainant, had been sent to an email address not attributable to her. The email contained, as an attachment, a provision by which the extra-regional admissions office of the health authority authorized the extra-regional hospitalization of the complainant. This document contained, in addition to the identifying data of the complainant, also the indication of the hospital institution where medical care was to be provided and a series of other elements, such as, for example, the presence of an accompanying person. Following the examination of the case, the illegality of the processing of personal and health data carried out by the company emerged, for having processed personal data in violation of the basic principles of processing pursuant to Articles 5 and 9 of the GDPR as well as the security obligations under Article 32 of the GDPR. In the sanctioning provision adopted against the company, it was taken into account that the processing concerned only one data subject, that the violation occurred due to an error in identifying the documentation to be attached to the email, and that the data controller had demonstrated a high degree of cooperation with the Authority (prov. March 23, 2023, no. 85, web doc. no. 9872621). Many provisions have concerned cases of dissemination of health data. Following a report, the Authority adopted a sanctioning provision against a health company that had published, on its website, documents containing praises received from patients regarding the services received for the treatment of specific pathologies from which - in almost all cases - it was possible to identify the patients themselves, as the personal data had been roughly obscured with a black marker, which nevertheless did not prevent reading the obscured parts (prov. March 12, 2023, no. 74, web doc. no. 9870171). In particular, the Authority represented that the manual cancellation procedure with a marker or correction fluid, by its nature imprecise and non-definitive, cannot be considered suitable to anonymize the personal information of the data subjects, nor can it be defined as a pseudonymization procedure, even when carried out effectively, being rather a simple manual procedure for obscuring the identities of the data subjects (see, in this regard, the provisions of September 17, 2020, web docs. nos. 9479364 and 9479382). The Authority also noted that the data published on the ASL website did not comply with the principle of minimization, as the publication of the praise as presented by the data subject had resulted in the dissemination of health data (e.g., clinical details) not relevant to the specific purpose, which could be traced back to the activity "of communication and information for improving relationships with users." Another health company was sanctioned by the Authority for having disseminated data on the health of a patient by posting outside the emergency room a billboard regarding the health services provided by

the company in which the personal data of that patient were visible (prov. June 1, 2023, no. 227, web doc. no. 9917728). In its provision, the Authority recalled that the publication of any information from which the state of illness or the existence of pathologies of the data subjects can be inferred is prohibited, including any reference to conditions of disability, physical and/or mental handicap. For this purpose, from the drafting phase of the acts and documents subject to publication, while respecting the principle of adequate motivation, personal data that are "excessive," "not relevant," "not indispensable" (and, even less, "prohibited") must not be included (see also guidelines on the processing of personal data, including in acts and administrative documents, carried out for the purposes of publicity and transparency on the web by public entities and other obligated entities, part II, par. 1, of May 15, 2014, web doc. no. 3488002). A further case involved the publication in some newspapers, including online, of images of health documentation relating to a subject long sought by law enforcement. During the investigation, it was established that a complaint had been filed with the Public Prosecutor's Office regarding the fact that the health company that had issued the reports disseminated had not provided copies of them to parties other than the data subject and that the health personnel...

authorized data controller declared itself unrelated to the dissemination of data (press release January 18, 2023, web doc. no. 9845388 and note June 28, 2023). The Authority also sanctioned a healthcare company regarding the presence, in the premises of a former sanatorium, of health documentation (e.g., prescriptions, medical records, and X-rays) in a state of abandonment and accessible to anyone (provision September 28, 2023, no. 424, web doc. no. 9946386). In the provision, the Authority recalled that the sector regulations identify specific retention periods that healthcare facilities must comply with concerning the type of health documentation in their possession (see, among others, circular of the Ministry of Health December 19, 1986, no. 900; art. 5 of the ministerial decree February 18, 1982; art. 4 of the ministerial decree February 14, 1997; ministerial decree August 3, 2001; legislative decree no. 200/2007; presidential decree no. 445/2000; legislative decree no. 42/2004; legislative decree no. 82/2005; legislative decree no. 502/1992). Where there is no specific regulatory provision identifying the retention periods for a document containing personal data, it is up to the data controller to determine an appropriate retention period for achieving the legitimately pursued purposes, which must also be indicated in the information to be provided to the data subject pursuant to art. 13 of the GDPR. The Authority noted that, although the company had adopted the corporate regulation on the retention of documentation (so-called disposal schedule), it had then left a large amount of health documentation in a state of abandonment, which should have been retained within the times and according to the methods indicated in the aforementioned regulation, in violation of the principles of integrity and confidentiality of data, as well as legality, fairness, transparency, and limitation of retention as per art. 5 of the GDPR.

In another case, a complainant reported the dissemination on the web by a healthcare company of their personal information (date of birth, residence, tax code) as well as health-related data. In particular, a note from the company's territorial pharmaceutical assistance service was disseminated, concerning the request for the purchase of a medication, along with a certificate confirming the pathology from which the complainant suffered and the medications they needed. In the sanctioning provision adopted against the company for having processed health data in violation of the basic principles of processing as per arts. 5, 6, and 9 of the GDPR as well as art. 2-septies, paragraph 8, of the Code, it was deemed unnecessary to adopt corrective measures, as the company had promptly de-indexed the erroneously disseminated personal data, removing it from the contents of search engine indexes (provision April 13, 2023, no. 126, web doc. no. 9891029). A similar violation regarding the dissemination of health data was established against a healthcare company that had disclosed the complainant's health information by posting a notice at the entrance gate of the clinic where the complainant worked as a hygienist, informing users that on a specific date the vaccination session would not be guaranteed due to service needs arising from their illness. According to the company, which had promptly removed and replaced the notice containing the complainant's information, the incident, which was unintentional, was caused by a misunderstanding between those who had given the order to inform users of the impossibility of providing the service they were waiting to receive and those who had actually executed that notification. The sanctioning provision adopted against the

company for having disseminated data related to the doctor's health, in violation of the basic principles of arts. 5 and 9 of the GDPR, as well as art. 2-septies, paragraph 8, of the Code, took into account the lack of intent and the short duration of the violation (provision June 8, 2023, no. 242, web doc. no. 9917883). In another case, following a complaint, the

The Authority has adopted a warning and corrective measure against an osteopath who had carried out an unlawful treatment of health data, in violation of the provisions contained in Articles 5, paragraph 1, letter a), 6, 9, 12, and 13 of the GDPR. From the documentation in the records, it emerged that the data controller had communicated the health data of the complainant to third parties without a suitable legal basis, also violating the principles of fairness and transparency. The osteopath, in fact, despite the explicit opposition of the complainant, had used the health data of the latter to create a thesis that was then submitted to the training school and to the supervisor. Furthermore, the healthcare professional had repeatedly denied having used the clinical case concerning the interested party for the thesis and had provided the same with information that lacked the essential elements referred to in Article 13 of the GDPR (provision of October 26, 2023, no. 497, web doc no. 9954241). In the provision, the Authority focused on the fact that the thesis contained numerous clinical and anamnesis-related information through which it was possible to identify the interested party, even indirectly, and took the opportunity to reiterate that the procedure for manual deletion cannot be defined as suitable for anonymizing personal information, nor can it be defined as a pseudonymization procedure according to the definition in Article 4, no. 4 of the GDPR (see, in this regard, provision of March 2, 2023, no. 74, web doc no. 9870171, cited). The Authority also referred to what is indicated in the code of conduct for the use of health data for educational and scientific publication purposes, approved by the Authority's provision of January 14, 2021, no. 7 (web doc no. 9535354), which provides for the anonymization of personal information used for such purposes (in light of the WP29 guidelines 05/2014) or, where it is not possible to proceed with the anonymization of the data (e.g., due to the peculiarities of the clinical case represented), the recourse to valid consent from the interested party, which was instead not found in the one acquired in the records, proving to be non-specific and uninformed regarding the purpose in question. Following some reports, the Office initiated an investigation against an IRCCS that had been identified as the healthcare facility of reference for vaccination against monkeypox. The investigative procedure concluded with a warning measure as the collection of numerous and detailed information on the health status and sexual life of the individuals involved in the vaccination campaign, already in the booking phase of the same and not also in the conversations between doctor and patient and without having provided the information referred to in Article 13 of the GDPR, was assessed as a violation of the principles of lawfulness, fairness, transparency, integrity, and confidentiality referred to in Article 5, paragraph 1, letter a) and f), of the GDPR (provision of July 6, 2023, no. 289, web doc no. 9920292). Regarding the processing of personal data carried out within the initiatives to combat monkeypox, the Office engaged with the Ministry of Health to ensure that there was no prior identification of the group of individuals to be vaccinated, as it was to be considered on a voluntary basis. The Authority also emphasized the respect for the principle of data minimization, requesting that the indication of the risk category not be included in the vaccination record. On this aspect, the Ministry assured that it would inform the regions and autonomous provinces that during the registration of the vaccination in the regional registry, in the "risk category" field, the code "01 no indication" would be used (note of August 10, 2022 and point 1 provision of July 6, 2023, no. 289, web doc no. 9920292, cited). Assurances from the Ministry of Health were received regarding the implementation of the circular adopted on "Monitoring episodes of violence committed against healthcare and socio-healthcare professionals in the exercise of their functions" (note of October 10, 2023).

According to what has been specified by the Ministry, following the initiation of an investigation by the Office, the entities responsible for acquiring regional data on adverse events (assaults), devoid of direct identifying elements, from public and private healthcare and social healthcare facilities, are the regional centers for health risk management and patient safety. Such data, following an anonymization process, may then be transmitted to the National Observatory of best practices on safety in healthcare established at the Ministry for the monitoring purposes assigned to it by the relevant regulations.

Cases of data communications made by private entities in the absence of a suitable legal basis have also been examined. In particular, following a complaint from a citizen and a notification of a data breach made by the data controller, the Authority addressed the delivery, by a private healthcare group, of an emergency medical record to a namesake of the complainant, on which clinical events concerning the namesake of the latter had been transcribed. The Authority, having ordered the consolidation of the procedure related to the breach notification transmitted pursuant to Article 33 of the GDPR with that activated by the complaint, considering that they concerned the same matter, ascertained the highlighted violation, deeming the processing unlawful due to the breach of the principles of accuracy, integrity, and confidentiality (Article 5, paragraph 1, letters d) and f) of the GDPR); furthermore, it assessed that, through the incorrect drafting of the emergency medical record, subsequently delivered to the patient who shares the name of the complainant, the same company had communicated health-related data concerning two patients in the absence of a suitable legal basis.

In determining the sanction imposed by the Authority, the following were considered:

- in addition to the company's turnover, the adoption of a previous measure against the same company for relevant violations, and the peculiar emergency context due to the Covid-19 pandemic – also the potentially serious effects that the drafting of incorrect health documentation could have on the health of the individuals involved (provision of December 15, 2022, no. 43 of 2023, web document no. 9870788).

On another occasion, improper management of personal data was found concerning a private healthcare facility, following a complaint from a citizen who reported receiving periodic messages from the company on his private number reminding him of medical appointments never requested, and having found, in the pre-filled 730 income tax return, certain invoices issued under his tax code concerning services provided by the company for the benefit of a namesake patient. In this case as well, a violation of the principles of accuracy, integrity, and confidentiality of the data was noted, and through the compilation of the invoice related to the services utilized by the namesake containing the information (address and tax code) of the complainant, a communication of health-related data (derivable from the services provided at the Center, for which the relevant invoices were issued) occurred in the absence of a suitable legal basis. The sanctioning measure adopted against the company also considered the fact that the episode occurred due to the namesake of the individuals involved (provision of June 1, 2023, no. 228, web document no. 9909889).

The Authority, in relation to another case subject to reporting, having ascertained, at the end of the investigative procedure, the unlawfulness of the processing of personal data carried out by a Lombardy healthcare facility, the data controller, as well as by the IT company appointed by this healthcare facility as the data processor for maintenance and software assistance services, warned both: the data controller for having carried out personal data processing in violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32, paragraph 1, of the GDPR (provision of November 30, 2023, no. 557, web document no. 9984477) and the

****Data Controller Liability for Violating Articles 5, Paragraph 1, Letter f) and 32 of the GDPR**** (Provision of November 30, 2023, No. 556, Web Document No. 9973790). In the case examined, the notifier was able to view, without legitimate authorization, personal health data contained in the acceptance document addressed to another data subject through the platform made available to patients by the aforementioned healthcare facility for downloading reports. It was noted that a bug in the application caused this breach of confidentiality. The Authority established liability for failing to conduct testing and validation following the update of the portal's functionality. The system's vulnerability—which could have allowed third parties, as indeed occurred, to access information related to acceptances addressed to other data subjects by manipulating the URL to access a specific page of the site—had been anticipated during the initial testing phase and appropriately blocked, but was not considered following an update operation of the same portal aimed at introducing the functionality that allowed viewing the log of operations performed. In these provisions, the Authority emphasized that although the data controller bears a "general responsibility" for the processing carried

out (see Articles 5, Paragraph 2, known as accountability, and 24 of the GDPR), even when these are performed by other parties "on its behalf" (Recital No. 81, Articles 4, Point 8, and 28 of the GDPR), the Regulation has governed the obligations and other forms of cooperation to which the data processor is subject and the scope of their respective responsibilities (see Articles 30, 32, 33, Paragraph 2, 82, and 83 of the GDPR). The Authority deemed this to be a "minor violation," pursuant to Recital 148 of the GDPR and the guidelines regarding the application and imposition of administrative monetary penalties for the purposes of the GDPR (adopted by the Article 29 Working Party on October 3, 2017, WP 253, and endorsed by the EDPS with Endorsement 1/2018 of May 25, 2018), as the incident was found to be an isolated event lacking intent, resulting from intentional behavior by the notifier and attributable to a degree of fault assessed as slight, considering that the violation concerned health data of only one data subject, and that both the controller and the processor acted promptly to mitigate the effects of the violation and prevent the recurrence of similar events, demonstrating extensive cooperation with the Authority.

Also within the scope of complaints received from citizens, the intervention of the Authority is noted regarding a nationally significant and highly specialized company that had lost histological slides and samples of a woman contained within her medical file, resulting in the inability for the appointed expert witness, called to express an opinion in the Court of Appeal in the context of a case brought by the data subject, to examine the aforementioned biological material and support or refute the validity of the compensation request made by the woman. In examining the described incident, the Authority considered that, regardless of the qualification of the aforementioned slides and samples as "genetic data," they certainly fall under the category of health data provided for in Article 9 of the GDPR, as they consist of biological materials from the woman, associated with numerical elements related to her identity, capable of revealing information regarding the provision of healthcare services to her. That clarified, it emerged that the company did not have written protocols for the management and custody of histological specimens. In this regard, it was noted that the guidelines from the Ministry of Health, Higher Health Council regarding "Traceability, collection, transport, preservation, and archiving of cells and tissues for diagnostic investigations of pathological anatomy" (May 2015), concerning the sampled material (paraffin blocks and slides), clarified that the stipulated ten-year term is a minimum term, at the expiration of which the obligation of preservation for the holding structure ceases. In any case, if civil or criminal proceedings are ongoing, the healthcare facility, after consulting the physician responsible for the conduct, is required to evaluate...

****5.4.2. Preservation of Material****

The opportunity to preserve the material even beyond the ten-year term, in consideration of the ongoing litigation (see point 5.3.2. of the aforementioned document), has been noted. In light of the highlighted circumstances, the Authority has assessed that the aforementioned circumstances should not have exempted the company from the obligation to document which processing operation (including any deletion and destruction) had been carried out on the personal data contained in the slides associated with uniquely identified individuals for health purposes. Therefore, even considering the principle of accountability (Article 5, paragraph 2, of the GDPR), the company, even if it was no longer obliged to retain the biological samples, should have nonetheless adopted methods aimed at ensuring their traceability and identified documented procedures for managing the operations carried out, in all phases of processing, taking into account, in particular, the risks arising from the loss of the retained personal data, as provided for by Articles 5, paragraph 1, letter f) and 32 of the GDPR. Regarding the loss of data contained in the slides belonging to the complainant, the illegality of the processing of personal data was consequently noted, for the violation of Articles 5, paragraph 1, letter f) and paragraph 2, and 32 of the GDPR, as well as the provision of June 5, 2019, no. 146, web document no. 9124510 containing the prescriptions related to the processing of special categories of data, pursuant to Article 21, paragraph 1, Legislative Decree no. 101/2018.

In defining the monetary sanctions, it was deemed that the violation of the cited provisions was the result of a single conduct (same processing or interconnected treatments), applying Article 83, paragraph 3, of the GDPR, while the level of severity was considered medium, taking into account the

number of affected individuals involved, the category of personal data concerned, the purpose of the processing, as well as the level of damage suffered by the data subject. The high degree of cooperation with the Authority at all stages of the procedure was also considered, and following the observations raised by the Office, the adoption of a specific procedure regarding the delivery of slides, samples, histological and cytological examinations (provision December 21, 2023, no. 601, web document no. 9980617).

****5.4.3. Measures Resulting from Office-Initiated Investigations****

On January 30, 2023, the President of the Guarantor sent a note to all regions and autonomous provinces regarding the guarantees that must be adopted in emergency departments when processing health data. In this note, the President highlighted that the legal framework provides specific protections for individuals undergoing particular types of health interventions or suffering from conditions characterized by strong social stigmatization. He also represented the necessity that the provision of health services, even in emergencies, be carried out in full respect, especially for the most vulnerable groups such as the disabled, both physically and mentally, minors, the elderly, and individuals in conditions of hardship or need, also ensuring the specific protections provided for victims of violence, those seeking access to clinical pathways anonymously, and patients affected by HIV. The President therefore called on local authorities to comply with these prescriptions, to continue the training of healthcare operators as provided by the GDPR, and to ensure that, in the provision of health services, including through the new methods offered by digital health, the protection of personal data is considered a foundational value from the design phase (note January 30, 2023, web document no. 10011979).

****5.4.4. Measures Related to the Processing of Personal Data Carried Out in the Context of the Health Emergency****

In 2023, hundreds of investigations initiated following reports and complaints regarding the processing of data related to the penalty for non-compliance with the vaccination obligation for individuals over fifty were closed. In this regard, it was recalled that, following the opinion issued on February 18, 2021 (web document no. 9746905), the Ministry of Health accepted the observations made by the Office during the investigation and introduced specific guarantee measures suitable for protecting the fundamental rights and interests of individuals. Specifically, the invitation to provide that the subjects receiving the initiation of the sanctioning procedure notify the Revenue Agency of the mere occurrence of the aforementioned communication to the competent ASL, in ways suitable to ensure compliance with the principle of data minimization as per Article 5, paragraph 1, letter c), of the GDPR, was accepted. Similarly, suitable methods were identified through which the Revenue Agency could communicate to the Ministry of Health the list of subjects for whom the notice of charge had not been produced, indicating solely the non-existence of the vaccination obligation or the impossibility of complying, without providing information likely to reveal the health status of the data subject, in compliance with the aforementioned principle of data minimization.

With reference to the processing of personal data carried out in the context of the health emergency, following a report, the Guarantor adopted a sanctioning measure against a nursing home that allowed access to the clinics only to those who possessed a green certificate—even after the cessation of the state of emergency—(provision September 28, 2023, no. 423, web document no. 9946369). In reconstructing the various...

****Regulatory Interventions on the Subject and the Related Opinions Issued by the Authority****

It has been represented that the limitation of personal freedoms carried out through the processing of health data of the individuals concerned, and realized by making access to places and services conditional upon possession of a certification attesting to vaccination or recovery from Covid-19, or a negative result from an antigenic or molecular test, is admissible only if provided for by a state law (Articles 6, paragraph 2, and 9 of the GDPR and Articles 2-ter and 2-sexies of the Code, Recital No. 48, Regulation of the Council on the EU Digital Covid Certificate adopted on June 14, 2021; see also Constitutional Court, Judgment No. 271/2005 on the state law reserve on data protection;

Constitutional Court, Judgment No. 37/2021). The sectoral regulation has never provided for the green certification for health needs, for which access to places designated for the procurement of medicines and medical devices has always been allowed, and, in any case, for any purpose of prevention, diagnosis, and care. Therefore, the access modalities to the healthcare services indicated by the nursing home have effectively resulted in differentiated and potentially discriminatory treatment.

Regarding the green pass, it is also highlighted that the Authority, on delegation from a Public Prosecutor's Office, conducted investigations in December 2023, together with the Special Privacy and Technological Fraud Unit of the Guardia di Finanza, pursuant to Article 370 of the Criminal Procedure Code, concerning the processing of personal health data carried out by a private clinic following the reporting of a positive Covid-19 test during the pandemic period. The investigations were initiated following a report from an individual who had received a report of a positive Covid-19 test that they had never undergone.

Full cooperation in this matter was also provided to a regional Prosecutor's Office of the Court of Auditors pursuant to Article 58, paragraph 2, Legislative Decree No. 174/2016 (Code of Accounting Justice), regarding the investigative activities carried out for the adoption of the warning measure adopted on May 25, 2021, against the Campania Region concerning the use of Covid-19 green certifications (doc. web No. 9590466) (note of May 4, 2023).

****5.5. Processing for Purposes Other than Care and/or Administrative Purposes Related to Care****

The Authority intervened in some cases (learned from news agencies) regarding the management of the burial of fetuses and aborted products, in which critical issues had emerged. Reference was made, in particular, to the communication by a health company to the cemetery services of a municipality of the list of women who had undergone an abortion, along with the documentation relating to the authorization for the transport and burial of the aborted products for each of them.

In the measure adopted against the company, the Authority clarified that according to sectoral regulations, voluntary interruption of pregnancy can be practiced when "the continuation of the pregnancy, childbirth, or motherhood would pose a serious danger to her physical or mental health, in relation to her health status," or when "the pregnancy or childbirth pose a serious danger to the life of the woman" or "pathological processes are ascertained, including those related to significant anomalies or malformations of the fetus, which pose a serious danger to the physical or mental health of the woman" (Articles 4 and 6, Law No. 194/1978). Furthermore, "the interruption of pregnancy, spontaneous or voluntary, in the cases provided for by Articles 4, 5, and 6 of Law No. 194 of May 22, 1978, is considered for all intents and purposes as an illness" (Article 19 of Legislative Decree No. 151/2001). Consequently, personal data relating to the interruption of pregnancy fully falls within the category of health data, not only because the reference to the physical and mental health of the woman is explicitly stated in the aforementioned regulatory provisions, but also because it is an event connected to a "provision of healthcare services" (also, for example, in the case of spontaneous abortion) (Article 4, paragraph 1, No. 15 of the GDPR) (see also provision of June 4, 2015, No. 334, doc. web No. 4130998).

The aforementioned Law No. 194/1978 has provided for a strict confidentiality regime to protect the woman, which is included in the specific sectoral provisions exempted by Article 75 of the Code. This confidentiality regime has, moreover, been reiterated several times by the Authority in various interventions, qualifying such data among those subject to "greater protection of anonymity" (opinion on the draft decree concerning the certificate).

of assistance at childbirth, March 1, 2000, web doc no. 1085431; opinion on the draft decree regarding FSE, May 22, 2014, web doc no. 3230826; guidelines on health dossier, June 4, 2015, web doc no. 4084632). With reference to the burial of aborted products, the regulations concerning mortuary police provide specific rules regarding the presumed gestational age of the same, contained in the d.P.C.M. no. 285/1990 (arts. 7 and 70), which must be interpreted and applied in light of EU regulations on personal data protection (art. 22, paragraph 1, legislative decree no. 101/2018). The Authority has therefore noted that the acquisition by cemetery services of the aforementioned information, directly

identifying the woman, was not necessary for the performance of the tasks assigned by law to cemetery services, nor was it required for the affixing of the plaque on the grave. In fact, according to the relevant regulatory framework, the information to be indicated pertains to that of the deceased, which cannot in any way be assimilated to that of women who have undergone an abortion. It was therefore deemed non-compliant with the principle of data minimization to indicate the information that directly identifies women in the authorization and burial order for the aborted products to be transmitted to cemetery services. Furthermore, such communication involves the inclusion of identifying information of women in cemetery records kept for the identification of buried fetuses in the appropriate areas, effectively allowing the extraction from such records, kept in an automated form, of the list of women who have undergone an abortion in all hospital facilities located in the reference territory, thereby resulting in a disproportionate processing in relation to the purpose pursued by cemetery services, which is to provide for the burial of aborted products. The communication of directly identifying data of women to cemetery services was also found to be unjustified, as claimed, as the only means of identifying the burial site of the conception product in order to allow the woman, if she wishes, to know the burial location later. In fact, this legitimate need can be adequately met by adopting specific measures that, on one hand, ensure such identifiability, and on the other hand, are suitable to reduce the risk of significant harm to the women concerned, considering the particularly sensitive nature of the data processed. The possible use of specific technical and/or organizational measures (such as the masking of identifying data of women, pseudonymization, or encryption of data) would ensure the possibility of accurately identifying the product of conception and the location of its burial, without allowing – directly – to trace back to the identity of the woman. The Authority therefore sanctioned the conduct of the company but deemed it sufficient to admonish the data controller, given the difficult interpretation of the lacunose regulatory framework; moreover, it was noted, on one hand, the absence of complaints and reports to the Authority against the company, and on the other hand, the high degree of cooperation that the latter demonstrated from the outset through its willingness to find shared solutions. The Authority finally ordered the company to adopt appropriate technical and/or organizational measures to ensure that women who have undergone an abortion are not immediately identifiable in the documentation to be transmitted to cemetery services (provision April 27, 2023, no. 165, web doc no. 9900503; see par. 4.6). The issue regarding the management of the burial of fetuses and aborted products also involved a municipality and its cemetery services, against which the Authority adopted specific measures (see par. 4.6). Other interventions by the Authority concerning treatments carried out for purposes different from those of care and/or administrative purposes related to care have occurred on 82.

THE ACTIVITIES CARRIED OUT BY THE AUTHORITY

THE ACTIVITIES CARRIED OUT BY THE AUTHORITY

request by the interested parties. In particular, in one case, a complainant had reported the transmission of information about their health by a doctor, whom they had approached for a specialized visit (pulmonary visit, with a polysomnographic examination), to the company that had referred the patient to the aforementioned healthcare professional, in order to have them purchase a device for ventilatory therapy, without their consent. In the sanctioning measure against the doctor, the Authority clarified that information intended to reveal health status can only be communicated to third parties based on an appropriate legal basis or at the request of the interested party, with prior written delegation from the latter (Articles 9 of the GDPR and 84 of the Code - in the version prior to the reformulation by Legislative Decree No. 101/2018 - in conjunction with Article 22, paragraph 11, Legislative Decree No. 101/2018). Furthermore, the Authority highlighted that the consent of the interested party is not required (Article 9, paragraph 2, letter h) and paragraph 3 of the GDPR) only for treatments "necessary" for pursuing specific healthcare purposes, carried out by (or under the responsibility of) a healthcare professional subject to professional secrecy. Such treatments are those "essential" for achieving one or more specific purposes explicitly related to health care (see Recital 53 of the GDPR, provision of March 7, 2019, No. 55, web document No. 9091942).

However, in this specific case, the transmission to the aforementioned company of information regarding the health status of the interested party, although allegedly aimed at facilitating the

acquisition of the device, could not be considered indispensable for care, given that the patient was already in a position to act independently to procure it. Finally, the defensive memoranda submitted by the doctor, asserting their role as data controller, were of no avail, as it was not established that the communication of health data to the supplier of the device had been made following specific instructions from the same company; on the contrary, it emerged that the decision in this regard had been made independently by the doctor, who was an autonomous data controller.

In the same measure, it was also considered that, in compliance with the principle of data minimization, for the purpose of "titling" activities, the company would have needed to acquire elements related only to the pathology of the potential recipient of the device, but not the entire report, including identifying data. Therefore, the conduct of the doctor was sanctioned as it was deemed in violation of the basic principles of processing set forth in Article 5, paragraph 1, letters a), c), and f) of the GDPR and in the absence of the legal bases provided for in Article 9 of the GDPR, considering that the acquisition of the consent of the interested party for the processing of their personal data for the aforementioned operation was not demonstrated (provision of September 28, 2023, No. 425, web document No. 9946712).

The Authority also addressed the online publication of documentation related to a training course for psychiatrists containing personal data of the complainant and information about the health and judicial investigations concerning the deceased son (biography, psychiatric assessments, medical history, medications taken, crimes for which he had been investigated). The aforementioned documents were part of the teaching material made available to participants via a link sent by email at the end of the course and were also accessible online by anyone who knew the URL. In the sanctioning measure, the Authority, in addition to reiterating that the data of deceased persons continue to be subject to the protections of data protection legislation, found that the company had carried out processing of personal data, concerning health and judicial matters, in violation of the basic principles of processing set forth in Articles 5, 6, 9, and 10, as well as the security obligations under Article 32 of the GDPR, and Articles 2-septies and 2-octies of the Code. In fact, in addition to verifying the adequacy of the anonymization measures adopted on the personal data of the complainant and the deceased son, the company should have implemented appropriate technical, organizational, and verification measures to permanently ensure the confidentiality of the processed data, using a computer authentication procedure to allow access to the documentation only to the doctors who had attended the course.

In determining the amount of the imposed sanction, the level of severity of the violation was considered high, taking into account the duration and categories of personal data involved (along with the company's revenue and other elements) (provision of November 16, 2023, No. 527, web document No. 9960948).

5.6. Exercise of Rights

Throughout the year, the Authority also dealt with complaints filed against public and private healthcare facilities for failing to respond to requests made by interested parties in exercising the rights guaranteed by the Regulation. In such cases, the Authority has always taken care to highlight that, if the data controller believes they do not want/cannot comply with the request of the interested party, they must still inform the latter, without delay, about the reasons for such non-compliance and the possibility of filing a complaint with the Authority or, alternatively, a judicial appeal (Article 12, paragraph 4, of the GDPR). Predominantly, the complaints concerned the failure to respond to requests for the exercise of the right of access to personal data under Article 15 of the GDPR. In numerous cases, the Authority, dealing with what was, in fact, a failure to respond...

****Response to requests aimed at accessing health documentation pursuant to Law No. 241/1990 or other sector-specific regulations (Law No. 24/2017, etc.)** has archived the complaint, highlighting, as previously noted, that the right of access guaranteed by EU and national legislation regarding data protection must be distinguished from the right of access to public documents established by national legislation. The assessments regarding the determinations made on the specific request for access to documentation fall outside the scope of the tasks assigned by law to the Guarantor (Articles 57 of the GDPR, as well as 154 of the Code), remaining subject to review by the competent authorities (see

Article 25 of Law No. 241/1990). In some cases, it has also been emphasized that the rationale for the right of access established by Article 15 of the GDPR is to make the data subject aware of the data processing concerning them carried out by the data controller, as well as to facilitate the verification of the lawfulness of the same, specifying that the institution of access to personal data cannot be used as a substitute for different tools and institutions recognized by other applicable sector-specific regulations. In this sense, the Authority referred to what was indicated by the EDPB – in explanation of what is provided for by Article 15, paragraph 3, of the GDPR, which states that “the data controller provides a copy of the personal data being processed” – in the document “Guidelines 01/2022 on data subject rights - Right of access,” particularly regarding paragraph 5.2.5, point 152, of the latter; essentially, the EDPB recalled that the obligation established by the GDPR is configured as an obligation to provide an unaltered copy of the personal data contained in individual documents, not to provide a copy of the documents containing the data, and that for this purpose, all personal data being processed must be provided, even in a compilatory form, as long as this allows the data subject to gain full knowledge of the processing in question. The Authority also recalled the case established by the jurisprudence of the CJEU, whereby the controller provides “a complete copy of the documents contained in their medical file that contain, among other things, said data, only if the provision of such a copy is necessary to allow the data subject to verify its accuracy and completeness as well as to ensure its intelligibility” (see CJEU ruling of October 26, 2023 – C-307/22).**

****THE ACTIVITY CARRIED OUT BY THE GUARANTOR****

In some cases, the Guarantor has adopted specific measures, including sanctions, following the complaints received. In one case, it sanctioned a health company for failing to respond to a request for access to data made by the data subject, pursuant to Article 15 of the GDPR, also in order to verify the correctness of the data processing related to the vaccination campaign. Specifically, since the health facility did not provide a response to the data subject within the time limits set by Article 12 of the GDPR, nor represented suitable reasons to justify such non-compliance, except following the request made by the Authority pursuant to Article 15 of the Guarantor Regulation No. 1/2019, a monetary sanction was imposed for the violation of Article 12, paragraph 3, in relation to Article 15 of the GDPR (provision of January 11, 2023, No. 6, web document No. 9853446).

In another case, the Guarantor adopted a sanctioning measure against a sole proprietor, who was the owner of a medical center organized in the form of an outpatient clinic, whose business had been removed from the business register after the date of submission of the request to exercise the rights made by the data subject. The latter, acting as a complainant, represented to the Guarantor, among other things, that they had exercised the rights provided for in Articles 15 to 22 of the GDPR against this owner, requesting access to their personal data, rectification, and deletion (Articles 15, 16, and 17 of the GDPR) of some inaccurate data – specifically, the report of a sample taken at the aforementioned health facility contained incorrect identifying data (date of birth and code). fiscal) – as well as the limitation of the same (Article 18 of the GDPR), without, however, receiving a response. The response was provided only following the invitation issued by the Authority to the data controller to comply with the requests of the data subject pursuant to Article 15 of the Authority's regulation no. 1/2019, which was deemed inadequate by the data subject. Therefore, the Authority imposed a monetary fine on the data controller for the violation of Article 12, in relation to the rights exercised under Articles 15, 16, 17, and 18 of the GDPR. In this circumstance, the Authority deemed that the conditions for adopting other corrective measures under Article 58, paragraph 2, of the GDPR were not met, as the sole proprietorship, to which the aforementioned violations were attributable, had been removed from the business register at the time of the adoption of the measure, as well as due to the fact that the state of emergency declared by the Council of Ministers on January 31, 2020 – in relation to which the request of the complainant for correction of the COVID-19 swab report was relevant – had ceased on March 31, 2022, based on Ministerial Decree no. 24/2022 (provision of August 31, 2023, no. 389, web document no. 9938463).

With regard to a complaint for the lack of response to a request for access to data, the Authority, after ascertaining the violation of Article 12 of the GDPR in relation to Article 15 of the same GDPR,

considered, based on the assessment of the circumstances of the case, that it was a "minor violation" under Recital 148 of the GDPR, and adopted a warning measure against a hospital institution, the data controller (provision of April 13, 2023, no. 179, web document no. 9909566).

6

Scientific Research

6.1. Measures Adopted Pursuant to Article 110 of the Code

In the field of scientific research, numerous measures are mentioned whereby the Authority, consulted in a preventive manner pursuant to Article 110 of the Code, expressed its opinion on the processing of personal data for medical, biomedical, and epidemiological research purposes in cases where it was impossible to obtain consent from enrolled patients, as they were deceased or not contactable, also pursuant to point 5.3. of the prescriptions related to the processing of personal data carried out for scientific research purposes (Annex no. 5 to the provision that identifies the prescriptions contained in the general authorizations that are compatible with the GDPR and the Code, June 5, 2019, web document no. 9124510).

As detailed below, the Authority particularly focused on the correct framing of the conditions for the lawfulness of processing, on the obligations related to transparency, on the data retention periods, and on the measures implemented for the pseudonymization and anonymization of data.

In most of the measures adopted, the Authority reiterated that the promoter of the study and the participating centers may begin the processing of personal data necessary for the realization of the study only after obtaining the favorable opinions of the respective ethics committees, as a condition for the lawfulness of the processing of personal data for the purposes in question where it is not possible to obtain the consent of the data subjects (cf. provisions of October 29, 2020, no. 202, web document no. 9517401 and November 1, 2021, no. 406, web document no. 9731827).

With specific reference to transparency obligations, the Authority reiterated the necessity to make public, for the entire duration of the study, the information to be provided to the data subjects, as they are deceased and not contactable, through a specific notice on the websites of the promoter and the involved testing centers, according to what is provided for by Articles 14, paragraph 5, letter b), of the GDPR and 6, paragraph 3, of the ethical rules for processing for statistical or scientific research purposes, Annex A5 to the Code.

A first measure concerned a university hospital that had submitted a request for preventive consultation for the realization of a multicenter, retrospective, observational, epidemiological, and non-pharmacological study aimed at "evaluating the impact of the COVID pandemic and related institutional measures of social distancing on emergency access for pediatric neuropsychiatric pathology (NPI) and placing this impact in the context of the trend preceding the pandemic itself," due to the fact that, because of the high number of patients to be enrolled in the study (between 6,000 and 10,000) and the non-profit nature of the study, obtaining consent would have entailed a disproportionate effort, such as to severely compromise the achievement of the research objectives.

In this regard, the Authority expressed a conditional favorable opinion, considering that the company had correctly identified the legal bases for processing and documented the disproportionate effort that the attempt to contact each individual patient would have entailed, taking into account the large number of participants and the non-profit nature of the study (point 5.3 of the prescriptions). However, it did not consider it valid to justify the impossibility of obtaining consent by referring to the "selection bias due to the fact that expressing consent..."

would be more easily the sensitive subjects to the research and/or the clinical issues in question, belonging to a socio-economic status that is on average higher and who have the possibility to invest about an hour of their time and come to the hospital to sign informed consents," as such motivation disregards the specificities of the case examined and is not included among those indicated in point 5.3 of the aforementioned prescriptions. The Authority also positively noted the correct application of Article 89 of the GDPR by the company, providing robust data minimization techniques throughout the processing phase and the possibility of pursuing the research purpose through the collection and

analysis of aggregated data, given that this type of information was found sufficient for the pursuit of research purposes, in compliance with the principles of accountability and privacy by design (Articles 5, paragraph 2, 24, and 25 of the GDPR).

The Authority imposed further specific conditions regarding the anonymization of data at the end of the retention period and in cases of data sharing with third parties. In particular, regarding generalization techniques, it requested the company to redefine the equivalence classes to ensure a minimum number for each of them, considering a threshold of at least 20 units to be appropriate. Furthermore, considering the number of variables subject to aggregation, it requested to ensure that the number of aggregated statistics to be made known to prevent the risk of reconstructing data attributable to individuals is significantly lower than the number of variables considered. Finally, the Authority requested the removal of any singularity, should the data controller become aware of it, by any means, at a later stage after the application of the aforementioned anonymization techniques, and the tracking of such events in order to repeat the risk assessment of re-identification upon reaching 1% of identified singularities out of the total information included in the database (provision of March 2, 2023, no. 73, web document no. 9875254).

The second opinion, also favorable but conditional, concerned the request for prior consultation submitted by another university hospital company promoting an observational, multicentric, retrospective, non-profit study aimed at providing a more accurate characterization of patients with rare histotypes of biliary tract neoplasms in order to ensure the best therapeutic approach (provision of June 22, 2023, no. 261, web document no. 9919244). The Authority considered that the company had correctly identified the legal basis for processing, having exhaustively represented the reasons underlying the impossibility of informing the data subjects and obtaining valid consent, particularly related to the high mortality incidence of the observed pathology and the circumstance that the retrospective analysis of the data would involve the collection of information starting from the year 2002 (point 5.3 of the prescriptions). Furthermore, the company demonstrated reasonable and proportionate efforts made to attempt to contact patients, including through the signing of an agreement with the relevant municipality for the telematic consultation of the national population registry database, which was deemed compliant with the applicable regulatory framework (Articles 34, paragraph 1, Presidential Decree no. 223/1989 and 58 of the CAD).

However, the Authority noted that the information form transmitted was not specifically related to the processing of personal data carried out within the study, deeming it necessary to condition the opinion on the modification of the information so that the company provided clearly, intelligibly, accurately, and explicitly (Article 12 of the GDPR) all the elements referred to in Articles 13 and 14 of the GDPR, particularly the relevant legal bases, the purposes of processing, and the retention periods or the criteria used to determine them.

The Authority then positively noted the reduction of the data retention period from the original twenty-five years to five years, which was deemed adequate for the purpose of the collection. Regarding the dissemination of data in anonymous and aggregated form, considering the company's generic reference to "generalization" as a technique for data anonymization, the Authority conditioned the favorable opinion on the assurance provided by the data controller that the result of the "generalization" was composed of groups (clusters) made up of a sufficient number of distinct data subjects to avoid singularities or immediate inferences.

The Authority also highlighted that the implementation of the measures referred to in Article 89 of the GDPR, aimed, in particular, at the effective application of the principle of minimization, does not exempt the data controller from also introducing appropriate technical and organizational measures pursuant to Article 32 of the GDPR, for an effective application of the principle of data integrity and confidentiality, which in this case were deemed appropriate (Article 5, paragraph 1, letter f), of the GDPR).

In another case, a French pharmaceutical company submitted a request for prior consultation as the promoter and data controller of a retrospective observational study aimed at evaluating the incidence

rates of thrombotic events in patients with cold agglutinin disease. The Authority expressed a favorable conditional opinion, noting in particular...

that the transfer of pseudonymized data of Italian patients to affiliated companies based outside the territory of the European Union, i.e., to third countries, is based in abstract on suitable legal grounds (Articles 24, 28, 44 et seq. of the Code). In this regard, considering that the aforementioned transfer would take place based on the binding corporate rules (BCR) of the company, the Authority highlighted that in any case, their effectiveness and correctness must be verified in concrete terms by the data controller, in application of the principle of accountability (Article 5, paragraph 2, of the GDPR).

In the provision under examination, the Authority provided specific indications to the company regarding the proposed hypothesis of conducting future research with the data collected for the purpose of the study, based on the consent of the data subjects obtained during the data retention period. In this regard, it was clarified that the provision concerned exclusively the study for which the company had submitted the request for prior consultation, and it was reiterated that, where the data controller found itself in one of the conditions of impossibility to obtain consent as referred to in Article 110 of the Code and in point 5.3 of the prescriptions, it would have to submit a specific request for prior consultation pursuant to the aforementioned Article 110 of the Code. The Authority also imposed precise conditions aimed at ensuring the effective application of the principle of transparency and thus, ultimately, the protection of the informational self-determination of patients. In particular, it deemed necessary that the information form be modified with the correct indication of the legal bases for processing related to contactable patients, referring to Article 9, paragraph 2, letter a), of the GDPR, and to those who are not contactable, integrating the reference to Article 9, paragraph 2, letter j), of the GDPR with that of Article 110 of the Code, and that it was also clarified how, in addition to consent for data processing for the study, an additional expression of will would be required solely for the purpose of being able to contact patients for future research purposes.

In relation to non-contactable patients, also for the benefit of their successors (Article 2-quaterdecies of the Code), the Authority considered that the mere posting of the information at each participating center was not suitable to ensure the effective application of the principle of transparency, nor consistent with the indications provided by Article 6, paragraph 3, of the ethical rules, as such a method requires that the data subjects go to the participating center, thus becoming effectively contactable (see also provision of December 7, 2023, no. 582 web doc no. 9971457).

88

THE ACTIVITY CARRIED OUT BY THE AUTHORITY

The Authority also noted, in the impact assessment, the lack of specific measures for monitoring activities that may be carried out remotely, conditioning the opinion on the company integrating the impact assessment with a specific section indicating such treatments and the related risks to the rights and freedoms of the data subjects and the necessary measures to mitigate them (provision of July 6, 2023, no. 285, web doc no. 9919999).

Another case, similar in many respects to the previous one, concerned the request submitted by a university hospital company for the conduct of a multicentric, retrospective, and prospective observational study to evaluate the safety and efficacy of a drug in oncological patients, involving all Italian oncology units (26 centers), with an estimated sample size of 50 patients. The Authority expressed a conditional favorable opinion, reiterating in particular what was already indicated in the previous opinion of March 2, 2023, no. 73 (web doc no. 9875254) regarding the anonymization of data and imposing specific conditions to ensure the effective application of the principle of transparency (provision of July 18, 2023, no. 315, web doc no. 9920977).

An American pharmaceutical company, with its own representative in the territory of the European Union in accordance with Article 27 of the GDPR, had submitted a request for prior consultation regarding a project (to be carried out in some countries of the European Union, including Italy) for Real World Data Collection (RWDC).

****Translation of Legal Document Text:****

concerning deceased or uncontactable patients to whom an antitumor drug had been administered. In this regard, the Authority reiterated what had already been highlighted in the aforementioned opinions regarding the transfers of data of patients in pseudonymized form to the data controller established in the United States of America, the transparency of treatments, the possibility that the monitoring activity of the sponsor would be carried out remotely, as well as the measures to prevent the risk of re-identification of the data subjects (provision of August 31, 2023, no. 364, web document no. 9936136).

Another conditional favorable opinion, which deserves to be noted, was adopted by the Authority concerning a university following the submission of a request for prior consultation for the retrospective collection of data necessary for a clinical study included in the European Horizon 2020 program and involving the enrollment of approximately 50 pediatric patients from the hospital company belonging to the applicant affected by two specific tumor pathologies. This study would have involved the creation of an open and cloud-based platform (functional for the clinical management of the aforementioned pathologies) in which the data of the patients would be saved in pseudonymized form and made accessible only to the members of the consortium based on the European research project (provision of September 28, 2023, no. 465, web document no. 9948285).

With specific reference to the legal bases of the processing, the Authority deemed relevant the impossibility of obtaining the consent of the patients, related to organizational impediments, due to the length of the observation period, the significant number of deaths due to the severity of the disease, and the serious prejudice to the completeness of the sample potentially resulting from the exclusion of data from deceased or uncontactable patients. However, the Authority noted that the university had not adequately demonstrated the reasonable efforts made or that it intended to make, which would attest to the actual irretrievability of the data subjects, and therefore requested to integrate the impact assessment accordingly.

The Authority instead considered that the legal basis for the processing of personal data collected in the study database by the members of the consortium should be identified in Regulation (EU) 1291/2013 of the Parliament and Council of December 11, 2013, which established the framework program for research and innovation named Horizon 2020 (2014-2020) as a provision of European Union law, in accordance with Article 9, paragraph 2, letter j), of the GDPR. Regarding the principle of transparency, while reiterating the measures already indicated in previous opinions, the Authority also deemed it necessary to mention in the information provided to the data subjects the retention period of the data collected by the university for the realization of the study or the criterion used to determine such period (Article 13, paragraph 2, letter a), of the GDPR).

Another conditional favorable opinion concerned a case similar to those mentioned above, regarding a request for prior consultation submitted by a French pharmaceutical company for the conduct of a multicenter, observational, retrospective, and prospective clinical study aimed at allowing the analysis of the aggregation of clinical, biological, genomic, and multimodal imaging data associated with the response to treatment and prognosis of patients with lung cancer. From the request, it emerged that the study would also aim to pursue multiple secondary purposes such as the development of a proprietary prognostic algorithm, to be used also for the treatment of other types of cancer, as well as the development of a commercial product and/or service offering and the creation of a pseudonymized database for statistical and clinical research purposes.

The opinion issued by the Authority concerned exclusively the processing of data necessary for pursuing the primary objectives of the study related to deceased patients, as for living patients the processing would be based on their respective consent; conversely, regarding the secondary purposes of the study, the Authority noted the persistence of critical issues particularly concerning the identification of the purposes of the processing (which were found to be unclear, overlapping with primary purposes or unrelated to scientific research objectives), the legal bases, and the data retention times, reserving the right to continue the investigative activity. Therefore, regarding the processing of data necessary for pursuing the primary objectives of the study, the Authority deemed that the company had correctly indicated the relevant legal bases, although it was noted that the indication in

the impact assessment and in the information of other legal bases for the processing of personal data, such as relevant public interest, was irrelevant and imprecise, as the company had not specified the provision of Union law or internal regulation on which such processing would be based (Articles 6, paragraph 1, letter e), paragraph 2 and 3; 9, paragraph 2, letter g); 89 of the GDPR and 2-sexies, paragraph 2, letter cc), of the Code).

Regarding artificial intelligence and machine learning techniques, the Authority highlighted how the collection and statistical analysis of information were essential for the subsequent creation of any predictive model. The predictions formulated by the algorithm, in this case, to develop a diagnostic tool for patients affected by the aforementioned oncological pathology, are indeed based on the prior examination, through mathematical and statistical models, of a large amount of information already held by the company.

****The Activity Carried Out by the Authority****

The activity was carried out with a much faster timing compared to what could be guaranteed by a human analyst, even if experienced. However, based on previous jurisprudential and doctrinal precedents, the Authority highlighted the necessity to integrate such automated processes with human intervention in order to review and possibly correct the probabilistic calculations formulated through algorithms (see Cons. di Stato, ruling no. 8472/2019; joint opinion of the EDPB and the GEPD, 5/2021 cited; document "Artificial Intelligence and Medicine: Ethical Aspects" dated May 29, 2020, from the National Bioethics Committee and the National Committee for Biosafety, Biotechnology, and Life Sciences).

The Authority also noted specific critical issues regarding the proposed hypothesis of creating a separate database for research and statistical purposes in order to promote the development of new diagnostic and therapeutic solutions. In particular, emphasizing the indeterminacy of such a purpose, it was highlighted that the processing of personal data for the pursuit of the aforementioned secondary purposes cannot be based solely on the legitimate interest of the data controller, since the referenced treatments concern data related to special categories pursuant to Article 9, paragraph 1, of the GDPR and therefore require the data controller to verify the existence of one of the specific exemptions from the prohibition on processing such data, as outlined in Article 9, paragraph 2, of the GDPR, including validly and correctly obtained consent. The Authority then noted some deficiencies in the information provided pursuant to Articles 13 and 14 of the GDPR and requested the data controller to address them before the commencement of processing (provision of October 12, 2023, no. 472, web document no. 9953841).

In another case, a pharmaceutical company based in Switzerland submitted a request for prior consultation for the realization of a multinational, observational, retrospective study based on the collection of data on Cytomegalovirus (CMV) infection in the context of solid organ transplants. The Authority expressed a conditional favorable opinion, deeming it necessary for the data controller to make at least three unsuccessful contact attempts, recorded in the patients' clinical files, before considering a patient lost to follow-up, and requesting the removal from the impact assessment and the information of references to irrelevant legal bases, such as the legitimate interest of the data controller (Article 6, paragraph 1, letter f), of the GDPR).

The Authority did not find the reasons provided by the company for retaining coded data for a period of 30 years from the conclusion of the study to be compliant with the principle of data retention limitation, as they were related to the need to align the aforementioned retention period with the national regulations of the countries in which the company operates, since further retention of data for scientific research purposes may be permitted, in accordance with Article 89, paragraph 1, of the GDPR, provided that appropriate technical and organizational measures are implemented to protect the rights and freedoms of the data subject. The Authority therefore conditioned its opinion on the retention of data for a period similar to that provided for the participating centers, and thus, for 7 years from the conclusion of the study. The Authority also reiterated the indications regarding the necessary measures for the anonymization of data already indicated in previous opinions, placing a specific condition regarding the dissemination or sharing of data with the scientific community (provision of

October 26, 2023, no. 498, web document no. 9960973).

Another conditional favorable opinion was issued by the Authority concerning a university hospital company for the realization of two retrospective studies (opinion of October 26, 2023, no. 499, web document no. 9963509).

In particular, the university hospital company submitted two separate requests for prior consultation as the promoter and data controller, due to the impossibility in both studies of obtaining the consent of the large number of data subjects involved, for justified and proven organizational, temporal, and economic reasons. The Authority ordered the consolidation of the proceedings, resulting in the adoption of a single opinion, given that the company acted as the promoter in both studies and that the main processing operations would be carried out in a similar context, through the same information system and applying the same technical and organizational measures (Article 10, paragraph 4 of the Authority Regulation no. 1/2019).

The conditions imposed on the favorable opinion again concerned the transparency of the processing, specifically the need to publish the information for the entire duration of the study pursuant to Articles 14, paragraph 5, letter b), of the GDPR and 6, paragraph 3, of the ethical rules, as well as in one case the necessity to specify, within the information and the impact assessment, the roles (of data controller, joint controller, or data processor) respectively attributed to the participating centers.

****In accordance with Articles 24, 26, and 28 of the GDPR, and to integrate the impact assessment by identifying, in relation to the considered risk scenario, adequate measures based on the probability and severity of the same (see also provision of December 21, 2023, no. 607, web document no. 9979453).**

In another case, the Authority expressed a conditional favorable opinion regarding a non-profit consortium (composed of the main pediatric hospitals in Italy and pediatric departments as well as national and international pediatric therapeutic networks) for the implementation of the retrospective phase of a study concerning hospital surveillance on lower respiratory tract infections in emergency departments and in the therapy departments of twelve main pediatric hospitals and/or pediatric departments in Italy (provision of November 16, 2023, no. 551, web document no. 9983501).

In particular, the Authority, believing that the data controller had correctly identified the legal bases for processing, the necessary measures to ensure effective application of the principle of transparency, and adequate technical-organizational measures to mitigate the risks associated with the processing, including the pseudonymization of data pursuant to Article 89 of the GDPR, noted only the lack of description of the measures for the anonymization and aggregation of the data of the data subjects and therefore conditioned the opinion, reiterating the indications already provided in previous opinions.

Another instance of preventive consultation was presented by a university hospital concerning the implementation of an amendment to a retrospective observational study, on which the Authority had expressed its opinion with provision no. 118 of April 7, 2022 (web document no. 9772545). This amendment, aimed at describing any changes in the epidemiological and clinical framework following the SARS-COV-2 pandemic, concerned the further extension of the observation period of emergency department visits for the population under 18 years of age, until April 2023, regardless of the reasons for hospitalization. The Authority, with provision no. 582 of December 7, 2023 (web document no. 9971457), expressed a conditional favorable opinion reiterating the necessity to publish the information in the amended version on the websites of the promoter and the health companies of the region, in accordance with Articles 14, paragraph 5, letter b), of the GDPR and 6, paragraph 3, of the ethical rules.

****6.2. Clarifications regarding Article 110-bis, paragraph 4, of the Code****

The Authority, in response to a request for preventive consultation submitted by a scientific hospital and care institute (IRCCS) for the implementation of a study concerning the processing of personal data of deceased patients or patients lost to follow-up within the research lines of the institute itself, provided specific clarifications regarding Article 110-bis, paragraph 4, of the Code, according to which

"the processing of personal data collected for clinical activity, for research purposes, by public and private scientific hospital and care institutes does not constitute further processing by third parties, due to the instrumental nature of the healthcare activity carried out by the aforementioned institutes with respect to research, in compliance with what is provided for by Article 89 of the Regulation" (note of July 18, 2023).

Preliminarily, it was clarified that the provision does not concern biomedical and epidemiological medical research, as the latter finds its special regulation in Article 110 of the Code, which, moreover, in cases where it is impossible to obtain consent, also takes into account the ethical implications related to such types of processing not covered by the article in question.

****THE ACTIVITY CARRIED OUT BY THE AUTHORITY****

Given this premise, it was clarified that under Article 110-bis, paragraph 4, of the Code, IRCCS can legitimately process health data collected for care purposes for further scientific research purposes, without having to obtain specific consent from the data subjects or, when this is not possible, without having to resort to the preventive consultation of the Authority referred to in the last part of Article 110, paragraph 1, of the Code. More specifically, the sector regulation of IRCCS binds their activity to strict control by the Ministry of Health and compliance with specific ethical and methodological standards (Article 8, Legislative Decree no. 288/2003), and this, together with Article 110-bis, paragraph 4, of the Code, provides IRCCS with a specific legal basis that, pursuant to Article 9, paragraph 2, letter j), of the GDPR, allows them to process data collected for care purposes also for further scientific research purposes in the medical, biomedical, and epidemiological fields.

Therefore, Article 110-bis, paragraph 4, constitutes one of those "legal provisions" referred to in Article 110 of the Code (first paragraph, second part), identifying as an additional requirement for the processing of data for research purposes in the medical, biomedical, and epidemiological fields, pursuant to Article 9, paragraph 2, letter j), of the GDPR, the conduct and publication of the impact assessment referred to in Article 35 of the GDPR. In this regard, it was also specified that Article 110-bis, paragraph 4, of the Code can concern both monocentric and multicentric studies, in the latter case limited to what is provided.

from the specific sector regulations, particularly with reference to the research networks of the IRCCS (art. 8, Legislative Decree No. 288/2003, cited).

From another perspective, given that consent to the processing of data constitutes a manifestation of will distinct from informed consent for research, the Authority has reiterated the obligation to ensure compliance with the standards and ethical regulations of the sector in the context of such research. It has finally been emphasized that, regardless of the legal basis for processing, the data controller is required to respect the applicable principles of processing and to fulfill the related obligations, in particular, to provide information to the data subjects, pursuant to Articles 13 and 14 of the GDPR (Articles 5, 24, 25, and 32 of the GDPR).

6.3. Other measures regarding processing for scientific research purposes

In the reference year, the Authority adopted a corrective and sanctioning measure against a company owning a biobank, following a complaint alleging the illegitimacy of the company's inaction regarding the collection of consent from the data subjects and the obligation to provide information, thus bringing an end to a complex and long-standing matter (Provision of April 27, 2023, No. 170, web document No. 9898815).

The Authority found that the company was storing personal data contained in the biobank in violation of the principles of transparency and accountability, as per Article 5, paragraph 1, letter a) and paragraph 2 of the GDPR, and the obligation to provide information to the data subjects, as per Article 14 of the GDPR.

The Authority first clarified that the company had legitimately come into possession of the data and biological samples contained in the biobank, following the bankruptcy of the transferring company, and therefore was not required to request the consent of the data subjects as it was the legitimate

transferee. However, such consent was necessary for carrying out further processing operations required for pursuing research purposes. In this regard, having claimed that it could not define, with the level of detail required by the sector regulations, the scientific research purpose for which to request the specific consent of the data subjects (Article 7 of the GDPR), the Authority noted that "scientific research" refers to a research project established in accordance with the relevant methodological and ethical norms of the sector, as well as with good practices (see Guidelines 5/2020 on consent under the GDPR adopted by the EDPS, and Opinion on scientific research of the EDPB of January 6, 2020).

Based on the documentation on file, it emerged that the company had acquired the biobank for the specific purpose of continuing the specific medical research project for which the biobank had originally been established, and therefore was sufficiently aware of the research purposes that it should at least continue. Even though the company had not actually carried out further processing operations for scientific research purposes, due to ongoing judicial seizures at the time, the Authority nonetheless established that it had not provided any information to the data subjects, either pursuant to Article 13, paragraph 4, of the Code, in force at the time of the events, or subsequently after the entry into force of the GDPR, pursuant to Articles 13 or 14 of the latter.

Regarding the alleged impossibility of verifying the specific content of the database and the other assets acquired, and consequently defining the purpose and the processing operations to be carried out, the Authority noted that the information notice is a document whose content the data controller can modify and update over time, depending on the needs related to the specific case.

In particular, considering that the company had not collected data from the data subjects, but from a third party, this obligation should have been fulfilled in the manner provided for in Article 13, paragraph 4 of the Code in force at the time, and subsequently after the entry into force of the GDPR, in the manner provided for in Article 14, paragraph 5, letter b), of the GDPR, also through suitable forms of publicity.

The Authority also deemed that the absolute inaction demonstrated by the company, even in the objectively complex and peculiar context in which the entire intricate matter took place, highlighted a conduct diametrically opposed to that inspired by the principle of accountability introduced by the GDPR and therefore also constituted a violation of Article 5, paragraph 2, of the GDPR.

It is worth highlighting here the corrective and sanctioning measure adopted against a private scientific hospital and care institution (IRCCS), following specific inspection findings (Provision of September 14, 2023, No. 400, web document No. 9941205). The Authority noted the illegality of the processing of personal data carried out by the IRCCS in question, as it was conducted in violation of the principles of lawfulness, minimization, privacy by design and by default, integrity and confidentiality, and accountability (Articles 5, paragraph 1, letters c) and f) and paragraph 2; 24, 25, and 32 of the GDPR and Article 110 of the Code).

The Authority established that the processing of personal data, particularly those necessary for research funded by the Ministry...

of health, pursuant to Article 12-bis of Legislative Decree No. 502/1992 and specifically those related to selection, collection, archiving, and pseudonymization of data, were generally carried out in violation of the principle of accountability and, as they were almost entirely entrusted to manual operations performed by staff, in violation of the principle of privacy by design and by default as per Article 25 of the GDPR. In fact, the ineffectiveness of the measures described regarding the obligation of data protection by default has been established, where providing specific instructions to its staff and authorized personnel constitutes a specific and autonomous compliance with the relevant regulations (Articles 29 of the GDPR and 2-quaterdecies of the Code) that cannot, however, replace or compensate for the obligation of the data controller to adopt measures that, by default and without necessarily human intervention, promote the effective application of the principles regarding data protection that are relevant from time to time and the reduction of risks for the rights and freedoms of data subjects, related to processing, pursuant to Article 25 of the GDPR.

The Authority has also established the violation of Article 110, paragraph 1, of the Code, as the

institution had not conducted and published the impact assessment prescribed therein for each research funded pursuant to Article 12-bis of the aforementioned Legislative Decree No. 502/1992. In light of the established violations, the Authority has ordered the data controller to bring the processing into compliance with the provisions of the GDPR by adopting specific corrective measures.

Finally, the Authority has expressed a favorable opinion on the draft decree containing provisions regarding the methods of telematic transmission of the informational content related to the declaration of consent for the use of one's body and post-mortem tissues for study, training, and scientific research purposes, in implementation of Article 3 of Law No. 10/2020 (provision of November 30, 2023, No. 555, web document No. 9966628). The draft decree and the related technical regulations, submitted to the Authority by the Ministry of Health, took into account the observations made by the Office during numerous discussions with the Ministry. In particular, the establishment of a specific section within the database of Advance Treatment Directives (DAT), maintained by the Ministry of Health as the data controller, is provided, where the Local Health Authorities (ASL) must promptly and electronically enter the consent declarations of the donors.

In addition to the information related to the donor, the consent declarations must also contain a series of elements such as the details of the proxy and the substitute appointed by the donor, the acceptance of the appointment by the proxy and the substitute, the declaration of consent by both parents in the case of minor donors, as well as any revocations. The declarations must be drawn up by public deed or authenticated private writing, or delivered in person by the donor to the civil status office of the municipality of residence or to health facilities, or communicated through video recording or devices that allow the donor with disabilities to interact. In all cases, the declarations must still be transmitted to the relevant ASL, which is responsible for keeping them and transmitting them electronically to the DAT database. Finally, the data may be disseminated by the Ministry of Health only in anonymized and aggregated form and must be deleted ten years after the donor's death, or upon reaching the age of 18 in the case of minor donors. The draft decree provides for the adoption of technical and organizational measures to ensure the integrity and confidentiality of the personal data collected in the database, in accordance with the protection objectives described in the technical regulations referred to in Annex 1 of the draft, as well as security procedures related to software and telematic services, in accordance with the guidelines containing the technical rules adopted pursuant to Article 71 of the CAD. Finally, it regulates the exercise of the rights provided for in Articles 15 to 18 and Article 21 of the GDPR, according to the methods indicated in the information provided by the health authority that collects the declaration, pursuant to Article 13 of the GDPR.

7

Statistics

7.1. Official Statistics

Within the framework of the processing carried out for the purposes of official statistics, it is worth highlighting the warning and corrective measure issued against the National Institute of Statistics (ISTAT), following the inspection assessments conducted by the Authority to verify compliance with the provisions regarding the protection of personal data, specifically concerning the implementation methods of the measures referred to in the provision of January 23, 2020, no. 10 (doc. web no. 9261093).

With this provision, the Authority completed the authorization process for the processing of personal data necessary for the realization of the permanent census, prescribing to ISTAT, among other things, to adopt pseudonymization techniques suitable to ensure the effective implementation of the principles of personal data protection, and in particular the principles of minimization, purpose limitation, and storage limitation, in accordance with the obligations of privacy by design and by default (Articles 5, paragraph 2, letters b), c), and e) and 25 of the GDPR).

In the aforementioned provision of 2020, the Authority had, among other things, noted specific criticalities regarding the assignment of a unique code that identifies the individual in the various databases of ISTAT; it had therefore prescribed to ISTAT to introduce a hierarchical decoupling mechanism for pseudonym codes in the various databases and to rotate them over time.

In the referenced warning provision, the Authority particularly established that, following the

classification of data from administrative archives, ISTAT had not provided specific differentiated measures concerning the risks related to the different classes of data processed, in violation of the accountability principle and the obligations of privacy by design and by default, as per Articles 5, paragraph 2, and 25 of the GDPR.

The Authority also noted that ISTAT, despite the volume of data it manages for the pursuit of its institutional purposes, had not yet provided technical interventions aimed at automatically detecting the presence of singularities and mitigating the risks of re-identification arising from these, aside from organizational measures in the management of specific integration domains.

The absence of specific technical measures aimed at ensuring the effective application of the minimization principle also resulted in the violation of Articles 5, paragraph 2, 24, and 25 of the GDPR. The pseudonymization system implemented by the Institute for each statistical unit that flows into the Integrated Microdata System is limited to calculating a hash code. In this regard, the Authority observed that while the hashing technique, on a formal level, is suitable to ensure the uniqueness of pseudonyms, the fact that the creation of the secret key used for generating pseudonyms is linked to an extremely volatile parameter (such as the current time to the millisecond) renders the "controlled reversibility" of the pseudonymization technique inapplicable on a concrete level.

Furthermore, the pseudonymization carried out by ISTAT did not yet foresee the use of diversified random secret keys for each statistical unit; consequently, in the event of a security incident, even involving a single statistical unit, knowing the data syntax, the compromise of the integration domain would have been total.

The Authority also noted that, since a single integration domain had been created, it was not possible to verify—three years after the adoption of the provision subject to compliance—the introduction of the prescribed hierarchical decoupling mechanism of the codes in the various databases and their rotation over time, also noting, in relation to this aspect, the violation of Articles 25 and 32 of the GDPR.

The Authority, therefore, pursuant to Article 57, paragraph 1, letter a), of the GDPR, declared the illegality of the processing of personal data carried out by ISTAT, warned the Institute for violating Articles 5, paragraph 2, 24, 25, and 32 of the GDPR, and ordered it to align its processing with the provisions of the GDPR, adopting specific corrective measures (provision of June 8, 2023, no. 337, doc. web no. 9921184).

By provision of November 16, 2023, no. 523 (doc. web no. 9966570), the Authority expressed a conditional favorable opinion on the draft National Statistical Program 2023-2025 (PSN) presented by ISTAT pursuant to Articles 58, paragraph 3, letter b) and paragraph 2, letter f), of the GDPR, Article 6-bis of Legislative Decree no. 322/1989, and Article 4-bis of the ethical rules for processing for statistical or scientific research purposes carried out within the National Statistical System, Annex A.4 to the Code.

The draft PSN 2023-2025 outlines the statistical work that will be conducted by ISTAT and other entities of the National Statistical System (SISTAN) during the new three-year programming period. In the opinion, the Authority noted that the information sheets for statistical work had been drafted using the new framework for representing information developed following a path of institutional collaboration with the Authority, aimed at making the aforementioned information sheets clearer and more consistent with the regulatory framework regarding the protection of personal data (art. 6-bis, paragraph 1-bis, Legislative Decree No. 322/1989).

Although the investigation conducted concerned the PSN as a regulatory act that impacts the processing of personal data, for which the involvement of the Authority in a consultative capacity is mandatory (art. 6-bis, Legislative Decree No. 322/1989), as is customary, it was also aimed at ensuring actual compliance within the scope of the aforementioned processing with the principles regarding the protection of personal data established by the GDPR (arts. 5 and 25).

The Authority made observations on specific statistical works starting from the one named IST-02854 Hate speech online, regarding which it deemed necessary that in the "objective" section of the information sheet, it should be reiterated that the classification of data carried out through machine learning tools will not be entirely automated, but will always be humanly supervised, thus conditioning the favorable opinion.

The Authority then recalled the constraints, in terms of data protection and transparency, that should be respected concerning the processing of personal data carried out through artificial intelligence tools, referring, also based on an important ruling of the Council of State (Cons. St., section VI, December 13, 2019, No. 8472): i) the principle of knowability, whereby everyone has the right to know the existence of automated decision-making processes concerning them and, in this case, to receive meaningful information about the logic used; ii) the principle of non-exclusivity of the algorithmic decision; and iii) the principle of non-algorithmic discrimination, according to which it is appropriate for the data controller to use appropriate mathematical or statistical procedures for profiling, implementing adequate technical and organizational measures to ensure, in particular, that factors causing inaccuracies in the data are rectified and the risk of errors is minimized, as well as to ensure the security of personal data, in a manner that takes into account the potential existing risks to the interests and rights of the data subject and that prevents, among other things, discriminatory effects against individuals, or the factors that lead to measures having such effects (see also the ten commandments for the realization of national health services through artificial intelligence systems published by the Authority on October 10, 2023, web doc No. 9938038).

The centrality of human supervision was therefore reiterated and how it should be carried out by highly qualified experts, in order to ensure compliance with the right not to be subjected to a decision based solely on automated processing. In this regard, it is also essential, as indicated in the aforementioned ten commandments of the Authority, that the quality of the data expressed in terms of completeness and representativeness of the subjects whose data are intended to be analyzed is ensured in the training and use of the algorithm.

Within the framework of the investigation conducted regarding the PSN scheme under examination, the Office then requested specific clarifications regarding the qualification of the statistical works carried out by the Higher Institute of Health (ISS) concerning pathology registers, specifically whether these are statistics from surveys (SDI) or statistics from administrative sources and new data sources (SDA). The difference is particularly relevant since survey statistics (SDI) presuppose direct contact with the data subject and, therefore, the possibility for the latter not to respond to questions regarding sensitive or judicial data (which, as is known, are exempt from the so-called obligation to respond pursuant to art. 7, paragraph 2, Legislative Decree No. 322/1989) as well as the right for the data subject to obtain information from the surveyor pursuant to art. 13 of the GDPR; on the other hand, in statistics from organized administrative sources (SDA), the SISTAN entity, holder of the statistical work - by virtue of the PSN, which serves as the legal basis of the...

processing - may collect personal data, including data concerning special categories, from other public or private subjects, fulfilling the informational obligations through the PSN itself, which serves as information for the interested parties (art. 6, paragraph 2, of the ethical rules). Based on these clarifications, considering that the pathology registers, indicated in the PSN and provided for by the D.P.C.M. of March 3, 2017, are fed based on the legal obligation, which falls under the specific sector regulations on healthcare structures (regions, ASL, reference clinical centers), to periodically transmit certain information to the holder of the register (on a regional or national basis), the Institute deemed it more appropriate to reclassify some of these works as statistics from organized administrative sources (SDA), correcting the related informational tables of the PSN accordingly.

Finally, regarding the work IST-00095 - Investigation on deaths and causes of death, in which it is specified that the dissemination of variables in disaggregated form is necessary solely for research purposes, given that this statistical work includes the processing of health-related data, the Guarantor, in its opinion, deemed it necessary for the Institute to reassess the need to disseminate the variables in disaggregated form, evaluating the possibility of making them available in such a format only to researchers, even those outside the SISTAN framework, in the forms and based on the channels provided by the current regulations (art. 5-ter, Legislative Decree No. 33/2013) and the guidelines for access for scientific purposes to the elementary data of SISTAN, adopted by the Committee for the Direction and Coordination of Statistical Information - COMSTAT, or to justify this need in clearer and more rigorous terms according to the principles of data minimization and accountability.

Lastly, it is noted that following the resolution promoting the new ethical rules for treatments for statistical or scientific research purposes carried out within the SISTAN on April 15, 2021 (doc. web n. 9582086), the Guarantor, in the reference year, completed the verification of the belonging to the category of subjects authorized to adopt the ethical rules, in reference to those who expressed their interest, pursuant to art. 23, paragraph 2, of the Guarantor's regulation No. 1/2019 (doc. web n. 9107633), and initiated working meetings aimed at analyzing the preliminary draft of the new ethical rules brought to its attention (art. 25 of the Guarantor's regulation No. 1/2019, cited).

98

ACTIVITY CARRIED OUT BY THE GUARANTOR

DATA PRODUCTION IN JUDICIAL PROCEEDINGS

8

Judicial and security-related treatments

8.1. Treatments in the judicial field

In the numerous complaints received even in 2023 regarding the legitimacy, from the perspective of data protection regulations, of the production of information in court, the Guarantor declared itself "incompetent" and ordered the archiving according to a now consolidated orientation. In fact, art. 160-bis of the Code establishes that the validity, effectiveness, and usability in judicial proceedings of acts, documents, and provisions based on the processing of personal data not compliant with legal or regulatory provisions remain governed by the relevant procedural provisions.

In this regard, the Authority has consistently reminded that, in order to safeguard the independence of the judiciary in fulfilling its judicial duties (see recital 20 of the GDPR), the Guarantor is not competent to control the treatments carried out by judicial authorities in the exercise of their judicial functions (see arts. 55, paragraph 3, of the GDPR and 154, paragraph 7, of the Code).

Below are summarized some of the cases where the aforementioned principles have been applied.

The first concerns a complaint against a professional hired to carry out renovation work on the property owned by the complainant, who allegedly produced in court deliberately misleading documentary evidence from an insurance consultant who had previously provided services in his favor and who was now a party against him in the proceedings. The Authority first noted that, in the event of the submission of personal data in court, it is up to the Judge to assess the lawfulness of the processing of the personal data of the interested party pursuant to the aforementioned article 160-bis of the Code. Furthermore, in archiving the complaint, the Guarantor specified that the legitimacy of the data processing in this context is ensured, for the special categories of data subject to documentation, by art. 9, paragraph 1, letter f), of the GDPR according to which processing is lawful if necessary for the establishment, exercise, or defense of a right in judicial proceedings and, all the more so, for all personal data, by art. 6, paragraph 1, letter f), of the same GDPR according to which processing is lawful if necessary for pursuing a legitimate interest of the data controller.

Additionally, with reference to a report/complaint regarding an alleged unauthorized access to a computer system and unlawful processing of data, also addressed to the Guarantor, the interested party complained about the unlawful...

****Acquisition and Production in a Civil Proceeding of Personal Data Contained in Procedural Documents Relating to a Different Proceeding, by the Counsel of the Opposing Party, a Subject Unrelated to the Proceeding to Which the Documents in Question Refer.****

Following the report of the facts, the interested party had transmitted to the Authority the decree of referral to trial from the competent Public Prosecutor's Office against the aforementioned lawyer for the offenses referred to in Articles 615-ter of the Penal Code and 167 of the Code.

In this regard, in archiving the proceeding, the Guarantor represented the necessity, in the case at hand, to maintain a distinction between the profile of the assessment of the lawfulness of the processing of the personal data of the interested party submitted in court, and that relating to the

acquisition of the procedural documents concerning the interested party and the subsequent processing of the data contained therein by the lawyer.

Specifically regarding this latter aspect, the Authority acknowledged the impossibility of interfering with the ongoing activity of the judicial authority and the obligation to respect the rights of the parties involved (such as, for example, the right not to make self-incriminating statements, pursuant to Article 64 of the Code of Criminal Procedure). Therefore, the Guarantor clarified that, in this case, it would not have been able to carry out the necessary verifications to make the determinations within its competence, as these were also conditioned by the outcome of the criminal proceeding, at least regarding the verification of the contested facts that are of the same nature.

In another complaint, it was reported that a lawyer, tasked with recovering a debt, had informed the employer of the interested party that a payment injunction would be notified in the following months. Following the investigative note sent by the Office to request any elements deemed useful for the handling of the matter, the holder specified that the communication with the employer of the complainant was preliminary to the execution of the garnishment of the debtor's salary and was due to the need to determine to which of the two addresses indicated on the company's website the notification of the act should be made.

The Guarantor, having evaluated all the circumstances of the case, archived the complaint noting that the processing of personal data had occurred within the context of a forced execution process (see Articles 543 et seq. of the Code of Civil Procedure) in order to achieve the effective satisfaction of a legally recognized right during the knowledge phase. Therefore, on one hand, the legitimacy of the processing of data to defend a right in court was reiterated (see Articles 6, paragraph 1, letter f) and 9, paragraph 1, letter f), of the GDPR), and on the other hand, the incompetence of the Guarantor to assess the potential unlawfulness of the processing of personal data produced in a proceeding pursuant to Article 160-bis of the Code.

Also concerning enforcement procedures, an interested party had filed a complaint with the Guarantor alleging unlawful processing of their personal data in relation to the judicial sale of an apartment they owned. In particular, the complainant stated that they had found their identifying data (name and surname) published on various online auction sites, including that of the court where the judicial proceeding in question was pending, complaining about the negligent behavior of the judicial custodian regarding the management of the forced execution procedures. In this regard, the Authority, acknowledging that the processing in question was carried out within a proceeding by the judicial authority and that the role of the judicial custodian falls among the auxiliaries of the judge with certain responsibilities (Articles 65-67 of the Code of Civil Procedure), proceeded to archive the complaint for incompetence (see Article 55, paragraph 3, of the GDPR and Articles 154, paragraph 7 and 160-bis of the Code).

On the subject in question, another part of the Report refers to a judgment of opposition against a decision of archiving by the Guarantor for the described reasons (see paragraph 20.2). We refer to the case decided by judgment on June 26, 2023, No. 2 by the Court of L'Aquila for the aspects specifically related to the issue of competence, an additional reason for not accepting the appeal.

By provision of April 27, 2023, No. 169 (web doc No. 9896450), the Guarantor admonished a lawyer for unlawfully processing sensitive data of the complainant through electronic notification of judicial acts, pursuant to Law No. 53/1994, carried out to the PEC address of the company where the interested party provided services, instead of to their personal address.

By provision of August 31, 2023, No. 388 (web doc No. 9938413), an administrative pecuniary sanction of €20,000.00 was imposed on the Bar Association of Taranto for the violation of Articles 5, paragraph 1, letters a), c), and f), and 10 of the GDPR and 2-octies of the Code, due to the disclosure on the institutional website of the Bar of judicial data present in the hearing records related to certain interested parties. On this occasion, the Guarantor reported this critical issue to the Court of Taranto, to the CSM, and to the relevant authorities.

Ministry of Justice, and as a result, the aforementioned Court and the Ministry have adopted three

circulars addressed to the judicial offices to raise awareness among justice operators about the importance of protecting judicial data.

By decision of September 28, 2023, no. 431 (web doc no. 9948262), the Authority has established that a lawyer, as the data controller, violated the provision of Article 12, paragraph 3, of the GDPR, by not respecting the legal deadline of thirty days, established by the same regulation, to provide the data subject with information regarding the action taken pursuant to Articles 15 to 22 of the GDPR; nor was it found that the same had communicated to the data subject the necessity of extending the deadline for responding to the request for information and the reasons for the delay, within one month of receiving the request, as also provided for by the aforementioned Article 12. Considering that there were no relevant previous violations committed by the same controller, that the level of damage suffered by the data subject appeared to be minimal, and that there were no aggravating factors, such as financial benefits obtained or losses avoided, directly or indirectly, as a consequence of the violation, the Authority did not deem it appropriate to impose an administrative monetary sanction; however, since the unlawfulness of the processing was nonetheless established, it applied to the lawyer the warning referred to in Article 58, paragraph 2, letter b), of the GDPR.

By decision of November 16, 2023, no. 528 (web doc no. 9973749), the Authority established the unlawfulness of the processing of personal data underlying a communication of personal data, carried out by a lawyer in violation of Articles 5, paragraph 1, letter c) and 6 of the GDPR, and consequently ordered the aforementioned lawyer to pay the sum of 500.00 euros as an administrative monetary sanction; it emerged, in fact, that the lawyer had transmitted on behalf of her client to the business PEC of the complainant, which was also accessible to third parties, documents related to a civil proceeding, specifically concerning a precautionary seizure of a sum in the complainant's bank account, to protect the credit claimed by his ex-spouse.

8.2. Processing by law enforcement agencies

The Authority had received a complaint regarding the use, by law enforcement agencies, of "video recordings from which photographs were obtained" for identification purposes in relation to the contestation of an administrative offense. The complaint was archived as, pursuant to Article 13 of Law No. 689/1981, the bodies responsible for monitoring compliance with the provisions for which the administrative sanction of payment of a sum of money is provided can, for the ascertainment of violations of their respective competence, acquire information and proceed to inspections of things and places other than private dwellings, to signal, descriptive, and photographic surveys, and to any other technical operation. It was also clarified that the use of video-photographic devices does not constitute the use of "facial recognition" systems, as claimed by the complainant, that is, specific computer systems that allow the unique identification or authentication of a natural person through the processing of biometric data (see, Recital 51 of the GDPR).

8.3. Opinions rendered on draft decrees in the judicial field or in relation to police activities

Regarding the advisory activity of the Authority on draft decrees that are not of a regulatory nature or general administrative acts, pursuant to Articles 36, paragraph 4, of the GDPR, 154, paragraph 5-bis, of the Code, and 37, paragraph 4, Legislative Decree No. 51/2018, the Authority, during 2023, expressed the following opinions:

- a) Opinion of May 17, 2023, no. 254 (web doc no. 9913657), on a draft decree of the Ministry of Justice aimed at defining the methods of payment, also electronically, of monetary penalties imposed by the judge with a judgment or decree of conviction, pursuant to and for the effects of Article 181-bis of Legislative Decree No. 271/1989, containing implementing, coordinating, and transitional provisions of the Code of Criminal Procedure;
- b) Opinion of June 22, 2023, no. 278 (web doc no. 9921438), on a provision containing the technical specifications of the dedicated portal for the electronic filing of procedural acts and documents in voluntary jurisdiction proceedings by individuals who are personally involved in the proceedings, pursuant to Article 36, paragraph 4, Legislative Decree No. 13/2023 (so-called online court);
- c) Opinion of July 18, 2023, no. 309 (web doc no. 9921455), rendered pursuant to Article 47, paragraph 1, Legislative Decree No. 51/2018, on the integration of the agreement between the

Revenue Agency and the Ministry of the Interior aimed at regulating access to the section of the Tax Registry called the Archive of Financial Relations. By decision of April 29, 2021, no. 163 (web doc no. 9670652), the Authority had rendered its opinion on the original draft of the agreement in question, which was favorable but conditioned on the acceptance of purely technical-informatic modifications; d) Opinion of October 12, 2023, no. 487 (web doc no. 9953490), on a document aimed at defining the technical specifications of the CTU register portal provided for by Article 16-novies,

****commi 4 e 5, d.l. n. 179/2012, convertito con modificazioni con l. n. 221/2012:**** In consideration of the identified structural deficiencies of the document, and in particular due to the lack of indications regarding the role and responsibilities assumed by the Ministry in the processing of data, particularly concerning their security and integrity, the Authority deemed that the opinion rendered could not be positive;

****e)**** Opinion of November 16, 2023, n. 524 (doc. web n. 9973657), on a draft provision from the Director of the General Directorate of Automated Information Systems (DGSIA) aimed at defining the technical specifications of the dedicated portal for the electronic filing of procedural acts and documents in voluntary jurisdiction proceedings, to be adopted by individuals who are personally involved in the proceedings, pursuant to Article 36, paragraph 4, d.l. n. 13/2023, converted by l. n. 41/2023. The text submitted for opinion took into account the indications provided by the Authority in the opinion of June 22, 2023, n. 278 (doc. web n. 9921438, cited), in which, in particular, the Authority highlighted some gaps in the original text regarding the role assumed by the Ministry and the judicial offices within the regulated system, with particular reference to lines of responsibility concerning data protection; specific guarantees and measures on an organizational and technical level necessary for the protection of data subjects; and some regulatory references. Therefore, the Authority expressed a favorable opinion on the updated draft;

****f)**** Opinion of November 30, 2023, n. 553 (doc. web n. 9967679), concerning a draft provision containing technical specifications for the submission of applications and the maintenance of the register of technical consultants and the national list of technical consultants, pursuant to Article 13, fourth paragraph, of the provisions for the implementation of the c.p.c. and Article 24-bis of the same implementation provisions, as amended by Article 4, paragraph 2, letter b) and letter g), d.lgs. n. 149/2022, as well as the register of experts at the court referred to in Article 67 of the provisions for the implementation of the c.p.p., amended compared to that already subject to opinion 12 October 2023, n. 487. With this last opinion (see above, letter d), rendered on the original text of the technical specifications in question, the Authority deemed it necessary to clarify the potential responsibility of the Ministry, particularly regarding the service of submitting applications and maintaining the registers of technical consultants, which appeared to be unique and provided by the same ministry, either directly or through external suppliers.

****8.4. The activity carried out by the Authority****

The choices of the administration regarding the design profile (Article 25 of the GDPR) and the technical and organizational security measures (Article 32 of the GDPR) have, in fact, undeniable implications for the protection of personal data (see, among others, letter j) of paragraph 1 of Article 5 of the GDPR). It was therefore deemed plausible that, while the ownership of the processing concerning the maintenance of their own registers by individual courts remained, the Ministry of Justice nonetheless had a role in the processing of data carried out through such registers, particularly concerning security aspects. Regarding this last aspect, the aforementioned opinion of October 12 had requested the integration of the text with the provision of some specific, applicable measures suitable to ensure a level of security effectively adequate to the risks associated with the processing. The provision subsequently submitted conformed to these indications, so the Authority's opinion was favorable.

****8.5. Control over the CED of the Department of Public Security****

Following reports received, even in 2023, the Authority, within the limits of its competencies in this area, ensured the response from the Department of Public Security of the Ministry of the Interior and peripheral police offices to the requests of the interested parties, both for access and communication

of data stored at the CED, and for any rectification of the same, in compliance with the provisions of Article 10, l. n. 121/1981, to which Articles 47 and 48 of d.lgs. n. 51/2018 refer.

****8.5. Control over the Schengen Information System****

The Schengen Information System (SIS II) allows national police, border control, and customs authorities to easily exchange information about individuals who may be involved in serious crimes. With the elimination of internal border controls, the SIS plays an essential role in facilitating the free movement of people in the Schengen area. The System also contains alerts about missing persons, especially minors, and information on certain goods, such as banknotes, cars, vans, firearms, and identity documents that may have been stolen, taken, or lost.

****8.5.1. Follow-up of the Schengen evaluation concerning Italy****

In October 2023, the final report from the European Commission resulting from the evaluation of Italy conducted in 2021 was received, which had led to specific verification activities by the Authority, as reported in the 2022 Report, p. 96. Regarding the part of the Authority's competence, the evaluation is compliant, although it requires some improvements (compliant but improvement necessary). In this regard, the Commission, considering the need for regular verification activities, emphasized that the Authority had not prepared...

****Annual or Multi-Year Inspection Plan.****

Regarding the audit activities on the data processed by the national section of the SIS (N.SIS), the evaluation team, while acknowledging that the Authority had begun to carry out said activities, noted that the same had not yet been concluded and therefore urged the Authority to complete it. In this regard, towards the end of the year, the relevant investigations aimed at the formal conclusion of the control activity of the Guarantor on the N.SIS entered the final phase.

103

****REPORT 2023IIII8****

****8.5.2. Control and Monitoring Activities on SIS II****

As is known, for the exercise of rights regarding the data registered in SIS II, the data subject can directly contact the authority that has central competence for the national section of the Schengen archive in Italy, namely the Department of Public Security (so-called direct access). The intervention of the Guarantor occurs in a secondary manner, should the data subject contact them because they are not satisfied with the response provided by the aforementioned Department. The Ministry sends quarterly to the Authority statistical reports, devoid of personal data, containing detailed information (nationality of applicants, police offices involved, types of requests, etc.), suitable for monitoring the flow of requests from data subjects and the consequent response activity carried out by the Department of Public Security. During 2023, there was an increase in the number of requests from data subjects directed directly to the Guarantor compared to the previous year; among these, the percentage of requests from data subjects who complained of an unsatisfactory or erroneous response to their requests by the police authority remained constant, and therefore they turned to the Guarantor in order to have them satisfied. Finally, there continues to be a steady decline in access requests from national control authorities of other EU States, consulted by data subjects regarding reports entered into the system by Italian police authorities.

The relevant information is communicated, after consulting the reporting offices, in compliance with the provisions of Articles 57 of Regulation 1861/2018 and 71 of Regulation 1862/2018.

104

****ACTIVITIES CARRIED OUT BY THE GUARANTOR****

****I****

****ACTIVITIES CARRIED OUT BY THE GUARANTOR****

****II8****

****9****

****Journalistic Activity****

The Authority continued to pay particular attention to aspects related to the freedom of expression,

carrying out a constant balancing activity between the freedom of information, on one hand, and the respect for personal identity and the protection of personal data, on the other. This occurred through the examination of the considerable number of complaints and reports received aimed at denouncing violations related to the dissemination of news online and on social media by the media.

****9.1. Statistical Data and Procedural Aspects****

The requests addressed to the Authority in the examined sector were received, in a substantially equivalent number, in the form of reports and complaints, regarding which, in some cases, it was necessary to request regularization due to the lack of the necessary formal and substantive prerequisites required by the reference legislation. In numerous cases, such regularization concerned complaints regarding the exercise of rights under Articles 15-22 of the GDPR, where they were found to lack the prior request made by the data subject to the data controller, as provided for by Article 15 of the Guarantor's Regulation No. 1/2019. A significant number of requests were also received in the form of reports, some of which, following a preliminary assessment, prompted an investigative activity according to the procedure provided for complaints, as the existence of the prerequisites for a possible violation of the law was identified. Several mixed requests (cease-and-desist letters and/or prior requests addressed directly to the data controllers and transmitted for information to the Authority) were also received, as well as various reports sent by the judiciary concerning news of crimes with supposed relevance in the field of personal data protection. A considerable portion of the complaints resolved in 2023 concerned requests addressed to search engine operators—primarily Google, due to relevance and number of cases—aimed at obtaining the de-indexing of content associated with the name of the data subject (so-called delisting). There were also requests concerning other search engines, such as Microsoft Corporation and Verizon Media Emea Limited, the owner of the Yahoo! search engine. Media outlets (newspapers, blogs, news sites, etc.) were also recipients of a similarly significant portion of the complaints. In these cases, the data subjects primarily complained about the publication of articles (but also e-books) containing personal data deemed excessive, particularly in relation to the principle of the essentiality of information in the...

treatments for journalistic purposes, or disseminated in violation of specific limits (data related to health, sometimes connected to the diagnosis of Covid-19, as well as data related to minors). An additional area of intervention concerned the complained publication of photographs, comments, and videos also on social networks in the absence of the consent of the interested party or another suitable legal basis. With specific regard to the exercise of the rights set forth in Articles 15-22 of the GDPR, there was frequent adherence by data controllers to the original requests of the complainants during the proceedings; this allowed, in many cases, to resolve complaints without the adoption of collegial measures.

105

REPORT 2023II9

In cases where the conditions were found to involve the College, the latter had to express itself by operating a delicate balance between the requests of the individual and the general public interest in information, resorting – where necessary – to the use of the corrective powers provided by the GDPR.

In more serious circumstances, the Authority

considered it appropriate to apply, regarding the identified unlawfulness of the conduct of the data controller, also pecuniary sanction measures, taking into account the peculiarities related to the exercise of such corrective power in an area of particular sensitivity such as the freedom of expression.

9.2. Processing of data in the exercise of journalistic activity

9.2.1. Judicial data

In addressing the recurring issue of the use of images accompanying journalistic articles on judicial matters, the Authority deemed unfounded the request of a complainant aimed at having an image featuring his face prominently removed from various news outlets, along with similar photographs of twenty other individuals investigated with him in a judicial proceeding, published immediately after the execution of the custody order in prison. It was deemed that the publication of the image in question appeared to be supported by reasons of public interest considering the seriousness of the charges, which were later found to be substantiated in the first-instance judgment. Moreover, in this specific case, the publication of the photograph could be considered responsive to the need for a more precise identification of the investigated subject (provs. 23 February 2023, no. 99, web doc no. 9890255; no. 100, web doc no. 9890983; no. 101, web doc no. 9891143; no. 102, web doc no. 9907828 and no. 103, web doc no. 9892670).

9.2.2. Unlawful dissemination of health data

The issue of the dissemination of information related to Covid-19 infections was the subject of several measures by the Authority even in the year in question. In particular, the complaints of an individual who had reported the publication, by a news outlet, of personal data – his name and surname and the position held within a ministry – along with the information that he “tested positive for the virus, then tested negative, but still in isolation” were deemed well-founded. The Authority noted that, even within the framework of a legitimate exercise of the right to report and criticize on matters of general interest (the observance of government provisions to contain infections within public offices and, in particular, those responsible for ensuring compliance with the provisions themselves), the disclosure of the identifying data of the complainant constituted an excessive treatment, not justified by a role of particular public relevance attributed to the individual. Due to the identified violation, concerning

personal data related to health status, the Authority, in addition to prohibiting further processing of the data, imposed a pecuniary sanction on the data controller (prov. 11 January 2023, no. 15, web doc no. 9861268).

The Authority also deemed a complaint well-founded and sanctioned a publisher in relation to a journalistic service in which the personal data (including the photograph) of the complainant were published in association with inaccurate information regarding her health status (isolation due to a swab), despite suitable documentation provided by the complainant proving the inaccuracy of the data.

In specifying that “having undergone a swab constitutes information that the Authority has repeatedly deemed to relate to health data, regardless of

106

THE ACTIVITIES CARRIED OUT BY THE AUTHORITY¹¹⁹

from its outcome, as it relates to the execution of a healthcare service,” the Authority recalled that it is the journalist's duty to verify the reliability and correctness of the information and to correct inaccurate information, as also referred to in Article 4 of the ethical rules. The data controller was also sanctioned for failing to respond to a prior request made by the interested party in the exercise of the rights provided for in Articles 15-21 of the GDPR (provision of October 26, 2023, no. 506, web doc no. 9955735 – provision appealed before the Court of Avellino).

The Authority intervened, declaring instead unfounded a complaint that lamented, in the context of a news article, the dissemination of information regarding the contraction of the Covid-19 virus by a municipal councilor, not having deemed the processing of data related to the health status of the interested party excessive due to the public role held by the latter in the local community and the relevance of the reference to his health status concerning the regular functionality of the municipal administration's organs. The details provided in the article, moreover, were not found to be damaging to the dignity of the interested party, and, in the printed version, the news had only been disseminated locally. The Authority also deemed the publication, accompanying the aforementioned article, of the complainant's photograph not excessive due to the circumstance that it was published on the administration's website, or present on various news sites (provision of March 2, 2023, no. 63, web doc no. 9874436).

In 2023, the Authority also intervened ex officio through the adoption of provisional limitation measures against certain publications that had published details (including the medical report) of the pathology affecting a dangerous criminal. The imposed limitation concerned the further dissemination of the health data indicated in the articles in question. Subsequently, the Office, in light of the elements that emerged during the investigation, confirmed the provisional limitation measures adopted, prohibiting any further processing of the disseminated health data (provisions of April 13, 2023, no. 134, web doc no. 9896877 – appealed before the Court of Rome – no. 135, web doc no. 9897055 and no. 136, web doc no. 9892869).

Also in relation to the dissemination of health data, the Authority intervened by prohibiting the dissemination of personal data contained in an article that described in extremely detailed terms the health conditions of the complainant following a bicycle accident in 2014, after which he had broken a shoulder and for which he had requested and obtained, through a first-instance ruling, a substantial compensation (provision of March 23, 2023, no. 110, web doc no. 9894184).

9.2.3. Data relating to minors

Particular attention was also paid, during the reference period, to the protection of minors, with particular regard to compliance with the guarantees provided by the ethical rules (Article 7) and the Treviso Charter.

For example, the parents of a deceased minor complained about the publication, along with the news

of the death, of a series of information including the (alleged) illness that was said to be the cause, as well as further data relating to family members. Although the Authority took note of the removal, during the investigation, of the URLs that referred to the articles in question, as well as the reasons put forward by the publishers regarding the intent to involve the small community to which the minor belonged in the tragedy, the Authority deemed it necessary to impose a ban on any further dissemination of the data subject to the proceedings, including online, even in the historical archive, and also proceeded to impose a financial penalty on the involved publishers (provisions of June 8, 2023, no. 247, web doc no. 9909715 and no. 248, web doc no. 9909732).

The reports of a parent who complained of a violation of the provisions for the protection of minors regarding the publication, by two newspapers, of a photograph depicting his daughter and other companions accompanying the news of the harassment suffered by them during a train trip, during which they encountered a group of boys who had participated in a gathering that degenerated into fights and acts of violence, were also deemed well-founded. The Authority reminded that the respect for the principle of the essentiality of information should be interpreted more rigorously in cases where the news concerns minors, whose superior interest must be considered prevailing, especially when they are involved in news events as victims of criminal actions, in which their anonymity must be guaranteed, avoiding any informative element capable of allowing their identification even indirectly (Article 114, paragraph 6, of the Criminal Procedure Code; Article 7, paragraph 1, ethical rules and Treviso Charter). In this specific case, the Authority found that such principles had been violated and therefore prohibited the further processing of the data and imposed a sanction on the newspapers involved in the report (provisions of August 31, 2023, no. 390, web doc no. 9944538 and no. 391, web doc no. 9944579). These measures were appealed before the judicial authority, which, regarding one publisher, confirmed the Authority's assessments while reducing the imposed sanction (cf. Court of Bologna, I civil section, ruling of February 16, 2024). Regarding another publisher, the proceedings are ongoing.

The validity of the request was also noted in a case where the interested party – a minor at the time the events referred to occurred and at the time of filing the complaint – complained about the unlawfulness of the processing carried out by a newspaper that had published some images and a video on the publisher's YouTube channel, concerning an unauthorized gathering interrupted by the arrival of law enforcement. The video footage was taken from a distance that allowed the identification of the individuals present, despite their attempts to avoid recognition. The complainant argued that she had suffered significant harm due to the negative connotation that the article attributed to all participants in the event. The Authority upheld the complaint, imposing a prohibition on the data controller for any further processing of the interested party's data, which had already been removed during the proceedings, as well as the payment of a monetary fine. Indeed, a violation of the principle of the essentiality of information was found, as the direct identifiability of the interested party did not appear relevant for informational purposes, to whom, moreover, due to her minor age, special protection should have been guaranteed considering the effects that her exposure, especially if negatively connoted, could have on a balanced psycho-physical development. It was also noted that, although it was possible that the journalist, at the time of the filming, was unaware of the minor age of the subjects filmed, the publisher had been informed of this circumstance at the moment when it was presented with a removal request from the interested party prior to the filing of the complaint, to which, however, no substantial intervention had followed (prov. June 22, 2023, no. 265, web doc. no. 9910270).

9.2.4. Data of Public Figures

During the reference period, the Authority had the opportunity to clarify the scope of correct processing for journalistic purposes even when it concerns personal data relating to public figures. This was particularly highlighted by a complaint regarding the alleged dissemination, through a magazine, of images depicting the interested party in private life moments while she was inside her home with some guests. The Authority upheld the complaint and sanctioned the publisher, noting an incorrect use of invasive techniques (art. 3 of the deontological rules) and a processing of personal data, even strictly private, that exceeded, with a sacrifice of the complainant's private sphere, the journalistic purpose

pursued (prov. June 8, 2023, no. 246, web doc. no. 9907956).

9.2.5. News of Significant Public Interest and Respect for the Essentiality of Information

Also during the reference period, the examination of complaints and reports concerning news events provided an opportunity for the Authority to reiterate the fundamental principles of the regulation regarding the protection of personal data in the journalistic field. Among these, particularly relevant is the principle of "essentiality of information" – enshrined both in the Code (art. 137) and in the deontological rules (arts. 6, 8, 10, and 11) – which must guide the journalist towards correct information that respects the rights of the individual.

In application of the aforementioned principle, the Authority upheld the complaint of an interested party who complained about the publication of his identifying data within an article reporting the news of a theft he had suffered. This is in line with a consolidated principle aimed at protecting data capable of identifying victims of crimes (prov. April 13, 2023, no. 139, web doc. no. 9897854).

Also with reference to the essentiality of information, a complaint regarding the dissemination in an article, published on the website of the newspaper, containing a photographic reproduction of the holographic will in which the name, date, place of birth, residence address, and the status of witness assumed for the purposes of the testamentary procedure by the complainant were visible, was similarly deemed well-founded (prov. August 31, 2023, no. 366, web doc. no. 9932951). A case was also considered well-founded where the publication, accompanying a news article regarding a regional councilor, included a photograph with the name of the street where his residence was located and the visibility of the related entrance, due to the location of the property in an area characterized by low population density that allowed immediate recognition by anyone (prov. June 22, 2023, no. 332, web doc. no. 9924481).

Similarly, a complaint regarding a case of dissemination on the social media of a journalist and commentator, of images, subsequently picked up by various online sites, collected through a mobile phone camera, and referring to two passengers during a flight, for the purpose of documenting their failure to use the necessary protective devices during the pandemic period, was evaluated. In this case, the role of journalist of the person who had taken the images was not made evident, nor the purposes of the collection, in violation of the obligations set forth in art. 2 of the deontological rules regarding the processing of personal data in the exercise of journalistic activity. Furthermore, appropriate measures had not been taken to avoid the identifiability of the interested parties, in violation of the principle of essentiality of information (prov. July 6, 2023, n. 336, web doc n. 9925450).

The Authority also intervened with a declaration of validity regarding a complaint that alleged the illegality of the processing carried out through the publication of an article and an e-book in which, in violation of the principle of essentiality of information, not only the identifying data of the interested parties were disseminated, but also other personal information, in the context of an incident that occurred many years prior in which only the father of the complainants was involved for abuses committed in the world of sports (provision of March 6, 2023, n. 62, web doc n. 9880427 - confirmed by the Court of Milan, I civil section, ruling of November 30, 2023).

The validity of the complaint was also assessed in relation to a case in which the interested party complained of a violation of the relevant regulations concerning the processing of data for journalistic purposes by a publisher who, in recounting a news event that concerned her (a robbery that occurred in her apartment), had reported, both in the printed and digital versions of the article, numerous pieces of information capable of identifying her. The publication had, in particular, disclosed the name of the interested party and her image taken from her Facebook profile, as well as numerous details regarding her residence and the school attended by her minor daughter, in stark contrast to the principle of essentiality of information, thereby placing her and the people living with her at risk.

A prohibition on further processing of the data in question and a limitation on the accessibility of the printed copy of the article, kept in the publisher's archive, were therefore imposed (provision of November 16, 2023, n. 534, web doc n. 9967845).

No excess information was found in the processing carried out by the publisher of a newspaper through the publication of an article that fully reported the personal details of the complainant and other

protagonists of a case related to the access methods for a university competition. The interested party, in fact, although not involved in the judicial proceedings in question, had played a primary role in the narrated case, and the journalistic purpose connected to the dissemination of his data was precisely to provide a clear picture of that context. Moreover, the article reconstructed the events without indulging in comments or details harmful to the dignity of the complainant (provision of March 23, 2023, n. 94, web doc n. 9883685).

The request for the removal of an article published very recently by a well-known newspaper was also deemed unfounded, with the complainant alleging the falsity of the content and its defamatory and offensive nature, without, however, providing the Authority with objective elements for evaluation. The same interested party also noted a violation of the principle of essentiality of information as the article also reported extraneous details, such as the home address and lifestyle habits. The Authority, agreeing with the deductions made by the data controller, rejected the complaint, affirming, for the relevant aspects concerning the protection of personal data, that the publisher had complied with the relevant principles in this area, considering the existence of a public interest in the knowledge of the news contained therein (provision of December 21, 2023, n. 618, web doc n. 9984512).

The unfounded nature of the claim was also declared concerning a complaint regarding the request for corrective and sanctioning measures following the publication of the personal details and age of the protagonist of a judicial case, concluded with a recent ruling of no grounds for proceeding due to the remission of the complaint, but of general interest, within the limited territorial scope, considering the profile of reporting behaviors related to the school context, the relationships between teachers and students, and the improper use of social media (provision of December 21, 2023, n. 620, web doc n. 9985641).

Partially unfounded was deemed a case in which the interested party complained about the publication of his personal details in several newspapers concerning a criminal proceeding in which he had been involved. This dissemination also occurred in a blog where the text of a precautionary order issued, among others, against the complainant was published, who claimed to have suffered significant harm as a result. In the published order, in fact, data such as the residential addresses and the mobile phone number used by the interested party were reported, which were considered excessive concerning the informative purpose connected to the exercise of the right to report. The absence of adequate information within one of the involved sites was also contested, specifically regarding the failure to indicate useful contact channels for the exercise of rights by the interested parties. The Authority ruled declaring the manifest unfounded nature of the complaint concerning the request for the removal of the name of the interested party published by the involved newspapers, reiterating a principle repeatedly.

pronounced, or that the publication of identifying data of individuals against whom a criminal proceeding has been initiated is not precluded by the current legal framework and should be framed within the guarantees aimed at ensuring transparency and control by citizens regarding the justice activity. With reference, instead, to the treatment consisting of the publication of the text of the precautionary measure, it was clarified that Article 114, paragraph 2, of the Criminal Procedure Code excludes precautionary orders from the more general prohibition of full publication of acts of the criminal proceeding no longer covered by investigative secrecy, noting, however, the unlawfulness of the processing of certain data contained therein, deemed to be in contrast with the principles set forth in Article 137, paragraph 3, of the Code and Article 6, paragraph 1, of the ethical rules, and imposing a prohibition on further processing of the data on the part of the data controller, who is also subject to a warning for the established violations (provision of October 26, 2023, no. 505, web document no. 9954906).

9.2.6. Requests for deletion addressed to publishers

Some measures taken by the Authority have concerned requests for deletion of data addressed to publishers in the exercise of rights (Article 17 of the GDPR) that remained unsatisfied. In relation to such cases, the Guarantor considered, as a proportional balancing measure between the right to be forgotten invoked by the complainant and the safeguarding of the information purposes invoked by the publishers, the adoption by the latter of specific technical measures aimed at prohibiting the indexing

of the articles in question—while safeguarding the integrity of the news, duly updated, within the archives of the newspapers. This occurred with reference to a complaint regarding certain articles in which the involvement of the interested party in a judicial matter (which had since been resolved in his favor) was particularly limited (“only two lines, in which he appears with name and surname and with his qualifications”) compared to that of other subjects, mentioned in the articles in much broader terms (provision of January 26, 2023, no. 29, web document no. 9867661). The adoption of the aforementioned technical measures was also provided for in relation to another complaint addressed to various publishers, in which the interested party complained about the harm arising from the availability, in association with his name and surname, of URLs containing excerpts of a telephone interception that provided a reading capable of attributing to the complainant significant, if not decisive, responsibilities in the investigations related to the collapse of the Morandi Bridge in Genoa. Such responsibilities, however, had not been confirmed by the outcomes of the investigations themselves and the subsequent developments of the proceeding, with the complainant not being among the persons investigated and subsequently charged in that context (provisions of March 23, 2023, no. 105, web document no. 9893743; no. 106, web document no. 9894160; no. 107, web document no. 9895432; no. 108, web document no. 9895464; and no. 109, web document no. 9896373).

Also in relation to the aspects concerning requests for the exercise of rights under Articles 15-22 of the GDPR, the Authority adopted a warning measure against a publisher that had not responded to a request from the interested party (aimed at obtaining the deletion of a service, which was dated and harmful to her dignity, repeatedly broadcast by the publisher during a satirical television segment) arguing in its defense that the request had not been sent to the email address indicated in the notice made available on its website. In particular, the Authority noted that, although the complainant had used a communication channel (the certified email of the company) different from that indicated in the aforementioned notice, it constituted the official electronic address (digital domicile) of the data controller and the related corporate group, intended for the transmission of acts having legal value. The channel used was therefore not extraneous to a possible use also for the exercise of the rights provided for by the data protection legislation, also in light of its suitability to provide a certain date of receipt of the communication itself (cf. paragraphs 55 and 57 of the guidelines on the right of access adopted by the EDPS on March 23, 2023; provision of November 26, 2023, no. 535, web document no. 9968111).

The Authority, on the other hand, deemed the request for deletion of a television service in which a video was replayed and facts related to a criminal proceeding involving the complainant among the defendants, which concluded in 2017 with the acquittal of the interested party, to be unfounded. The Authority, having examined the service in light of journalistic discipline and the principle of "essentiality of information" mentioned above, considered that it provided an updated informational framework of the facts and the criminal proceeding involving the complainant (also mentioning the favorable outcomes for him). This had occurred by drawing on a public document (the ruling of the Milan Court of 2017, also published by the complainant himself) in which information of significant general interest was reported, regardless of the criminal relevance or otherwise of the facts attributed to the complainant, who had access to information intended to be confidential, related to individuals belonging to the world of politics or entertainment, due to hacking actions attributed to third parties (provision of April 13, 2023, no. 140, web document no. 9907900).

9.3. Data Processing by Search Engines

As previously mentioned, the complaints filed against search engine operators constituted, during the reference period, a considerable part of the overall complaints received by the Authority regarding the field of freedom of information.

The majority of the delisting requests received concerned processing carried out through the search engine operated by Google LLC, which was followed by the initiation of corresponding proceedings. Conversely, regarding companies that manage other search engines – particularly Microsoft Corporation concerning Bing and Verizon Media concerning Yahoo! – recourse was made, where it was not possible to resolve the complaint following a preliminary information request, to the cooperation mechanism, thus initiating a direct dialogue with the lead authority pursuant to Articles 56

and 60 of the GDPR.

With respect to the requests made against Google, it should be noted that, in some cases, they were satisfied following a spontaneous adherence by the data controller subsequent to the transmission of the complaint by the Authority, while in the remaining cases, action was taken through a collegial decision.

This possibility of a “national” solution was made possible by Google’s choice to maintain its search engine servers outside the EU, thus allowing the individual authorities of the countries where the complainant is established to independently initiate and manage the cases of respective competence. The decisions taken by the Authority during the reference period present, as a type, a substantially equivalent number of assessments of unfoundedness and of acceptance, even if only partial, of the requests made by the interested parties.

The grievances expressed by the latter mainly concerned the prejudice suffered by them due to the online availability of information regarding judicial matters in which they had been involved and which had evolved over time to create a discrepancy between what was reported in the relevant newspaper articles and their current situation. This was determined, in some cases, by subsequent verification of the absence of involvement of the interested party or their non-guilt, while in other cases, despite a conviction having been issued against them, the change in the overall context of their judicial position resulted in a substantial inaccuracy of the original news.

Regarding the first hypothesis, one can refer to the case of an interested party who had submitted a request for the removal of URLs linked to content concerning a judicial matter in which they had been acquitted several years prior. The complainant, in particular, lamented the prejudice suffered due to the persistent availability of information regarding crimes, which they allegedly committed, for which they had instead been declared innocent. However, this latter circumstance had not been mentioned in the contested comments, nor were there any further updated information available online regarding the matter. The Authority accepted the request, considering that the right of the interested party should be deemed to prevail over the public interest reasons put forward by the data controller, as the ongoing dissemination of outdated information constituted a particularly prejudicial treatment for the legal sphere of the complainant and was likely to provide internet users with an inaccurate and misleading representation regarding their involvement. The latter had also requested the acceptance of their request concerning non-European domains (so-called global delisting); however, in this case, the Authority noted an excessive generality of the reasons put forward to support this request, which did not allow for an appreciation of the actual prejudice alleged by the interested party (decision of March 23, 2023, no. 111, web document no. 9883613).

It should be considered, in general terms, that the processing of judicial data is subject, even when carried out by search engine operators, to the adoption of appropriate precautions dictated by the particular nature of the data in question. In this direction, the Court of Justice of the European Union has also oriented itself, which in the judgment of September 24, 2019, delivered in case C-136/17, highlighted the necessity that search engine operators also observe the precautions indicated in Article 10 of the GDPR, balancing in a particularly rigorous manner the needs related to the necessity of ensuring public information with the guarantee of the rights of the interested party in a particularly delicate area. This orientation is also shared by the national legislator, who, through recent reforms of the criminal judicial system, has indicated, as an elective path, the minimization of the processing of judicial data in order to avoid that improper use of these may give rise to phenomena of sensationalism that in some way anticipate or influence the course of investigations under the jurisdiction of the judiciary.

Specific provisions have also been issued (see Article 64-ter of the transitional provisions of the Criminal Procedure Code, introduced by Legislative Decree No. 150/2022) aimed at limiting, from the outset or subsequently, the circulation of judicial information related to individuals who have subsequently seen their position favorably changed as a result of definitive measures in the proceedings that have excluded their responsibility, such as dismissal decrees or acquittal sentences. The reference in the provision to the limits set forth in Article 17 of the GDPR has raised doubts about its suitability to exempt requests that present the characteristics described above from the balancing judgment.

The interpretation provided on this point by the Authority – contained in the opinion formulated regarding the draft legislative decree implementing Law No. 134/2021, which delegates the Government for the efficiency of criminal proceedings as well as in matters of restorative justice and provisions for the swift resolution of judicial proceedings (opinion of September 1, 2022, No. 292, web document No. 9802612) – has then found concrete application in the decision of some complaints evaluated by the Authority. Among these, it is deemed useful to recall the case of an individual who had submitted a request for de-indexing to the operator of a search engine concerning certain URLs linked to articles associated with his name and surname regarding a judicial matter in which he had been involved and which had subsequently concluded with a dismissal decree.

The individual had obtained from the court clerk the formal annotation at the bottom of the dismissal decree, as a suitable title for obtaining de-indexing from the search engine. In response to the denial issued by the operator, motivated by the current nature of the news, which was also updated, and its relevance to the public role held by the individual, the latter had turned to the Authority, which, in this case, shared the position expressed by the data controller, declaring the complaint unfounded. The reasons provided by the Authority for the decision are attributable to the fact that the reference to Article 17 of the GDPR, contained in Article 64-ter of the transitional provisions of the Criminal Procedure Code, is to be understood as a safeguard clause for the exceptions provided for in the same Article 17 to the exercise of the right to erasure, among which is that related to the need to ensure the proper exercise of freedom of expression and information with which the right to be forgotten must be appropriately balanced. In the case examined, it was deemed that the news, recent and updated, was still of public interest as it was connected to the professional role still held by the complainant, who had moreover renewed his interest in the matter by openly referencing it during an interview given to a newspaper (provision of September 28, 2023, No. 430, web document No. 9946736 – provision challenged before the Court of Naples).

In another case, in which the individual had similarly invoked the application of Article 64-ter of the transitional provisions of the Criminal Procedure Code, it emerged during the proceedings that there was a lack of the annotation affixed to the provision by the clerk of the competent judge, to be understood as a formal prerequisite for accessing such an opportunity. On the merits of the matter, the Authority nonetheless considered that there were no grounds to deem the right of the individual to be prevailing, given that the contents subject to the request were of recent publication, updated – moreover due to a statement from the individual's lawyer reported in the article – and related to the professional role performed by the same (provision of December 21, 2023, No. 616, web document No. 9981652).

Conversely, the Authority found the complaint valid in which the individual, recipient of a favorable provision, requested the de-indexing of outdated content related to earlier phases of the proceedings (judicial administration provision of the company of which the complainant was the managing director, a provision later revoked; results of investigations also involving the same, which were then concluded in his favor with a dismissal). The complaint had been submitted before the entry into force of Article 64-ter of the transitional provisions of the Criminal Procedure Code, but after the entry into force of the enabling law, containing the guiding principle of the provision. The Authority's acceptance provision in this case (provision of December 21, 2023, No. 619, web document No. 9979832) is situated within the framework of a balancing act between the right to be forgotten and accessibility to information carried out by the Authority for similar cases even before this legislative novelty (cf. provisions of February 10, 2022, No. 52, web document No. 9750669; October 20, 2022, No. 352, web document No. 9838182).

The balancing operation underlying the evaluation of removal requests must take into account, on one hand, the protection needs expressed by the individuals concerned and, on the other hand, the necessity to ensure users of the network access to useful information regarding the same. In order to appreciate the existence of a current public interest in the knowledge of certain information, it is necessary to...

****Consideration of the Actual Relevance of the Information****

Taking into account the actual relevance of the information and its suitability to effectively contribute to the construction of a profile of the interested party that corresponds to their current identity. However, such suitability was found to be absent in some of the cases brought to the attention of the Authority. In particular, the de-indexing of two URLs linking to certain pages of a news aggregation site was ordered, which contained previews of two articles fully accessible only to subscribers; the previews had limited informational content and did not include the identifying data of the complainant, even though they appeared in the so-called snippet. The Authority found that this search result constituted an excessive processing of personal data compared to the content made available in the previews directed at the generality of users not registered on the site (Provision of March 22, 2023, No. 104, Web Document No. 9892698).

To these cases, additional instances were added in which the Authority, considering the specific characteristics of the represented case, did not find the existence of prevailing public interest reasons compared to the right to be forgotten invoked by the interested parties (among others, Provisions of April 27, 2023, No. 176, Web Document No. 9916702; May 17, 2023, No. 204, Web Document No. 9903127; and November 30, 2023, No. 563, Web Document No. 9979890).

In light of the criterion of prevailing public interest, the Authority reached a different conclusion in the case of an interested party who requested the de-indexing of certain URLs referring to pages of online encyclopedias containing information related to him, including those concerning judicial matters in which he had been involved and which were resolved with favorable decisions for him. The Authority, agreeing with the position expressed by the data controller, declared the complaint unfounded, considering the continued existence of a public interest in knowing the relevant information, given that the contested pages contained not only judicial data (updated in light of subsequent developments) but also various types of information that contributed to reconstructing the profile of the complainant, including regarding the political role he played (Provision of November 16, 2023, No. 533, Web Document No. 9972735).

The Authority also declared unfounded: a complaint aimed at obtaining the removal of a URL that linked to an article – deemed still current – accompanied by images related to public statements made in youth by the complainant, who had also run for political-administrative positions (Provision of June 22, 2023, No. 268, Web Document No. 9919295); a request for de-indexing of certain URLs dating back to 2017 concerning the political activity carried out by the complainant within a political party, which the Authority deemed maintained a public interest, also due to the short time elapsed since the events represented therein and considering the natural public dimension of any political activity (Provision of October 26, 2023, No. 507, Web Document No. 9955703); a complaint invoking the right to be forgotten regarding URLs linking to news from 2019 that reported on the precautionary measure ordered by the judicial authority against the complainant in the context of an investigation by the Financial Police, from which alleged corrupt conduct involving tax magistrates, including the interested party – a journalist and prominent figure in the television environment – emerged in connection with his professional activity (Provision of April 13, 2023, No. 138, Web Document No. 9897822).

The existence of a current public interest was also noted in relation to the case of an interested party who requested the removal of certain URLs linking to content associated with his name and surname, also together with other search criteria not referring to his personal data, concerning events that had involved certain companies declared bankrupt, to whose management he claimed to be unrelated, complaining about the personal and professional discredit resulting from such association. The Authority, limiting its assessment to the search results retrievable through the name of the interested party, declared the complaint unfounded, as it emerged that the interested party had played a specific professional role within the subsequently bankrupt company and that the latter was still connected to another company of which he had been a minority shareholder, and whose representation was held by his relatives. The public interest in the knowledge of the contested news was also correlated to the professional activity still carried out by the complainant in the same sector (Provision of December 21, 2023, No. 613, Web Document No. 9981324).

Lastly, the Authority was called to rule on the request for de-indexing of URLs related to various events

involving the complainant, accepting the request in cases where the relevant pages reported outdated content regarding the measures taken in favor of the interested party (rehabilitation, archiving measures, and non-prosecution orders), and instead rejecting the request concerning the pages that reported the aforementioned updates; this determination was reached due to the public's interest in knowledge considering the public role of the complainant, evidenced by the numerous positions, including leadership roles, held over the years in public and private entities and by his current professional activity (Provision of December 21, 2023, No. 619, Web Document No. 9979832).

10

Cyberbullying and Revenge Porn

Reports regarding cyberbullying received in 2023 primarily concerned the publication of defamatory and derogatory posts, as well as the creation of fake social media profiles. The requests were addressed by formulating specific intervention requests to the data controller/site manager involved, also making phone or email contacts with the reporter to acquire additional information or to provide them with useful guidance regarding the reported incident. Furthermore, there were some cases where the prerequisites for proceeding were not met, sometimes due to the reporter's failure to indicate the necessary elements for sending the relevant request to the platform manager and, in certain instances, due to the lack of the minimum requirements established by Law No. 71 of May 29, 2017, to qualify a conduct as an act of cyberbullying. The commitment of the Authority to prevent and combat the phenomenon of the dissemination, with vindictive intent and in the absence of the consent of the person concerned, of images with sexually explicit content (revenge porn) under Article 144-bis of the Code has also significantly intensified. A specific online reporting procedure has been implemented on the institutional website of the Authority, which, by facilitating communication methods from the interested parties, has contributed to a significant increase in the reports received (about 650) during the reference period. The reports were processed by providing guidance to the interested parties and, where necessary, requesting appropriate supplements for subsequent processing, including, in certain cases, the transmission of material with sexually explicit content whose acquisition is provided for by Article 144-bis of the Code. In some cases, the material sent by the reporters was found to be unsuitable (as in the case of screenshots of video calls or chats) for sending to the concerned platforms, given the possibility for the malicious person to upload the original image in their possession. The examination of the reports led, in almost half of the cases, to the urgent adoption of a managerial determination (in total, about 300), subsequently ratified by the Board, directed at the managers of the involved platforms to obtain the preventive blocking of the material with sexually explicit content subject to the feared dissemination activity. Finally, a sample verification activity was carried out to assess the correct fulfillment of the preventive blocking measures regarding revenge porn adopted by the Authority. In this context, some platform managers were requested to provide information on the measures implemented following the notification of specific provisions transmitted during the reference period.

11

Marketing and the Processing of Personal Data

11.1. The Phenomenon of Unwanted Telemarketing and the Action Against It

Despite the strong counteraction carried out by the Authority over time and particularly in recent years with the full use of new tools, including punitive measures offered by the GDPR, the phenomenon of unwanted telemarketing shows no signs of significant regression. 2023 was therefore characterized by multiple actions against operators (from clients to intermediaries, up to the last link in the chain, namely call centers), which confirmed the critical issues encountered so far, namely, above all, the lack of a proper control chain that prevents companies from "receiving" contracts generated from contacts made in violation of the regulations. In numerous cases related to reports of promotional calls from subjects, or made on behalf of clients, not identified, or for which the calling number and/or other essential elements for the Authority's control activity were not indicated, as well as in relation to the phenomenon of so-called silent calls, responses were provided, as usual, through standard notes containing clarifications and operational indications or references to initiatives already undertaken by the Authority in various capacities in previous years (in particular, the FAQs published on the

institutional website of the Authority concerning silent calls). In other cases, where the reports and complaints received were specific, attributable to specific data controllers and relevant in terms of personal data protection, the Authority initiated investigations, some of which were lengthy and complex, resulting in corrective and/or punitive measures, outlined in the subsequent paragraphs. The Authority adopted several measures originating from investigations related to unwanted marketing conducted via telephone or email, the management of the exercise of the rights of the interested parties, and the critical issues regarding the principles of accountability, privacy by design, and data security. In numerous cases, the investigations concerned the processing of personal data provided to the controllers by third parties (list providers) in the absence of checks regarding the lawfulness of the processing, particularly concerning the information provided and the consents obtained from the interested parties. Following the receipt of a complaint concerning an unwanted call regarding the promotion of boiler maintenance services offered by a company, the Authority adopted a measure in which it acknowledged the absence among...

****Holder and provider of a contract or other legal act suitable for regulating the respective privacy roles in the contested processing.****

In the context of the same investigation, it was found that the personal data acquired from the list provider were stored in the company systems for at least one year, without a justifiable reason. The company was fined 3,000 euros (provision March 9, 2023, no. 71, web doc no. 9880336).

Similar violations were found in the provision adopted against a company active in the promotion and dissemination of artistic initiatives also on behalf of third parties (provision March 9, 2023, no. 61, web doc no. 9873408). This provision was linked to a parallel investigation concerning another holder, as a result of which it was possible to ascertain that this subject, presenting false personal details, proposed the dissemination of promotional emails using lists created without any suitable legal basis (provision March 2, 2023, no. 60, web doc no. 9880317). The imposed fine of 5,000 euros was not paid, and therefore, the procedure for registration in the role was initiated.

The Authority then imposed an administrative fine on a company for having made unwanted promotional phone calls in the absence of the legality requirements of the processing, with particular reference to the obligations of the information notice (inadequate regarding the text used for telephone contacts) and consent for marketing. The investigation revealed that the list containing the complainant's data came from an American company with which the holder had come into contact through one of its business partners, and that the issues related to the information notice and consent existed both in relation to the lists provided by the American company and regarding the personal data obtained from Italian partners, regardless of the guarantees offered in the contracts or the location of the main establishment of the holder (Italian or non-EU). Therefore, the Authority clarified that, regardless of the origin of the data, it is the holder's responsibility to verify and prove compliance with the regulations on personal data protection (accountability principle) and imposed an administrative monetary fine of 10,000 euros (provision October 26, 2023, no. 503, web doc no. 9964761).

In order to combat wild telemarketing, the Authority intervened against a call center for violations related to the obligation of information, imposing a fine of 10,000 euros (provision July 6, 2023, no. 334, web doc no. 9927358).

During the investigative activities and in the provision phase, the Authority repeatedly reminded that the making of unwanted phone calls is subject to the obligation of consent under the special law referred to in Article 130 of the Code, and the holder cannot invoke the condition of legality of legitimate interest. At the same time, it was reiterated that data present in public lists cannot be used for promotional purposes. Therefore, a publishing company was prohibited from any further processing of the data thus collected, and was also ordered to delete such data and to adopt measures that ensure full and effective compliance with the exercise of the rights of the data subjects. In light of this, the Authority deemed the application of an administrative monetary fine of 15,000 euros appropriate (provision July 6, 2023, no. 294, web doc no. 9941250).

The Authority then conducted an investigation against a company active in the online comparison sector, as a result of which an administrative monetary fine of 40,000 euros was imposed. The investigation arose from a complaint regarding the persistent receipt of promotional phone calls to a

number registered in the RPO, even after the data subject had expressly opposed during the unwanted contacts and through formal requests for the exercise of rights that went unanswered. The main issues identified by the Authority concerned the information notice (absent during the first telephone contact and inadequate regarding the website) and the collection of consents, which were obtained through the company's website and referred to processing activities not actually carried out by the company (such as profiling). Regarding the corrective measures identified, the Authority prohibited the processing of personal data for which suitable consent had not been obtained for profiling activities, ordering their deletion as well, and instructed the holder to adopt adequate procedures aimed at constantly verifying, including through random checks, that the personal data provided by the provider were processed in full compliance with the regulations, as well as to facilitate the exercise of the rights of the data subjects, receiving the requests already at the moment of the telephone contact. Furthermore, the holder was ordered to provide the interested parties – both in the context of phone calls and in a specific section of the website – with suitable information indicating the processing operations actually carried out by the company (provision of July 18, 2023, no. 322, web document no. 9921112).

Finally, regarding the numerous reports of promotional calls, the Authority has initiated a series of parallel investigations aimed at ascertaining the existence and adequacy of the technical and organizational measures adopted by some holders to combat wild telemarketing and ensure control of the supply chain from contact to contract. This initiative has been undertaken against various actors in the telecommunications, energy, interactive TV, and door-to-door sales sectors. These holders have been recipients of several requests for information, pursuant to Article 157 of the Code, aimed at obtaining a list of purchase proposals coming from their respective sales networks that led to the activation of the related services or the sale of products. For a complete assessment of the processing activities, the Authority has involved the Ugo Bordoni Foundation (FUB) requesting verification of the registration of the called numbers in the RPO and, therefore, any violation of Article 130, paragraphs 3 and 3-bis, of the Code, concerning electronic communications, as well as, more generally, Articles 5, paragraph 1, letter a) and 6, paragraph 1, letter a), of the GDPR, regarding the principle of lawfulness and the legal basis of consent for promotional purposes.

11.1.1. Illegal telemarketing in the telecommunications sector

During 2023, several important investigations aimed at combating the phenomenon of illicit promotional calls fueled by the so-called undergrowth of telemarketing, that is, by all those subjects who procure customers and contracts for the official sales network of large telecommunications and energy companies, have been concluded.

In the context of investigations into telemarketing in the telecommunications services sector, the Authority has adopted a corrective and sanctioning measure amounting to 100,000 euros, noting gaps in the information provided to the interested parties, resulting in violations of the principles of fairness and transparency; the lack of a legal basis for the processing of data for certain processing activities; some critical issues in the use of so-called soft spam conducted via SMS rather than via email, the only permitted method for making offers of products and services similar to those already purchased by the interested parties, even in the absence of specific, free, prior, and documented consent for marketing purposes (see Article 130, paragraph 4, of the Code); the inadequacy of the data retention periods for data processed for marketing and profiling purposes (provision of July 18, 2023, no. 321, web document no. 9920942).

With specific reference to the aforementioned retention, it was noted that the processing was in conflict with the principles of purpose, minimization, and limitation of retention, as the company had identified excessively extended terms.

On this occasion, the Guarantor established that, as also asserted by the company, the provision of February 24, 2005 "Fidelity card and guarantees for consumers," although no longer binding, was still to be considered applicable as a guideline and, therefore, so was the timing provided therein (24 months for data related to marketing; 12 months for data related to profiling). Moreover, while valuing the principle of accountability, even with reference to the delicate matter of data retention, one cannot certainly conclude that a holder, based on this principle which needs to be balanced with the other

fundamental principles provided by the Regulation, can deviate excessively from the aforementioned provisions without incurring a violation of the principle of limitation of retention (see Article 5, paragraph 1, letter d), of the GDPR).

Furthermore, in the Authority's opinion, the previous cases cited by the company could not be given weight (see provisions of April 24, 2013, document 120).

THE ACTIVITIES CARRIED OUT BY THE GUARANTOR THE ACTIVITIES CARRIED OUT BY THE GUARANTOR II 11

web n. 2499354 and May 30, 2013, doc. web n. 254783), as measures adopted by the Authority under different conditions and referring to the retention periods of data related to the purchase of luxury goods, that is, in relation to situations not adaptable to the case in question. In calculating the monetary sanction (euro 100,000), several factors were taken into account, such as the timely adoption of corrective measures, some of which were initiated immediately after the conclusion of the inspection assessments; the constant and fruitful collaboration with the Authority; the severe socio-economic crisis experienced by the sector and its heavy repercussions on the economic and financial situation of the company, which, however, at the same time, had decided to maintain its workforce unchanged and had proceeded with the internalization of personnel from other companies, otherwise destined for dismissal. In this way, the socio-economic function of the Authority's activity was also valued.

To complete the investigative activity that had already led to the adoption of a prescriptive and sanctioning measure against a telecommunications company (prov. November 12, 2020, n. 224, doc. web n. 9485681), the Authority adopted another measure (prov. February 23, 2023, n. 50, doc. web n. 9871886) against an agency of the sales network of that telecommunications company. This agency had acquired and communicated to the contracting company, between 2019 and 2020, contact lists containing personal data of approximately 4.3 million users in the telecommunications sector. The agency was accused of having operated, in the context of the procurement of the demographic lists, as an independent data controller and not as a data processor for the telecommunications company, a role it had assumed only in relation to the telephone contact activities of users for promotional purposes. The measure established that the agency had acquired demographic lists from third parties by independently contacting such parties, signing the relevant contracts in its own name, and subsequently transferring those lists into the telecommunications company's system. In this way, the so-called double passage of data was realized, from the list provider to the agency and from the agency to the telecommunications company, the latter of which occurred in the absence of free, specific, informed, and unequivocal consent from the data subjects, with the exclusive destination of the data (which merely represented a guarantee in the interest of the provider) and the prior authorization and subsequent validation of the data by the telecommunications company (functional solely to the entry of the lists into the corporate databases) being of no relevance in demonstrating the agency's role as mere data processor.

With the measure, in addition to the application of an administrative monetary sanction, the Authority imposed on the agency a ban on any further processing of the acquired data and the adoption of a procedure for acquiring demographic lists that would clarify for the data subjects the ownership of the various processing activities carried out and the legal basis for any data communications.

11.1.2. Illegal Telemarketing in the Energy Sector

Illegal telemarketing in the energy sector was also the subject of the Authority's enforcement action in 2023. In particular, in this area, the action of abusive agencies that, using the names of energy companies, made phone contacts in total disregard of the provisions regarding RPO and acquired contracts that they then managed to funnel into the customer management systems of energy companies, exploiting the weaknesses of such systems in terms of data protection and security measures, proved to be more penetrating.

In relation to the situations described above, the Authority adopted the measure of April 13, 2023, n. 184 (doc. web n. 9893718), following a long and articulated inspection activity initiated by the Financial Police and then continued by the Authority. The measure sanctioned four companies operating in the

Tuscan and Veneto territories that had created a widespread parallel organization capable of operating in the name of numerous energy companies, contacting various customers and proposing continuous changes of operator, even in the absence of economically more advantageous offers, in order to profit from commissions. The various agencies were interconnected, in some cases even at the corporate level, and none of them, except for one, was officially included in the sales network of the energy companies: all acted without any formal mandate and based on a fictitious, merely formal distribution of responsibilities in the field of privacy, with severe deficiencies in the adoption of effective security measures for the protection of their systems. With the measure, the Authority, for the first time, applied to the involved companies the accessory sanction of confiscation of the databases and demographic lists used for unwanted contacts and promotions, due to their type, their illegal origin, and the high probability of their reuse despite the prohibition of processing, as the companies had structured their entire business activity on the systematic violation of the provisions regarding the protection of personal data.

With reference to marketing in the energy sector, a measure was adopted against a call center active in the teleselling sector for the conclusion of electricity contracts. This same call center had already been the subject of a sanctioning measure in 2022, for...

failure to respond to the request for information pursuant to Article 157 of the Code (provision of October 20, 2022, no. 350, web document no. 98325449). From the investigative activity, the absence of information and consent emerged, as well as the inadequate management of requests to exercise rights (given that the certified email (PEC) designated for this purpose was found to be non-functional), as well as the failure to verify the contacts in the RPO. The Authority deemed it necessary to impose an administrative monetary fine of €60,000 considering that the company, despite the sanctioning provision of 2022 and even after the contestation raised, continued to evade the regulations regarding the protection of personal data (provision of November 30, 2023, no. 561, web document no. 9971433). The Authority has also adopted measures against two additional companies operating in the energy sector (provisions of April 14, 2023, nos. 181 and 182, web documents nos. 9893693 and 989463), which were subject to fines of €676,956 and €237,800, respectively, for failing to adopt suitable measures to ensure the traceability of all operations carried out on the platforms for submitting contractual proposals and for not demonstrating full awareness of all processing carried out within the telemarketing supply chain.

11.1.3. Illegal Activation of Telephone Cards

During the year, the activity to combat the illegal activation of telephone cards continued, a phenomenon that has seen a significant increase, resulting in serious violations of the regulations on the protection of personal data and which is potentially capable of creating further and much more alarming illegalities and constituting an obstacle to the prevention and repression of crimes, including those of an associative nature. Following an investigation initially launched against a telecommunications company, the Authority adopted provision no. 405 of September 14, 2023 (web document no. 9936215) against one of the main dealers of the aforementioned company: it was found that this dealer, who had his commercial establishments in Campania, had activated several telephone cards in the name of a citizen residing in Lombardy, without the latter ever having visited those stores, using a copy of the identity document of the customer of unknown origin and entering formally correct banking data into the systems of the telecommunications company that were not attributable to the same interested party. With the provision, the Authority imposed an administrative monetary fine on the dealer and prohibited any further processing of the interested party's data.

11.1.4. Use of Call Centers Located Outside the European Union

Also in 2023, with unchanged numerical consistency, notifications were received from holders who use call centers located outside the European Union, in accordance with the provisions of Article 24-bis of Decree Law no. 83/2012, as replaced by Article 1, paragraph 243 of Law no. 232 of December 11, 2016.

11.1.5. Evolving Scenarios in the Illegal Telemarketing Sector: The Code of Conduct

An important moment in the fight against wild telemarketing was marked by the approval of the code of

conduct for telemarketing and teleselling activities promoted by representative associations of clients, call centers, telesellers, list providers, and consumers (provision of March 9, 2023, no. 70, web document no. 9868813). The code will take effect once the accreditation phase of the Monitoring Body (ODM) is completed and the subsequent publication in the Official Gazette. The Authority has consistently worked with the proposing associations to provide clarifications that have allowed for the correct submission of the documentation approved by the Authority. From another perspective, following the full operation of the automated reporting system regarding telemarketing, launched on the institutional portal in November 2022, the Authority has initiated systematic and periodic data extractions from the thousands of complaints received. Based on the initial results of these extractions, investigations have been initiated, which are still ongoing, comparing the data with some elements collected from data controllers during inspection activities or other investigations. The online reporting collection system is therefore poised to become an essential tool to support the Authority's investigative activities in this sector. Considering the numerous feedback received from users regarding its operation, possible improvements to the system have been examined to facilitate its usability and use (introducing, for example, the option for authentication via SPID). All reporters, as previously mentioned, have been provided, automatically, with detailed information regarding the phenomenon of wild telemarketing and suggested some possible operational measures to take initial action against it.

11.1.6. Marketing and Profiling

The Authority has identified and promoted investigations and inspection checks aimed at verifying any critical issues in the processing of personal data in the context of loyalty cards. In this area, the Authority has sanctioned a well-known Italian company operating in the clothing sector with a fine of €240,000 (provision of April 27, 2023, no. 188, web document).

n. 9902472), for unlawfully processing the personal data of a significant number of customers and former customers, through an unlimited retention of personal data (receipt details and accumulated points) for marketing and profiling purposes and in the absence of adequate security measures. From the checks carried out, it emerged that the management database was accessible by all staff in the group's stores, present in 7 European countries, from any device connected to the internet, via a single password and a single account. Given the high number of affected individuals and the considerable duration of the violations, the company was ordered to adopt all necessary measures to comply with privacy regulations, to delete or anonymize the data of former customers dating back more than 10 years (without prejudice to ongoing litigation) and to implement adequate organizational solutions and security measures aimed at ensuring the proper retention of customer and former customer data in compliance with the principles of purpose and minimization of the GDPR. The Authority also adopted a measure against a well-known multibrand company (prov. June 8, 2023, n. 253, doc. web n. 9909907), sanctioning some violations of the regulations regarding data retention for marketing and profiling purposes and those related to the impact assessment on the rights of the data subjects. The Authority intervened following a report from a customer who, after an altercation with a store employee, found her loyalty card issued years ago canceled and a new, unsolicited card activated in the name of a non-existent person, in violation of the principles of integrity and confidentiality, fairness, and lawfulness. Furthermore, the information notice did not indicate the activities carried out through Facebook-Meta, which involved forwarding customers' email addresses to the American company. Regarding the e-commerce activity present on the site, despite conducting extensive profiling activities, it was found that the company had not established the impact assessment procedure required by the GDPR. The Authority instructed the data controller to define differentiated retention periods, distinguishing between processing for marketing purposes and processing for profiling purposes, and to delete or anonymize data that was found to be retained beyond the established terms. In determining the amount of the fine at 300,000 euros, the Authority considered the high number of subjects involved in the violations (approximately 2,400,000 individuals registered in physical stores or on the website), their duration, and the economic capacity of the company. The Authority sanctioned a company due to identified violations regarding the information notice (inadequate concerning the website and referring to activities not actually carried out by the company);

the consents obtained through the online form, for marketing and profiling purposes, as they were not freely given; the procedure for managing the right to object, which was incorporated into promotional phone calls, and the request to exercise rights; the absence of checks on the legality requirements within the supply chain of the partners promoting the company's products. Due to the failure to pay, even partially, the imposed fine, proceedings were initiated for registration (pursuant to Article 16, paragraph 3, of the Garante Regulation n. 1/2019) (prov. July 18, 2023, n. 323, doc. web n. 9925674). Finally, following the receipt of numerous complaints and reports, the Authority intervened against a university institution for which promotional SMS were being sent. The affected individuals, in addition to complaining about receiving unwanted communications, also reported the lack of response to requests for the exercise of rights. Following the investigation, as no corrective action had been taken by the data controller and the erroneous belief of being able to use legitimate interest as a legal basis for sending promotional SMS persisted, a corrective and prohibitory measure was adopted with a monetary sanction of 75,000 euros (prov. July 18, 2023, n. 393, doc. web n. 9939507).

11.1.7. Marketing through dark patterns and illicit databases

Following an inspection activity focused on the more general control of databases used for marketing, the Authority adopted a corrective and sanctioning measure in which it expressed for the first time its position on the use of dark patterns for the creation of interfaces aimed at collecting data and consents, a matter that has so far been primarily addressed in the consumer context but is also of significant importance for assessing the freedom of consent given for the processing of personal data. The measure also expressed principles and clarifications for operators regarding the creation of databases for marketing and the roles.

processing carried out by the various subjects in the supply chain, with particular regard to the responsibilities during the selection of database suppliers. The company was fined 300,000 euros (provision of February 23, 2023, no. 51, web document no. 9870014).

The Authority adopted a prohibition and sanctioning measure following a series of investigations aimed at identifying the subject who, presenting false personal details, proposed the distribution of promotional emails using lists created without an appropriate legal basis. Consequently, a fine of 5,000 euros was imposed on the data controller, prohibiting the use of the collected data (provision of March 2, 2023, no. 60, web document no. 9880317).

Following an inspection activity, the Authority adopted a corrective measure against a data controller that creates databases for marketing through a website for free advertisements. Considering that no significant illegalities had emerged, general principles were provided, particularly regarding the proper management of the roles of the various subjects involved in the data processing supply chain (provision of January 11, 2023, no. 9, web document no. 9861941).

Also regarding databases created illegally for marketing purposes, the Authority, following a complaint, adopted a prohibition and sanctioning measure in which general principles regarding the use of legitimate interest for marketing activities and the illegality of behaviors based on the use for promotional purposes of data provided by users for other purposes were illustrated. The company was fined 10,000 euros (provision of May 17, 2023, no. 202, web document no. 9899880).

11.1.8. Activities carried out in the context of consumer protection in electronic communication services

The Authority is present among the competent authorities to cooperate in the European network CPC (Consumer Protection and Cooperation) based on Regulation (EU) 2017/2394 of the European Parliament and of the Council on cooperation between national authorities responsible for the enforcement of consumer protection laws, which repeals Regulation (EC) 2006/2004, which came into force on December 12, 2017, and is applicable from January 17, 2020.

In particular, the Authority is competent to intervene in the event of violations of the rules laid down in Article 13 of Directive 2002/58/EC, implemented by Article 130 of the Code concerning unsolicited communications. To this end, the Authority has participated in a series of meetings with the European Commission and other competent European authorities in the field of consumer protection. The

meetings were aimed at initiating studies and discussions on issues of common interest and possible areas of cooperation.

The Authority also participates in the Task Force Consumer & Competition (TF C&C;), in order to increase opportunities for coordination at the European level between the areas of protection of data protection authorities and those under the jurisdiction of competition and consumer protection authorities. Currently, the work of the TF C&C; is focused on the development of guidelines regarding the interrelation between the GDPR and the Data Markets Act (DMA) (see chapter 21).

12. Electronic communication services and the internet

12.1. Meta Election Day Information (EDI)

The Authority adopted an urgent measure against Meta concerning the Election Day Information (EDI) functionality applied during the elections for the renewal of the Italian Parliament in September 2022 (provision of December 21, 2022, no. 448, web document no. 9853406).

Following this measure, the Authority activated two distinct procedures aimed at obtaining recognition of exclusive national competence to proceed. The Irish Authority recognized this competence of the Authority after assessing that the processing carried out by Meta through the EDI functionality substantially affects only Italian data subjects (in accordance with Article 56, paragraph 2, GDPR).

The Authority then notified the allegations of the alleged violations pursuant to Article 166 of the Code, concurrently initiating the relevant proceedings.

12.2. Retention of traffic data

Following an inspection activity initiated based on a complaint and a report, the Authority intervened against a...

****Holder, operator of electronic communication accessible to the public, offering SMS sending services via the web. In the decision, corrective and sanctioning, the illegality of the retention of the content of SMS messages was declared, inadequate measures for the retention of traffic data were noted, and a ruling was expressed regarding the legal bases to be used for conducting anti-fraud checks, providing some preliminary clarifications regarding the use of legitimate interest as a legal basis. The company was fined 80,000 euros (decision of January 11, 2023, no. 12, web document no. 9864063).****

****12.3. Data retention for judicial purposes****

Even in 2023, reports and complaints regarding the retention of telephone traffic data were received, albeit in fewer numbers compared to previous years, particularly concerning the lack of or delayed responses to requests for access to call logs for judicial purposes (civil and criminal). For these latter cases, a note was sent informing the reporter/complainant that, at first glance, based on the relevant regulations (essentially Articles 123 and 132 of the Code, as amended by Legislative Decree no. 132/2021, converted into law on November 30, 2021), access to call logs can be obtained through the ordinary judiciary in the context of a criminal proceeding and no longer by directly contacting the telephone company. The Authority has monitored the judicial follow-up of the measures adopted between 2020 and 2022 against a well-known telephone company (appealed by the same) regarding the previous regulations (Article 132 of the Code), which recognized the right of the accused/investigated to contact the Authority in case of denial (total or partial) by the company of the request for access made by the interested party (see chapter 20.2).

****12.4. Cookies and other personal data tracking tools****

Regarding personal data tracking tools, a procedure was initiated to verify the legality of the implementation by the main Italian publishing groups of a cookie wall mechanism whereby the failure to provide consent for receiving cookies prevents access to information sites. Following information gathered from four of the main national publishing groups, given the possible related violations, the Authority proceeded to send the required notices pursuant to Article 166, paragraph 5, of the Code. At the same time, the Authority opened an investigation—related to the subject matter—against a provider of electronic mail services. For this procedure as well, the Authority sent a communication

with the allegations of the alleged violations that emerged during the investigation phase. The Authority also initiated remote checks regarding the compliance of numerous websites with the obligations concerning the processing of users' personal data through cookies and other tracking tools, also following the receipt of a significant number of reports and complaints. In particular, the Authority, in collaboration with the Special Privacy and Technological Fraud Protection Unit of the Guardia di Finanza, conducted a series of targeted checks aimed at verifying compliance by various websites with the indications contained in the guidelines on cookies and other tracking tools adopted on June 10, 2021, which came into force in January 2022 (see paragraph 19.2).

****12.5. Processing of personal data online****

The Authority intervened against a sole proprietorship that, following lengthy and complex investigations, was found to be the owner of a website where numerous personal data such as names, addresses, and phone numbers, including those of individuals not listed in public telephone directories, had been published in list form for years. The site had been the subject of numerous reports since 2012 from individuals who had been included in this list without their knowledge and had been unable to exercise their right to erasure. Regarding another website, found to belong to the same owner, a similar prohibition and sanctioning measure had been adopted on May 26, 2022, no. 204 (web document no. 9780409). The absolute lack of references on the site and the use of constantly changing servers located abroad necessitated lengthy investigations to identify the owner of these websites. Given the seriousness of the violations detected, the high amount, and the fraudulent conduct, the sole proprietorship was fined 60,000 euros. With the decision in question, the Authority clarified that the creation of public telephone directories derived from information not extracted from the unique database - DBU is illegal (decision of May 17, 2023, no. 201, web document no. 9903067). The Authority requested the Special Privacy Unit of the Guardia di Finanza to conduct an inspection at the registered office of a holder who was engaged in promoting, via a website, the works of artists and their profiles. The company in question had not responded to the request for information made by the Authority following a complaint, in which the interested party had reported the continued presence of their personal data on the website despite...

the request for cancellation and the termination of the publication contract. With the initiation of the procedure, pursuant to Article 166, paragraph 5, of the Code, the violation of provisions of the GDPR was contested, in particular the dissemination of personal data on the web in the absence of an appropriate legal basis, the failure to respond to the request for the exercise of rights made by the interested party, and the failure to timely register the related opposition, in addition to the unjustifiably prolonged retention of the complainant's data.

From a complaint regarding the right to be forgotten concerning portals and search engines, the need to investigate emerged, first through written requests and then, as these were not found to be conclusive, through on-site verification, of the data processing related to the operators of said engines, with particular regard to the retention of browsing data and its communication to Google as well as the marketing and profiling activities indicated on their respective websites. The investigation revealed the grounds for some violations not only concerning the aforementioned data transfer but also regarding their collection (and subsequent processing) through forms related to websites and cookies, highlighting some mechanisms of consent that were not free and specific for the individual purposes of processing pursued.

In the provision, the Authority first addressed the aspect related to the search engine service offered within the aforementioned portals and attributable to Google LLC, also with reference to the corresponding roles in the processing of browsing data; in this regard, the Irish Authority was duly involved, as the lead authority pursuant to Article 56, paragraph 1, of the GDPR concerning the processing by the American company. Additional distinct aspects were also considered, such as the management of consents for marketing and profiling purposes, the processing of minors' data when activating email accounts, and the processing of excessive data (such as identity documents) for the closure of email accounts. Since the company intervened autonomously to correct many of the issues mentioned above, it was deemed appropriate to order, only with reference to the treatments shared

with Google LLC related to internet search, to provide suitable information describing such treatments and the related roles, also concerning the management of the rights of the interested parties.

12.6. Processing of personal data through connected devices

Following the collaboration, already initiated in 2021, with the Irish Data Protection Authority on the analysis of Ray-Ban Stories smart glasses, a connected and wearable device equipped with a voice assistant, designed and marketed by Facebook/Meta in collaboration with an Italian company specialized in the production and trade of eyewear, the Authority concluded the related investigation, gathering various information. In particular, the integration of the smart glasses with the WhatsApp messaging service, the characteristics of the device, and its modes of operation led to the conclusion regarding the applicability of the special regulation provided for in the e-Privacy directive. Therefore, as the single window mechanism provided for in Article 60 of the GDPR was not applicable, the Authority exercised its powers to conduct a targeted investigation from this perspective, identifying several possible violations, including those related to Article 122 of the Code and the general principles governed by the GDPR. Such alleged violations were notified and communicated to the data controller, pursuant to Article 166, paragraph 5, of the Code, for the initiation of the related procedure.

12.7. Activities regarding data processing through artificial intelligence systems

The need to ensure the protection of the rights and freedoms of the interested parties emerged with particular relevance in light of the new risks arising from the large-scale processing of personal data related to the creation and functioning of generative artificial intelligence services. In this regard, the Authority intervened against a U.S. company that manages a well-known relational artificial intelligence model capable of simulating and processing human conversations. Given the absence of information to users and all interested parties whose data had been collected by the controller and processed within the service, the absence of an appropriate legal basis to justify the collection and massive retention of personal data for the purpose of "training" the algorithms underlying the functioning of the platform, the non-correspondence of any of the information provided by the service to the actual data, and the consequent inaccuracy of the personal data subject to the processing activities of the controller, as well as the absence of any filter for verifying the age of users, the Authority adopted an urgent provision for the temporary limitation of the processing of personal data of interested parties established in Italian territory (provision of March 30, 2023, no. 112, web document no. 9870832).

In light of the information acquired and the willingness expressed by the controller to implement a series of concrete measures to...

****Protection of the Rights and Freedoms of Data Subjects****

The Authority has adopted a subsequent measure to suspend the provisional limitation (measure of April 11, 2023, no. 114, web document no. 9874702) on the condition that the data controller adopts a notice in the terms and manner provided for in Article 12 of the GDPR and makes it easily available, through a link, from the registration phase and in a position that allows it to be read before proceeding with registration; implements appropriate measures to ensure the exercise of the rights of data subjects and a tool through which to request and obtain the correction of any personal data or to proceed with their deletion; offers an easily accessible tool through which to exercise the right to object to the processing of their data collected during the use of the service for training algorithms if the legal basis is legitimate interest; modifies the legal basis for the processing of users' personal data for the purpose of training algorithms, eliminating any reference to the contract and adopting consent or legitimate interest as the legal basis for processing, in relation to the company's competence assessments, in a logic of accountability; includes an age-based filter (age gate) that excludes, based on the declared age, underage users; submits to the Authority a plan for the adoption of age verification tools; promotes a non-promotional information campaign on all major Italian mass media.

Against the same data controller, the Authority is continuing its investigative activity also within a task force established ad hoc within the European Data Protection Committee.

With reference to the processing of personal data through services based on LLM (large language

models), the Authority also adopted an urgent measure of provisional limitation of the processing of personal data of data subjects established in Italian territory carried out by a U.S. company that offers a chatbot, with written and vocal interface, based on artificial intelligence that generates a virtual friend (measure of February 2, 2023, no. 39, web document no. 9852214), noting the absence, in the information provided to users, of essential elements, the absence of a suitable legal basis to justify the various processing operations, as well as any filter for verifying the age of users both at the registration phase for the service and during its use.

Following subsequent discussions with the data controller, the Authority ordered the suspension of the aforementioned provisional limitation (measure of June 22, 2023, no. 280, web document no. 10013893) on the condition that the data controller presented Italian users with an updated notice, implemented an age verification filter (age gate) on all registration pages for services related to a "cooling-off period" aimed at preventing minors from entering a different date of birth when access to the services was denied, provided users in Italy with the ability to exercise their rights regarding personal data protection in a simple and effective manner, and submitted to the Authority a plan for the development of a process aimed at preventing access to the service by individuals under the age of 18, possibly accompanied by a subsequent prohibitive language analysis mechanism, as well as a plan for the implementation of functions that would allow users to report inappropriate content. The Authority is also continuing its investigative activity against this data controller.

Finally, the Authority has initiated an exploratory investigation into web scraping that will conclude in 2024 with the aim of acquiring observations, comments, and any operational proposals on the measures adopted and to be adopted by website and platform operators, both public and private, regarding the mass collection of personal data carried out through web scraping techniques by companies developing generative artificial intelligence systems for the purpose of training their algorithms (measure of December 21, 2023, no. 621, web document no. 9972593).

****12.8. Final Decision Schemes Pursuant to Article 60, Paragraphs 7 or 8, of the GDPR****

The Authority has adopted the final decision scheme pursuant to Article 60, paragraph 8, of the GDPR in a case concerning a company based in Cyprus (measure of April 27, 2023, no. 174, web document no. 9908362) based on a draft decision presented by the Cypriot Authority proposing the dismissal of an Italian complaint, as no violation was found on the part of the data controller, who, in the proceedings, claimed to be unrelated to the conduct complained of by the complainant. However, with this decision, it was deemed appropriate to inform the Cypriot Authority that the phenomenon of unwanted calls aimed at promoting online trading activities (the subject of the complaint) is assuming increasingly significant proportions in Italy, and from some reports and complaints received by the Authority, it is often inferred that there is involvement, in various forms, of data controllers or processors established in Cyprus. Therefore, the Cypriot Authority, which in these cases is the lead supervisory authority (LSA) under the GDPR, has been asked to monitor the phenomenon and to implement all suitable measures and strategies to carry out effective control actions.

12.9. European Cooperation Procedure Regarding Cross-Border Processing of Personal Data Carried Out by Information Society Service Providers

The one-stop shop mechanism, better known in its English formulation as "one stop shop," represents a unique shared decision-making system at the European level, based on the two complementary principles of cooperation (among supervisory authorities) and consistency (through the intervention of the EDPB and, in some cases, the European Commission). This mechanism, now in its fifth year of application, thanks to the experience gained and a series of guidelines adopted by the Committee, constitutes a well-established pan-European administrative system of constant and growing relevance, both quantitatively and qualitatively; it should be noted that cases of cross-border processing of personal data have become ordinary, especially in the context of information society services, where the legal principle of national territoriality has long lost its significance and effectiveness.

In 2023, cooperation procedures in the field of telematic networks increased by approximately 23% (see section IV, table 16), with a significant rise in cases involving amicable settlement procedures, a

method of amicable dispute resolution that combines the pursuit of prompt and satisfactory protection for complainants with the need to alleviate the workload on supervisory authorities. This procedure is utilized, as provided for in their respective national legislations, by the Irish and Dutch Authorities, based on the EDPB guidelines 6/2022 on amicable settlement and the EDPB guidelines 2/2022 on the application of Article 60 of the GDPR. In such investigations, the supervisory authority plays a mediating role between the data controller and the complainant, in order to resolve, where possible, the grievance raised in a complaint, particularly concerning complaints related to the rights set out in Articles 15 to 22 of the GDPR, where compliance by a controller with the exercise of a right by a data subject, in the absence of systematic criticalities, may justify the closure of the case without prejudice to the protection of the fundamental right.

On the merits, the issues addressed within the frameworks of cooperation and consistency are of particular interest and range from the legal basis for the processing of personal data for behavioral advertising purposes, to the protection of minors in the information society, to the processing of geolocation data, up to the issue of transferring personal data to third countries.

During the period of interest, with specific reference to the general trends in cooperation procedures, the prevalence of true cooperation procedures (Articles 60 et seq. of the GDPR) over the numerous preliminary procedures under Article 56 of the GDPR, namely the procedures related to the initial phase of identifying the lead authority and the concerned authorities, has been confirmed. This phenomenon is mainly due to the fact that, with regard to the most well-known data controllers (consider the large US providers of information society services and social networks established in Ireland), the respective lead authorities are now well-known, and the complaints for which they are competent are transmitted directly. Specifically, a considerable number of procedures handled by the Authority in relation to complaints lodged by Italian data subjects against controllers established in Ireland can be attributed to cooperation with the Irish supervisory authority. In relation to this type of procedure, a more efficient case management has been observed thanks to a standardized, albeit always personalized, handling of communications between the Garante and the Irish supervisory authority as well as between the latter and the complainants, through the Garante.

In the context of true cooperation procedures, there has been a constant increase, in line with the EDPB guidelines 2/2022 on Article 60 of the GDPR, in the search for a shared consensus between the lead authority and the concerned supervisory authorities from the investigative and pre-decisional phases, through the sharing of final investigative reports and the anticipation of draft decisions (which, as is known, are subject to a very strict procedure characterized by very tight deadlines) through informal consultation procedures or mutual assistance pursuant to Articles 60 and 61 of the GDPR. Cooperation has also been strengthened by the implementation, following the decisions made at the meeting of authorities held in Vienna.

in April 2022 (see 2022 Report, p. 177), of the specific regime provided for cases of strategic importance (strategic cases) by the EDPB based on a predefined selection procedure. The Authority has been actively involved, in collaboration with other supervisory authorities, in the joint handling of a case that the Authority had already outlined as a priority for the related topic (Internet of Things). The tool of informal consultation has been used, in particular, by the Irish Authority to share documentation related to the enforcement phase (compliance orders) of final decisions pursuant to Article 65, paragraph 6, of the GDPR, adopted in compliance with the binding decisions of the EDPB 2 and 3 of 2022 regarding the issue of the legal basis for the processing of personal data for behavioral advertising purposes by Meta in relation to Facebook and Instagram services. As is known, the debate on the validity conditions of consent in relation to the so-called pay or ok model is still ongoing and is being closely monitored by the Authority. The debate has further enriched in conjunction with the publication of the EU Commission's paper on the so-called cookie pledge, as well as with the recent approval by the plenary of the EDPB of the document in which it expressed its opinion on the matter (see para. 21.2).

In 2023, important investigations against large international data controllers established in the European Union were concluded as a result of the consistency mechanism. These are decisions that

express the effectiveness and vitality of the one-stop-shop mechanism and the strength of the dialogue between authorities on issues of indisputable complexity and relevance. Among the numerous final decisions in which the Authority has cooperated, particular interest is represented by the two binding decisions of the EDPB against Meta Platforms Ireland Ltd. (hereinafter Meta) and TikTok Technology Ltd. (hereinafter TikTok), to whose drafting the Authority participated as the interested supervisory authority.

The first binding decision (1/2023) refers to a draft decision shared by the Irish Authority regarding the transfer of personal data to the United States by Meta in relation to the Facebook service. The draft decision originated from an ex officio inquiry initiated on August 28, 2020, concerning the lawfulness of international transfers of personal data of individuals in the EEA who visit, access, use, or interact with the Facebook service, carried out by Meta based on standard contractual clauses, pursuant to Article 46, paragraph 2, letter d), of the GDPR, following the judgment of the Court of Justice of the EU delivered on July 16, 2020, in case C-311/18 (the so-called Schrems II judgment). Following the presentation of some motivated and relevant objections, on January 19, 2023, the Irish supervisory authority submitted the dispute to the EDPB pursuant to Article 60, paragraph 4, of the GDPR, thus initiating the dispute resolution procedure under Article 65, paragraph 1, letter a), of the GDPR itself.

By decision of April 13, 2023, the EDPB invited the Irish supervisory authority to impose an administrative monetary fine on Meta for the violation (already established by the Irish Authority in the draft decision) of Article 46, paragraph 1, of the GDPR, in line with the principles of effectiveness, proportionality, and deterrence, based on the assessment of the factors set out in Article 83, paragraph 2, of the GDPR, which are detailed, as well as the aggravating factors referred to in Article 83, paragraph 2, letters a), b), g), d), and k), of the GDPR. Applying for the first time the principles expressed in its guidelines 4/2022 on the calculation of monetary penalties, the EDPB qualified the violation in question as of high severity and indicated the initial amount for the further calculation of the fine at a level between 20 and 100% of the maximum applicable fine, taking as a reference the consolidated revenue of the group led by Meta Platforms, Inc. Regarding corrective measures, the EDPB in the cited binding decision invited the Irish supervisory authority to include in its final decision an order.

****Compliance Measures Regarding Processing under Chapter V of the GDPR****

1. The controller is instructed to cease, within six months from the date of notification of the final decision, the unlawful processing, including the retention, of personal data of users in the EEA transferred in violation of the GDPR to the United States.
2. On May 12, 2023, the Irish Authority, in compliance with the binding decision of the EDPB, modified its draft decision and adopted the final decision pursuant to Article 65, paragraph 6, of the GDPR, imposing an administrative fine of 1.2 billion euros on Meta (the highest fine ever since the GDPR came into force) and ordering compliance with transfers to third countries under Article 58, paragraph 2, letter d), of the GDPR within six months.
3. The second binding decision (2/2023) of the EDPB relates to a draft decision shared by the Irish Authority regarding TikTok. This draft decision originated from an ex officio investigation initiated on September 14, 2021, concerning TikTok's compliance with the obligations under Articles 5, 12, 13, 24, and 25 of the GDPR in relation to the processing of personal data of registered users on the TikTok platform aged between 13 and 17 years, as well as some issues related to the processing of personal data concerning minors under the age of 13 during the period from July 31 to December 31, 2020.
4. Following the submission of several relevant and justified objections, on May 10, 2023, the Irish supervisory authority referred the dispute to the EDPB pursuant to Article 60, paragraph 4, of the GDPR, thereby initiating the dispute resolution procedure under Article 65, paragraph 1, letter a), of the latter.
5. By decision dated August 2, 2023, the EDPB invited the Irish supervisory authority to include in its final decision the additional violation of the principle of fairness under Article 5, paragraph 1, letter a), of the GDPR, resulting in an extension of the compliance order originally provided in the draft decision

concerning the registration pop-ups and video publishing on the TikTok platform.

6. Regarding Article 25 of the GDPR, the EDPB considered, based on the elements available to it in the context of the consistency procedure, that it did not have sufficient information to definitively assess the existence of a violation of the principle of privacy by design during the reference period and invited the Irish Authority to amend the conclusion of the draft decision accordingly.

7. The participation of the Authority, also within the EDPB, in drafting the urgent binding decision (1/2023), pursuant to Article 66, paragraph 2, of the GDPR, approved by the EDPB on October 27, 2023, is also noteworthy. This decision relates to a request made by the Norwegian Authority for the adoption of definitive measures regarding the processing of personal data of individuals in Norway for online behavioral advertising (OBA) without adequate legal basis by Meta in relation to the Facebook service. Following the consistency procedure, the EDPB deemed it necessary to impose a processing ban under Article 58, paragraph 2, letter f), of the GDPR concerning the processing of data for OBA by Meta based on Article 6, paragraph 1, letters b) and f), of the GDPR throughout the EEA.

8. Lastly, it is worth mentioning the cooperation activity carried out regarding the procedure conducted by the French Authority concerning a company specialized in retargeting advertising, through tracking users' internet browsing on partner websites, for real-time bidding of personalized advertisements. The procedure was initiated by the French Authority following a series of complaints from Privacy International and NOYB and concluded with a final decision (shared by all supervisory authorities, without EDPB intervention) in which the French Authority, having established the violation of Article 7, paragraph 1, of the GDPR due to the lack of valid consent from users for the processing of their data for personalized advertising purposes, as well as Articles 12, paragraph 1, and 13 of the GDPR for informational deficiencies regarding the legal basis and purposes of processing, imposed an administrative fine of 40 million euros on the company.

13

The protection of personal data in private and public employment relationships

13.1. Processing of data via email

The Authority has adopted numerous measures regarding the processing of personal data carried out via email within the context of employment relationships. In this regard, it has been reiterated that, in this context, the processing must conform to the respect of the rights and fundamental freedoms as well as the dignity of the data subject, particularly when it concerns communications made via the email account, considering the particular protections that the legal system associates with different forms of communication. There is no doubt, in fact, that the protection of private life also pertains to the work environment, where relationships develop that express the personality of the worker (see Articles 2 and 41, paragraph 2, of the Constitution), also taking into account that the boundary line between the work/professional sphere and the strictly private sphere cannot always be clearly drawn (consider, in this regard, the extensive case law of the European Court of Human Rights on the matter – for all, see *Copland v. UK*, April 3, 2007 (application no. 62617/00), especially para. 41, and *Bărbulescu v. Romania* [GC], September 5, 2017 (application no. 61496/08), especially paras. 70-73).

All this matter lies at the crossroads between data protection regulation and sector-specific rules regarding remote monitoring, to which the national legislator has made explicit reference in the context of adapting the national legal system to the provisions of the GDPR (Articles 113, 114, and 171 of the Code; Article 88 of the GDPR; Articles 4 and 8, Law No. 300/1970 and subsequent amendments). In the reference year, the Authority adopted a measure against a company that, as the data controller, had kept active, after the termination of the collaboration (and not an employment relationship) with the complainant, the email account assigned to her with an extension related to the company; an automatic forwarding system to the sales director of incoming communications had also been set up, which allowed for viewing the content of the same account, to the extent that emails sent during the collaboration were produced in court. The Authority found that the conduct of the data controller had been carried out in the absence of an appropriate criterion of legitimacy for the processing, thus in violation of Articles 5, paragraph 1, letter a) and 6 of the GDPR. Furthermore, considering that it did not emerge that the data controller had provided the data subject with an appropriate notice regarding the

processing carried out on the email account, the Authority established the violation of Articles 12 and 13 of the GDPR, specifying that even in the context of pre-contractual negotiations, the obligation to inform the data subjects is also an expression of the general principle of fairness (Article 5, paragraph 1, letter a) of the GDPR). It was also established that the company, having not provided an appropriate response to the request for deletion submitted by the complainant, had violated Article 12, paragraph 4, of the GDPR with reference to Article 17 of the latter. For the violations found, the Authority imposed a monetary sanction. The data controller appealed the decision before the ordinary judiciary. With judgment of July 20, 2023, the Court of Reggio Emilia confirmed the Authority's measure, regarding the violation of Articles 5, paragraph 1, letter a) and 12 also with reference to Articles 17, 13 of the GDPR, although reducing the amount of the monetary sanction, declaring the non-existence of the violation of Articles 5, paragraph 1, letter c) and 6 of the GDPR (measure of January 11, 2023, No. 8, web document No. 9861827).

The issue of the processing of the individualized email account was also addressed by the Authority with reference to the internship relationship, following a complaint in which the unlawful processing of the account that had been assigned to the complainant within such a relationship was alleged. The Authority found that a consortium had kept the aforementioned account active by accessing the related communications after the interruption of the internship; it also emerged that the consortium had prevented the data subject from accessing the content of the account and had not provided him with appropriate information regarding the data processing. With the measure, it was established that the conduct of the data controller had violated Articles 5, paragraph 1, letters a) and c); 12 and 13 of the GDPR. In this regard, it was specified that the Authority's orientation, according to which the company on the communications exchanged via the individual email accounts of employees and collaborators. The Authority emphasized that the legitimate interest in ensuring the security of systems does not justify the systematic monitoring of private communications, which are protected by confidentiality guarantees. The treatment of personal data must always comply with the principles of legality, fairness, and transparency, as well as the minimization of data collection.

The Authority has reiterated that any monitoring of communications must be proportionate and must respect the privacy of employees and collaborators. It is essential to implement appropriate organizational and technical measures to ensure that personal data is processed in compliance with applicable regulations.

In this specific case, the Authority found that the company had violated several principles, including the principles of legality, fairness, and minimization, as well as the obligation to provide information as stipulated in Articles 5, paragraph 1, letters a) and c), and 13 of the GDPR. Consequently, the Authority imposed an administrative monetary fine (provision March 23, 2023, no. 93, web doc no. 9888206).

The Authority also addressed a complaint from a collaborator (not an employee) regarding the systematic access by the company's management to non-individualized accounts, which, although used by individual employees and collaborators, were linked to the company itself and a different controlled company. This access allowed the management to view email exchanges that had occurred through individualized accounts by reconstructing the "chain" of sent messages. With this configuration of the email management system, the company provided indications, requested clarifications, and expressed comments and evaluations (often critical) on the actions of employees and collaborators, leaving and/or copying all interlocutors of the original communication (in some cases including others), so that all participants in the conversation were informed of the content, including third parties (clients and consultants).

The Authority deemed the treatment illegal concerning multiple aspects, particularly for violating the principles of legality, fairness, minimization, and the failure to provide information as required by Articles 5, paragraph 1, letters a) and c), and 13 of the GDPR. It established that the legitimate need to ensure the continuity of communication flows within the company can and must be pursued through proportionate methods of managing email messages, refraining from systematic intervention in the actions of individual employees and collaborators, which was also made known to other

colleagues/collaborators, using expressions that were damaging to the dignity, including professional dignity, of the recipients, thereby interfering with the private and professional sphere of collaborators and employees. An administrative monetary fine was imposed on the company (provision March 23, 2023, no. 93, web doc no. 9888206).

system, albeit gradually, that led to the identification of the complainant as a user of the same systems, to the precautionary suspension of his account and, subsequently, to the blocking of the email account and the SIM card.

The provision reiterated that the employer has the obligation to clearly and specifically indicate to its employees and collaborators what the correct usage methods of the tools provided are and whether, to what extent, and in what manner, even following unforeseen or exceptional events, controls are carried out that must, in any case, comply with the principles of legality, proportionality, and graduality (see guidelines of the Guarantor for electronic mail and the internet, provision of March 1, 2007, no. 13, web doc. no. 1387522). Within the employment relationship, regardless of its nature, the obligation to inform the interested parties about the processing carried out or that one intends to carry out also constitutes an expression of the general principle of fairness (art. 5, par. 1, lett. a), of the GDPR).

With the decision adopted, the Guarantor established that the company, in the specific case, had failed to inform the complainant about the specific method of processing carried out through the controls conducted on the use of IT devices and the analysis of the data contained within the devices subject to return (subsequently subjected to forensic investigation), in violation of what is provided for by art. 13 of the GDPR as well as art. 5, par. 1, lett. a), of the GDPR. The company was imposed an administrative pecuniary sanction (provision of April 13, 2023, no. 127, web doc. no. 9891673).

There continues to be a significant number of cases submitted to the Guarantor regarding the management of corporate email accounts after the termination of the employment relationship. The Guarantor found that a company, in accordance with its internal corporate policy, had kept active the accounts assigned to two complainants for about two years from the day following the termination of the employment relationship, after deactivating and simultaneously redirecting them to a different corporate address.

With reference to the purposes of the processing thus carried out, the Authority first considered that, in relation to the facts subject to complaint, the company had not provided evidence of the specific elements that, immediately after the resignations of the complainants, would have caused the emergence of "numerous suspicions" regarding the correctness of their actions, and the consequent decision to adopt "extraordinary measures," compared to the ordinary procedures for processing the personal data of former employees. In reality, the company, based on what was ascertained, had in any case provided for the continued activity of the corporate account, without any reference to specific purposes pursued by the former employer and without establishing the duration of the processing carried out through the redirection.

The Guarantor therefore established that the systematic continued activity of the corporate account previously assigned, even after the termination of the employment relationship, through redirection to another employee's account, in the absence of any indication of a specific, explicit, and legitimate purpose pursued, is not compliant with the principle of data minimization (art. 5, par. 1, lett. c), of the GDPR) and of purpose limitation (art. 5, par. 1, lett. b), of the GDPR).

Furthermore, the absence of determinations regarding the duration of the processing, identified based on what was deemed appropriate in relation to the pursued purposes, is not compliant with the principle of storage limitation (art. 5, par. 1, lett. e), of the GDPR). Sending, then, to third parties who sent messages directed to the account of the former employee or collaborator, a message containing the indication that "the email address is no longer active," does not comply with the principle of fairness (art. 5, par. 1, lett. a), of the GDPR) as it may lead the aforementioned third parties to believe that the messages are not being processed by the company.

Finally, regarding the obligation to inform about the management methods of corporate email even after the termination of the employment relationship, the Authority considered that the mere inclusion

of informational documents within a community whose access is reserved for employees, upon registration, is not sufficient to fulfill the informational obligation provided for by the GDPR. The data controller should have at least invited all employees, with adequate periodicity, to review the documents containing internal rules on the management of email and the internet, highlighting their importance. The processing carried out by the company has therefore violated what is provided for by art. 13 of the GDPR as well as art. 5, par. 1, lett. a), of the GDPR which establishes the general principle of fairness of processing. The company was imposed an administrative pecuniary sanction (provision of April 27, 2023, no. 171, web doc. no. 9909235).

In a different case, the Guarantor, following a complex investigation initiated in response to a report, found that an insurance agency, after terminating the collaboration with two agents, had kept active the email accounts assigned to them during the collaboration for a considerable period of time (equal to 120 days). During this period, the emails in transit on the aforementioned accounts were redirected. to inform them about the specific purposes of the processing, the legal basis for the processing, the retention period, and the rights of the data subjects.

The Authority, therefore, concluded that the pension fund's actions constituted a violation of the principles of legality, data minimization, and storage limitation as outlined in Article 5, paragraph 1, letters a), c), and e) of the GDPR. Consequently, the pension fund was instructed to align its data processing activities with the provisions and principles regarding personal data protection. An administrative monetary sanction was also imposed (provision of June 22, 2023, no. 263, web document no. 9920814).

In relation to a complaint filed by a former employee of a pension fund, the Authority initiated an investigation, which revealed that the data controller had engaged in non-compliant conduct regarding the processing of the individualized corporate email account assigned to the complainant during their employment. Specifically, it was found that the pension fund, after the termination of the employment relationship with the complainant, had activated an automatic forwarding system to a shared account for electronic communications received on the account assigned to the complainant for a significant period of time, thereby gaining access to the content of those communications. This was confirmed not only by the statements of the fund itself but also by the selection of certain conversations deemed personally relevant to the complainant that were forwarded by the fund to the complainant at a different email address. For a considerable period, the fund had full operational access to the individualized account assigned to the complainant and the actual ability to manage it without any limitations, activating a system to forward incoming communications from that account to a different address accessible by multiple individuals.

Such conduct was deemed a violation of personal data protection regulations, particularly the principles of legality, data minimization, and storage limitation as set forth in Article 5, paragraph 1, letters a), c), and e) of the GDPR. Through the forwarding practice, the fund accessed, among other things, data belonging to special categories of data under Article 9 of the GDPR related to the complainant – and to third parties – (in particular, health data) in the absence of an appropriate legal basis and in violation of Article 9 of the GDPR. It was found that the complainant did not provide any consent after the termination of the employment relationship for the processing of health-related data by the fund as required under Article 9, paragraph 2, letter a) of the GDPR. It was also noted that the fund's conduct was carried out without adequate information regarding the monitoring that the employer would conduct on the electronic tools assigned to the complainant after the termination of the employment relationship.

The Authority reminded that the data controller must regulate how the processing will be carried out in accordance with data protection regulations before such processing takes place, explicitly stating this in appropriate informational documents. Furthermore, the content of the information must comply with data protection regulations, as it is not sufficient to inform the data subject of the essential characteristics of the processing; it is also essential to inform them about the specific purposes of the processing, the legal basis for the processing, the retention period, and the rights of the data subjects. that the information provided outlines operations of processing that are lawful in themselves. The

Authority therefore deemed the conduct of the fund to be in violation of Article 13 of the GDPR (a corollary of the principle of transparency set forth in Article 5, paragraph 1, letter a), of the same GDPR) and with the general principle of fairness (see Article 5, paragraph 1, letter a), of the GDPR) and ordered the application of an administrative pecuniary sanction (Article 58, paragraph 2, letter i), of the GDPR) (provision of December 21, 2023, no. 602, web document no. 9978536).

In the insurance sector, there is also a report of a reprimand against an insurance company for the unlawful processing of an employee's data (use and retention of corporate email) following the violation of Articles 5, paragraph 1, letters a), c), e), and f); 12 and 13 of the GDPR (provision of August 31, 2023, no. 464, web document no. 9942133); specifically, considering the limited duration of the violation, the involvement of only one data subject, as well as the deletion of the email account requested by the data subject, the case was classified as a "minor violation" (pursuant to recital 148 of the GDPR).

****13.2. Exercise of Rights****

Also in the reference year, there was significant case law regarding the failure to respond or inadequate responses to requests for the exercise of rights presented in relation to processing carried out during the employment relationship. The Authority, reiterating its established guidelines on the matter, has repeatedly referred to the Guidelines 01/2022 on data subject rights - Right of access, 2.0., adopted by the EDPB on March 28, 2023.

In particular, the Authority reiterated that the data controller has the obligation to respond to requests for the exercise of rights presented by the data subject by providing the requested information within the timeframe indicated in Article 12, paragraph 3, of the GDPR or, if unable to comply with the request, informing the data subject without delay and in any case within one month of the request regarding the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority and of seeking judicial remedy (Article 12, paragraph 4, of the GDPR).

Furthermore, it was reminded that the data subject's right to access the information provided for in Article 15 of the GDPR cannot be considered satisfied solely by having provided the information required by Articles 13 and 14 of the GDPR, as this right and the so-called right to information, although related legal positions, constitute rights enshrined in distinct provisions of the legal framework, responding to needs for protection and guarantee of the data subject that are not completely overlapping.

Following a complaint lodged against a company, the Authority found that the company had not provided an adequate response to a request for access and deletion concerning data acquired from a video surveillance system at a condominium. In particular, the data controller company was reprimanded for failing to comply with the provisions of Article 12 of the GDPR with reference to Articles 15 and 17 of the GDPR because, in response to a request submitted via certified email and in the absence of evidence of the data subject's intention to receive information on the matter orally, it did not appear that a written response or other suitable means had been provided.

The Authority emphasized that in responding to requests for the exercise of rights, the data controller must adapt the information indicated in necessarily general terms in the privacy notice (or in the register of processing activities) to the specific condition of the data subject, tailoring the information in light of the concrete processing operations carried out (provision of January 26, 2023, no. 27, web document no. 9865404).

****Right of Access and Right to Deletion****

****ACTIVITY CARRIED OUT BY THE AUTHORITY****

****ACTIVITY CARRIED OUT BY THE AUTHORITY****

****13****

Following the submission of a complaint against a company that was subsequently subject to a merger by incorporation, the Authority, in light of Article 2504-bis of the Civil Code and considering the provisions regarding merger and demerger operations adopted by the Authority (provision of April 8,

2009, web document no. 1609999), reprimanded the incorporating company for failing to provide an adequate response to the request for access to the document of evaluation of the complainant. The response provided was, in fact, devoid of any information in addition to the requested data.

In this regard, the Authority referred to the orientation of the jurisprudence of legitimacy according to which the right of access to data "cannot be understood, in a restrictive sense, as the mere right to know any new and additional data compared to those already in the knowledge and, therefore, in the disposal of the same data subject interested in the processing of their own data, given that the purpose of the [right] is to guarantee, in protection of the dignity and privacy of the data subject, the verification *ratione temporis* of the occurrence of the insertion, permanence or removal of data, regardless of the circumstance that such events had already been brought to the knowledge of the data subject by other means, verification carried out through access to the data collected about oneself at any time during their relational life" (Supreme Court, December 14, 2018, no. 32533). The request of the worker to access their personal file constitutes, in fact, a subjective right that is protected as such and derives from the employment relationship. According to the judges of...

legitimacy the aforementioned right derives, even before the regulations concerning personal data protection, from the "respect for the principles of good faith and fairness that burden the parties in the employment relationship pursuant to Articles 1175 and 1375 of the Civil Code" (Court of Cassation, April 7, 2016, no. 6775). Considering that the data controller had declared, without providing any evidence, to have orally provided the data subject with some of the information requested in the access request during an interview, the Authority recalled that Article 12, paragraph 1, of the GDPR specifies that the responses of the data controller to the data subject must be provided in writing or by other means, including, where appropriate, by electronic means, and that only if requested by the data subject can the information be provided orally. The Authority reminded that Article 5, paragraph 1, letter a), of the GDPR states that personal data must be processed transparently (even when the processing is carried out within the employment relationship); in this context, the obligation to process data transparently also derives from the principle of fairness, so that the data controller, in response to a specific request from the data subject, is required to provide adequate information regarding the methods of data processing. In the case at hand, such information was provided adequately only during the investigation.

It was also clarified on this occasion that the right, recognized for the data subject, to access the information provided for in Article 15 of the GDPR cannot be considered satisfied solely by having provided the information referred to in Articles 13 and 14 of the GDPR. The conduct of the company was therefore found to be in violation of Articles 5, paragraph 1, letter a) and 15 of the GDPR (provision of March 2, 2023, no. 55, web document no. 9873272). Following a procedure initiated as a result of the submission of several complaints by employees of a company who had reported the lack of response to repeated requests for access to their data contained in the attendance tracking system via badge, the Authority found, also through inspections delegated to the Special Privacy and Technological Fraud Unit of the Guardia di Finanza, that the data controller had not provided any response to the data subjects despite having claimed otherwise during the investigation.

In particular, the Authority deemed the response through the hand delivery of the data subject to the aforementioned requests not compliant with Articles 12 and 5, paragraph 2, of the GDPR since the communication was not documented and was contested by the complainants. The Authority also reiterated that the current regulations do not require the request to exercise rights to take on a particular formal appearance, and stated that the data controller is required to respond to the data subject even if it does not comply with the latter's requests (e.g., because it no longer holds the data), specifying the reasons and informing about the possibility of lodging a complaint with the supervisory authority and of bringing a judicial appeal (Article 12, paragraph 4, of the GDPR).

Finally, it was determined that the signing of a conciliation report, related to the position of one of the complainants, which concerned purely labor-related aspects and not those related to data protection, is not sufficient to determine the closure of the procedure against the company, also considering that the power of verification attributed to the Authority is not dependent on the initiative of the parties (see

on this point Cass., ord. September 22, 2021, no. 40635: although referring to the regulatory framework prior to the amendments of Legislative Decree no. 101/2018, the current Articles 57 of the GDPR and 154 of the Code similarly regulate the powers of the Authority). An administrative pecuniary sanction was imposed on the company for the violations found (provision of March 9, 2023, no. 66, web document no. 9874604).

Also in the matter of exercising rights, the Authority, following the submission of ten complaints by fifty employees, adopted a provision sanctioning a company for failing to provide any response to requests for access to certain data, including payroll data. Only after the opening of the investigation did the company respond to the complainants stating that it did not consider it "appropriate" to respond to the requests for the exercise of rights, given what is provided for in Article 2-undecies, paragraph 1, letter e), of the Code. Examining the conduct of the data controller, the Authority imposed an administrative pecuniary sanction for the violation of Articles 12 and 15 of the GDPR and also ordered the company to fully satisfy the access requests of the complainants by integrating those already provided during the investigation. As for the data that the company considered to be independently accessible by the complainants, the Authority held that the data controller should have provided a response, even if only with the mere indication of the platform on which to find the requested data; this also due to the fact that, contrary to what was claimed by the data controller, the disclosure of the requested data would not have caused an effective and concrete prejudice to the exercise of a right in judicial proceedings. Therefore, with regard to these specific data, it could not, in practice, be considered that the prerequisite referred to in letter e) of paragraph 3 of Article 2-undecies of the Code existed. As for the data that the company had...

****Considered that it could not provide****

as the disclosure of the same would have caused it prejudice in terms of defense in court, such conduct has been deemed in violation of Article 12, paragraph 4, of the GDPR with reference to Article 15 of the GDPR, as repeatedly noted by the Authority (see above). Furthermore, based on Article 2-undecies of the Code, the delayed exercise, limitation, or exclusion of the exercise of the rights recognized by the GDPR can only be ordered for the time and to the extent that it constitutes a necessary and proportionate measure, with a reasoned communication provided without delay to the data subject. The aforementioned communication may not be sent only if it "could compromise the purpose of the limitation." This circumstance has been deemed not to be present in the case at hand. It has finally been noted that the temporal scope of the limitation of the right of access is confined to what is strictly necessary to avoid prejudice to the exercise of the right (see Article 2-undecies, paragraph 3, of the Code) and therefore, once the reasons for the prejudice have ceased, no obstacle can be placed to the exercise of the right provided for in Article 15 of the GDPR. The Authority has also highlighted that the 90-day deadline referred to in Law No. 689/1981, Article 14, does not apply to the proceedings before it, but rather the timeframe specifically identified by the Authority, pursuant to Article 154, paragraph 3, and Article 166, paragraph 9 of the Code, with the Authority's regulation No. 2/2019 (provisions of June 22, 2023, No. 264, web doc No. 9909702 and November 16, 2023, No. 529, web doc No. 9960854). The Authority dealt with two requests for access to personal data contained in an investigative report commissioned by the employer. In a case where the investigative activity concerned only the aspect related to the exercise of rights, and not also the legitimacy of the collection carried out by the appointed investigative agency, the complainant had complained of having learned of the existence and content of the investigative report only at the time of the establishment of the data controller in the appeal against the dismissal proposed by the complainant himself before the competent judicial authority, despite having repeatedly submitted requests for access to the data used to raise the disciplinary charge that followed the dismissal. The Authority preliminarily reiterated some firm points regarding the right of access, relating them to the facts subject to the complaint. First of all, the requests for access to their own data made by the complainant are to be qualified as the exercise of the right of access guaranteed by Article 15 of the GDPR even if this provision was not expressly cited in the requests (in accordance with what was indicated on this point by the EDPB, Guidelines 01/2022 on data subject rights - Right of access, March 28, 2023, 3.1.1, No. 47). Furthermore, it is not compliant with what is established by the same Article 15 to ask the data subject for a detailed

indication of the documents to which access is requested, in order to be able to respond to the access request. Moreover, in this case, the complainant's request was anything but generic, referring expressly to all the data used to make the disciplinary charge. On this point, the aforementioned Guidelines 01/2022 on data subject rights - Right of access have also intervened, stating that the request for access to personal data generally concerns all data held by the data controller and that the latter may have doubts about the content of the request only if it has been formulated in extremely generic terms (see in particular paragraph 2.3.1, No. 35). The Regulation also does not impose any requirement on data subjects regarding the form of the request for access to personal data (see also the Guidelines 01/2022 on data subject rights - Right of access, paragraph 3.1.2, No. 52). That said, the Authority has established that Article 15 of the GDPR, in defining the subject of the right of access, also includes the "categories of personal data" as well as, in cases where the data is not collected from the data subject, all "the information available on their origin" (see Article 15, paragraph 1, letters b) and g), of the GDPR). Therefore, the company, in response to the access request, taking into account the origin of the data used to raise the disciplinary charge, should have provided all the data collected with the investigative report, also considering the presence, within it, of categories of data relating to the complainant (photographs, a GPS survey, descriptions of places, people, and situations) that were not transferred in the disciplinary charge. Finally, if the employer had deemed that, in the specific case, one of the concrete conditions provided for by Article 2-undecies of the Code was present, it should have communicated this to the data subject with a reasoned response, as also established, in general terms, by Article 12, paragraph 4, of the GDPR. The conduct of the data controller has also been deemed non-compliant with the general principle of fairness of processing (Article 5, paragraph 1, letter a), of the GDPR).

For the violations identified, the company was subjected to an administrative monetary sanction (provision of July 6, 2023, no. 290, web document no. 9927300).

With a different provision, the Authority established the unlawfulness of the conduct of a company that had failed to respond to a detailed request for access to the personal data used for the dismissal of an employee. Only after the complaint was submitted to the Guarantor, during the proceedings initiated on the case and following the inspection carried out by the Special Privacy and Technological Fraud Protection Unit of the Guardia di Finanza, in light of the absence of a response to the Authority's requests, did the data controller send a response to the complainant and transmit the report from the investigative agency used for the disciplinary contestation and subsequent dismissal.

In particular, the absence of any response to the request to exercise the right was deemed contrary to Articles 15 and 12 of the GDPR, with the stated purpose, according to the data controller, of avoiding prejudice to the company's right of defense in the event of an appeal against the dismissal of the interested party. According to the referenced norms, in fact, the data controller should have provided the complainant with a response indicating the reasons for non-compliance and the possibility of filing a complaint with the Guarantor or an appeal to the ordinary judicial authority (Article 12, paragraph 4, of the GDPR; Article 2-undecies of the Code). Regarding the failure to respond by the data controller both to the request to exercise the right of access and to the Authority's requests, the provision referenced the orientation of the Court of Cassation according to which the responsibility for the failure to read a communication/notification received via PEC is to be attributed to the entrepreneur, if resulting from a deficiency on their part regarding the maintenance and control of the mailbox (see Court of Cassation no. 13917/2016).

In the specific case, a violation of the deontological rules related to the processing of personal data carried out for defensive investigations or to assert or defend a right in court was also established, published pursuant to Article 20, paragraph 4, Legislative Decree no. 101/2018, where such rules establish that the assignment must be conferred in writing and specifically mention the right intended to be exercised in court, or the criminal proceeding to which the investigation is connected, as well as the main factual elements justifying the investigation and the reasonable time within which it must be concluded (Article 8, cited deontological rules). The company had indeed orally conferred the assignment to an investigative agency to carry out defensive investigations against the employee, thus

violating one of the conditions of lawfulness of the processing (see Article 2-quater, paragraph 4, of the Code). An administrative monetary sanction was applied to the company (provision of July 6, 2023, no. 292, web document no. 9924466).

The Authority dealt with a complaint concerning a generic response provided by the data controller to a request for the exercise of the right of access to the personal data of the complainant processed within the context of an employment relationship that was no longer in effect and for the deletion of the same. The Authority reiterated that the request for access to personal data can also be made in relation to data processed based on a legal obligation or data already made available to the interested party or already delivered to them. The purpose of the right of access is indeed to allow the interested party to verify (even at "reasonable intervals" of time: see recital 63 of the GDPR) whether a specific processing is ongoing and to assess its lawfulness and correctness (also taking into account that the methods and number of data processed may change over time). Article 15 of the GDPR does not impose any limitation regarding the information related to the interested party that may be subject to access, and the GDPR expressly provides for the possibility that the interested party submits multiple access requests (subject to the possibility for the data controller).

****Request for access and deletion of data after the termination of the employment relationship****

****ACTIVITIES CARRIED OUT BY THE GUARANTOR****

****ACTIVITIES CARRIED OUT BY THE GUARANTOR****

processing, in the case of "excessive requests, particularly due to their repetitive nature," to charge a reasonable fee; Article 12, paragraph 5, of the GDPR). Regarding the request for the deletion of data processed following the termination of the employment relationship with the complainant, the Authority established that the company should have provided a specific response, while clarifying that some personal data related to the worker must be retained by the employer based on sector regulations. In accordance with Article 12, paragraph 4, of the GDPR, the data controller should have informed the data subject of the reasons for not fulfilling the request or for providing a partial response, as well as the remedies available against such a decision.

The data controller had responded to the data subject during the proceedings. However, the Authority found that the response to the access request was still not adequate to meet the requirements set forth by the regulations on personal data protection. The company was ordered to comply with the request to exercise the right of access by the data subject to the data still held, and an administrative monetary sanction was imposed (provision of July 18, 2023, no. 318, web document no. 9929053).

With the provision in question, the Authority reiterated its stance on the right of access to data processed within the employment relationship, particularly concerning data related to the processing carried out by the employer to calculate working hours and mileage reimbursements. It was noted that it cannot be considered sufficient, to comply with Articles 12 and 15 of the GDPR, to provide a response if the latter is found to have inadequate content. In this specific case, it was established that the data controller, despite having provided a response, did not give a complete answer to the analytical and clear requests for the exercise of rights. The company, in particular, had limited itself to indicating the methods and purposes of the processing without communicating the specific data related to the complainants (processed, among other things, through the terminal provided to them in the context of their work performance) nor the information requested by the complainants regarding the aforementioned processing.

Considering that the company, as the data controller, had processed, among other things, data related to the geolocation of smartphones provided to the complainants for the performance of their work and, therefore, data of the complainants (specifically, at least, their geographical position at the time of reading the water, gas, and electricity meters to which they were assigned), it should have provided them with the data related to the specific readings/geographical coordinates obtained with the GPS of the smartphone activated by the workers in proximity to the meter for its reading.

The Authority, in light of the non-compliant conduct with data protection regulations, imposed an administrative monetary sanction and ordered the company to fulfill the access requests of the

complainants, providing them with the data related to them as well as the information expressly requested in the requests, excluding what had already been limitedly indicated (provision of September 14, 2023, no. 403, web document no. 9936174).

Following the submission of a complaint, the Authority found the non-compliance with data protection regulations in the conduct of a company regarding access requests for training certificates made by a former employee. In particular, it was established that there was a violation of Articles 12 and 15 of the GDPR for the data controller's failure to provide an adequate response to an initial access request, not having clarified, in accordance with Article 12, paragraph 4, of the GDPR, the reason preventing access to the training certificates nor indicated the right to lodge a complaint with the Authority or to seek judicial review in the event of denial.

145

Right of access to geolocation data

Right of access to professional training certificates

REPORT 2023IIII13

Failure to respond to the request for the exercise of rights expressed. It was also established that even following a second access request, the data controller had not provided an adequate response to the data subject. Furthermore, considering that the company had not provided any response to the information request made by the Authority, to the extent that it was necessary to request the intervention of the Special Privacy and Technological Fraud Protection Unit of the Financial Police, a violation of Article 157 of the Code was also established.

In light of the violations found, the Authority imposed an administrative monetary sanction on the data controller (provision of October 12, 2023, no. 475, web document no. 9965598).

In a particular case, the data controller had justified the lack of response to a request for the exercise of rights from one of its employees due to the breadth and generality of the information requested. In this specific case, the Authority noted that, in light of the declared difficulty in fulfilling the request for the exercise of rights within the timeframes set by the regulations, the company had not availed itself of the option recognized by the GDPR to address the data subject with appropriate specifications, nor had it informed the requester of the reasons for the delay, thereby failing to comply with the provision of Article 12, paragraph 3, of the GDPR.

GDPR (as reiterated in the Guidelines 01/2022 on data subject rights - Right of access, 2.0, cited). For the violations identified, an administrative monetary sanction was imposed (provision of November 16, 2023, no. 530, web document no. 9960875, similarly also provision of June 1, 2023, no. 230, web document no. 9917820). Among the other reasons put forward by the data controllers to justify the lack of response to requests for the exercise of rights, the argument related to organizational and coordination difficulties among various organizational units is often cited. Therefore, in another case, the Authority clarified that such arguments cannot serve as a valid reason for excluding liability, based on established case law which, in the context of administrative violations, establishes that good faith excludes liability where "the offender can demonstrate that they have done everything possible to comply with the legal norm" (see, among others, Cass. II civil section no. 10841/2008). In a similar sense, the provision contained in Article 24 of the GDPR obliges the data controller to implement "appropriate technical and organizational measures to ensure (...) that the processing is carried out in accordance with the Regulation." For the violations identified, an administrative monetary sanction was imposed (provision of March 9, 2023, no. 67, web document no. 9877728).

13.3. Processing of Biometric Data

The Authority, following the submission of a complaint, found that a company had installed a presence detection system based on biometric technologies. In particular, during the investigation, it was established that the system, based on fingerprint recognition, had involved 13 employees and had been implemented at two operational sites for about 2 years. This system had been removed during the proceedings and replaced with a badge-based detection system. In line with an established orientation, the Authority reiterated the general rules applicable to the processing of biometric data, to

be followed both during the so-called enrolment phase, consisting of acquiring the biometric characteristics (in this case, fingerprints) of the data subject (see points 6.1 and 6.2 of Annex A, provision of November 12, 2014, no. 513, web document no. 3556992), and during the biometric recognition phase, at the time of presence detection (see also point 6.3 of Annex A to the cited provision).

The Authority also reminded that the processing of biometric data is permitted only when one of the conditions indicated in Article 9, paragraph 2, of the GDPR is met and, with regard to processing carried out in the workplace, only when the processing is necessary to fulfill the obligations and exercise the specific rights of the data controller or the data subject in the field of labor law and social security and social protection, as provided for by national or Union law or based on a collective agreement, and in any case in the presence of appropriate safeguards for the fundamental rights and interests of the data subject (Article 9, paragraph 2, letter b), of the GDPR; see also, Article 88, paragraph 1 and recitals 51-53 of the GDPR). For the purposes of evaluating the case subject to the complaint, the Authority took into account the legal provision of Article 9, paragraph 2, letter b), of the GDPR, which establishes the conditions under which the processing of biometric data can be lawfully carried out in the workplace, as well as what is provided for by Article 2-septies of the Code, according to which such processing must take place “in accordance with the safeguards established by the Authority” in relation to each category of data. Therefore, with reference to the examined case, the Authority established the unlawfulness of the processing carried out, as the use of biometric data for the ordinary management of the employment relationship (such as the activity of presence detection) does not appear to comply with the principles of minimization and proportionality of processing, as well as legality, fairness, and transparency (Article 5 of the GDPR). Among other things, the Authority deemed the information provided by the company to be entirely inadequate, as the company had not informed the employees of the essential characteristics of the biometric device as required by Article 13 of the GDPR. For the violations identified, an administrative monetary sanction was imposed (provision of September 14, 2023, no. 404, web document no. 9940565).

13.4. Processing of Health Data

Following the submission of a complaint, it was established that a company had engaged in conduct not compliant with the personal data protection regulations during the selection procedure of the complainant in the context of training internships aimed at hiring under Law no. 68/1999. In particular, the company had processed sensitive data (now data belonging to special categories) of the complainant as the data controller in the absence of an appropriate legal basis. The company, in fact, after receiving the complainant's name from the competent employment office and after inviting them for an interview with the commercial representative of the corporate group to which the company belongs, deemed it necessary to conduct a “pre-analysis” of the medical documentation by the competent doctor to evaluate the actual inclusion of the complainant. Therefore, it requested the complainant to send the documentation related to the medical examination report/conclusive report prepared by the integrated medical commission and, upon receiving the communication containing the link from which to download the medical documents, had... forwarded the aforementioned communication to the competent doctor. By doing so, it had demonstrated that it had material availability of the documents containing specific data of the complainant.

It was noted, in this regard, that the violation occurred on a date prior to the full effectiveness of the GDPR, but that the rules involved in the violation, in force at the time of the incident, were identical, in content, to those currently provided for by the GDPR. Therefore, with reference to the described conduct, it was established that the Company had violated Articles 11 and 26 of the Code, in the version prior to the amendments made by Legislative Decree No. 101/2018, provisions that correspond to Article 9 of the GDPR which, in turn, constitutes an expression of the principle of lawfulness of processing (Article 5, paragraph 1, letter a), of the GDPR).

The unlawfulness of the processing was also noted in relation to specific sector regulations applicable, in particular Legislative Decree No. 81/2008 and Law No. 68/1999. The Authority also established that

the processing of the aforementioned data by the company had been carried out without providing adequate information to the data subject, pursuant to Article 13 of the Code, in the version prior to the amendments made by Legislative Decree No. 101/2018, now reproduced by Article 13 of the GDPR, which constitutes a direct expression of the principle of transparency (see Article 5, paragraph 1, letter a), of the GDPR); in particular, the purposes of the processing and the recipients of the collected data had not been clearly communicated.

Considering that the obligation to inform a job candidate pursuant to Law No. 68/1999 is an expression of the general principle of fairness, the principle of fairness, provided for by Article 11, paragraph 1, letter a), of the Code, in the version prior to the amendments made by Legislative Decree No. 101/2018, which now corresponds to Article 5, paragraph 1, letter a), of the GDPR, was also found to be violated.

During the investigation, the inconsistency of the conduct held by the company regarding requests to exercise the right of access (aimed at knowing the name of the competent doctor and the reason behind the opinion expressed by him regarding the unsuitability) was established, and thus the violation of Articles 12 and 15 of the GDPR was noted, considering that the conduct, which began before the full effectiveness of the Regulation, continued thereafter.

The principle of purpose limitation (set forth in Article 11, paragraph 1, letter b), of the Code, in the version prior to the amendments made by Legislative Decree No. 101/2018, which today corresponds to Article 5, paragraph 1, letter b), of the GDPR) was also found to be violated since, after requesting the complainant for medical documentation to send to the competent doctor for the pre-employment visit, the company communicated the aforementioned data to the competent doctor for the preparation of a preliminary opinion.

In light of the identified violations, the Authority imposed an administrative pecuniary sanction (provision of June 8, 2023, No. 245, web document No. 9924438).

During the investigation, the Authority deemed it appropriate to admonish the then competent doctor of the company for having processed the sensitive data of the complainant (among others, the health data contained in the report of the medical commission for the assessment of disability, even in the version without omissions) as the data controller without providing the necessary information to the data subject.

In this regard, the Authority's orientation regarding the position of the competent doctor as an autonomous data controller concerning processing aimed at assessing the worker's suitability for the job was recalled (see, for example, provision of April 27, 2016, No. 194, web document No. 5149198; but also see, with particular regard to the management of health and risk records by the competent doctor and the different activity of maintaining and updating the personal files of employees by the employer, the guidelines on the processing of personal data of workers for the purposes of managing the employment relationship with employers, web document No. 1364939) (provision of August 31, 2023, No. 522, web document No. 9965614).

13.5. Video Surveillance in Private Sector Workplaces

In the reference year, following a report from a union and the related on-site inspection activity, the Authority adopted an administrative pecuniary sanction against a company for the established violation of Articles 5, paragraph 1, letter a), 88 of the GDPR and Article 114 of the Code.

In particular, from the investigation it emerged that the company had installed and used surveillance systems at a multitude of its sales points, capable of recording workers during their work activities, in the absence of an agreement with the trade union representatives or authorization issued by the Labor Inspectorate pursuant to Article 4 of Law No. 300/1970. The activation of the guarantee procedure referred to in the aforementioned Article 4, in fact, occurred only after a significant period of time following the installation and activation of the surveillance systems. Consequently, the processing was found to be unlawful, in some cases, until the deactivation of the cameras following the intervention of the Labor Inspectorate and, for others, until the stipulation of the agreement or the issuance of the

authorization. The aforementioned guarantee procedure, as repeatedly emphasized by the case law of legitimacy, "protects collective and super-individual interests," so the conduct of the employer who does not activate it will harm the collective interests that this procedure is intended to safeguard (see, among others, Cass., Section III Criminal, December 17, 2019, No. 50919). The Authority particularly emphasized that the non-derogability of the cited procedure also responds to the disproportionate situation existing between the employer's position and that of the workers.

Considering that in the specific case the surveillance systems were positioned in such a way as to capture areas where employees necessarily passed for the performance of their work activities, or even to access areas for the performance of work activities, the Authority recalled that even the areas where employees transit or stay—sometimes continuously—(e.g., access to the structure and garages, loading/unloading areas, vehicle and pedestrian entrances), if subjected to surveillance, are fully subject to the application of the regulations on personal data protection (see, among others, provisions of September 16, 2021, No. 331, web document No. 9719768; July 30, 2015, No. 455, web document No. 4261028; July 4, 2013, No. 334, web document No. 2577203; April 18, 2013, No. 200, web document No. 2483269; February 9, 2012, No. 56, web document No. 188699; November 17, 2011, No. 434, web document No. 1859558; February 26, 2009, web document No. 1601522). This is also in accordance with what has been established by the case law of legitimacy (see Cass. March 6, 1986, No. 1490; see also, with reference to a tool other than video surveillance, Cass. March 13, 2007, No. 15892).

It was also noted that the powers that the legal system recognizes to the Authority pursuant to Article 114 of the Code are additional (and do not replace or diminish) the powers of the Labor Inspectorate. Following the inspection, it emerged that at one sales point the images collected through a camera of the surveillance system had been recorded and stored for a period longer than the term established in the agreement stipulated pursuant to Article 4 of Law No. 300/1970. Moreover, it was found that at a different sales point the recordings of images with the surveillance system had been made during working hours even though the relevant authorizations from the Labor Inspectorate specified that the cameras should remain off during the operational hours open to customers.

Considering that the identified unlawful acts had ceased during the investigation, only an administrative monetary sanction was adopted against the company (provision of March 2, 2023, No. 58, web document No. 9880398). Following the submission of two complaints against, among others, a foundation, in which the violation of data protection regulations was alleged with respect to the right of access and the principle of lawfulness, the Authority warned the aforementioned foundation as the data controller for having provided an inadequate response (as it was generic) to the access request submitted by the complainant in violation of Articles 12 and 15 of the GDPR, as well as for having transmitted to a third party the video depicting the complainant, made with its own surveillance system, in the absence of an appropriate condition of lawfulness of the processing, thus in violation of Article 6 of the GDPR (provision of November 30, 2023, No. 559, web document No. 9970864).

Following an inspection carried out by the Special Privacy Protection and Technological Fraud Unit of the Guardia di Finanza subsequent to a report, the Authority found the unlawfulness of the processing carried out by a company through a surveillance system and an alarm system, installed at the legal headquarters, which could be activated and deactivated with fingerprints as well as a system for detecting the geographical position of employees functioning through an application installed on the mobile phones used by them.

Regarding the alarm system operating through the processing of biometric data, it was noted that the company had processed, until uninstallation, biometric data (fingerprints) of its own employees in the absence of an appropriate legal basis, considering that, as already clarified by the Authority, there is processing of biometric data both in the registration phase (so-called enrollment) and in the biometric recognition phase. Based on the data protection regulations...

Sonali, in fact, the processing of biometric data is permitted exclusively when one of the conditions set out in Article 9, paragraph 2, of the GDPR applies and, with regard to processing carried out in the workplace, only when the processing is necessary to fulfill the obligations and exercise the specific

rights of the data controller or the data subject in the field of labor law and social security and social protection, and where provided for by national or Union law or based on a collective agreement, and in any case in the presence of appropriate safeguards for the fundamental rights and interests of the data subject (Article 9, paragraph 2, letter b), of the GDPR; see also Article 88, paragraph 1 and recitals 51-53 of the GDPR). The case under examination did not fall within this hypothesis of lawful processing of biometric data.

With reference to the processing of biometric data, a violation of Article 13 of the GDPR was established as the processing had been carried out without providing suitable information to the data subjects. Regarding the geographical location system, the conduct of the company was deemed contrary to the sector regulations concerning remote monitoring (cf. Articles 5, paragraph 1, letter a), of the GDPR in relation to Articles 114 of the Code and 4 of Law No. 300 of May 20, 1970, a provision saved by Article 88 of the GDPR). The company had processed the geolocation data of its technical staff without activating the guarantee procedure provided for by Article 4, Law No. 300/1970, despite the continuous tracking of the workers' positions during the performance of their work activities when the application installed on smartphones was in use. In addition to the data concerning the geographical position, the company had also collected, through the system, the data regarding the time and date of the position detection, referring to very distant periods (2014).

It was therefore found that the system used had violated the principle of data minimization, as stated in Article 5, paragraph 1, letter c), of the GDPR, considering that the system had collected not only the data regarding the geographical position detected at the time of the technician's call closure but also the geographical position of the worker for the entire time the application was active and the technician had accessed it. Furthermore, also regarding the processing of geolocation data, no suitable information had been provided to the data subjects, in violation of what is provided for by Article 13 of the GDPR as well as Article 5, paragraph 1, letter a), of the GDPR, since within the employment relationship the obligation to inform the employee is also an expression of the principle of fairness.

150

THE ACTIVITY CARRIED OUT BY THE GUARANTOR

Finally, regarding the processing of data carried out through the video surveillance system, it was established that the use of the aforementioned system could lead to remote monitoring of work activities: in particular, the legal representative of the company could view, in real-time, what was captured by the camera at the reception area, thus monitoring the activities of the workers who worked and passed through the captured area; the system could also capture sounds and record images. Nevertheless, it was found that the data controller had not activated the guarantee procedure provided for by Article 4 of Law No. 300/1970. It was also not found that any information had been provided regarding the processing of data through the video surveillance system. The Guarantor therefore ordered the prohibition of processing carried out through the video surveillance system, the prohibition of continuous monitoring of the worker's position regarding the geographical position detection system, as well as the application of an administrative monetary sanction (provision of June 1, 2023, No. 231, web document No. 9913830).

13.6. Publication of data on the internet

The Authority established a violation of personal data protection regulations by a football club that, following the termination of the employment relationship with the complainant, continued to process, through retention with...

possibility of consultation, the card related to the same on its website within the "roster" of the players of the team, also containing the data related to body weight (a data that in this case falls under the so-called common data); the processing was found to be lacking a legal basis and, therefore, in violation of Article 5, paragraph 1, letter a), of the GDPR (principle of lawfulness). Furthermore, the Authority deemed that there was a violation of the principle of data retention limitation (Article 5, paragraph 1, letter e), of the GDPR) considering that the company had permanently deleted the online card related to the complainant more than a year after the termination of the employment relationship and that during this time the aforementioned card remained consultable. Finally, a violation of Article

12 of the GDPR was established for the company's failure to provide adequate feedback to the complainant, following the request in which he complained about the publication of the data related to body weight asking for its deletion. For the violations committed, the Authority admonished the football company (provision of April 27, 2023, no. 180, web document no. 9910193).

13.7. Processing of data through technological devices

The Authority adopted a guidance document, titled "Programs and IT services for managing email in the workplace and processing of metadata," addressed to public and private employers also taking into account the outcomes of certain specific investigations carried out. It emerged, in fact, that some email management programs and IT services, marketed by suppliers, even in cloud mode, are configured to collect and store - by default, preventively and generally - the metadata related to the use of employees' email accounts (e.g., date, time, sender, recipient, subject, and size of the email). In some cases, moreover, the systems do not allow employers to disable the systematic collection of data and reduce the retention period. The guidance document - while providing the data controllers with useful indications to prevent data processing in violation of data protection regulations and the norms that protect the freedom and dignity of workers - urges them to verify that the email management programs and services used by employees (especially in the case of market products provided in the cloud or as-a-service) allow for modifying the default settings, preventing the collection of metadata or limiting their retention period to a maximum of 7 days (extendable, in the presence of proven needs, by an additional 48 hours), a period considered adequate, from a strictly technical perspective, to ensure the regular functioning of the email used by the worker. The document also clarifies that if employers, for organizational and productive needs or for the protection of the holder's informational assets (e.g., for specific security needs of the systems), need to process metadata for a longer period, they must instead carry out the guarantee procedures provided for by the Workers' Statute (union agreement or authorization from the labor inspectorate), as a longer retention period of metadata may involve indirect remote monitoring of the worker's activity (provision of December 21, 2023, no. 642, web document no. 9978728).

The Authority also sanctioned two municipalities for the unlawful use of audio-video recordings of a conversation that took place at a local police command. The Authority intervened following a complaint from an employee of a municipality, at the time a deputy local police commissioner, who had gone to the offices of the local police command of another municipality and there had a conversation with an officer about work-related issues and working conditions. The commander of the local police of the municipality where the complainant worked had requested and obtained from the other municipality the audio-video recordings of that conversation, recorded by the camera placed inside the Command, referring to a vaguely defined judicial police investigation. The recordings had been used to impose a sanction on the deputy commissioner, who subsequently resigned. The Authority, reiterating that the employer can process the personal data of employees only if necessary for the management of the employment relationship and to fulfill specific obligations or tasks arising from the sector regulations, deemed the transmission and use of the recordings used to impose the disciplinary sanction unlawful, as they lacked an adequate legal basis. In particular, the Authority noted the disproportion of acquiring audio through surveillance devices, with the risk of capturing information about the opinions, relationships, or private matters of workers or about facts that are not relevant within the employment relationship. Several violations were contested, including the failure to comply with sector regulations regarding remote monitoring of workers, the collection of data not relevant to work activity, the lack of transparency towards the data subjects, the unlawful communication of the complainant's personal data from one municipality to another, and the failure to conduct an impact assessment in relation to... surveillance system, the violation of the principle of data retention limitation (provisions of November 16, 2023, nos. 577 and 578, web documents nos. 9963453 and 9963486).

13.8. Processing of data in the context of procedures for acquiring and managing reports of unlawful acts (so-called whistleblowing)

Following the entry into force of Legislative Decree No. 24 of March 10, 2023 (implementation of Directive (EU) 2019/1937 of the European Parliament and of the Council, of October 23, 2019, regarding the protection of persons who report breaches of Union law and containing provisions

regarding the protection of persons who report breaches of national regulatory provisions), the Authority has issued a favorable opinion on the draft guidelines developed by ANAC in this area, specifically related to the procedures for the submission and management of external reports, as provided for by Article 10, paragraph 1, of the aforementioned Legislative Decree No. 24/2023 (provision of July 6, 2023, no. 304, web document no. 9912239).

The guidelines, subsequently adopted by ANAC on July 12, 2023, replace the previous ones on which the Authority had expressed its opinion with provision No. 215 of December 4, 2019, web document no. 9215763. The consultation of the Authority, from the early stages of the document's preparation, has allowed for the necessary coordination between the sector-specific regulation and the legal framework regarding the protection of personal data in the context of procedures for acquiring and managing reports of alleged unlawful acts, also in light of the particular protection granted by the sector-specific regulation to the identity of the whistleblower and other interested parties and, in general, the specific risks to the rights and freedoms of the interested parties in the workplace context (Article 88 of the GDPR).

The draft guidelines also provide clarifications and general principles that public and private entities can consider in their choices, including at the organizational level, aimed at establishing and managing their internal reporting channels, also in line with the principle of accountability and the principles of data protection from the design stage and by default. The draft guidelines incorporate a large part of the observations and indications of the Authority, also with reference to the aspects related to the security of processing, characterized by high risks to the rights and freedoms of the interested parties, among which the following are particularly noted:

- the necessity to precisely identify the objective scope of the reports and to clearly define the cases of exclusion from the scope of application of Legislative Decree No. 24/2023;
- the necessity to ensure coordination with sector-specific regulations, including those of European origin, that govern the timing and methods of procedures under the jurisdiction of administrative authorities required to process the external report, transmitted by ANAC, when the report concerns matters within the competence of the aforementioned authorities;
- the necessity to use encryption tools within internal channels and the external reporting channel;
- the necessity to exclude tracking of reporting channels in cases where access to internal channels and the external reporting channel occurs from the internal data network of the obligated entity and is mediated by firewall or proxy devices, both on the IT platform and in the network devices potentially involved in the transmission or monitoring of the whistleblower's communications;
- the necessity to ensure, where possible, the tracking of the activities of authorized personnel in compliance with the guarantees protecting the whistleblower, in order to prevent the improper use of data related to the report, provided that, in compliance with the guarantees provided by the sector-specific regulation regarding remote monitoring (Articles 4, Law No. 300/1970, as well as Article 114 of the Code; see also Article 88 of the GDPR), such tracking can only be carried out to ensure the correctness and security of data processing;
- the necessity that access by authorized users to the ANAC IT platform, for the purpose of managing external reports, occurs through a multi-factor authentication procedure.

13.9. The protection of data in the context of public employment

During 2023, the Authority addressed, based on complaints, reports, and requests for opinions (also submitted by DPOs), numerous issues related to the processing of personal data in the workplace context, carried out by public entities or by private entities performing tasks of public interest, with regard to, in

specifically, to the treatments related to the use of technological tools or aimed at ensuring health and safety in the workplace (also in the context of the SARS-CoV-2 epidemiological emergency), or anyway carried out in connection with the fulfillment of obligations arising from specific sector regulations, such as the discipline regarding the transparency of administrative action and that relating to the protection of the privacy of employees who report illegal activities (so-called whistleblowing) (see 13.8).

**13.9.1. Processing of data for the purposes of establishing and managing the employment

relationship**

Also with regard to the phases preceding the establishment of the employment relationship (usually within the context of competitive or selective procedures) and, more generally, within the management of the relationship itself, the Authority, based on investigations initiated following complaints submitted by public employees or by other individuals working for public entities and organizations pursuing public interest goals, has ascertained the illegality of certain treatments.

****13.9.1.1. Processing of data within competitive procedures****

Some complaints have concerned the processing of data in the various phases of managing competitive procedures and, in many cases, the online dissemination of personal data during the publication of rankings and acts of competitive procedures, on which the Authority has traditionally provided specific indications to public administrations regarding the precautions to be adopted (see the guidelines on the processing of personal data, also contained in acts and administrative documents, carried out for the purposes of publicity and transparency on the web by public entities and other obligated entities, adopted with provision of March 2, 2011, no. 88, web document no. 1793203, specifically II, par. 3.b, as well as the guidelines on the processing of personal data of workers for the purposes of managing the employment relationship in the public sector, adopted with provision of June 14, 2007, no. 161, web document no. 1417809).

In one case, a national council of a professional order had published on its institutional website the final ranking of a competitive procedure (in which the complainant was listed as a non-winner), then adopted and published a resolution aimed at the adoption of a measure excluding the complainant due to the existence of previous criminal convictions (with the name and surname of the complainant and the reasons underlying the exclusion obscured) and, finally, published on the same site a corrected version of the aforementioned ranking, devoid of references to the complainant. The Authority - while recalling that the sector regulation provides for the publication of only the definitive rankings of the winners of the competition and not also the results of the intermediate tests or the personal data of non-winning or non-admitted competitors (see art. 15, paragraph 6-bis, of Presidential Decree no. 487/1994; art. 19, paragraphs 1 and 2, Legislative Decree no. 33/2013) - noted how, in this case, the publication of the intermediate ranking, not provided for by law, also resulted in the dissemination of information regarding the exclusion of the complainant from the competitive procedure in question, due to the possible comparison between the different versions of the ranking subject to publication, in violation of articles 5, paragraph 1, letter a), and 6 of the GDPR, as well as 2-ter of the Code. In light of these violations, the Authority imposed an administrative pecuniary sanction (provision of March 23, 2023, no. 83, web document no. 9888096).

In another case, the Authority criticized the untimely response by a municipality to the request to exercise the right to erasure of data, made by an individual pursuant to art. 17 of the GDPR, regarding data related to criminal convictions and offenses acquired by the municipality in the context of a competitive procedure in which the individual had participated, and a report made by the entity to the judicial authority against the same. The municipality - which had not, moreover, informed the individual, without delay and at the latest within one month of receiving the request, of the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority or judicial appeal - had also provided the individual with responses not fully compliant with the requirements set forth in articles 12, paragraphs 3 and 4, and 17 of the GDPR. Taking into account all the specifics of the case - particularly with regard to the circumstance that the same territorial archive and library superintendent, in expressing its denial of authorization to dispose of the administrative documents containing the personal data of the complainant, had reserved the right to seek an opinion from the competent general directorate of the Ministry of Culture, given the particular sensitivity of the issue - the Authority deemed it sufficient to admonish the data controller (provision of April 13, 2023, no. 118, web document no. 9889553).

Following a complaint, the Authority then initiated an investigation against a university, which had published some minutes, drawn up in the context of a selective procedure for a fixed-term researcher position, containing personal data of the complainant and eight other participants in said procedure,

including the evaluations and judgments expressed by the examining commission in relation to them. This had occurred, however, in a manner not compliant with the sector regulation, which provides for the publication of only the definitive rankings of the winners of the competition and

****non also the minutes of the selection procedure containing the personal data of the candidates (see, in particular, Article 7, Presidential Decree No. 3/1957).****

Considering that the university had not demonstrated the existence of an appropriate legal basis that could justify the dissemination of the personal data of the interested parties, the Authority deemed that the prerequisites for the adoption of a warning measure were met (measure of May 17, 2023, No. 195, web document No. 9908484).

In one case, during the execution of a competitive procedure announced by the Bank of Italy, it emerged that the selection and recruitment office had sent an email to the email addresses of numerous participants in the competition, reminding the addressed candidates of the date and time for the pre-selection test and the reminder to comply with the measures to contain the Covid-19 contagion, also providing detailed indications to ensure the correctness and safe conduct of the test. The Authority noted that the sending of the aforementioned email, although carried out as a result of an error made by an employee, had resulted in the availability of the email addresses of each of the recipients to the others who—also considering the definition of "third party" contained in Article 4, paragraph 1, No. 10, of the GDPR—had no right to know the aforementioned addresses. The transmission of the message in the described manner had also made all the interested parties, recipients of the aforementioned email, mutually aware of their participation in the competition, leading to a communication of personal data in the absence of a specific legal basis. The Authority indeed considered that the consent given by the candidate at the time of submitting the application for participation in the selection procedure could not be considered valid for this purpose, as has long been affirmed in numerous measures, the processing of data related to the conduct of competitive procedures finds its legal basis in the specific sector regulations governing access to employment in public administrations and the modalities for conducting public competitions, and not in the consent of the interested parties.

Taking into account the circumstances of the specific case, the Authority adopted a warning measure against the data controller (measure of February 23, 2023, No. 47, web document No. 9868646).

****13.9.1.2. Processing of data carried out in connection with the verification of the vaccination requirement for healthcare professionals****

In one case, following suspension from the exercise of the profession for failure to undergo vaccination against SARS-Cov-2 by a healthcare company, an employee reported having exercised the rights under Articles 15 to 22 of the GDPR against the employer and not having received an appropriate response. In particular, the interested party, having the matter received wide coverage in the local press, had exercised the aforementioned rights in order to acquire elements regarding the lawfulness and correctness of the processing of their personal data carried out by the company itself in the context of verifying the vaccination requirement for healthcare professionals pursuant to Article 4, Legislative Decree No. 44/2021, without, however, receiving the due response. The Authority, in the measure in question, highlighted that, although the company had stated that the processing of personal data concerning the interested party had been carried out within the framework of sector regulations—an aspect that was not evaluated in the measure—it had followed up on the complainant's request well beyond the expected one-month deadline due to a mere organizational oversight (measure of September 14, 2023, No. 419, web document No. 9941795).

In another case, a provincial order of surgeons and dentists had instead sent to some public entities a copy of its own resolution, with which, pursuant to Article 4, Legislative Decree No. 44/2021, the suspension of the complainant, a registered professional, had been ordered due to the lack of possession of the SARS-Cov-2 vaccination requirement. With a further communication addressed to the municipality in which the complainant exercised their professional activity, the same order had also informed the entity of the interested party's positive Covid-19 status, in order to prompt the revocation

of the act of suspension of the authorization to exercise healthcare activities previously adopted by that municipality. The Authority, taking into account all the specific circumstances that emerged during the investigation, deemed it sufficient to warn the data controller for having communicated personal data to third parties, some of which related to health status, in the absence of a legal basis, in violation of Articles 5, paragraph 1, letter a), 6, and 9 of the GDPR, as well as Articles 2-ter and 2-sexies of the Code (measure of May 17, 2023, No. 194, web document No. 9910245).

****13.9.1.3. Communication of data to third parties and circulation of information in workplace contexts****

In a case subject to complaint, a university had communicated personal data of the complainant, including data related to crimes, to a territorial labor inspectorate (in response to a summons for a conciliation attempt regarding the alleged non-payment of emoluments supposedly owed to the complainant for work performed).

c) to the Inspectorate for Public Function at the Presidency of the Council of Ministers (in response to a request from the same to carry out internal checks on the regularity of the administrative action). In relation to both communications, the Guarantor highlighted that the university had not demonstrated the existence of an appropriate legal basis that could justify the communications, as it was not necessary for the entities receiving the two notes to be informed of the criminal proceedings against the interested party. Given that the university had invoked Article 2-octies, paragraph 3, letter e), of the Code, the Guarantor reminded that the processing of personal data carried out for the purpose of protecting rights must refer to ongoing disputes or pre-litigation situations, and not to abstract and indeterminate hypotheses of possible defense or protection of rights. Furthermore, the university, with the stated aim of protecting its reputation, had sent a letter to all rectors of Italian universities, stigmatizing certain behaviors attributed to the complainant and dissociating itself from them, also in this case without having demonstrated the existence of an appropriate legal basis. Having established the violation of Articles 5, paragraph 1, letter a), 6, and 10 of the GDPR, as well as Articles 2-ter and 2-octies of the Code, the Guarantor adopted a sanctioning measure against the university (April 27, 2023, no. 167, web doc. no. 9897931).

In another case, a municipality, following the cessation of service by the complainant, had sent, with the same email addressed to her and two of her former colleagues, the evaluation forms related to the last year of service, along with the ranking with the score obtained, thereby allowing all recipients of that email to become aware of their respective personal data, including those contained in the documents in question. Considering that the communication had been made in the absence of a legal basis, the Guarantor adopted a sanctioning measure against the entity for the violation of Articles 5, paragraph 1, letter a) and 6 of the GDPR, as well as Article 2-ter of the Code (provision June 1, 2023, no. 223, web doc. no. 9916798).

13.9.1.4. Online dissemination of employee data

Complaints against administrations continue to be numerous regarding the publication on institutional websites, in some cases in the Transparency Administration section or in the Public Register section, of acts and documents containing personal data of employees (see paragraph 4.4). In two separate cases, the Guarantor, in declaring the illegality of the online dissemination of personal data of public employees, focused on the specific suitability requirements that must be met by the legal basis that provides for the dissemination of personal data, both in terms of the quality of the source and in terms of the proportionality of the regulatory intervention concerning the pursued purposes. The Authority emphasized that, within the framework of the European-derived data protection regulation, from the perspective of legal certainty, as well as the principle of non-discrimination, differentiated levels of protection of personal data are not permitted, neither on a territorial basis nor at the level of individual administrations.

In particular, in the first case, ruling on the illegality of the publication by a health company of a resolution concerning the acknowledgment of the conclusion of a disciplinary procedure as well as further documentation related to economic progressions of certain employees, it highlighted that, in terms of the processing of personal data, collective agreements must limit themselves to detailing in

favor of the interested employees the regulatory framework already established at the national level and cannot provide for or justify in any way the introduction of processing not provided for by national regulations (provision April 13, 2023, no. 125, web doc. no. 9907846).

In a second case, in sanctioning a municipality for the publication on the online Public Register, by virtue of provisions contained in the decentralized territorial supplementary collective agreement, of a determination relating to the attribution of incentives for individual productivity, with an attached list of names and their respective compensations for about 70 employees, as well as the names and amounts related to horizontal economic progressions of some other employees, the Guarantor reiterated the inadequacy of collective agreements to directly innovate the legal system in terms of the processing of personal data (provision July 6, 2023, no. 287, web doc. no. 9920145).

A regional school office had published a decree that ordered the publication in the online Public Register section of the proposal for assignment and the allocation of the location in favor of teachers included in the provincial substitute rankings for secondary schools of the first and second degree. Two tables were attached to the aforementioned decree.

****belle che riportavano numerosi dati personali****
referring to the claimant and other interested parties (about 300), including information related to the category, reserve, first name, last name, date of birth, assignment location, and in particular the indication (or not) of the precedence condition, pursuant to Law No. 104/1992. The Guarantor on this occasion, reiterating more radically that there is no suitable legal basis that legitimizes the online publication of personal data of teachers assigned to specific locations, also observed that the measure, as represented by the school office during the investigation, to remove from the aforementioned documents subject to publication the reference to Law No. 104/1992, while still maintaining the reference to the presence of a precedence condition, could not, in any case, be considered compliant with the regulations on data protection also due to the fact that, as highlighted by the same school office, the precedence condition existed exclusively in the case of benefiting from the benefits under Law No. 104/1992. It was therefore ordered to limit the ongoing processing, prohibiting the school office from any further dissemination of the personal data of the interested parties (provision of April 27, 2023, No. 168, web document No. 9896845). Considering that the conduct of the regional school office had taken place in the context of the rapid evolution of the sector's regulatory framework, which, however, did not provide for any obligation to publish personal data of the recipients of the assignment proposal and the assignment of the specific service location, within the procedure for granting temporary assignments to

teaching staff, the Guarantor has

involved the Ministry of Education and Merit
so that, within its

guidance and coordination tasks, it would raise awareness among the
territorial bodies involved in the aforementioned
procedures to operate

in compliance with the sector's regulatory framework
and data protection regulations. The Ministry then intervened
in this regard on June 5, 2023, providing
specific indications and clarifications
to the territorial offices in order to prevent similar
initiatives of unlawful dissemination of personal
data.

More generally, many cases addressed during
2023 have involved the online dissemination of acts
and documents containing personal data of
workers. The Guarantor,
in declaring the unlawfulness of the processing, due
to the absence of a suitable legal basis, has adopted numerous provisions, as
follows, concerning the
publication on the respective institutional website of:

- a provision from a regional school office
regarding the transfer of the claimant, containing personal
information related to the same, as well as
the indication of the reason for "precedence" attributed
to the interested party in the territorial mobility operations, identified "in the assistance
to the disabled parent," pursuant to Law
No. 104/1992 (provision of January 11, 2023, No. 3, web document
No. 9857610);
- decrees from a municipality ordering the
interim replacement of an
employee as "absent due to illness" (provision
of March 23, 2023, No. 84, web document
No. 9888113);
- a resolution from a municipality declaring
the nullity of the dismissal
of the claimant, identified through the initials
of the last name and first name (provision of April 13,
2023, No. 124, web document No. 9890273);
- three determinations from a municipality
regarding the liquidation of the
incentive fund with reference to the individual performance
of each employee, containing the list of the interested parties with
the indication of the first name, last name, category
of belonging, and amount disbursed (provision of September 14,
2023, web document No. 9940457);
- numerous personal data, including health-related
data, of workers from a company
that specializes in the production and
transformation of steel, by a ministry (provision of September 28, 2023, No. 420,
web document No. 9944603);
- a draft of contractual documentation from a

region with some companies providing public transport services and the lists of employees of the companies involved in the operation, including data related to the employment relationship, the income received, pending judicial proceedings with the workers, and the health conditions of certain interested parties (provision of October 26, 2023, No. 496, web document No. 9955372);

- a decree from a region containing references to the amounts related to an indemnity for workers who had exercised the option in lieu of stabilization (provision of July 6, 2023, No. 286, web document No. 9920116);

- a determination from a municipal entity containing personal data of the claimant and another employee and, specifically, the reference to a dispute before the labor court for the restitution of sums unduly received (provision of January 26, 2023, No. 28, web document No. 9865528);

- the teaching sheet of a contract teaching position by a university in which the name and surname of the teacher were reported even after the conclusion of the teaching course (provision of April 13, 2023, No. 119, web document No. 9889627).

****13.9.2. Personal data of workers in public databases****

Considering that, starting from the year 2023, all public administrations are obliged to use the single recruitment portal pursuant to Article 35-ter, Legislative Decree No. 165/2001 for the initiation and management of all competitive and selective procedures aimed at the hiring of temporary and permanent personnel and

are exempt from the obligation of publication in the Official Gazette, the Authority has urgently issued its opinion on the draft decree of the Minister for Public Administration, concerning the characteristics and operational modalities of the aforementioned portal, developed by the Department of Public Function of the Presidency of the Council of Ministers and available at www.inpa.gov.it. The discussions with the Authority aimed to ensure that the treatments governed therein— in compliance with the general principles of processing as well as those of data protection by design and by default (Articles 5 and 25 of the GDPR) and taking into account the high risks characterizing the processing in the specific context under examination—are carried out in such a way as to ensure simultaneous compliance with the regulations concerning administrative action and the recruitment and selection of personnel within public employment, as well as those concerning data protection, even in the phases preceding the establishment of the employment relationship (Article 88 of the GDPR, Article 113 of the Code in relation to Article 8 of Law No. 300/1970, and Article 10, Legislative Decree No. 276/2003). The Authority highlighted that the treatments carried out through the portal present high risks to the rights and freedoms of the data subjects, as they may also involve the processing of data belonging to special categories or relating to criminal convictions and offenses, and that the treatments are carried out on a large scale. In particular, the indications provided by the Authority were aimed at ensuring:

- the precise identification of the roles played respectively by the Department of Public Function and by public administrations in relation to the distinct purposes pursued within the portal;
- the modalities to ensure that only the personal data of the data subjects necessary for achieving the

specific purpose of selection, recruitment, and hiring of personnel are processed;

- the precise identification of the types of personal data acquired from the data subjects from the stage of filling out the curriculum vitae during registration on the portal, as well as the measures aimed at ensuring the processing of only accurate and updated data and the measures to ensure coordination with the sector regulations concerning administrative documentation and checks on the veracity of the declarations made by the data subjects;

- the identification of the data acquired in the context of the IT authentication procedures concerning the personnel authorized to operate on the portal on behalf of the individual administrations to protect the privacy of the worker (Articles 88 of the GDPR and 113 of the Code);

- the correct identification of the retention periods for the different types of personal data processed and the measures aimed at ensuring that applications for participation, completed but not submitted, are visible to the announcing administration only for activities supporting the submission of the application;

- the adoption of specific formal acts aimed at ascertaining the malfunctioning of the portal, communicating this to the public administrations and providing informative notices for the benefit of users;

- the measures to ensure coordination with the sector regulations concerning the publicity of final provisions and the rankings of procedures related to competitions, selective tests, and recruitment procedures for personnel of public administrations.

Considering that the draft decree has incorporated all the observations made during the urgent discussions, the Authority expressed a favorable opinion (provision of November 3, 2023, No. 521, web document No. 9954845). Similarly, the Authority expressed its opinion on the draft decree of the Minister for Public Administration, adopted in concert with the Ministers of the Interior, Defense, Economy and Finance, and Justice, concerning the use of the same portal by the armed forces, police forces, and the National Fire Corps. The Authority's indications primarily aimed to ensure uniform guarantees regarding the processing of personal data of the data subjects to access public employment on equal terms, as well as to make effective the coordination with the sector regulations concerning recruitment and selection of personnel within the armed forces, taking into account the specificity of their respective regulations (provision of December 21, 2023, No. 605, web document No. 9976653).

In order to implement the new support measures of the ADI and the SFL, introduced by Law Decree No. 48 of May 4, 2023, the Ministry of Labor and Social Policies submitted to the Authority for consultation two draft decrees concerning, respectively, the establishment and functioning of the Information System for Social and Labor Inclusion (SIISL) and the establishment and implementation of the SFL, on which a favorable opinion was issued (provision of August 3, 2023, No. 354, web document No. 9918937; see paragraph 4.2). The draft decree has incorporated the indications provided during the urgent discussions concerning, among other aspects, the specific guarantees to be adopted regarding the processing of personal data, including automated processing carried out for profiling purposes within the activities of training, qualification, and requalification, orientation, and job placement.

consider the provisions set forth in analogous cases (cf. Program for the Guarantee of Workers' Employability (GOL), on which the Authority expressed a favorable opinion with provision of October 20, 2022, no. 353, web document no. 9827428). Similar guarantees were referenced in the subsequent opinion issued by the Authority on the draft decree of the Ministry of Labor and Social Policies concerning the regulation of ADI, in the implementation process of the aforementioned decree law no. 48/2023 (provision of December 12, 2023, no. 597, web document no. 10000877).

With regard to the protection of workers in the educational sector and higher education, the Authority expressed, on an urgent basis, a favorable opinion, subject to conditions, pursuant to Articles 36, paragraph 4, and 58, paragraph 3, letter b), of the GDPR, as well as Article 21, paragraph 4-quinquies, decree law of June 22, 2023, no. 75, on the draft decree of the Minister of Education and Merit concerning "the regulation on the processing of personal data carried out by the Ministry of Education

and Merit and by state educational institutions within the Families and Students Platform" (provision of October 10, 2023, no. 468, web document no. 9953443, cf. paragraph 4.3).

Lastly, with reference to the draft decree of the Minister of Education and Merit, concerning criteria and methods related to the section of the National Education Registry regarding students enrolled in ITS Academy programs and consequent adjustments in the functions and tasks of the national database for the quantitative and qualitative monitoring of the tertiary technological education system, pursuant to Articles 12, paragraphs 1 and 2, and 14, paragraph 6, law no. 99/2022, an opinion was provided both regarding the processing of personal data of teachers operating at the aforementioned institutions and regarding the processing of personal data of attending students, particularly in the context of monitoring the outcomes of the training course in view of their employment insertion (provision of November 16, 2023, no. 525, web document no. 9966592; cf. paragraph 4.3).

****Processing of Data Relating to Deceased Individuals****

****14****

****Economic Activities****

****14.1. Processing of Data in the Insurance Sector****

In line with trends from previous years, a significant influx of requests was recorded in 2023, particularly reports and complaints related to the insurance sector, mostly concerning topics that had already been examined and resolved by the Authority, as documented in previous Reports (see Report 2020, p. 179; Report 2021, p. 175; Report 2022, p. 142). Many of the requests received concerned the issue of the accessibility, by heirs and beneficiaries, of the identifying data of beneficiaries of policies taken out during the lifetime of deceased individuals.

Considering the doubts and uncertainties encountered by data controllers in the application phase, the conflicting positions taken on this issue by case law, and the current regulatory framework regarding personal data protection as interpreted by the EDPB through the guidelines on the right of access of the data subject to their personal data (finalized on March 28, 2023, following public consultation), the Authority deemed it necessary to provide general clarifications on the interpretation of the GDPR provisions (Article 15, and recitals 27, 63, and 64) and the Code as amended by Legislative Decree no. 101/2018 (Article 2-terdecies) applicable to the case at hand.

The provision began with an analysis of Article 15 of the GDPR concerning the right of data subjects to access information (sufficient, transparent, and easily accessible) on the processing of personal data concerning them and, in general, not to that referring to third parties, i.e., subjects other than the data subject. However, the Authority highlighted that, availing itself of the option provided by recital 27 of the GDPR, the national legislator, with Article 2-terdecies, paragraph 1, of the Code, also regulated the possibility of exercising the right of access in relation to data concerning deceased individuals by "those who have a legitimate interest [...] or for family reasons worthy of protection."

Also considering that, precisely in this area, the case law has recently affirmed (with order of December 13, 2021, see Cass. civ., section I, no. 39531) that "the interest in the confidentiality of personal data must yield to the protection of other legally relevant interests, including the interest, if authentic and not surreptitious, in exercising the right of defense in court," the Authority concluded that, among the data to which access is possible pursuant to the combined provisions of Articles 15 of the GDPR and 2-terdecies of the Code, personal data of beneficiaries of insurance policies taken out during the lifetime of a deceased person are also included, provided that they...

****in the presence of specific prerequisites and following a careful comparative assessment of the interests at stake conducted by the data controller insurance company. Therefore, in light of the declared interest of the applicant to know the names of the beneficiaries of the policies, the data controller must verify not only that the subject exercising the right of access to the data of the deceased holds a position of substantial subjective right in the succession context (corresponding to the status of heir or beneficiary of the inheritance), but also that the pursued interest is concrete, current (i.e., actually existing at the time of access to the data), and instrumental or preliminary to the defense of their own succession right in judicial proceedings (provision of October 26, 2023, no. 520, web doc no. 9954881).****

****162****

****THE ACTIVITY CARRIED OUT BY THE GUARANTOR****

****THE ACTIVITY CARRIED OUT BY THE GUARANTOR****

****||****

****14****

****Exercise of the rights of the data subjects****

****14.2. Processing of data in the banking-financial sector and credit information systems****

Also, 2023 was marked by a high number of requests (reports, complaints, inquiries, and requests for opinions) concerning the processing of personal data carried out by credit institutions, financial companies, and credit information systems managed by private entities (so-called SIC), including aspects already thoroughly examined in the past by the Guarantor through the adoption of collegiate measures (specifically, provision of October 25, 2007, no. 53, web doc no. 1457247), which have been extensively reported in previous Reports (see Report 2020, p. 181; Report 2021, p. 175; Report 2022, p. 143).

There has been an intense flow of requests regarding the exercise of the rights of the data subjects, specifically concerning the right of access to personal data.

In line with the established orientation of the Authority in this matter, it has been reiterated that the right of access to personal data, regulated by Article 15 of the GDPR, is different from the right to access banking documents regulated by Article 119 of Legislative Decree no. 385/1993 – consolidated text of the laws on banking and credit.

Therefore, requests for access to personal data must not only comply with the regulations on data protection (Articles 12 et seq. of the GDPR) but must not aim to obtain (in view or in copy) banking documents and do not allow for the receipt of data relating to subjects other than the data subject or the deceased (if the request is addressed to the data controller pursuant to Article 2-terdecies of the Code).

With provision of October 26, 2023, no. 501 (web doc no. 9965201), the Guarantor identified a violation of Article 12, paragraph 3, of the GDPR against a company that offers online banking and payment services, for failing to provide a timely response to the request submitted by the complainant pursuant to Articles 15 et seq. of the GDPR. In particular, the data subject, having failed to complete the registration process on the company's platform for the activation of services related to rechargeable credit cards, had submitted a request to exercise their rights and for the simultaneous deletion of data relating to themselves and their children. The company, however, despite having assured a response within the time limits set by the GDPR, had not sent any feedback on the matter, except following the invitation to comply issued by the Authority, limiting itself, on that occasion, to stating that the delay was due to an error (without providing further clarifications).

During the investigation, the company, while clarifying that the reason for the delay was caused by "a mere accidental error attributable to a procedural-organizational defect," represented that it had implemented specific measures aimed at ensuring compliance with the deadlines and had, in particular, automated the calculation of the processing times for requests, which had previously been managed manually, in order to avoid the recurrence of human errors related to determining the deadline to be respected for providing feedback to the data subjects within the prescribed time limits. The Guarantor, while having identified the violation of Article 12, paragraph 3, of the GDPR, considered, due to the measures already implemented by the company, that there were no grounds for applying corrective measures and to classify the case as a minor violation, pursuant to Article 83 and recital 148 of the GDPR, adopting the measure of reprimand against the company, pursuant to Article 58, paragraph 2, letter b), of the GDPR.

Similarly, with provision of March 23, 2023, no. 90 (web doc no. 9888188), the Authority found the complaints of the complainant against a bank that had failed to provide feedback on the request for access to the personal data of the deceased mother submitted pursuant to Articles 15 of the GDPR and 2-terdecies of the Code to be well-founded.

****163****

****REPORT 2023****

|||

14

In this specific case, following the intervention of the Authority, the data controller communicated the requested information to the data subject, explaining that the lack of response was due to an operational misunderstanding within a structure of the bank which, in response to the access request, instead of forwarding the request to the competent privacy function, assigned it to the structure responsible for succession matters (where a case related to the same deceased was already open). The bank also added that the delay in the response originated from the fact that the access request, formulated under the data protection regulations but in an extremely generic manner, had been sent to a different PEC mailbox than the one specifically and properly dedicated to the exercise of rights.

In this regard, the Authority noted that the reasons provided by the credit institution to justify its omission could not be taken into consideration, as the Guidelines 01/2022 on data subject rights - Right of access - Version 2.0 clarify that the burden of specifying the legal basis for the request does not fall on the data subjects, so that - if the data controller has doubts regarding the right that the data subject intends to exercise - they must ask the data subject to specify the subject matter (see Guidelines 01/2022 cited, point 47 and point 48).

Furthermore, regarding the sending of the request to a PEC mailbox different from the one specifically dedicated to the exercise of rights, the aforementioned Guidelines 01/2022 specified that data subjects are not obliged to adopt a specific format for submitting requests to exercise the right of access (see Guidelines 01/2022 cited, point 52). In this case, the Authority, considering the particularity of the situation and positively evaluating the organizational measures implemented by the data controller to prevent the recurrence of similar episodes as well as the absence of previous violations for the same case, decided to resolve the case by adopting, pursuant to Article 58, paragraph 2, letter b), of the GDPR, the measure of admonition.

Conversely, although regarding a similar case, the Guarantor, with decision of September 14, 2023, no. 402 (web doc no. 9941780), imposed an administrative monetary sanction on another credit institution that had failed to provide a response to a parent who, in exercising their parental authority, had requested access to data related to their minor child. In this case as well, the bank stated that it had only become aware of the access request at the time of the opening of the investigation procedure by the Authority due to "an operational error that occurred in the management process" of the request itself; specifically, the access request had been sent to a general PEC mailbox rather than to the one properly dedicated to the exercise of rights regarding personal data protection. In the case examined, the Authority, for the purpose of determining the sanction and its amount, took into account the fact that the data controller had already been the recipient of previous relevant measures under Article 58 of the GDPR.

Also regarding the exercise of rights, with decision of May 17, 2023, no. 200 (web doc no. 9902499), the Authority accepted the complaint filed against a credit institution that had not provided the data subject with a timely and adequate response to the request for access and deletion of prejudicial information contained in credit information systems related to a loan that had been granted to her by the same institution; more specifically, the institution in question, in response to the requests made pursuant to Articles 15 and 17 of the GDPR, had first failed to provide a response within the legal timeframe and then, belatedly, that is, after the thirty days from the requests, instead of communicating the requested data to the data subject, limited itself to informing her that, due to the assignment of the credit, the data could be obtained from the assignee company as the new and actual data controller, and therefore the only entity able to provide updated information.

Moreover, during the investigation procedure, the credit institution represented that, while wanting to consider itself as the actual recipient of the requests...

****Exercise of Rights (in place of the assignee)****

The lack of and insufficient response would not be attributable to him but rather to the company designated as the data processing manager for the management and sorting of complaints and

customer requests. However, the credit institution, as soon as it received the invitation to comply issued by the Authority, communicated the requested data to the interested party, also specifying that the prejudicial information reported in the SIC was no longer visible, as the retention periods provided for by Article 7 of the code of conduct adopted by the Guarantor on September 12, 2019 (n. 163, web doc n. 9141941) had expired. Therefore, at the conclusion of the investigation, the Authority, considering the violation of Article 12, paragraphs 3 and 4 of the GDPR by the credit institution to be established, made some observations regarding the arguments put forth by the party.

In relation to the "lack of passive legitimacy," it recalled that Article 15 of the GDPR recognizes the interested party's "right to obtain from the data controller confirmation as to whether or not personal data concerning him or her is being processed" and, consequently, in the affirmative case, the right "to obtain access to the data" itself and to further information, also for the purpose of verifying the accuracy and completeness of the data subject to processing (even where it concerns only the retention of data – see Article 4, paragraph 2, of the GDPR).

Regarding the alleged responsibility of the entity appointed as the data processing manager pursuant to Article 28 of the GDPR, the Authority emphasized that the obligation to respond to the requests of the interested parties regarding the exercise of rights (Article 12, paragraphs 1 and 2, of the GDPR) specifically rests on the data controller, while it is the responsibility of the processor to whom the practical management of individual requests has been outsourced to assist the controller, taking into account the nature of the processing, in order to satisfy the controller's obligation to fulfill the same requests (Article 28, paragraph 3, letter e), of the GDPR). The nature of such assistance must, therefore, be evaluated in light of the characteristics of the processing, and its specifics must be explicitly provided for in the contract which, pursuant to the aforementioned Article 28, paragraph 3, "binds the data processor to the controller [...]"

Still in relation to a complaint regarding the exercise of rights, the Authority examined the issue of the necessary coordination between the principles of the data protection legislation and the complex and articulated legislation on anti-money laundering (provision of November 16, 2023, n. 531, web doc n. 9967641).

In this case, the complainant – to whom the credit institution had communicated the notice of unilateral withdrawal from the contract because "routine checks carried out on the clientele" had revealed that his name appeared on publicly accessible websites concerning criminal investigations conducted against him by the judicial authority – had approached the institution to find out which source had been used to acquire the aforementioned information (allegedly related to him), also requesting the limitation of processing pursuant to Article 18 of the GDPR and opposition to further processing for marketing purposes. Although the bank, in the days following the receipt of the access and limitation requests, clarified that, following "further analysis," it had been found that the acquired information was not accurate and that it was a misunderstanding – resulting in the cancellation of the withdrawal procedure – also providing the interested party with the URL of the web source from which the information had been collected, the Guarantor, while acknowledging that the aforementioned requests had been satisfied within the terms provided for by Article 12, paragraph 3, of the GDPR, held that the processing of personal data of the interested party carried out by the credit institution was in contrast with the general principles of data minimization and accuracy, as set out in Article 5, paragraph 1, letters c) and d) and paragraph 2 of the GDPR.

Indeed, the Authority, in reconstructing the EU regulatory framework regarding the prevention and combating of money laundering – which has currently developed into five directives – highlighted the commitment made by it over a twenty-year period – especially...

**In the context of the opinion on the decrees for the implementation of the aforementioned directives into the national legal system – in order to balance the fundamental principles regarding the protection of personal data with the needs of an extremely complex regulation, subject to continuous amendments, applications, and interpretations, which imposes on a wide range of subjects the obligation to carry out complex operations aimed at combating the phenomenon of money laundering. In particular, the Authority has highlighted how the same European Data Protection Board (EDPB)

(and, even earlier, the Article 29 Working Party) has, on several occasions, pointed out the importance of finding a “just balance” between the interest in preventing money laundering, on one hand, and the interests underlying the fundamental rights to data protection and privacy, on the other (see letter to the European Commission dated May 19, 2021).**

In light of such a legal framework, which is extremely complex and continuously evolving, the Authority, in the case examined, has determined that the bank, in carrying out the customer due diligence procedures to which it is obliged under the so-called anti-money laundering legislation pursuant to Legislative Decree No. 231/2007 (as amended by Legislative Decree No. 90/2017, Legislative Decree No. 125/2019, and, lastly, by Article 12-bis, Law No. 136/2023 converting Legislative Decree No. 104/2023), which consists of numerous and specific activities, including the monitoring and continuous control of existing contractual relationships according to the criteria established by the Bank of Italy in the provision of July 30, 2019, through the consultation of so-called open sources (i.e., publicly and generally accessible sources to anyone), had collected, from a newspaper article, information concerning a person involved in a criminal investigation, erroneously associating it with its customer, solely based on the name (first and last name), age, and geographical area of operation; in this way, based on this improper association, it had deemed that the risk profile of the customer, in light of the anti-money laundering legislation, required the adoption of risk mitigation measures – consisting of the communication of the withdrawal notice – thereby resulting in an unlawful processing of the personal data of the complainant, as it was based on inaccurate and irrelevant data.

The unlawfulness arises from the fact that information obtained from a single source (a single newspaper article), dating back two years, was used without any further necessary verification by the data controller regarding its accuracy and relevance to a specific identified customer (Article 5, paragraph 1, letters c) and d), of the GDPR). It is indeed the precise duty of the data controller to ensure that, in the face of a “suspicious” data point that could abstractly refer to an identified customer, an appropriate procedure is always defined that provides, in addition to consulting multiple sources – the updating of which is always ensured (see Article 17, paragraph 3, Legislative Decree No. 231/2007 as amended by Law No. 136/2023) – also a careful verification regarding the certain referability of the information to the data subject, in the absence of which the processing of that data must be considered prohibited. Consequently, the use of data from open sources in the context of data processing necessary to fulfill a legal obligation to which the data controller is subject in the area of anti-money laundering is not compliant with data protection regulations if the conditions to attribute the information with certainty, beyond any reasonable doubt, to a specific data subject do not exist.

In this regard, the recent guidelines of the Advisory Committee of Convention 108 on the processing of personal data for the purposes of combating money laundering and countering the financing of terrorism (adopted on June 16, 2023) should be recalled, which indeed recommend the implementation, by obligated subjects, of procedures suitable to ensure compliance with the accuracy principle as per Article 5, paragraph 1, letter d), of the GDPR in any data processing related to customer due diligence operations, in order to avoid risks and harmful effects on the rights of the customer/data subject that could arise from the processing of outdated data (see paragraph 3.5 - recommendation).

****THE ACTIVITY CARRIED OUT BY THE AUTHORITY****

****THE ACTIVITY CARRIED OUT BY THE AUTHORITY****

****||****

****14****

The same guidelines also add that in the event that the information has been collected and processed by a third party (on which the data controller relies), the obligation to update the data and information related to the adequate verification of the customer still rests with the data controller (par. 3.5 - AML/CFT contextualization 37).

It is finally noted that, in this specific case, the Authority deemed it appropriate to consider the violation identified as minor, resulting in a warning to the data controller, pursuant to Articles 143 of the Code

and 58, par. 2, lett. b), of the GDPR; in this regard, account was taken, on the one hand, of the behavior of the bank which, in addition to promptly interrupting the correlation of the customer's data with information regarding a third party, had immediately communicated to the interested party the origin of that information; on the other hand, of the complexity of anti-money laundering regulations in light of the intricate legal framework of reference.

The issue of the limitation of the rights of the data subjects, as per Articles 15 to 22 of the GDPR, was also addressed, with specific reference to the interests protected by the provisions on money laundering (Legislative Decree No. 231/2007, implementation of Directive 2005/60/EC concerning the prevention of the use of the financial system for the purpose of money laundering of proceeds from criminal activities and financing of terrorism). In particular, two complaints were received by the Authority from the same interested party, which highlighted the incomplete response to the requests for the exercise of rights made by the same to two different credit institutions, and which, following the investigative activity, were resolved by the Authority with separate warning measures for the violation of Articles 5, par. 1, lett. a) and c) and 15 of the GDPR.

It emerged that the refusal by both credit institutions to provide the interested party with all the information in their possession related to him was based on both Article 2-undecies of the Code, which allows the application of the limitation principle when the exercise of such rights could cause harm "to the interests protected under the provisions on money laundering," and on the anti-money laundering regulations which provide "the prohibition for subjects required to report a suspicious transaction and anyone who is aware of it, to communicate to the interested customer or to third parties the occurrence of the report, the sending of further information requested by the UIF or the existence or likelihood of investigations or inquiries regarding money laundering or financing of terrorism" (Legislative Decree No. 231/2007, Article 39). The credit institutions, therefore, since it concerned information subject to evaluation within the framework of anti-money laundering regulations, believed that communicating such information to the interested party, of which they had become aware through the press and by accessing public databases, could lead to a violation of the aforementioned provisions.

The Authority, at the conclusion of the investigative activity, deemed that, in the cases examined, the conditions for the application of the measure provided for by Article 2-undecies concerning the limitation of the right of access were not met, since, being information accessible to anyone – as it came from public databases – and known to the interested party, their communication would not have resulted in an actual and concrete harm to the general interest protected by the provisions on money laundering that would justify the limitation of the rights of the interested party. In particular, the Authority specified that not all information collected for anti-money laundering purposes must necessarily be subject to limitation in terms of the exercise of the rights of the data subjects, but rather it is necessary for the data controller to carry out an assessment regarding the nature of the information and the consequences of its communication. This assessment cannot disregard considering whether the limitation constitutes a necessary and proportionate measure in relation to the interests intended to be safeguarded.

In this regard, the European Data Protection Board (EDPB) also expressed itself in the guidelines 10/2020 on restrictions pursuant to Article 23 of the GDPR adopted on October 13, 2021. The same guidelines mention, among the cases in which such limitation may apply, the safeguarding of "the prevention, investigation, establishment, and prosecution of crimes or the execution of criminal sanctions, including the protection and prevention of threats to public security." In particular, in the case of anti-money laundering, the limitation on rights may be necessary where providing information to individuals under investigation could compromise the success of the investigation itself. The omitted information, however, should be provided as soon as its communication no longer prejudices the ongoing investigation. The application of the limitation, therefore, must adhere to the principles of necessity and proportionality, according to which the right of the data subject to receive information concerning them cannot be eliminated but may be deferred to a later time.

For this reason, the national legislator, in regulating the limitations of the rights of the data subject, has provided, according to a criterion of graduality, the possibility to delay, limit, and ultimately exclude the

exercise of the rights of the data subjects. It is also established that the data controller is required to inform the data subject of the option, recognized to them, to exercise their rights also through the Authority, in the manner provided for in Article 160 of the Code, so that appropriate checks can be carried out, at the end of which “the Authority informs the data subject that it has carried out all necessary checks or has conducted a review, as well as the right of the data subject to file a judicial appeal” (Article 2-terdecies of the Code).

In both measures adopted, the Authority deemed it appropriate to apply the measure of admonition, taking into account the complexity of the legal framework of reference, the novelty represented by the case, as well as the absence of previous rulings by the Authority on this specific topic (provisions of April 13, 2023, no. 128, web doc no. 9888438 and no. 129, web doc no. 9888457).

Throughout the year, requests directed to the Authority regarding cases related to identity theft and cyber fraud have increased. In the cases examined, it was noted that, in light of the increase in increasingly sophisticated and complex cyber frauds from a technological standpoint, the Authority has long made available, on its website, an information sheet to raise awareness among users so that they adopt precautions and measures to avoid becoming victims of fraudulent and illegal behaviors (see web doc no. 5779928). It was also reiterated that guidelines on behaviors to adopt or avoid to not fall victim to this type of fraud are always present on the institutional websites of every bank and financial intermediary that allows customers to operate remotely and that, in addition to the tools and initiatives already adopted in terms of security by ABI, institutions, and individual banks, there is also a Vademecum (from 2022 and subject to periodic updates) that ABI itself and the State Police have jointly created and is available on their respective institutional websites.

Moreover, considering that all the data subjects had reported the events that occurred to the authorities responsible for verifying the criminal offenses identifiable in the behaviors subject to subsequent requests to the Authority, it was reserved – also in light of Article 167, paragraph 4, of the Code – to take any determinations at the end and based on the results of the checks already activated in judicial proceedings.

There have been multiple complaints and reports regarding the processing of personal data recorded in credit information systems managed by private entities (so-called SIC). Some requests concerned the issue of prior notice to be given to the data subject in the event of delays in the payment of the agreed amounts and before the insertion of data into the SIC; others concerned the retention periods of data in the SIC (which vary depending on whether the recorded relationship has been established or not and, in the affirmative case, whether it has a regular trend or not).

Identity theft and cyber fraud

Processing of data in credit information systems (SIC)

THE ACTIVITIES CARRIED OUT BY THE AUTHORITY

In all the cases examined, the norms contained in the code of conduct were specifically referenced—an instrument of self-regulation based on voluntary adherence capable of contributing, in the relevant sector, to the correct application of the regulations regarding the protection of personal data (art. 40)—approved by the Authority first on September 12, 2019, and definitively with the provision of October 6, 2022, no. 324 (doc. web no. 9818201), which also accredited the relevant monitoring body.

In almost all of the examined cases, regarding the requests received by the Authority, no proven violations of the regulations concerning the protection of personal data were found.

During 2023, the participation of the Authority continued as a permanent member in the activities of the FINTECH Coordination Committee established at the Ministry of Economy and Finance (d.m. no. 100/2021, implementing the delegation provided by d.l. no. 34/2019), with the aim of examining and authorizing experimentation in a controlled environment (sandbox) of projects related to technologically innovative products and services in the banking, financial, and insurance sectors, presented by supervised intermediaries and operators in the FINTECH sector.

The experimentation takes place for a limited period (18 months), and during this phase, FINTECH operators can benefit from a simplified transitional regime, in constant dialogue with the supervisory authorities (Bank of Italy, CONSOB, IVASS), also through the derogation of general acts as well as the norms or regulations adopted by the supervisory authorities, specifically indicated by art. 10 of d.m. no. 100/2021.

During the year, experiments related to the projects presented and accepted were conducted with the first time window open from November 15, 2021, to January 15, 2022, and the second phase of experimentation was initiated with a time window open from November 3 to December 5, 2023. The Authority participated, along with other administrations, in the periodic meetings of the Committee, during which the supervisory authorities (Bank of Italy, CONSOB, IVASS) provided an update on the status of the investigations related to the requests received and the experiments of the accepted projects. In relation to certain projects, the Bank of Italy requested an informal discussion with the Authority, which also took place through meetings with the individual companies involved. There were also meetings with individual companies that, through the competent supervisory authority, requested a discussion with the Authority regarding any critical issues in the processing of personal data that emerged from the presented projects.

Within the Working Group "Network of DPOs in the Banking Sector," the primary objective was to provide a "snapshot" of the characteristics that define the role and activity of the DPO in this context, through a questionnaire shared between ABI and the Authority. The illustrative report of the main findings of the questionnaire is the result of contributions from about 90 ABI members, among banking groups and individual banks, and can therefore be considered well representative of the sector.

The questionnaire and the accompanying letter were sent by the trade associations to the DPOs of the associated banks on February 10, 2023, with an invitation to complete the questionnaire by March 15, 2023. The questionnaire was formulated through 46 questions divided into 5 macro sections: designation, requirements, and experience of the DPO; tasks and resources of the DPO; role and position of the DPO; description of the data controller, resources, and training of the DPO; notes, observations, and suggestions. The administration of the questionnaire and the analysis of the responses provided by the banks were carried out by ABI and FEDERCASSE. Eighty-seven (87) respondents participated in the questionnaire, among individual banks and group leaders of banking groups.

Regarding the main findings of the questionnaire concerning the methods of designation of the DPO, the conduct of activities, and corporate framing, it emerged that, in almost all cases, the data controller formalized the appointment of the DPO through a specific act of designation, mainly through the signing of specific service agreements. In larger and medium-sized banks, the data protection officer is predominantly an employee of the data controller. In contrast, in smaller banks, in most cases, the DPO is an external subject to the bank. In all three cases, it emerged that, in general, the DPO does not perform activities exclusively for the data controller.

Another significant aspect concerns the fact that the same DPO often performs their function for multiple legal entities (often belonging to the same group and also operating in sectors outside the banking sector). This raises considerations regarding the sufficiency of resources allocated to DPOs (also in terms of staff and time) as well as potential conflict of interest situations. The description of the tasks provided by the data controller substantially corresponds to those actually performed by the DPO. Furthermore, in general, the DPO has access to and receives the necessary information to carry out their tasks.

Additionally, in smaller and medium-sized banks, there are generally procedures to track the consultations and opinions issued by the DPO, but in most cases, no internal processes have been established to document the decisions made by the data controller that disregard the indications of the DPO.

In most cases, the DPO participates in training initiatives at least once or twice a year, generally through attending courses and conferences. The use of certifications in the field of security and data

protection (UNI 11697:2017), which is quite common in the sector, also requires continuous training for the DPO.

On November 28, 2023, a meeting was held with ABI and some DPOs from the "Network" to discuss the illustrative report, and on this occasion, it was proposed to the Network – as an objective to pursue in 2024 – to work together on defining homogeneous and simplified information notices (pursuant to Articles 13 and 14 of the GDPR) through the use of standardized icons for the sector. The illustrative report of the questionnaire results is available on the institutional website of the Authority.

On June 23, 2023, the event "DPO at the Center!" was held in collaboration with Lepida S.c.p.A. DPOs from the public and private sectors participated in a day of discussion with the Authority. Five years after the application of the GDPR, the Authority met again in Bologna with the DPOs to take stock of the experience gained and to identify areas of intervention aimed at strengthening the role of this figure in the near future. Approximately 800 participants were present, and the event was recorded and made available to users on the institutional websites of the Authority and Lepida. The topics addressed included: designation, requirements, experience, training, and updating of the DPO, risks related to the position of the DPO (independence and conflict of interest); preventive value of the DPO's activities (contribution of the DPO in complex situations and relationship with the Authority) (see par. 23.1).

14.3. Companies

Regarding the exercise of the rights of data subjects, the Authority ruled against a long-term rental company concerning the inaccurate response to a request for the right of access, imposing a monetary fine of 40,000 euros (prov. May 17, 2023, no. 199, web doc no. 9899914).

The violation particularly concerned Articles 12 and 15 of the GDPR due to the failure of the data controller to provide personal information of the applicant – obtained through access to credit information systems (CIS) – used to reach an assessment of unreliability that hindered the acceptance of the long-term rental financing request.

The Authority, while reminding that the data controller is required to provide access to the personal data of the data subject in a complete and updated form, clarified that controllers, in the context of responses pursuant to Article 12 of the GDPR, cannot limit themselves to merely mentioning the reliance on creditworthiness assessments – as had occurred in the contested case – nor can they simply invite the data subject to contact the CIS manager to obtain them, but must instead provide, also due to their role as participants in the CIS, in compliance with Article 15 of the GDPR, all information acquired and actually processed therein.

The provision served as an opportunity to reiterate the importance of the right of access to one's data in relation to the activities of private companies functional to verifying customer reliability, due to the particularly sensitive nature of the information processed (related to the creditworthiness of the data subjects) as well as the possible detrimental consequences on the rights and freedoms of the individual arising from an inaccurate response by the controller to access requests under Article 15 of the GDPR (foremost among them, the inability to verify the accuracy of the information processed to deny the requested financing and, therefore, to assess the potential exercise of the right to rectification/deletion of the same).

With reference to processing concerning special categories of personal data (Article 9 of the GDPR), the Authority adopted a corrective and sanctioning measure against the operator of an online dating platform aimed at allowing registered users to search for potential partners within the national territory (prov. December 7, 2023, no. 599, web doc no. 9978568).

The decision, made following a complex investigative activity that also required an on-site inspection, revealed the illegality of the processing of personal data (including those related to preferences and sexual orientations) of approximately 1 million users registered on the dating site in violation of Articles 5, par. 1, lett. a), e), and f) and paras. 2; 9, 13, 24, 32, 30, 35, and 37 of the GDPR. In this case, it was established that the company had processed the personal information of users collected during the registration of their accounts in the private area of the site, as well as subsequently uploaded by them

(such as, for example, those contained in their personal photos), in the absence of the necessary legal bases for processing and in light of an inadequate information notice. It also emerged that the aforementioned controller did not have a specific privacy policy regarding the retention periods of the processed personal data, limiting itself to proceeding in a disjointed manner to delete inactive accounts and the information contained therein, as well as unsuccessful registration requests.

Similarly, with reference to the obligations set forth in Article 33 of the GDPR, it was found that there were no appropriate technical-organizational measures in place to ensure the integrity and confidentiality of the personal information processed, especially in light of their sensitivity and the associated significant risks to the rights and freedoms of the data subjects involved. The company, finally, despite being required to do so, had not drafted the record of processing activities, had not appointed the DPO, nor had it prepared the impact assessment required by Article 37 of the GDPR. Due to the numerous violations identified, the Authority imposed a monetary fine of 200,000 euros and ordered a series of corrective measures aimed at bringing the contested processing into compliance with the GDPR. In this context, the company was specifically instructed to identify appropriate retention periods for the personal information processed, ensuring the deletion of user profiles whose retention is deemed excessive; to draft the impact assessment regarding personal data protection; to adopt specific technical measures aimed at strengthening the security of the processing carried out within the dating platform (including, for example, Identity and Access Management systems; encryption or pseudonymization measures for sensitive data; log files equipped with timestamps and integrity checks).

In 2023, the investigation against a company belonging to a multinational group operating in the hospitality sector was concluded. The checks conducted revealed violations that led to the imposition of a monetary fine of two hundred thousand euros (provision of June 1, 2023, no. 229, web document no. 9980043). The identified violations specifically concerned the registration in the hotel booking system of personal data relating to guests' allergies and/or food intolerances (collected at check-in and following specific requests from them) as well as the contracts entered into by the company with parties that process the personal data acquired through the video surveillance systems installed at the hotel facilities.

Regarding the first aspect, the Authority reiterated the obligation on the part of the company, as the data controller, to adequately inform customers at the time of collecting the aforementioned data, pursuant to Article 13 of the GDPR, so that the data subjects are placed in a position to give their consent in an informed manner regarding this specific purpose. Furthermore – considering the nature of the information in question, particularly sensitive from the perspective of fundamental rights and freedoms, as it relates to health data – it was reiterated that consent can only be considered validly given if it is not only specific and informed but also provided by the data subjects in explicit form, as established by Article 9, paragraph 2, letter a), of the GDPR (see on this point recital 51 of the GDPR and paragraph 4 of the guidelines 5/2020, cited). These are measures that, as established during the investigations, and particularly following the examination of the documentation prepared by the company, had not been adopted by the latter, in violation of the provisions of Articles 5, paragraph 1, letter a), 9, and 13 of the GDPR.

Moreover, regarding the further aspect related to the video surveillance systems located at the hotel facilities, it was noted that the company relied on design, installation, and maintenance services provided by third parties, as suppliers. Considering that the provision of such services could involve the processing of personal data of hotel guests by the appointed parties (even just due to access to the images recorded by the cameras during maintenance activities), this resulted in an additional violation of Article 28 of the GDPR. During the checks, it was indeed established that the company had not regulated the relationship established with the suppliers responsible for the maintenance of the aforementioned systems, which should instead have taken place through the preparation of a contract (or other legal act) designating the data processor and the related instructions, in accordance with the aforementioned provision.

The Authority ruled against a company concessionaire of the motorway network following a request

submitted by a consumer association, which reported an app aimed at allowing the total or partial reimbursement of the cost of the motorway ticket for delays due to construction works (provision of June 22, 2023, no. 264, web document no. 9909702). The Authority declared the unlawfulness of the processing of personal data of approximately 100,000 users, carried out through the aforementioned app and for the purpose of providing the aforementioned service, due to the identified violation of Articles 5, paragraph 1, letter.

a); 13 and 28 of the GDPR, and imposed a monetary fine of 1 million euros.

During the investigation, following the assessment of the specific circumstances related to the case at hand, it was found that, contrary to what was indicated in the contractual documentation acquired in the records and reported in the information provided to users pursuant to Article 13 of the GDPR, the company acted as the data controller and not as the processor; the latter role was instead held by another company tasked with the development and management of the app in question.

In fact, it was the concessionaire company that defined the purposes and means of processing, establishing the mechanism for reimbursing the toll cost, the conditions and requirements for users' requests, and the type of delay related to the presence of construction sites. Conversely, the developer acted in accordance with the express mandate given to it and based on the procedures and criteria identified by the concessionaire company. The incorrect qualification of the privacy roles held by the two companies had immediate repercussions on the compliance with the GDPR of the information, which did not correctly indicate the actual identity of the data controller and the purposes of the related processing, nor did it provide the additional information aimed at ensuring, in compliance with the general principles set out in Article 5 of the GDPR, a correct and transparent processing of users' personal data.

Finally, in noting that the relationships between the two companies should have been governed, pursuant to Article 28 of the GDPR, based on a contract or other legal act, an additional violation was noted consisting of the failure to designate the data processing responsible party. Of significant relevance was the request – qualified as a prior consultation pursuant to Article 36 of the GDPR – with which a company expressed its intention to proceed, on its own and in the interest of other companies in the group, with the processing of personal data related to criminal convictions, offenses, or related security measures of its contractual counterparts, including potential ones, in order to protect its activities from the risks of criminal infiltration.

In particular, in order to establish economic relationships with "reliable" partners, the companies in the group intended to request from these latter, at the time of their registration on the procurement portal, a self-declaration regarding the absence, on the part of the relevant "significant subjects," of judicial proceedings pursuant to Legislative Decrees Nos. 231/2001 and 159/2011, and then verify the potential truthfulness through information independently acquired from "open sources."

Given the sensitivity of the proposed processing, the company had conducted an impact assessment pursuant to Article 35 of the GDPR, identifying, however, also following the negative opinion provided in this regard by its DPO, a high "residual" risk for the rights and freedoms of the data subjects, due to the absence in the legal framework of an appropriate legal basis for the processing of the aforementioned data.

In a note dated July 5, 2023, the Office, having established the inadequacy of the request made by the company (which was found lacking in terms of detailed information and based, more on the indication of the "residual" risks that could not be mitigated by the data controller, on the very absence of an appropriate legal basis for the processing), nevertheless provided initial guidance to the latter, first recalling the regulatory prerequisites for the processing of data related to criminal convictions, offenses, or related security measures (Article 10 of the GDPR, Article 2-octies of the Code; Article 22, paragraph 12, Legislative Decree No. 101/2018) and subsequently highlighting the necessity of an appropriate legal basis (of a legislative nature or, in cases provided for by law, regulatory) as a condition for the legitimacy of the processing itself.

In this specific case, the non-existence – highlighted by the same DPO of the company – of adequate legislative or regulatory provisions governing the processing in question and that also provided for appropriate measures to protect the rights and freedoms.

of the interested parties did not consent, during the interim period of the adoption of the ministerial

decree referred to in the aforementioned Article 2-octies of the Code, to identify suitable grounds for the lawful processing of the aforementioned data; however, it was noted that the processing of data related to criminal convictions, offenses, or related security measures is nonetheless permitted, based on the already mentioned Article 22, paragraph 12, of Legislative Decree No. 101/2018, and until the date of entry into force of the aforementioned ministerial decree, if carried out in implementation of the memoranda of understanding provided for by that provision. The group companies were therefore invited to await the conclusion of the (already initiated) procedure for adherence to the aforementioned protocols for the potential processing of the data in question.

14.4. Concessionaires of Public Services

In relation to the processing carried out by concessionaires of public services, 2023 was characterized by intense monitoring and control activities aimed at verifying the correct compliance with personal data protection regulations by suppliers operating in the free market of electricity and gas, also considering the significant implications—in terms of expanding the pool of interested parties involved—resulting from the imminent completion of the energy market liberalization process. The Authority focused its attention on the various reports received from interested parties involved in the first phase of the aforementioned liberalization process, consisting of the migration to the Gradual Protection Service of supply contracts provided for micro-enterprises that had not yet transitioned to the free market as of April 1st. In this regard, the Authority clarified that this Service, based on the current regulations (Article 1, paragraph 60 of the annual law for the market and competition No. 124/2017), operates by default towards the aforementioned customers and determines an automatic transition of the same to specifically identified suppliers for the territory based on public procurement procedures. Therefore, in light of the aforementioned sector provisions, the processing of personal data of customers forcibly migrated to the aforementioned new supplier of the Gradual Protection Service is lawful as it is carried out within the framework of the aforementioned regulatory framework (see Article 6, paragraph 1, letter c), of the GDPR).

Also in light of the context outlined above, several investigative activities have been initiated, in some cases including inspection checks, specifically aimed at identifying unlawful practices by the aforementioned suppliers, aimed at acquiring unsolicited contracts in the energy sector through the processing of inaccurate and outdated personal data of potential customers. This is a phenomenon that is now widely spread and continuously evolving, generally resulting from fraudulent activities carried out by agents who disregard the duties assigned to them contractually as well as the instructions provided by the data controllers pursuant to Article 28 of the GDPR, taking advantage, in most cases, of the inadequacy, in terms of accountability, of the technical and organizational measures adopted by energy suppliers to align the processing of customers' personal data with the GDPR (Articles 5, paragraph 2 and 24).

On this point, the Authority first expressed itself, with provision No. 427 of September 28, 2023 (web doc No. 9940988), against a supplier operating on a national scale. In this instance, the unlawfulness of the processing carried out by this supplier concerning approximately 5,100 affected customers was established in violation of Articles 5, paragraph 1, letters a) and d) and paragraph 2 and 24 of the GDPR. It particularly emerged that the technical and organizational measures adopted by the data controller, within the processes of contracting customers implemented through the door-to-door agency channel, were not adequate to the nature, context, purposes, and risks of the processing, primarily constituting a violation of the accountability principle that requires the data controller to implement an organizational and management system characterized by effective and demonstrable data protection measures. Article 24 of the GDPR also requires the data controller to configure the processing from the outset by adopting all necessary guarantees to effectively protect the rights of the interested parties, requiring a careful analysis of the risks to the rights and freedoms of these parties.

After establishing the inadequacy of the accountability tools adopted by the company, the Authority imposed a monetary fine of 10 million euros and required the company to adopt a series of technical and organizational measures aimed at ensuring the accuracy of the personal data of potential customers, which, given the significant increase in recent years of the phenomenon of unsolicited

activations in the free energy market, must be suitable to strengthen the monitoring activities of the supplying companies over the actions of the external agencies tasked with contracting customers. The measures in question include, in particular, the introduction of alert systems capable of detecting any incorrect and/or fraudulent behavior by agents in acquiring the data of potential customers; the implementation of mechanisms to ascertain the actual receipt of communications sent to the customer during the contracting phase.

contractualization; the adoption of procedural rules aimed at strengthening audit activities concerning the actions of the agencies selected to carry out contractualization activities in a door-to-door manner.

It should be noted that, with reference to the data of customers for whom the activation of unsolicited contracts had been confirmed through the unlawful processing of their personal information, the Authority also noted the absence of a system suitable for anticipating, following a complaint regarding unsolicited activation (and pending its resolution), forms of segregation of any further and different processing activities of customer data, in order to precautionarily suspend any unlawful processing of the aforementioned data (e.g., for marketing or profiling purposes).

To this end, it was therefore prescribed, with the same decision, the implementation by the data controller of a procedure that provides for the timely limitation of any further processing activities of personal data related to contracts/contractual proposals for which a complaint regarding unsolicited activation has been submitted, based on mechanisms for data masking and logical and physical segregation of the same aimed at ensuring the separation of the related processing operations from those carried out in the context of ordinary customer management activities.

Also in the context of unsolicited contracts, a decision of similar nature was adopted on October 12, 2023 (prov. no. 476, doc. web no. 9965217) against a smaller energy supplier; in this case as well, the failure to adopt adequate technical-organizational measures aimed at ensuring the legitimacy of the processing of customer data during the contractualization phase was confirmed. This latter deficiency resulted in the loading into the company's systems of approximately 196 unsolicited contractual proposals, corresponding—during the reference period considered by the investigative activity—to 22% of the total contractual proposals acquired by the supplier through its door-to-door sales network.

The unlawfulness of the processing carried out by the company was therefore noted for the violation of Articles 5, paragraph 1, letters a) and d) and paragraph 2 and 24 of the GDPR, and various corrective measures were prescribed aimed at imposing on the data controller the preparation of a system of preventive controls aimed at promptly intercepting any incorrect and/or fraudulent behaviors of its agents under Article 28 of the GDPR (in this case, door-to-door agents), even before the submission of the complaint by the customers. At the same time, a monetary fine of two hundred thousand euros was imposed.

14.5. IMI Procedures Related to Data Processing in Economic-Production Contexts

Participation in the IMI system provided for by Regulation (EU) 1024/2012, for the management of cooperation and consistency mechanisms referred to in Chapter VII of the GDPR, has now become a significant commitment for all data protection authorities in the EEA (European Economic Area).

Regarding the economic sector, it is emphasized that IMI procedures concern heterogeneous cases related to a varied plurality of data controllers and processors, considering the granularity of the relevant sector.

In 2023, the prevalence of IMI procedures aimed at identifying the lead authority (pursuant to Article 56, paragraph 1, of the GDPR) and the concerned authorities (pursuant to Article 4, no. 22 of the GDPR) in the presence of cross-border processing, which represent about 80% of the procedures handled, was confirmed.

In 2023, the Authority declared itself "interested" in 78 cases (32%), while assuming the position of lead authority in a limited number of cases concerning companies with a single or main establishment in Italy.

Regarding complaints submitted to the Authority in 2023 pursuant to Articles 143 and following of the Code against companies based in another Member State, for which it became necessary to initiate the applicable cooperation procedures by transmitting the relevant documentation to the competent lead authority, the following are noted: a complaint alleging that when creating an account on a globally leading health and fitness app, the individual was forced to consent to the transfer of their data to the United States and other countries with different data protection laws, expressing consent that would not meet the requirements of the GDPR; another complaint in which it was alleged that during the password recovery procedure on a website of an Italian company, the complainant's PC browser incorporated the reCAPTCHA verification system, resulting in the automatic transfer of the individual's data to the United States, without them having expressed any consent in this regard; finally, a complaint concerning a request to a bank based in Luxembourg to access data preventing the issuance of a credit card and simultaneously obtain the deletion of the data.

The number of informal consultation IMI procedures provided for by Article 60, paragraph 1, of the GDPR remains substantially stable compared to 2022. In this regard, it is noted that the authorities of ****Data Protection****

They have now understood the importance, repeatedly emphasized by the EDPB, and particularly in the guidelines 2/2022 on the application of Article 60 of the GDPR, of resorting to this procedure aimed at allowing the exchange, between the lead supervisory authority and the concerned authorities, of information, assessments, and documents related to the dispute before the actual decision-making phase.

On the other hand, the cooperation procedures that reached the decision-making phase in the private sector have slightly increased compared to 2022. Regarding the draft decisions uploaded to the IMI platform by the competent lead authorities, it was deemed appropriate to share them while limiting, where appropriate, to raising only comments or requests for clarification. Furthermore, there is a case in which the complainant alleged a possible violation of the right of access following an alleged data breach; the Authority (the authority that received the complaint), after sharing the line decided by the lead authority to archive the case as no violation of Article 15 was found, adopted, pursuant to Article 60.8 of the GDPR, the final rejection measure (provision of March 23, 2023, no. 92, web doc no. 9885177).

Regarding the cases in which the Authority declared itself as the lead authority in relation to cases of cross-border relevance transmitted by other European data protection authorities, investigations were initiated (with related exchanges of information with the other concerned authorities) regarding a series of complaints or reports against companies headquartered in Italy (for example, price comparison platforms, e-commerce, car rentals), in which the data subjects mainly complained about the failure to exercise the rights of access or deletion or the possible violation of personal data.

In a case concerning a complaint filed by an Austrian citizen against a small company based in Italy operating in the publishing and website development sector, aimed at obtaining the deletion of the data of the data subject, the Authority proposed, through the IMI informal consultation procedure pursuant to Article 60, to amicably resolve the dispute, without adopting corrective/sanctioning measures. In the specific case, it was deemed that the conditions for an amicable settlement provided for by the EDPB guidelines 6/2022 on the practical implementation of amicable resolutions were met, and in particular: exercise of a right (deletion) and corresponding obligation fulfilled by the data controller, also thanks to the intervention of the Authority; limited number of data subjects involved and data processed; non-systematic nature of the violation and its mild effects; satisfaction of the data subject (who did not raise further objections). The Authority, as the lead authority, then shared its draft decision with the other concerned authorities, which did not raise relevant and motivated objections pursuant to Article 60, paragraph 4; the final decision was subsequently adopted with an amicable resolution of the dispute and closure of the procedure pursuant to Article 60, paragraph 7.

Regarding mutual assistance between supervisory authorities pursuant to Article 61 of the GDPR, still with reference to the economic sector, the use of the relevant IMI procedure to obtain information on

national regulations regarding data protection or on issues related to the application of specific provisions of the GDPR is confirmed. In particular, responses were provided to some requests for mutual assistance regarding: data retention of purchase data within loyalty programs; recording of customer phone calls; recording of employee data; Google Pay payment system; authentication methods in online payment systems; anti-money laundering regulations; debt recovery; installation of video surveillance systems in condominiums; video recordings through the use of dashcams.

Finally, on July 4, 2023, the European Commission presented the proposal for a regulation containing additional procedural rules in the context of the single window mechanism, regarding which the EDPB and the GEPD adopted a joint opinion on September 20, 2023 (see chapter 21). In this regard, it should be highlighted that the new regulatory framework, once the approval process is completed, will not only require the adaptation of the IMI platform to the requirements set forth by the new procedural rules but will also have an immediate impact on the national procedural provisions applicable in the handling of cases of cross-border relevance.

15

Other Treatments in the Private Sector

15.1. Processing of Personal Data in the Context of the Condominium

Even in 2023, there was a significant influx of requests related to the condominium sector, primarily concerning issues that had already been examined and resolved in the past, particularly regarding the circulation of data among the participants in the condominium assembly.

Regarding the possibility for condominium administrators to communicate the personal data of individual participants in the condominium assembly to other condominium owners, the Office, recalling the general provision of the Guarantor dated May 18, 2006 (doc. web n. 1297626) (for aspects compatible with the amended regulatory framework), clarified once again that only data relevant and not exceeding the purpose of administration and management of the condominium may be subject to lawful processing by the condominium (usually with the assistance of the administrator in their potential role as data processor); in particular, it was reiterated (see, among others, note of October 20, 2023) that, as a rule, the data—such as telephone numbers and/or email addresses (see, in this regard, Vademecum “The Condominium and Privacy” dated October 10, 2013, doc. web n. 2680240)—which, while potentially facilitating (especially in cases of necessity and urgency) contacts between the interested parties and/or the performance of the duties incumbent upon the administrator, are not, however, functional to the determination of rights or obligations related to the common property.

In the same perspective, guidance was provided regarding the publication of documents containing personal data (note of July 20, 2023). Starting from the established principle that personal data contained in notices, communications, or other documents posted in publicly accessible spaces cannot, as a rule, be disseminated—thus constituting “an unlawful processing (also in violation of the principle of proportionality)” —the Guarantor reiterated that utmost caution is necessary when publishing documents in condominium spaces that are publicly accessible, and appropriate security measures must be adopted, “if necessary, also by the condominium administrator,” to prevent the undue knowledge of data relating to the interested parties (for example, by publishing only general notices, or those devoid of personal data relating to identified or identifiable individuals).

Another relevant issue, already addressed in the past by the Authority (see Report 2015, p. 130, and 2022, p. 155), concerned the possibility of accessing the data of the condominium registry.

The Office, once again referring to two rulings on the matter of accessibility by individual condominium owners to the condominium registry (Trib. Palermo n. 2514/2021; Trib. Brescia n. 2177/2018), reiterated that “the knowledge of information concerning the participants in the condominium assembly must remain unaffected if this is in accordance with civil law or is otherwise provided for by other norms present in the legal system, provided that the relevant conditions set by law are met,” while maintaining the accessibility of the registry in question under the terms indicated by the same civil law (art. 1129, paragraph 2, c.c.) (note of July 14, 2023).

The Authority also reminded that personal information relating to each condominium owner may be processed for the purpose of managing and administering the condominium and that sensitive

personal data or judicial data may also be processed to the extent strictly necessary to pursue the same purposes. In particular, information relating to individual condominium owners may only be communicated to third parties with the express consent of the interested parties, or in the presence of another lawful basis identified in Article 6 of the GDPR and, in any case, in compliance with the general principles set out in Article 5 of the GDPR.

Following the handling of a complaint regarding the posting of a warning notice in the stairwells of a super condominium addressed to the complainants and containing certain personal data of the interested parties, the Guarantor reminded that condominium bulletin boards are to be used for general notices and not for communications that involve the use of personal data relating to individual condominium owners. For individualized communications, it is, instead, necessary to resort to alternative methods that prevent the risk of third parties becoming aware of information relating to individual condominium owners or tenants (note of November 9, 2023).

In defining a complaint regarding the sending of email communications with the email addresses of the interested parties in plain text, the Authority called upon the pro tempore administrator of the condominium to scrupulously observe the regulation on data protection, with an invitation to refrain from carrying out further data processing operations that do not comply with the aforementioned. Although the content of the emails in question pertains to issues concerning the management and administration of the condominium, the “cumulative” and “clear” use of the email addresses of the interested parties without the prior adoption of suitable measures to prevent the mutual visibility of the data by the recipients of the message – such as, for example, the bcc function (blind carbon copy) – is not in compliance with the principles of data protection (note of November 24, 2023).

Finally, reference is made to the decision of March 23, 2023, no. 91 (web doc no. 9885127) adopted following a complaint regarding the disputed communication of certain information about the health status of the complainants by the condominium administrator. The latter, in fact, having learned that the two complainants had contracted the Covid-19 virus, sent an email to all the condominium owners informing them of this particular circumstance. The Authority therefore established that the condominium administrator violated Article 9, paragraphs 1 and 2 of the GDPR, having processed the aforementioned data in the absence of any legitimate basis. In particular, the Authority clarified that the exemption for the processing of special categories of personal data (such as those subject to the processing in question) applies only in the cases expressly provided for by Article 9, paragraph 2, of the GDPR and had not been affected by the emergency regulations resulting from the Covid-19 epidemiological emergency, so that the prohibition remained unchanged for any public or private entity to disseminate, through websites or other channels, and to communicate (as in this case) the names of confirmed Covid-19 cases or individuals subjected to isolation measures for the purpose of containing the spread of the epidemic.

The Authority decided on a complaint filed by an interested party who lamented the installation of certain cameras in their condominium without an assembly resolution being adopted. In this regard, it should be noted that, in accordance with Article 1122-ter of the Civil Code (introduced by the condominium reform law with Law No. 220 of December 11, 2012), in conjunction with Article 1130, paragraph 1, point 1, of the Civil Code, the installation of video surveillance systems in condominium areas is subject to a decision made by the condominium owners through an assembly resolution, to be executed by the administrator by virtue of the mandate received.

During the investigation, conducted with the intervention of the Privacy Protection Unit of the Guardia di Finanza, documentation was obtained to prove that the installation of the aforementioned cameras had indeed been ordered directly by the administrator, in the absence of a condominium resolution, and that the administrator had limited themselves to communicating the intention to install a video surveillance system suitable for protecting the external condominium space, inviting the condominium owners to submit quotes at a subsequent assembly.

The Authority clarified that the condominium resolution represents the necessary prerequisite for the lawfulness of the processing carried out through the installation of cameras in condominium spaces. In

fact, through this act, the condominium owners contribute to defining the main characteristics of the processing, identifying the methods and purposes of the processing itself, the retention periods of the recorded images, and the identification of the authorized persons to view the images.

In the case at hand, it was also found that the condominium administrator, in addition to the installation of the cameras, had also decided their viewing angle and had equipped themselves with an application to view the images directly on their smartphone, upon entering authentication credentials known only to them. These circumstances, examined as a whole, allowed for the identification of the administrator (and not the condominium) as the data controller.

As a result, the processing of the personal data in question was carried out by the administrator in the absence of an appropriate basis for legality, pursuant to Article 6 of the GDPR. The Authority therefore declared the processing unlawful because it was carried out in violation of the general principles of lawfulness, fairness, and transparency (Article 5, paragraph 1, letter a) of the GDPR towards all interested parties (both condominium owners and non-owners) as well as in the absence of an appropriate basis for legitimacy pursuant to Article 6 of the GDPR (decision of October 26, 2023, no. 502, web doc no. 9960920).

Also in relation to the processing of data carried out by condominium entities through video surveillance systems for monitoring common areas, indications were provided regarding the profile of the legitimacy of the data controller to communicate the recorded images to third parties, specifying that such communication can only be lawfully made in the presence of adequate prerequisites and based on an appropriate legal basis.

It is necessary, in particular, to verify whether the processing is carried out solely for the purpose of protecting common property or also for the purpose of protecting the property of third parties. In this latter case, the (potential) communication of the data of the third party captured by the cameras could be admissible, and the legal basis could be identified in the pursuit of a legitimate interest also of the third party.

third parties, provided that the interests or rights and fundamental freedoms of the data subject do not prevail (Article 6, paragraph 1, letter f)). It remains clear, however, that any communication of data as defined above remains a mere option for the data controller and does not constitute a right of the data subject (note September 28, 2023).

15.2. Processing of data by associations and foundations

Regarding the processing of personal data carried out by associations and political parties, numerous complaints have concerned the lack of response from data controllers to requests made by data subjects pursuant to Articles 15 et seq. of the GDPR. Following an investigation initiated as a result of a complaint, the Authority issued a warning to an association that had informed the data subject, in response to their specific request, that it had deleted their personal data, but then sent them an additional email regarding the automatic renewal of their membership in the association.

In light of the circumstances that led to the delay in responding to the data subject and the actions taken by the data controller, the Authority deemed the case to be a minor violation, pursuant to Article 83, paragraph 2 and Recital 148 of the GDPR (decision August 31, 2023, no. 365, web doc no. 9936247).

The Authority also addressed the processing of certain personal data of the complainant, collected by a local committee during the signing of a petition directed to the mayor of their municipality and the president of the province, and subsequently disseminated through a post published on the Facebook page of a civic list associated with the mayor; the post included the name and political role of the complainant as a signatory of the aforementioned petition in order to discredit them regarding the issue of school closures/openings during the pandemic period and the adoption—within a few days—of diametrically opposed positions.

Following the investigative activity, during which the civic list stated that it had removed the post in question, the Authority, while acknowledging the political notoriety of the data subject and their participation in the political debate concerning the petition, recognized the unlawfulness of the processing carried out by the aforementioned civic list, against which it issued a warning.

The Authority considered that, in this case, the principles concerning processing carried out for journalistic purposes and other expressions of opinion, as referenced by the data controller in their detailed defense memorandum (Articles 136 et seq. of the Code), were not as relevant as the fact that the civic list, given its "political proximity" to the mayor and the majority representatives in the municipal council, had processed the personal data of the data subject—acquired by the aforementioned subjects for the performance of institutional functions—for its own purposes and in the absence of suitable legal grounds, as well as in violation of the general principle of lawfulness, fairness, and transparency as provided for in Article 5, paragraph 1, letter a), of the GDPR (decision April 13, 2023, no. 131, web doc no. 9892911).

In another case, the Authority expressed its opinion on a complaint concerning the dissemination of a press release regarding the removal of the complainants from the list of members of a political party, in the absence of their consent, deeming the protection of the legitimate interest of the aforementioned party underlying the said communication to prevail over the opposing interests of the data subjects, due to the specific context of reference.

It noted that the processing of the data of the data subjects by the party had been carried out based on the statutory acts of the organization and that the decision to publicly communicate the determinations made was in response to the need to provide accurate information to its voters and supporters in the context of the choices they were called to make during the then imminent administrative electoral consultations. This circumstance, supported by the presentation and candidacy of the complainants in competing electoral lists not supported by the party in question, in a local context of limited size, could plausibly have led the party's electorate to mistakenly support candidates no longer politically associated with it.

It was also highlighted that the political affiliation of the complainants could be considered already known to the local public due to their activism and the positions held by various interested parties at the time of the "suspension," thus meeting the condition provided for in Article 9, paragraph 1, letter e), of the GDPR. Therefore, the dissemination of the press release in question was found to be functional to transparency and the

correct information of the local community called to renew the representatives of the municipal administration, also highlighting the preeminence of protecting third-party voters and their legitimate interest in exercising their vote consciously and expressing their political preference (note June 7, 2023). Following a request made by a trade union association, as well as by some individual members of the same, the Authority intervened regarding the processing of data carried out through communications made via email within the association. More specifically, the complainants – mostly members of the trade union association that had submitted the report, but also individuals holding various positions within it – complained about the unlawful use, by a trade union organization different from their own, of their email addresses. The aforementioned organization had repeatedly sent various communications to these personal addresses, which contained messages of various kinds, largely informative regarding initiatives taken by it in the course of its trade union activities, involving a significant number (about 150) of third parties whose addresses were included in the mailing lists. Following the investigative activity – during which the association did not provide indications regarding the legitimacy requirements and the purposes of the contested processing, nor clarifications on how the addresses of the interested parties were obtained – it was found that the association in question had engaged in unlawful processing of the personal data of the complainants. In particular, starting from the assumption that the data consisting of an email address is personal in nature (cf. art. 4, no. 1, of the GDPR; see also WP 136 - opinion 4/2007 on the concept of personal data of the Group ex Art. 29 of June 20, 2007), the Authority first noted that the transmission of the contested communications to the email addresses of the aforementioned recipients had taken place in the absence of prior consent from them (or in any case in the absence of another suitable legal basis provided for by art. 6, par. 1, of the GDPR). Furthermore, it was established that such transmission had occurred through a single sending addressed to a multiple and undifferentiated number of interested parties whose personal data – in this case, the email addresses – were visible in clear text. This had indeed resulted in the mutual and unlawful communication of the email addresses of all the recipients involved in the contested emails, among whom were the complainants. Such transmission could have taken place in

an individualized manner, thus preventing undue communication of personal data to parties other than the individual recipient (see, in this sense, provisions of November 30, 2005, web doc no. 1213644; November 26, 2006, web doc no. 1364099, and May 18, 2006, web doc no. 1297626), or could have been carried out through the adoption by the association of appropriate measures to prevent the knowledge of the data of the various recipients of the messages, e.g., by using the so-called blind carbon copy function (see provision of July 4, 2013, web doc no. 2542348 and provision of January 9, 2020, web doc no. 9261234). The Authority therefore proceeded, based on the criteria indicated by art. 83 of the GDPR, to sanction the association in question for violation of the provisions contained in art. 5, par. 1, lett. a) and f), of the GDPR, as well as in art. 6, par. 1, lett. a), of the GDPR (provision of April 13, 2023, no. 130, web doc no. 9892716). In 2023, several requests regarding the so-called "de-baptism" were received. In particular, some failures to respond were reported by certain parishes to requests for rectification/deletion made by interested parties regarding the personal data contained in the register of baptized individuals and the annotation of their wish to no longer belong to the Roman Catholic Apostolic Church. While noting that the issue of the deletion of personal data in the religious context had already been examined by the Authority (see in particular provision of September 13, 1999, web doc no. 1090502, confirmed by the Court of Padua, section I civil, May 26, 2000, no. 3531/99), it was also reiterated, in general terms, that "baptism is not only an act of a confessional nature but also a constitutive legal act that marks a person's entry into the Catholic Church" and that therefore the deletion of an ineliminable piece of information cannot be requested "without altering the very representation of one's reality." Notwithstanding the above, the Authority intervened in cases where the requests for rectification/annotation had remained unanswered, contacting the relevant parishes and inviting them, in light of art. 16 of the GDPR and arts. 3, par. 1, lett. d) and 7, par. 2, of the general decree approved by the CEI on May 24, 2018 (which establishes the right to request the correction of personal data when incorrect or outdated, with an obligation for the data controller to adopt "all reasonable measures to delete or rectify inaccurate data in a timely manner concerning the purposes for which they are processed") to provide adequate feedback to the interested parties (note February 17, 2023). Of particular interest was also the feedback provided to a reporter regarding the processing of their personal data carried out by the Christian Congregation of Jehovah's Witnesses. The complainant had reported that, on the occasion of

****Public Meeting****

The so-called elders would have disclosed information regarding his exit from the Congregation, consequently suffering the effects on the level of relationships with other members (so-called ostracism). Referring to its provision of February 25, 2021 (doc. web no. 9574136), the Authority clarified that the Christian Congregation of Jehovah's Witnesses is a religious confession recognized as a moral entity with legal personality and, as such, is authorized to process the personal data of its members in accordance with its internal organization and the principles of worship to which it adheres. In this context, the personal data of members can be lawfully processed by the Congregation for the performance of the multiple activities related to worship and spiritual assistance to the faithful, including the processing of the same data for "the better achievement of its religious and worship purposes" (art. 3 of the Congregation's statute; see also the "Global Information of Jehovah's Witnesses regarding the processing of personal data" and the "Information on the processing of personal data – Italy," available on the Congregation's website).

Starting from these premises, the Authority, while recalling the conditions of lawfulness of the processing carried out by the Congregation (arts. 6, par. 1, lett. f) and 9, par. 2, lett. d), of the GDPR), deemed that the processing carried out by its territorial branches and religious bodies and ministers of worship in accordance with their internal practices—which may include, among other things, so-called public announcements—and in compliance with the precepts and principles disseminated by the same, were not in conflict with the regulations on the protection of personal data, both because the related processing operations would have taken place in respect of the faith activities professed by the organization, according to the doctrinal and catechetical provisions of the same confessional order, and because there was no evidence that the information processed by the Congregation had circulated outside the community.

It was finally represented (also in light of what was established by Trib. Roma on May 23, 2021, RGN 76320/2016, regarding the recognition of the right of the religious confession to inform its community about the cessation of the membership status of one of its (ex) members), the absence of suitable grounds for further initiatives by the Office as well as the possibility for the interested party to assert any further contentious aspects in another competent venue (arts. 57 of the GDPR and 154 of the Code) (note March 31, 2023).

****2023 REPORT****

****Video Surveillance in Commercial or Professional Contexts****

15.3. Video Surveillance in the Private Sector

In 2023, data processing carried out through video surveillance systems by private entities was the subject of a significant number of complaints and reports. Numerous violations in this area were committed by commercial establishments, particularly small to medium-sized businesses, reported by customers and local police who intervened for relevant checks. The most frequently detected violations concerned: external cameras with an excessively wide field of view, extending to public places or areas attributable to other private entities, well beyond the area immediately adjacent to the commercial establishment; cameras that frame the internal spaces of the store, installed to protect assets, but without requiring prior authorization from the territorial labor inspectorate or fulfilling the alternative obligations provided for by the Workers' Statute; failure to affix appropriate informational signs indicating the presence of cameras.

These are obligations that could be fulfilled by the owner of the commercial establishment with minimal effort (including financial), but which are often underestimated and, in the event of a violation, can lead to both administrative and criminal sanctions. Below are some of the numerous sanctioning measures adopted, in continuity with the orientations already consolidated in previous years, against some individual enterprises and some companies that had processed personal data through video surveillance systems in violation.

With the provision of June 8, 2023, no. 244 (doc. web no. 9917900), the Authority sanctioned a company for having installed a video surveillance system not adequately signaled by the affixing of appropriate signs containing the information referred to in art. 13 of the GDPR. Furthermore, from the inspection findings, it emerged that at the company's premises there were "six cameras, two inside the warehouse and four monitoring the external areas," capable of capturing the work activities of employees without the procedures provided for by art. 4 of Law no. 300/1970 being activated, and that some cameras were able to capture the public road as well. The Authority therefore adopted an injunction order requiring the company to pay a sum of money as an administrative pecuniary sanction and prescribed that the company conform the processing to the provisions on the protection of personal data that were violated.

With the provision of July 6, 2023, no. 293 (doc. web no. 9920881), the Authority sanctioned a company which, based on the findings made by the Guardia...

of private property, was found to be capturing images of public spaces and third-party properties. The Authority noted that the data controller failed to demonstrate a legitimate interest related to an actual risk that would justify such processing. Consequently, an administrative monetary sanction was imposed, along with a reasonable timeframe to bring the processing into compliance with general principles.

In the context of surveillance systems installed in private settings, particular attention should be given to certain measures adopted against individuals. Although, in general, the provision of Article 2, paragraph 2, of the GDPR excludes from the scope of data protection law the processing carried out by a "natural person for the exercise of activities of an exclusively personal or domestic nature," in the cases at hand, the Authority not only deemed the general regulation applicable but also noted the lack of suitable legal bases for the related processing activities.

It is not possible to invoke the exclusion provided for in Article 2, paragraph 2, of the GDPR when the scope of data communication exceeds the family sphere of the data controller, or when the images are subject to communication to third parties or dissemination, or when the processing extends beyond strictly relevant areas by capturing images in common areas (including condominium types such as staircases, hallways, parking lots), publicly accessible places (streets or squares), or areas belonging to third parties (gardens, terraces, doors, or windows belonging to third parties). Only in the presence of actual risk situations can the data controller, based on a legitimate interest, extend the camera coverage to areas that fall outside their exclusive relevance. In such cases, the data controller is required to comply with the provisions on personal data protection, also in light of the guidelines 3/2019 on the processing of personal data through video devices, adopted by the EDPS, and the general provision on video surveillance of April 8, 2010 (doc. web no. 1712680).

The Authority specifically adopted the provision of April 27, 2023, no. 173 (doc. web no. 9896468), which established the illegality of the processing carried out by an individual who had installed cameras to protect private property, which, however, were oriented in such a way as to also capture public spaces and third-party properties. Given that, during the investigation, the data controller did not demonstrate the existence of a legitimate interest related to an actual risk that would justify such processing, an administrative monetary sanction was applied, along with the indication of a reasonable period within which to bring the processing into compliance with general principles.

A similar rationale to that briefly outlined above is contained in the warning provision adopted by the Authority against a farming company whose surveillance system, also installed for the protection of private property, was found to be capturing images of public spaces and third-party properties. of the private residence of the data controller, it was found to be potentially suitable to also capture the areas owned and related to the complainants (provision of March 2, 2023, no. 59, web doc no. 9872567). Considering the activities carried out by the data controller during the proceedings, the case was classified as a "minor violation," pursuant to Article 83, paragraph 2, and Recital 148 of the GDPR.

By provision of July 18, 2023, no. 319 (web doc no. 9935503), adopted at the conclusion of a procedure initiated following a complaint, the Authority identified an unlawful processing of personal data carried out through a video surveillance system capable of capturing the public road in the absence of lawful grounds for processing and, therefore, deemed it necessary to order the data controller to adopt the necessary measures to restrict the recording to the strictly relevant areas, as well as to pay the sum of €400.00 as an administrative pecuniary sanction.

Similarly, in a case reported by the municipal police of the Municipality of Arezzo, the Authority issued a warning to a private individual who had installed two cameras on the exterior of the property capable of capturing the public road. The cameras had been installed to monitor the vehicle parked in the parking space assigned to the data controller, but in fact also captured the adjacent public road and part of public parking areas. Following the adoption of masking measures, the recording was restricted to the parking area of the vehicle (provision of September 28, 2023, no. 429, web doc no. 9947775).

Finally, the Authority noted that a camera capable of capturing the public area in front of a private individual's property, where a playground and a square are located, had been installed on the exterior wall. This camera, in addition to capturing images, also allowed for audio recording in the immediate vicinity and for intervention by speaking through the microphone. In this case as well, the investigation highlighted that the recording of areas beyond those relevant had occurred in the absence of suitable lawful grounds, considering that the data controller had not demonstrated the existence of a legitimate interest related to an actual risk situation that would justify such processing. The same conclusions applied to the capture of conversations occurring in public spaces through audio devices.

Having replaced the previously installed camera with a fixed one aimed only at the entrance of the residence, the Authority warned the data controller for the violation of Article 5, paragraph 1, letters a) and c), and Article 6, paragraph 1, of the GDPR (provision of October 12, 2023, no. 477, web doc no. 9949494).

THE ACTIVITY CARRIED OUT BY THE AUTHORITY

****Artificial Intelligence and the Right to Personal Data Protection****

****Towards the EU Regulation on AI****

The term "artificial intelligence" (hereinafter AI) has now entered common usage, and its multiple applications continue to be the subject of extensive debate with the aim of finding a balance between innovation and regulation (in the various forms it can take), so that the potential of the latest technological advancements can find space without compromising not only the fundamental rights and freedoms of individuals but also supra-individual interests, such as the preservation of the democratic nature of legal systems. It is particularly in the supranational dimension that the search for this balance has taken place throughout 2023; indeed, efforts have continued to identify a (sufficiently) shared regulatory framework (as already highlighted in the previous 2022 Report, p. 159) both within the European Union, regarding the AI regulation, and within the Council of Europe, concerning the Framework Convention on Artificial Intelligence, Human Rights, Democracy, and the Rule of Law. Without delving into a detailed analysis of the content of these instruments, some brief considerations can nonetheless be made here.

A priority relevance for EU member states is represented by the regulatory framework aimed at governing the social applications of AI and the conditions that will regulate the introduction of AI systems into the European market: in this regard, following the proposal for a regulation presented by the European Commission on April 21, 2021 – on which the joint opinion, issued on June 18, 2021, by the EDPB and the EDPS focused (profiles referred to in the 2021 Report, p. 194) – the common position of the EU Council was formed on December 6, 2022 (in <https://data.consilium.europa.eu/doc/document/ST-14959-2022-INIT/it/pdf>) and the negotiating position of the European Parliament was reached on June 14, 2023 (see https://www.europarl.europa.eu/doceo/document/TA-9-2023-0236_IT.html).

Following the political agreement reached within the so-called interinstitutional trilogue in December 2023, the Provisional Agreement on the regulation was reached on February 2, 2024, with subsequent approval of the text by the European Parliament on March 13, 2024; the legislative procedure can conclude, according to the ordinary procedure, with the formal approval by the EU Council, in accordance with Article 194 TFEU. The AI regulation, which expressly preserves the rules on personal data protection (see Article 2, paragraph 7), will nonetheless find gradual application starting from its entry into force.

Wishing to make a quick reference to the contents – with...

the eye particularly focused on aspects of direct relevance for the protection of the right to private life and personal data –, it can be said that the regulation identifies certain prohibited applications of AI systems and establishes differentiated obligations for the remaining ones based on possible risks and the level of impact on fundamental rights and freedoms (so-called risk-based approach).

Regarding prohibited AI practices, these are indicated in Article 5, a provision that will require careful assessment (not free from some interpretative effort) in view of their precise identification: only in very rough approximation (and by way of example), it can be said that AI systems that use subliminal or manipulative techniques or exploit the vulnerabilities of individuals and groups are subject to prohibition. Also prohibited, under the indicated conditions, are social credit systems as well as certain so-called predictive policing AI systems (if based exclusively on profiling or assessing the characteristics of a person); emotion recognition systems in the workplace and educational institutions; furthermore, biometric categorization systems based on sensitive characteristics and the indiscriminate extrapolation of facial images from the internet or from closed-circuit surveillance recordings to create facial recognition databases.

However, AI systems that allow remote "real-time" identification for law enforcement purposes – critically assessed in the opinion of the EDPB/EDPS No. 5/2021 (see 2021 Report, p. 223) – may be used in the presence of the conditions indicated by the regulation (in Article 5, letter h) of the latter), in compliance with the protective measures and necessary and proportionate conditions regarding use,

in accordance with national law that authorizes such use, as well as prior impact assessment on fundamental rights by the authority intending to employ them. The use of such systems is also generally subject to prior authorization granted by a judicial authority or by an independent administrative authority and is subject to notification to the relevant market surveillance authority and the personal data protection authority.

In relation to the design and use of high-risk AI systems – such as, by way of example, those related to education and vocational training, employment, the provision of basic public and private services, the use of certain countermeasure systems, as well as systems designed for border management, for justice purposes, and in the context of democratic processes (such as in the case of AI systems used to influence elections) – penetrating obligations are foreseen, including those to assess and mitigate risks in advance (Article 9); to adopt governance practices for training, validation, and testing datasets (Articles 10-11); to prepare and maintain the relevant technical documentation (Article 11); to keep an automatic logging of events for the entire duration of their lifecycle (Article 12); to fulfill transparency obligations, so as to allow “deployers to interpret the system's output and use it appropriately,” including through specific usage instructions (Article 13); to ensure effective human oversight during the period in which they are in use, in order to prevent or minimize risks to health, safety, or fundamental rights that may arise when a high-risk AI system is used in accordance with its intended purpose or in reasonably foreseeable misuse conditions (Article 14); to ensure accuracy, robustness, and cybersecurity (Article 15).

Specific obligations are also outlined for the various subjects that design, use, or otherwise contribute to the marketing of high-risk AI services (providers, authorized representatives, importers, distributors, and deployers of high-risk AI systems). Individuals are granted the right to submit complaints regarding AI systems (without prejudice to other forms of protection, including those provided by personal data protection regulations) and to receive explanations regarding decisions based on high-risk AI systems that affect their rights.

The regulation also governs AI systems for general purposes (not mentioned in the original proposal of the Commission), also providing specific transparency requirements (Articles 50 and 51 et seq.). In relation to more powerful models, which could pose systemic risks, additional obligations are foreseen, such as conducting model assessments, evaluating and mitigating systemic risks, as well as reporting incidents. Images and artificially or manipulated audio or video content (the so-called deepfakes) must be clearly labeled as such (Article 50, paragraph 4).

Member States must establish and make accessible at the national level regulatory experimentation spaces (so-called sandboxes) and mechanisms for testing under real conditions. in order to promote the development of innovative AI systems with a view to their market introduction (Articles 57 et seq.); in this context, personal data protection authorities may also be called to operate (cf. Article 57, paragraph 10).

In this regard, the AI regulation expressly preserves the rules concerning personal data protection (and, therefore, the powers of the independent authorities established under the GDPR and the national legislation implementing Directive 2016/680: in the Italian case, the Garante). That said, it must be noted that, at first glance, it appears complex and to a significant extent left to the intervention of national legislators, who are called to identify the competent national authorities - one (or more) national notification authority and one (or more) national market surveillance authority - the institutional framework that, at the national level, must ensure oversight of the proper functioning of various AI systems and the harmonious coordination among the various authorities that (also in different capacities) may be called to carry out an overall oversight activity on the functioning of AI systems. In this regard, on several occasions and in line with what was already represented during the informal hearing held on March 9, 2022, before the IX and X Committees of the Chamber of Deputies in the margins of the proposal for a regulation (EU) on artificial intelligence (web doc. no. 9751565), the Garante (not differently from the opinions expressed in the past by the EDPB and the EDPS) reiterated the reasons in favor of a position of primacy of the Authority, namely the close connection between the matter of personal data processing and the functioning of AI systems, often high-risk, focused on the

use (in the design or execution phase) of such data as well as the full independence that should characterize the actions of those required to carry out enforcement on AI systems based on the provision contained in Article 70, paragraph 1. In fact, from the perspective shared by European data protection authorities, the processing of personal data carried out through AI (or that contributes to the so-called training of the latter) naturally falls within the scope of protection provided by data protection regulations, among which is the oversight by data protection authorities, in line with the provision contained in Article 8 of the Charter of Fundamental Rights of the European Union.

Also within the supranational framework, it is worth highlighting the work of the Committee on Artificial Intelligence (CAI), to which a representative of the Authority contributed, in agreement with the Ministry of Foreign Affairs and in close coordination with the Permanent Representation of Italy to the Council of Europe. Initiated in Rome on April 4, 2022, with the Inaugural Meeting organized by the Council of Europe and the Italian Presidency of the Committee of Ministers of the Council of Europe, the negotiation of the Convention required a commitment greater than initially anticipated, as evidenced by the larger number of meetings held compared to those originally planned in order to gather broader consensus among participants (cf., in detail, Part IV, Table 22); for further information, see also <https://www.coe.int/en/web/artificial-intelligence/cai>. As is known, the drafting of the framework Convention involved not only the contracting Parties but also, as observers, representatives of civil society and numerous other States in whose jurisdictions the main actors in the development of AI systems often operate: among others, Canada, Japan, Israel, and the USA. The text drafted by the Committee will be submitted for adoption by the Committee of Ministers of the Council of Europe to then be opened for ratification, including by States other than the contracting Parties (similarly to what has already occurred in the past with Convention 108/1981 on the protection of individuals with regard to the automated processing of personal data or with the Convention on Cybercrime 185/2001).

Considering, as already mentioned, the now undisputed transnational relevance of the issue, aspects of AI are constantly the subject of discussion in various forums for in-depth analysis and discussion: thus, during the third Roundtable of G7 Data Protection and Privacy Authorities held on June 20 and 21, 2023, in Tokyo, AI topics were also discussed among those related to emerging technologies, and the Garante, represented by Vice President Ginevra Cerrina Feroni, contributed to the drafting of the Statement on Generative AI of June 21, 2023 (see also paragraph 21.4). Indeed, AI topics (which are also present in the Action Plan: cf.

https://www.ppc.go.jp/files/pdf/G7Roundtable_202306_actionplan.pdf) will be discussed again during the fourth Roundtable of G7 Data Protection and Privacy Authorities, which, organized by the Garante, will be held in Italy from October 9 to 11, 2024 (cf. web doc. no. 9956837).

Also on the international collaboration front, the effects of AI on the right to data protection and on fundamental rights have continued to be the subject of discussion and subsequent elaboration, also with the constructive contribution of the Authority, within the Global Privacy Assembly (GPA): this activity, following the work carried out particularly within the GPA Working Group on Ethics and Data Protection in AI (AIWG), led to the adoption, during the 45th meeting of the GPA (Hamilton, Bermuda, October 15-20, 2023), of the Resolution on AI and Employment and, picking up the theme already addressed in the context of the aforementioned G7 DPA Roundtable, the Resolution on Generative AI Systems (available at <https://globalprivacyassembly.org/document-archive/adopted-resolutions/>).

The Italian practical experience regarding the GDPR in relation to the first cases of integration with AI has also been the subject of discussion within the European Case Handling Workshop (ECHW) 2023 (Bern, November 8-9, 2023), specifically referring to the theme “Personal data and face detection,” which was prompted by a measure adopted by the Authority on April 13, 2023, no. 122 (web doc no. 9896412, see further par. 4.12).

The dynamism characterizing the technological as well as institutional developments related to AI has been the subject of multiple meetings (see also par. 23.4): it is worth recalling the active participation of a representative of the Office, together with representatives of other European data protection authorities, at the event titled “Towards the Artificial Intelligence Act,” organized by Hon. Brando

Bonifei at the European Parliament (March 7, 2023) and focused on the AI regulation proposal, as well as at the panel dedicated to the theme “AI Beyond Privacy: Solving the Governance Dilemma” within the 12th IAPP Europe Data Protection Congress 2023 (Brussels, November 15, 2023), alongside a representative of the French supervisory authority and Hon. Dragoș Tudorache, as well as at the international conference “Next Democratic Frontiers for Facial Recognition Technology” (University of Florence, September 29, 2023) and at the seminar “Improving GDPR compliance at work: the path ahead” organized by the Friedrich-Ebert-Stiftung’s Competence Centre on the Future of Work (Brussels, November 19, 2023).

Among the interactions with various stakeholders dealing with AI-related issues, it is worth mentioning some working groups at CEN/CENELEC JTC 21, particularly dedicated to the profiles of identifying and managing risks associated with AI (AI risk catalogue and risk management) as well as to the theme of so-called data quality. The work of standardization bodies will assume increasing relevance with the adoption of the AI regulation.

The action (and attention) of the Authority has not been limited to the supranational level. From the regulatory activity of the Authority, it is indeed possible to infer an increasing use of AI techniques, primarily in the context of medical-scientific research (see in this regard the measures of September 28, 2023, no. 465, web doc no. 9948285 and October 12, 2023, no. 472, web doc no. 9953841), and, more generally, in the provision of national health services, a topic on which the Authority has provided general guidance regarding the lawfulness of the processing carried out with the “Decalogue” published on October 10, 2023 (web doc no. 9938038; see further par. 5.2). As already highlighted in the previous Report (see p. 161) with reference to the activity against evasive/elusive phenomena in the tax field, the use of AI systems in support of control activities has also been envisaged, with the legislative proposal for a guarantee framework, in the draft legislative decree concerning the simplification of controls on economic activities in implementation of the delegation to the government referred to in art. 27, paragraph 1, law no. 118/2022, regarding which the Authority provided its opinion with measure of August 31, 2023, no. 387 (web doc no. 9929069, see par. 3.1.2).

It is also worth mentioning the measure of February 2, 2023, no. 39 (web doc no. 9852214), which imposed a temporary limitation regarding the processing of data relating to individuals residing in the national territory adopted by the Authority against a company established in the United States that manages a chatbot, equipped with a written and vocal interface, which, using an AI system, generates a “virtual friend.” This measure was adopted

****On the assumption that the application would present concrete risks, particularly for minors (e.g., in relation to the formulation of inappropriate responses to the developmental level of minors or in the presence of emotionally fragile individuals), which is further increased due to the perceived absence of mechanisms to verify age, as well as for certain deficiencies identified by the Authority regarding the privacy policy (see further paragraph 12.7).****

****The valuable collaboration with the National Interuniversity Consortium for Computer Science - CINI (which was already mentioned in the 2021 Report, p. 195) has continued within the framework of the three-year framework agreement formalized on January 17, 2022. In this spirit, the President of CINI participated, with an opening speech, in the work of the International Working Group on Data Protection in Technology (the so-called Berlin Group), held in Rome from June 6 to 7, 2023 (regarding which see the summary reported in web document no. 9902660).****

****Cooperation with CINI has materialized in multiple discussions that took place throughout the year with the "National AI Lab," in order to facilitate mutual understanding of the interrelations between AI issues and personal data protection disciplines. Similarly, collaboration with the National Lab "Informatics and School" has continued, particularly in relation to the initiative "Program the Future"; in this context, a second cycle of webinars organized by Authority staff and dedicated to issues of interest to minors regarding new technologies took place in 2023; all webinars (recorded and enriched with primary reference materials) are accessible at the address <https://programmailfuturo.it/notizie/webinar>. Finally, thanks to the coordination provided by the National Lab "Informatics and Society" and the participation of teachers and researchers from some of the universities affiliated with CINI, an internal**

seminar series on various aspects related to the development of ICT was held at the Authority.**

Cooperation has also continued within the framework of the research project called Legality Attentive Data Scientist (LeADS), funded by the EU under the Horizon 2020 – Research and Innovation Framework program and coordinated by Prof. Giovanni Comandé (Scuola superiore Sant’Anna di Pisa), in which the Authority participated as a partner. This initiative, aimed at training experts in data science and law, involved the University of Luxembourg along with Paul Sabatier Toulouse III, Vrije Universiteit Brussels, the University of Piraeus, the Jagiellonian University, and the National Research Council, as well as some companies. Within this framework, the Authority hosted four doctoral candidates affiliated with the university consortium at its headquarters during the year.

****II.16 THE ACTIVITIES CARRIED OUT BY THE GUARANTOR****

****17 Personal Data Breaches****

From January 1 to December 31, 2023, the Authority received notifications of 2,037 personal data breaches pursuant to Article 33 of the GDPR or Article 26 of Legislative Decree No. 51/2018 (see section IV, table 9) from public (37% of cases) and private (63% of cases) entities. A large portion of the personal data breaches was reported in phases (about 64% of cases) with the initial submission of a preliminary notification and subsequently one or more supplementary notifications (see section IV, table 10).

In particular, in the public sector, personal data breaches primarily involved municipalities, educational institutions, and healthcare facilities; in the private sector, large companies in the telecommunications, energy, banking, and services sectors were involved, as well as small and medium-sized enterprises and professionals.

**The majority of the reported personal data breaches concerned the loss of confidentiality or availability (even if only temporary) of personal data (about 88% of cases; see section IV, table 11). The most frequently encountered phenomena were the dissemination of ransomware-type malware, compromising the availability and, in many cases, the confidentiality of data within server systems or workstations of public and private organizations; unauthorized or unlawful access to personal data processed within information systems; the compromise... **

****Transfer of Personal Data Abroad****

****BCR****

In 2023, the collaboration activity of the Authority within the Task Force 101 (so-called TF 101) was concluded. This task force, as previously reported in the 2022 Report (p. 164), was specifically tasked by the European Data Protection Board to coordinate the examination of 101 complaints regarding the legality of transfers of personal data to the USA, carried out by certain website operators through the use of Facebook Pixel.

As a result of the coordination activity and the exchange of information among the various participating national supervisory authorities in TF 101, elements regarding the characteristics of the services provided by Meta Platforms were acquired, which were useful for defining the national investigations, also considering the imminent adoption of the EU-US agreement known as the Data Privacy Framework (see 21.1).

The evaluation of requests received by the Authority regarding the approval of Binding Corporate Rules (BCR) pursuant to Article 47 of the GDPR also continued.

In particular, on June 8, 2023, the Authority approved (provision no. 243, web document no. 9921218) the BCR prepared by a multinational corporate group, a leader in the digital infrastructure sector (see 2022 Report, p. 165).

These binding corporate rules concern intra-group transfers, as specifically identified in the appendix attached to the Authority's provision, carried out by the group companies as data controllers.

In this regard, it is worth highlighting that this is the first European cooperation procedure aimed at the approval of BCR conducted by the Authority as the Lead Authority (so-called BCR lead).

This procedure involves the activation of the so-called consistency mechanism, within which a favorable opinion from the EDPB was obtained on May 17, 2023, pursuant to Article 64, paragraph 1,

letter f), of the GDPR (see Opinion 9/2023 of May 17, 2023).

At the conclusion of this procedure, the Authority approved, pursuant to Articles 57, paragraph 1, letter s), and 58, paragraph 3, letter j), of the GDPR, the binding corporate rules for the data controllers prepared by the aforementioned group, as adequate safeguards under Articles 46, paragraphs 1 and 2, letter b) and 47, paragraphs 1 and 2 of the GDPR for the intra-group transfer of personal data to third countries, carried out by the companies belonging to that group.

19

Inspection Activity

19.1. Inspection Activity Between Planning and Contingencies

After the inevitable difficulties and constraints that characterized the long period of the state of emergency caused by the Covid-19 pandemic, the year 2023, marking a general return to normality, has also allowed for a more regular conduct of inspection activities. The statistical data that condenses the commitment of these months is testimony to this: a total of 144 on-site inspection interventions were carried out in 2023, of which 51 were conducted directly by personnel serving at the Office of the Guarantor, and the remaining 93 were delegated to the Special Privacy and Technological Fraud Unit of the Guardia di Finanza. In addition to these significant numerical values, considering the limited human resources available, there were also 49 remote inspections (so-called online inspections) aimed at verifying compliance with the provision containing the Guarantor's guidelines on cookies and other tracking tools dated June 10, 2021, no. 231 (doc. web no. 9677876) (see below). All inspection activities carried out, both those arising from autonomous initiatives of the Office and those related to the definition of ongoing investigations (also conducted urgently), have obviously been aligned with the two resolutions approved by the Board (provisions of January 26, 2023, no. 23, doc. web no. 9862660 and August 3, 2023, no. 339, doc. web no. 9920683) with which, according to the prescription of art. 4 of reg. no. 1/2019, the Guarantor has set the lines for the semi-annual programming of inspection activities.

As for the operational modalities of the inspections carried out directly by the Office, one data emerges with increasing frequency: the complexity of the verifications to be carried out. This has made it customary to resort to specific inspection teams composed of officials from the competent legal department, inspectors with functions of judicial police officers, and IT specialists belonging to the Technological Department of the Authority. Attention to technological aspects and, within these, to the verification of measures to protect so-called cybersecurity, has acquired a central relevance that is explicitly reflected in the prescriptive and/or sanctioning provisions that, also following on-site verifications, define the related investigations.

For a better understanding of the activities carried out, it may be useful to dedicate a brief mention to some of the areas in which some of the most significant inspection interventions have been concentrated:

- SPID. The constant attention of the Office towards issues related to digital identity and its use has led to a series of inspections (set to continue into 2024) aimed at verifying the correctness of the procedures for issuing and using SPID, especially regarding the proper identification of individuals wishing to use it, stemming from numerous reports of irregularities and fraud received by the Office;
- Scientific Research. A series of inspections has concerned the correctness of the procedures adopted, particularly by IRCCS (Institutes for Hospitalization and Care of Scientific Character), in carrying out research activities, with particular regard to the information provided, the consents obtained, and the adoption of proper data anonymization techniques;
- Facial Recognition Technologies. In relation to these technologies (which are subject to great attention and explicit regulatory limits even at the EU level), inspection interventions have been conducted both at airport facilities that had initiated trials in this regard and at companies that unlawfully employed such technologies for monitoring employee attendance. During some of these interventions, suppliers of the equipment were also traced, and through their accounting documentation, other purchasing subjects were identified, in order to extend the scope of the verifications and prevent the proliferation of unlawful uses, often to the detriment of employees;
- Data Breach. The on-site verification of the reasons that led to the occurrence of personal data breaches and the control over the actual adoption of all necessary technical and organizational

measures to remedy them represent one of the main areas of inspection interventions in recent years. With regard to violations affecting particularly sensitive and/or large databases, special attention has been paid to evidence of unlawful access carried out by employees of public administrations;

- VIS System (Visa Information System). The inspection cycle, which had already begun the previous year (see 2022 Report, p. 167), dedicated to controls on this computerized system for sharing data related to entry visas into the Schengen area, was completed in 2023. In particular, an on-site verification was conducted.

at the Italian Consulate in Tunis, preceded by the necessary discussions with the Ministry of Foreign Affairs and the Italian Embassy in Tunisia;

- marketing. Under this generic heading, the numerous inspection activities carried out on-site in the past year, particularly concerning companies operating in the broadly understood energy sector, are included. In view of the widespread opening to the market, the phenomenon of so-called wild marketing has developed, which, starting from the acquisition and trade of enormous databases of users from former monopolists, leads to a concerning proliferation of commercial and advertising calls in the absence of the consent of the interested parties and the signing of contracts with false signatures or obtained by misleading the good faith of the recipients.

19.2. Online checks on the so-called guidelines regarding cookies

As already mentioned in paragraph 19.1, the year 2023 has seen the addition of remote inspections to traditional on-site checks, carried out through the verification, via the internet, of the compliance of a significant number of websites with the rules identified by the Authority in the guidelines regarding cookies and other tracking tools of June 10, 2021, no. 231 (web doc no. 9677876). This is an effective operational mode that allows for the realization of a substantial number of checks, thus multiplying the possibilities of verifying the actual adherence of data controllers to the principles established by the regulations and the indications of the Guarantor, with particular regard to the completeness of the information provided by the websites and the correct acquisition of the consents of the interested parties.

19.3. Collaboration with the Guardia di Finanza

The collaborative relationship with the Guardia di Finanza, defined in the Memorandum of Understanding of March 21, 2021, (web doc no. 9570071), is now a consolidated reality and has allowed the Guarantor, even in 2023, to increase the number of on-site inspection interventions. This has mainly occurred with the commitment of the special privacy and technological fraud unit of the Guardia di Finanza, and, through it, in some circumstances, collaboration has been activated with the territorial departments of the Corps. The delegated activities have concerned a wide range of situations: from the notification of acts and documents, to the collection of information on-site, to the search and identification, through field checks and/or consultation of the databases in use by the Corps, of data controllers and processors. In addition to these essential but certainly more routine activities, more complex and delicate inspections have been carried out in total autonomy or with the simultaneous participation of personnel from the Office. In this perspective, a continuous training commitment has continued, through meetings and in-depth studies at the Guarantor's headquarters, aimed at qualifying and specializing the inspectors of the Unit and thus facilitating the realization, in full autonomy, of more numerous inspection cycles.

20. The jurisdictional litigation

20.1. General considerations

In application of the current regulatory framework, all disputes concerning the application of the regulations on personal data protection must be communicated to the Guarantor, even if they do not relate to the appeal of measures of the Authority (art. 152 of the Code and art. 10, paragraph 9, legislative decree no. 150/2011, as amended by art. 17 of legislative decree no. 101/2018). In relation to this informational obligation, a significant increase has been recorded in the past year compared to the past: against 58 appeals in 2021 and 70 in 2022, in 2023 the Authority was informed of the pendency of 101 disputes regarding data protection among third parties. On the other hand, the other obligation, on the part of the court registries, to transmit to the Guarantor a copy of the measures

issued by the judicial authority in matters of data protection and cybercrime (art. 154, paragraph 6, of the Code) is not always fulfilled punctually. Such communications contribute to enriching the Authority's knowledge of the evolution of jurisprudence in the field of personal data protection and to identifying the legislative interventions deemed necessary for the protection of the rights of the interested parties, to be reported to Parliament and the Government.

20.2. The oppositions to the measures of the Guarantor and

****Judicial Decisions of Major Importance****

The year 2023 recorded a significant reduction in the filing of appeals against measures of the Authority: 75 compared to 123 appeals in 2022. Furthermore, during the past year, the Authority was informed of 159 decisions from the judiciary related to appeals against measures of the Guarantor (of which 37 pertained to payment notices), compared to 113 received in 2022. Below is a summary of the most significant rulings.

With judgment dated June 9, 2023, no. 451, the Court of Cuneo rejected the appeal filed by a municipality pursuant to Article 615, paragraph 1, of the Italian Civil Procedure Code against the payment notice imposing a monetary sanction issued by the Authority following the measure whereby the Office contested the violation of Article 13 of the Code, sanctioned by Article 161 of the same Code, both in force at the time, for having carried out processing of personal data without providing adequate information to the interested parties.

The proceedings originated from a report in which the interested party complained about the inadequacy of the information concerning the processing of personal data carried out by the municipality through an electronic device for detecting traffic light violations. During the proceedings, the regulation provided for by Legislative Decree No. 101/2018 intervened, so that the immediate contestation act referred to in Article 14 of Law No. 689/1981 assumed the "value of the injunction order [...] without the obligation of further notification" (pursuant to Article 18, paragraph 3, Legislative Decree No. 101/2018), whereby the Authority proceeded to register the said amount owed by the municipality due to the report of administrative violation dated December 7, 2016.

It is essential to highlight that the judge deemed the preliminary objection raised by the Guarantor regarding the inadmissibility of the appeal due to the expiration of the term pursuant to Article 10, paragraph 3, Legislative Decree No. 150/2011, to be unfounded. According to the Court, in fact, "by virtue of Article 18 of Legislative Decree No. 101/2018 (considered fully applicable in this context), the intra-procedural act of contestation of the violation notified to the alleged offender on December 7, 2016, was transformed, by operation of law, into a final measure of the sanctioning procedure having the value of an injunction order. In other words, by virtue of the legislative amendment, the sanctioning measure that prejudiced the position of the municipal entity coincides entirely with the act of contestation of the violation of Article 13 of the Privacy Code in its formulation in force at the time: it is a measure that was formed progressively by silentium and, in particular, by virtue of the notification of the act of contestation to the alleged offender and, following the entry into force of Legislative Decree No. 101/2018, due to the failure of the latter to submit defensive memoranda to the administrative authority within the peremptory term set by the legislator.

Having stated this, the party subject to the sanction may assert the defects of illegitimacy of the sanctioning measure (as emerging from the act of contestation which has the value of an injunction order) – as well as the constitutional defects of Article 18 of Legislative Decree No. 101/2018 that transformed the act of contestation of the violation into a conclusive measure of the administrative procedure and that, therefore, indirectly, impact the validity of the sanctioning measure – within the expiration term referred to in Article 10, paragraph three, of Legislative Decree No. 150/2011, which obviously runs from the date on which the notification of the payment notice was perfected, as the latter represents the first act through which the municipality was informed of the imposition of the sanction against it.

The opposition to execution is therefore considered in this instance as "recovering" a guarantee denied to the addressee by virtue of the intervening legislation, and the thesis (supported by the Office and the

Legal Counsel) that the starting point, from which the 30 days for appeal have elapsed, should be identified as the date on which the ninety days after the entry into force of the decree expired, after which, in the absence of facilitated payment or submission of new memoranda, the contestation would have been converted by operation of law into an injunction order, is not accepted.

The judge's considerations regarding the constitutional legitimacy of Article 18, paragraphs 2 and 4, of the aforementioned Legislative Decree No. 101/2018 appear interesting. Despite the premise regarding the procedure specified, the judge nonetheless deemed the overall structure of Legislative Decree No. 101/2018 to be constitutionally legitimate, highlighting its rationale of reducing the administrative burden, providing a reading of the Constitutional Court's ruling No. 260/2021 which found this regulation non-compliant only in the part relating to the interruption of the five-year prescription period for the administration's right to... collect the sums (paragraph 5).

It has also fully accepted all the exceptions raised in the merits by the defense of the Guarantor, confirming the provision of the Authority and the failures of the municipality regarding the information provided to citizens.

With judgment of May 31, 2023, no. 8722, the Court of Rome confirmed the corrective-sanctioning provision of the Guarantor of November 26, 2020, no. 236 (web doc no. 9522206) concerning the administrative liability of the legal entity for the actions of the employee. The case involved the dissemination online of a video concerning a man, filmed inside the premises of a public security police station in the Capital, while he was engaging in self-harming acts in a state of evident psychophysical alteration. The video clearly showed the man's face as he inflicted injuries to his head, and it was clearly heard that, amidst desperate moans, he declared that he was suffering from cancer and had AIDS.

The procedure initiated ex officio by the Guarantor led to the ascertainment of the unlawfulness of the treatment overall carried out by the police operators, imposing a monetary fine of 60,000 euros on the Ministry of the Interior, as well as imposing corrective measures on it. With the judgment in question, the Court of Rome rejected the appeal filed by the aforementioned Ministry, which was also ordered to reimburse the legal costs in favor of the opposing party.

In particular, the Court deemed fully shareable what was asserted by the Guarantor in the contested provision where it states that "the data, which the Ministry had in its possession due to and for the performance of its institutional duties, which were under its full and exclusive control and in relation to which it had a custody obligation well detailed by the regulations on personal data protection, were communicated and disseminated in violation of the same regulations and in a manner that severely harmed the dignity of the person concerned."

Regarding the attribution of administrative responsibility for the dissemination in question to the same Ministry, the Court of Rome did not find the observations of the appealing administration to be well-founded, as both the sharing of the video on the WhatsApp application chat and its dissemination on the internet would have been the individual act of the single employee (pursued criminally and disciplinarily), with the consequence that the administration could not be called to respond for the unlawful act in question, due to the existence of a mere "necessary occasionality" link, as it was "external" to its control possibility, unlike what occurs for the civil liability of the employee in the case of an aquilian unlawful act (referring to Cass., SS.UU., no. 13246/2019, in addition to Articles 28 of the Constitution and 2049 of the Civil Code).

Therefore, the administrative responsibility of the Ministry was recognized for the failure to adopt minimum security measures aimed at preventing the sharing and dissemination of data.

The Court of Padua, with judgment no. 649/2023, published on March 31, 2023, accepted the appeal filed by a municipality against the Revenue Agency-collection and the Guarantor for the annulment of a tax collection notice based on an administrative violation contested by the Guarantor, which had assumed ope legis the value of an injunction order, pursuant to Article 18, paragraph 2, Legislative Decree no. 101/2018.

The contestation originated from a report received by the Authority in which the interested party represented that, after downloading from the local police website some photos related to a fine

received, he noticed that in the frames made available it was possible to view not only the license plate related to his motorcycle but also that, not obscured, related to another vehicle, not involved in the administrative procedure. After acquiring information from the municipality, which admitted the fact characterizing it as a "oversight," the Authority noted that the municipality had carried out an unlawful processing of personal data by publishing on its website frames related to a violation of the highway code, containing irrelevant and excessive data for the purpose of ascertaining behaviors contrary to the provisions on road signage, in violation of the prescriptions contained in point 5.3.1. of the Guarantor's general provision of April 8, 2010, contesting the related administrative sanction.

The Court of Padua accepted the appeal, considering in particular that "[...] the element of the license plate number, without any indication regarding the driver, cannot be included among the personal data deserving protection under the privacy regulations, Legislative Decree no. 196/2003 and subsequent amendments, as it concerns data retrievable in public registers, linked to vehicles, which allow their identification and not to persons representing the asset protected by the aforementioned regulations." For these reasons, the Authority proposed to the competent legal office to appeal against the decision.

****Appeals Against Tax Collection Notices****

The Supreme Court overturns the ruling, also due to the importance of the legal principle at stake, taking into account the pre-existing jurisprudence in the matter both at the national level and from a union perspective.

The Court of Cassation, with ruling dated September 11, 2023, no. 26267/2023, confirmed the legitimacy of the fine of 20,000 euros imposed on a region for having published on its institutional website a resolution of the Regional Council concerning "Mobility for organizational needs of an employee within the staff of the Regional Council," which contained assessments on the professionalism and conduct of the identified individual. The Court recognized the correctness of the Authority's provision, as under Article 19 of the Code (subsequently repealed following the amendments made by Legislative Decree no. 101/2018), the dissemination of personal data by a public entity was permitted only when provided for by a law or regulation. The Court specified that the purpose of controlling the administration's actions through the transparency of information must be implemented through forms of publicity whose knowledge is reasonably and effectively connected to the exercise of control, in compliance with the limits of proportionality and relevance, and that a total and indiscriminate disclosure of the data itself is not justified (see Constitutional Court no. 20/2019), even under the regime of Legislative Decree no. 33/2013.

With order dated September 21, 2023, no. 26974, adopted following a lawsuit initiated by a municipality, the Supreme Court stated that "Article 18 of Legislative Decree no. 101 of 2018, implementing the GDPR, introduced a derogation to Article 16 of Law no. 689 of 1981 regarding sanctioning procedures for violations of Articles 161, 162, 162-bis, 162-ter, 163, 164, 164-bis, paragraph 2, of the Code concerning the protection of personal data, such that, in the event of non-definition and failure to present 'new defensive memoranda,' the title crystallizes in the violation report, provided that it contains all the necessary elements to identify a well-defined sanctioning claim; hence, the payment notice that is subsequently notified constitutes not the first act aimed at asserting the patrimonial claim, but rather the act of collection, which is permitted through the role, given the definitiveness of the title upstream." Furthermore, the Supreme Court also examined the issue of the constitutionality of the norm, considering that the Constitutional Court, with the well-known ruling no. 260/2021, deemed the criticized regulation unconstitutional within the limits of the repeated fifth paragraph, for violation of the principle of reasonableness and the standard of proportionality, not finding "any reason capable of justifying such an intense level of compression of the private individual's position" (thus stated the Constitutional Court). And with this - continues the Court of Cassation with this order - the Constitutional Court "implicitly deemed legitimate, instead, the legislative choice in its further prescriptive profile, since the rationale lies in the simplification of the procedure, and this rationale resides in the need to address the overload of administrative burdens arising precisely from the entry into force of the GDPR. Thus, only the interruption of the statute of limitations is illegitimate [and this has been declared], as it constitutes an additional and unjustified prerogative of the

administration to pursue the aforementioned goal. It follows that the profiles of unconstitutionality of the legal regulation concerning the specific case are clearly unfounded."

With ruling dated May 9, 2023, no. 1544, the Court of Appeal of Milan accepted the appeal presented by the Authority and, as a result, completely reformed the first-instance decision, rejecting the opposition proposed by a company against a tax collection notice issued by the Revenue Agency for violations of the regulation concerning the protection of personal data pursuant to Article 18 of Legislative Decree no. 101/2018. In particular, the Court stated that, in the case at hand, at the time of entry...

**In force of the amendment, the procedure had not yet been defined with the injunction order, nor had the company accessed the facilitated definition within the terms of the law, nor finally had it provided for the submission of memoranda, so that in light of the aforementioned provision, the report of the violation, which underpins the issuance of the tax collection notice opposed by the company in the forms of art. 615 of the Italian Civil Procedure Code (c.p.c.), has acquired value (rectius has converted into) an injunction order "without the obligation of further notification," opposable only in the forms and within the terms of law no. 689/81. Therefore, the opposition ex art. 615 c.p.c. proposed against the tax collection notice based on the sanction imposed by the Guarantor could not be validly accepted in light of the fact that the alleged sanction is to be considered crystallized due to the lack of ritual opposition, that is, within the terms and forms of the relevant legislation. The Court of Arezzo with judgment of January 25, 2023, no. 74, rejected the opposition proposed by a company against the payment notice issued by the Revenue Agency for violations of the regulations on personal data protection pursuant to art. 18 of Legislative Decree no. 101/2018, for the sum of 22,000 euros plus accessory charges. In particular, the Court stated that art. 18 of Legislative Decree no. 101/2018 is clear in establishing that, upon expiration of the legal term, the act by which the details of the violation were notified assumes the value of an injunction order, without the obligation of further notification, unless the offender submits "new" defensive memoranda. This last circumstance was clearly not present in the case at hand, as the company had not submitted any new memorandum following the entry into force of the aforementioned legislative decree. It follows that, upon expiration of the term, the report had converted ex lege into an injunction order (and thus constituted the executive title on which the payment notice was based), without the need for further notification. Nor did the Court find the assumption of the applicant party, according to which, at the time of the entry into force of the norm, the "peremptory terms" for the conclusion of the administrative procedure had expired, "it being undisputed that the injunction order can be issued until the five-year limitation period has expired," to be shareable. The Court also noted that there were no reported profiles of unconstitutionality of the norm. In fact, the right of defense was not violated, as the party could fully exercise its right, both within the administrative procedure (by submitting new defensive memoranda) and in judicial proceedings (by timely challenging the report of violation, which had become an injunction order); there was no violation of the principle of formal equality, since the legislator has established a uniform regulation for subjects who found themselves in the same situation, nor did the mechanism introduced by the legislator appear manifestly unreasonable, being counterbalanced by the possibility for the offender to obtain extinction through payment in a reduced amount and in any case by the option to obtain an express provision through the submission of new defensive memoranda (without prejudice to the right to challenge the final provision). Against the aforementioned judgment, the company has appealed to the Court of Cassation. It is also worth noting the judgment of the Court of Cassation in civil matters (section I, December 20, 2023, no. 35568) which, in the context of a dispute brought by a company against the Guarantor, reiterated that, in terms of personal data protection, art. 18 of Legislative Decree no. 101/2018, implementing the GDPR, "[...] has introduced a mechanism for the facilitated definition of violations not yet defined with an injunction order as of the date of application of the Regulation itself. This translates, in the absence of such definition and the submission of new defensive memoranda, into the ex lege conversion of the report of violation, already notified, into an injunction order for which no further notification is required, so that the dies a quo of the term for proposing the opposition (...) is to be identified (...) in the last useful moment to produce the aforementioned memoranda pursuant to paragraph 4 of the same article, nor can the recipient of the first take advantage of the so-called

recovery opposition.” The Court of Naples with judgment no. 3661 published on April 5, 2023, rejected the opposition proposed by the applicant against the payment notice issued by the Revenue Agency for violations of the regulations on personal data protection pursuant to art. 18 of Legislative Decree no. 101/2018, for the total sum of 22,783.08 euros. In particular, the aforementioned Court had qualified the claim made regarding the alleged failure to notify the executive title, supposedly to be found in judgment no. 1764/19 (issued by the same Court to conclude the proceedings concerning the annulment of the managerial provision of January 25, 2018, after which, during the notification of the summons, the Guarantor had contested the administrative violation) as an opposition to executive acts ex art. 617 c.p.c. The Court of Naples therefore declared this claim inadmissible due to the expiration of the term provided for by art. 617 c.p.c. since the payment notice had been notified on November 12, 2021, and the proceedings were only initiated on April 12, 2022.**

Furthermore, having qualified the applicant's request as an opposition to execution pursuant to Article 615 of the Italian Civil Procedure Code, the Court deemed that the conversion ex lege of the act of contestation into an injunction order pursuant to Article 18, paragraph 2, Legislative Decree No. 101/2018, had been concretely realized, which could only be precluded by the filing of memoranda subsequent to the entry into force of Article 18. The Civil Court of Cassation (Section I, Order of August 1, 2023, No. 23405), following a previous ruling (No. 13406 of May 12, 2023), stated that, in terms of administrative sanctions, the hearing of the offender and the related summons do not constitute acts capable of interrupting the statute of limitations, pursuant to Article 28, second paragraph, Law No. 689/1981, as they are not functional to asserting the administration's right to collect the monetary penalty in such a way as to constitute the exercise of the sanctioning claim. If, in fact, it is undisputed that when the administration proceeds, for example, to redetermine the sanction, even reducing it in acceptance of the defensive remarks of the offender (see Cass. No. 787/2022), it nonetheless expresses its intention to proceed with the sanctioning procedure and, therefore, to continue with the punitive action, a different meaning must instead be attributed to the summons for the hearing, pursuant to Article 18, paragraph 2, Law No. 689/1981, ordered at the request of the interested party, which only serves to allow the exercise of the right of defense before the administration proceeds to a definitive assessment of the correctness of the previously executed verification (in this case, the act of contestation). Thus, the act of summons, having a neutral nature with respect to the sanctioning claim, responding only to a need to safeguard the principle of adversarial proceedings, which must also be protected in administrative proceedings (as inferred from Article 10, Law No. 241/1990), cannot certainly be considered suitable to constitute default for the recipient of the verification act, pursuant to Article 2943 of the Civil Code.

On the subject of the procedure in question, the ruling of the Court of Cassation No. 22798/2023 is also noted, which clarified some aspects of the transitional regulation for the facilitated definition of violations concerning personal data protection, as referred to in the aforementioned Article 18, previously subject to dispute in the case law. In particular, the Cassation established, as recalled above, that the transitional procedure referred to in the first four paragraphs of Article 18 entails that if the offender does not make the payment at the facilitated rate or does not produce new memoranda within the terms indicated by the regulation, the conversion of the contestation into an injunction occurs ex lege and no recovery action is permitted. The Supreme Court also deemed that the transitional procedure referred to in the first four paragraphs of Article 18 is constitutionally legitimate and does not infringe on the rights of defense, observing that "the Constitutional Court, with ruling No. 260/2021, which declared the unconstitutionality for violation of the principle of reasonableness and the standard of proportionality of Article 18, paragraph 5, Legislative Decree No. 101 of 2018, [...] implicitly recognized the constitutional validity of the first four paragraphs of the same article, which outline the mechanism for the facilitated definition of violations concerning personal data protection."

With ruling of May 17, 2023, No. 1386, the Court of Foggia - Section San Severo, annulled the injunction order of July 12, 2012, No. 202, with which the Guarantor had ordered a company to pay 11,000 euros as an administrative monetary sanction pursuant to Articles 161 and 162, paragraph 2-bis, of the Code for sending advertising emails in violation of Articles 13, 23, and 130 of the Code, in force at the time. In accepting the opposition, the Court represented that even in this case, the

orientation expressed by the Criminal Court of Cassation applied, according to which "in order for the conduct to assume criminal relevance, it is necessary that for each recipient there is an actual 'nocumento', which cannot certainly be exhausted in the mere annoyance of having to delete unwanted emails each time, but must translate into a concrete prejudice, even if non-pecuniary, but nonetheless susceptible of being legally appreciated [...]" (cf. Cass. pen. No. 41604/2019). It follows that an adequate factual verification is required to ascertain, for example, whether the user has informed the sender that they do not wish to receive a certain type of messages and whether, despite this initiative, the acting party (i.e., the data controller or processor) has persistently continued to send unwanted messages, thus creating real discomfort for the recipient. In relation to the case at hand, it was particularly added that "in light of the non-negligible amount ordered as a sanction, no objective evidence has been provided by the opposing party regarding the actual number of emails sent by the opponent."

In 2023, the dispute between TIM and the Guarantor, which arose following the appeal by the telecommunications company against several measures with which the Guarantor had sanctioned the failure to respond to requests from lawyers aimed at obtaining telephone traffic data for defensive needs in criminal matters, based on Article 132, paragraph 3, of the Code in the text in force at the time of the facts, was concluded (this concerns four judicial appeals relating to the challenge of as many measures of the Guarantor: injunction order of May 14, 2020, No. 85 (doc. web n. 9442587); ordinance-injunction May 27, 2021, n. 216; ordinance-injunction January 13, 2022, n. 10 (doc. web n. 9744518); ordinance-injunction July 8, 2021, n. 272 (doc. web n. 9693464).

In this case, in light of the aforementioned lack of response, the interested parties had turned to the Authority, which, framing the complaints as a complaint to the Guarantor, conducted the relevant investigation, at the conclusion of which it ordered TIM to provide the requested data and imposed monetary sanctions.

TIM's appeal, in summary and with various nuances based on the specifics of the individual cases, was based on the perceived existence of the principle "electa una via, altera non datur," in the sense that in response to the direct request to the provider by the defenders, aimed at obtaining data related to the accounts registered in the name of their client in the manner indicated by Article 391-quater of the Criminal Procedure Code, the remedy available in case of inaction would solely be that provided by the same procedural norm, namely the request to the Public Prosecutor, with possible intervention by the Judge for Preliminary Investigations (Articles 367 and 368 of the Criminal Procedure Code).

204

THE ACTIVITY CARRIED OUT BY THE GUARANTOR

THE ACTIVITY CARRIED OUT BY THE GUARANTOR

II20

The Guarantor, on the other hand, argued that the provision of Article 132 did not exclude the possibility, in the event of denial of access, to file a complaint with the Guarantor; indeed, not only is such exclusion not provided for by Article 132 of the Code, but it would not even be abstractly conceivable, since the right of the interested party to file a complaint with the supervisory authority is established without limitations by Article 77 of the GDPR. Article 23 of the GDPR provides that any limitations may be introduced by national legislation concerning the "scope of obligations and rights under Articles 12 to 22," but not regarding the right to appeal to the Guarantor in case of violations. On this issue, no artificial distinction is admissible between the access procedure under Article 15 of the GDPR and the access procedure pursuant to Article 132, paragraph 3, of the Code, as the issue concerns the protection of rights and not the procedures: the right of access, recognized in general terms by Articles 15 and following of the GDPR, cannot know any limitation in terms of protection in case of non-compliance, including the case of access to telephone traffic data.

In the first case of the series (ordinance-injunction May 14, 2020, n. 85), the Court of Milan had rejected TIM's appeal (judgment April 9, 2021). However, this decision was overturned by the Court of Cassation (judgment n. 21314/2022), according to which, when the direct request of the defender is

made under Article 391-quater of the Criminal Procedure Code, as referenced by the old text of Article 132, paragraph 3, of the previous Code, the subsequent procedure in case of lack of response must solely be that provided by the Criminal Procedure Code, with respect to which the Guarantor is not competent.

In light of the aforementioned ruling of legitimacy, the Court of Milan, before which the other disputes were pending, accepted the remaining appeals of TIM (judgments n. 591/2023; 841/2023; 4100/2023); however, likely considering the conflict of jurisprudence highlighted in reference to the first case, the Court ordered the compensation of costs for all the appeals.

The Authority decided not to continue the litigation by appealing to the Court of Cassation against the aforementioned judgments of merit, also considering that the disputed issue pertains to the application of norms that are no longer in force.

With the judgment of the I civil section December 23, 2023, n. 5648, the Court of Cassation rejected the appeal presented by a company against an ordinance-injunction with which the Guarantor had ordered the payment of 30,000 euros as a monetary sanction for having unlawfully implemented a small part of the parking meters of the Municipality of Rome (the so-called advanced parking meters) through "[...] the optional entry of the vehicle's license plate, in order to avoid the driver having to display the ticket or payment receipt on the vehicle's dashboard." The Supreme Court fully accepted the defensive arguments of the Guarantor, confirming the imposed sanction and ordering the losing party to reimburse the legal costs incurred by the Guarantor, quantified at 5,000 euros. First of all, it unequivocally established, in line with the thesis supported by the Guarantor, that the vehicle's license plate is to be considered personal data (a thesis repeatedly contradicted by the first-instance judges). Furthermore, the Cassation established an important principle, namely that "The existence of contractual obligations of a private nature between the opponent and its client cannot justify a treatment carried out without compliance with regulatory provisions." Therefore, if there is a contract between the opposing party and a third party, this is not sufficient to qualify the third party as responsible for the related data processing arising from the execution of the aforementioned contract. With judgment n. 603 published on January 13, 2023, the TAR Lazio rejected the appeal with which a major highway service company had challenged, seeking its annulment, provision n. 28601 of the AGCM adopted against it for unfair commercial practices pursuant to Articles 21 and 22 of the

205
Mobility and Technologies

REPORT 2023

III20

****Consumer Code in relation to a dispute regarding omitted information towards users requesting quotes on car liability insurance through a specific application.****

The Authority, intervening in the proceedings, noted that in the dispute the AGCM had not obtained its opinion, pursuant to Article 27, paragraph 1-bis, of the Consumer Code, and that the Guarantor has the "EU mandate" to ensure "not only the protection of individual rights in the processing of personal data (and thus in the informational self-determination of the individual), but also the 'free movement of data';" in this context, it also recalled the principle of loyal cooperation among authorities (Article 154, paragraph 4, of the Code), as well as the conclusions of the Advocate General in Case C-252/21 Meta v. Federal Cartel Office.

From the perspective of interest, the TAR stated that "there was no legal obligation to consult the Guarantor, as it was not a matter of requesting a mandatory opinion within a regulated sector, pursuant to Article 27, paragraph 1-bis of the Consumer Code. The Guarantor for the protection of personal data is a general authority responsible for the transversal protection of a fundamental right and not a sector regulatory Authority. From another aspect, the lack of involvement of the Guarantor cannot even be considered a flaw in the investigation, given the aforementioned total autonomy of the protection plans."

Telepass appealed the aforementioned ruling before the Council of State. The Guarantor entered the proceedings, reiterating its role of primacy recognized by the EU legal framework in ensuring not only the protection of personal data but also the free movement of such data. By virtue of this primacy, the Authority requested to "affirm the principle, fully respectful of the respective competences, of the

necessary loyal cooperation among Authorities whose regulatory compass is capable of covering overlapping cases and situations." In this regard, it was also recalled what was established by the Court of Justice of the EU in the aforementioned Case C-252/21, in continuity with the conclusions formulated by the Advocate General, and in particular the necessity for such Authorities to utilize their mutual competences and knowledge in the spirit of loyal cooperation, in order to dispel any doubt regarding the scope of the decisions to be made in the individual case.

This line was fully embraced by the Council of State with ruling no. 497/2024 published on January 15, 2024.

With ruling dated July 20, 2023, no. 912, partially favorable, the Court of Reggio Emilia reduced the fine from 5,000 to 3,000 euros and compensated the costs in a case where an employee had complained about the use of the company email with an address including their name, even beyond the termination of the employment relationship.

With ruling dated May 16, 2023, the Court of Pordenone, in partial acceptance of the appeal proposed by a regional health company regarding a matter related to the processing of personal data through the FSE, redefined the originally imposed fine, which was 50,000 euros, reducing it to 5,000. The Court nonetheless confirmed the correctness of the Guarantor's provision, rejecting the appellant's thesis regarding their non-guilt, as the company would have been only formally the data controller, in light of the role of the in-house company, responsible for processing through the FSE on behalf of all regional health companies, as well as the region itself. It was therefore confirmed that the ownership of the processing imposes precise obligations established by the GDPR that cannot be evaded, at least through a continuous directive and control activity towards its data processor.

The Court of Cassation in civil proceedings (Section I, order of October 11, 2023, no. 28417), overturning with referral the ruling of the Court of Ravenna (March 31, 2022, no. 188), which had accepted the opposition proposed by the local ASL against the Guarantor's provision of January 27, 2021, no. 36, stated that the act of communicating the need for healthcare treatment and, therefore, the existence of a "disease" in a broad sense – understood thus as a situation that necessitates healthcare treatment – pertains to health data: it is not necessary, for this purpose, to specify which healthcare treatment or which disease is involved. The Court cites numerous precedents on the broad concept of health data. Furthermore, regarding administrative sanctions, recalling numerous precedents, the Court held that the opposition to the injunction does not constitute an appeal against the act, but rather introduces an ordinary judgment on the basis of the claim of the administrative authority, devolving to the seized judge the full knowledge regarding the legitimacy and validity of the same, with the judge having the power and duty to examine the entire relationship, with extended knowledge – within the scope of the parties' deductions – to the complete examination of the merits of the validity of the injunction, including the determination of the amount of the sanction based on discretionary assessment.

The Court of Milan, with ruling dated February 28, 2023, no. 9157, rejected an appeal filed by a company against a prescriptive provision of the Guarantor regarding data breach and violation of security measures, condemning the losing party to pay the costs. This resulted in the Guarantor's victory in the related case concerning the injunction that had been imposed by the Authority for data breach, even though the judge reduced the amount of the penalty from €600,000 to €400,000 (Trib. Milan, January 31, 2024, no. 1165). As of now, the motivations for the judgment have not been filed.

With the judgment of December 13, 2023, the Tribunal of Milan rejected the opposition appeal filed by a company against the decision of the Guarantor dated December 2, 2021, no. 424 (web doc no. 9731682), which had defined a complaint regarding the sending of an SMS and the consequent exercise of the right of access to personal data. In the appeal, the amount of the penalty imposed by the Guarantor was contested, considering that the violations were minor compared to the significance of the marketing activity carried out and that the processing of the data in question had not caused harm to the individuals concerned. The judge, agreeing with the defense line proposed by the Guarantor, particularly found that the Authority had already balanced the factors (on one hand, the maximum penalty provided for by Article 83, paragraph 5, of the GDPR, which is significantly higher than the amount subject to injunction; the duration of the violation, which occurred during 2019 and

2020; the absence of evidence of the controls referred to by the opponent even in the appeal under discussion; the limited degree of cooperation activated in relations with the Authority; on the other hand, the nature of the data processed, which is common; the economic results recorded in the balance sheet in 2020; the absence of previous proceedings against the opponent) that could affect the quantification of the amount subject to injunction, such that the identified sum could not be considered excessive.

With judgment no. 2 of June 26, 2023, the Tribunal of L'Aquila clarified two important aspects, often recurring in proceedings related to the appeal of the Guarantor's decisions: one of a merely procedural nature and the other relating to a matter of jurisdiction. The case originated from a document personally submitted by the opponent proposing opposition against a decision of the Guarantor (note of October 21, 2022) with which the complaint filed by the same had been archived. The Tribunal, referring to Article 10 of Legislative Decree no. 150/2011, in the part that provides that decisions regarding data protection follow the labor procedure, while considering the possibility for the appellant to be represented by a third sector entity, reiterated the applicability of the civil procedure code rules on representation in court, and therefore of the mandatory technical defense. In this case, since the appeal was personally submitted by the party, the mandatory forms for proposing the judicial request were not followed, and the lawyer was appointed only during the proceedings. The judge considered that such constitution could not remedy the original defect and therefore deemed the appeal inadmissible.

The judge then identified an additional aspect for not accepting the appeal. The appellant indeed complained that, in a notice of judicial auction, within an enforcement procedure, a technical expert report (CTU) had been attached in which their data as a debtor and that of their spouse (as well as those of neighboring third parties) had not been obscured. The Guarantor had ordered the archiving, stating that it could not interfere in judicial activity. The judge found the deduction valid, noting that it was a matter that had to be raised in the judicial proceedings, "in any case, regarding which the Guarantor has no role, pursuant to Articles 184, paragraph 7, and 160-bis of the Privacy Code, in accordance with the provisions of Regulation (EU) 2016/679."

With judgment of September 12, 2023 (n.r.g. 4262/2022), the Tribunal of Rome rejected the opposition filed by the appellant against the decision to archive the complaint they had submitted to the Authority. The complainant had alleged that they had become aware of an alleged violation of their privacy due to the transmission of their personal data, provided to the local health authority (ASL), the data controller, for the purpose of registering in the register of external professionals, to another public entity (the regional legal office) without their consent. The judge rejected the appeal, fully agreeing with the motivations provided by the Guarantor in the contested decision, according to which: "for public entities, the processing of personal data is lawful if necessary 'for the performance of a task carried out in the public interest or in the exercise of official authority' (Article 6, paragraph 1, letter e), of the GDPR), thus disregarding the consent of the data subject (recital 43 of the GDPR)."

The judgment of the Tribunal of Milan on November 10, 2023, no. 8893 revisited the issue of the disclosure of third-party data beneficiaries of policies subscribed by the deceased, in relation to which the Guarantor is incompetent as the access rules for personal data of the data subject (in this case, the deceased) cannot be applied to the data of a third party (the beneficiary of the policy), and instead Article 24, paragraph 1, letter f), of the Code applies (the processing of data is justified by the purpose of defense in court). Therefore, any evaluation is left to the judge and not to the Authority, whose intervention in this type of dispute appears superfluous (due to lack of passive legitimacy).

With a judgment favorable to the Guarantor, the Tribunal of Mantova (n.r.g. 2833/2022) on October 31, 2023, clarified the concept of

"essentiality" of the information in relation to the request to declare the illegitimacy of the publication of personal data such as the place and date of birth of the appellant. With judgment of May 24, 2023, no. 160, the Court of Verbania ordered the annulment of only the part of the ruling of the Guarantor that had imposed on a company providing electronic communication services to order the results chronologically from the most recent to the least recent, which the opposing party had demonstrated,

during the proceedings, to be technically unfeasible, in addition to constituting an *ultra petita* with respect to what was requested and obtained by the appellant. The costs were fully compensated due to the particularity and novelty of the case; for these reasons, it was not deemed appropriate to appeal to the Court of Cassation.

The Court of Milan, with judgment of November 30, 2023 (n.r.g. 15976/2023), rejected the appeal presented by a publishing house against a ruling of the Guarantor (ordinance-injunction of March 2, 2023, no. 62, doc. web no. 9880427, which imposed a fine of 2,000 euros) concerning the unlawful publication of personal data and further information in violation of Articles 5, paragraph 1, letters a) and c), of the GDPR and Article 137, paragraph 3, of the Code, as well as Articles 5, paragraph 2, and 6 of the ethical rules regarding the processing of personal data in the exercise of journalistic activity. The Court accepted the reasons expressed by the Legal Office in defense of the Authority, with particular reference to the principle established by the Supreme Court (united sections, July 22, 2019, no. 19861), according to which the “mention must be considered lawful only in cases where it refers to individuals who currently attract the interest of the community, both for reasons of notoriety and for the public role held. Otherwise, the right of the individuals concerned to privacy prevails over past events that harm their dignity and honor and of which the collective memory has now faded.”

20.3. The contribution of the Guarantor in data protection proceedings

As seen in paragraph 20.1, the judicial authority must inform the Guarantor of the pendency of a dispute by sending a copy of the introductory documents (Article 10, paragraph 9, Legislative Decree no. 150/2011, as amended by Article 17 of Legislative Decree no. 101/2018). This communication allows the Authority, “in cases where it is not a party to the proceedings,” to “submit observations, to be made in writing or in a hearing, on the ongoing dispute with reference to aspects related to the protection of personal data.” In accordance with judicial guidelines and the opinion expressed by the Attorney General of the State, the Guarantor, in proceedings other than those directly related to rulings of the Authority, generally limits its contribution to cases where there arises, or may arise subsequently, the need to defend or otherwise assert specific legal issues.

In this regard, the case communicated by the Court of Bari concerning the pendency of a lawsuit initiated by the parents of a deceased young man, as heirs and in their own right, against a company due to the denial of their request for access to the personal data of their deceased son, pursuant to and for the effects of Articles 15 of the GDPR and 2-terdecies of the Code, is noteworthy. Following a complex investigation, the Authority submitted a detailed opinion to the judge on the delicate issue. The Authority has nonetheless closely monitored all disputes in which it did not deem it appropriate to intervene, requesting the district legal offices of the State to be informed about the evolution of the legal proceedings and to receive communication regarding the outcomes.

21. The community and international relations

Data protection, competition, consumer protection

In 2023, at the European level, there was a significant commitment from data protection authorities aimed at improving and fostering cooperation among them to ensure a more harmonized and rapid action, especially in cases of personal data processing that have a cross-border nature. As will be seen below, for this purpose, the European Commission, also at the urging of the European Data Protection Board (EDPB), initiated the legislative process aimed at adopting new procedural rules that allow for a more effective application of the GDPR, without, however, modifying any provisions of the same. Another trend has involved the increase in the international activities of the Guarantor during 2023: in addition to the bodies that have always been actively followed by the Authority, such as the Council of Europe and the OECD, there has been a growth in activities related to other international instances, such as in the case of the Global Privacy Assembly, within which a permanent secretariat has been established, and of the initiatives of the data protection authorities of the G7 countries, also in preparation for the Italian presidency scheduled for 2024. The proliferation of international activities has led to the creation of a specific Task Force within the EDPB to ensure adequate coordination among EU authorities.

2023 has also been marked by the intensification, at both European and international levels, of activities related to the deepening of the interrelationship between data protection and competition and consumer protection disciplines. Indeed, there has been growing attention regarding the necessity for competition and data protection authorities to cooperate on issues and cases in areas of common interest, also in light of the ruling of the Court of Justice known as Bundeskartellamt (Case C-252/21), which not only paved the way for interaction between competition law and data protection but also affirmed the obligations of cooperation among competent authorities. Reflections on the relationship between these sectors have led to the establishment of a specific Task Force (Task Force Competition and Consumer Protection Law) within the EDPB and, at the international level, to the intensification of work carried out by the corresponding Digital Citizen and Consumer Working Group of the Global Privacy Assembly (GPA), to which the Authority has adhered.

Overlapping profiles between data protection, competition, and consumer protection are also present in the Digital Markets Act (DMA), the European regulation applicable from May 2, 2023, aimed at ensuring that large online platforms acting as gatekeepers of digital markets, controlling access, maintain fair behavior. The DMA established a specific High Level Group, subsequently set up by the European Commission pursuant to Article 40 of the DMA on February 23, 2023, which includes, in addition to various regulators and European networks (electronic communications, competition, consumer protection, audiovisual media), also the EDPB (European Data Protection Board) and the EDPB (represented by five delegates including the President of the Authority, Prof. Pasquale Stanzione). This Group provides the Commission with advice and expertise to ensure that the digital markets law and other sector-specific regulations applicable to gatekeepers are implemented in a coherent and complementary manner and provides expertise in market investigations on services and emerging practices, thereby contributing to ensuring that the digital markets law is adequate to future needs.

In particular, on September 20, 2023, the EDPB and the EDPB (through the aforementioned Task Force) provided their joint contribution to the European Commission on the model regarding the description of consumer profiling techniques, which gatekeepers are required to present annually to the Commission pursuant to Article 15 of the DMA. The EDPB and the EDPB emphasized that, to be effective in ensuring full transparency regarding the profiling techniques of gatekeepers, the description should highlight how they comply with data protection regulations, providing the supervisory authorities with sufficient information in this regard.

Indeed, other EU regulations on digital and data, recently adopted, contain overlapping profiles with the GDPR, such as the Digital Services Act (DSA), the Data Governance Act (DGA - the European regulation applicable from September 24, 2023, aimed at creating a harmonized framework for data sharing and establishing some basic requirements for data governance), the Data Act, and the forthcoming EU regulation on AI. In this context, the EDPB and the EDPB ensure their participation, each with its own representative, in the European Data Innovation Board (EDIB), the expert group established by the European Commission on February 20, 2023, pursuant to Article 29 of the DGA, tasked with providing advice and assistance to the European Commission on key aspects related to the implementation of the DGA itself, including, in particular, the development of guidelines for common data spaces, the European consent model for data altruism, as well as issues related to standardization and interoperability.

21.1. Cooperation among data protection authorities in the European Economic Area: the European Data Protection Board

Since May 25, 2023, the Committee has a new President, Anu Talus, who is also the President of the Finnish Data Protection Authority, elected to succeed the outgoing President Andrea Jelinek. During 2023, the plenary of the EDPB met 15 times, five of which were in person. Nearly two hundred meetings of the subgroups and Task Forces that make up the work of the EDPB, which deal with the application of the GDPR and the law enforcement directive in various sectors, have taken place. The information provided in the following paragraphs about the documents produced only partially reflects the volume of work to which the Authority has also contributed, as for many documents (see, in

particular, the guidelines on legitimate interest or on data processing involving minors), discussions and analysis have continued tirelessly, albeit without reaching conclusions, during the considered period.

In view of the evaluation that the European Commission will be called upon to publish in 2024, the second after the full application of the GDPR, the EDPB adopted its informational contribution on December 12, 2023. This indicates a consolidation of the position of the EU body responsible for...

****Guaranteeing the consistent application of the GDPR, utilizing the full range of tools available, from guidelines to decisions made within the framework of consistency procedures.** The Committee has paused to reflect, based on statistical data and information regarding the activities carried out by European authorities within the mechanisms of cooperation and consistency over the past two years, on the functioning of the cooperation tools provided by the GDPR and has recognized that they have the potential to achieve this objective, particularly when used in a sufficiently harmonized manner. The EDPS, together with the EDPB, has provided a joint opinion on the proposed regulation establishing additional procedural rules related to the application of the GDPR in proceedings concerning cross-border processing, presented by the European Commission on July 4, 2023, as part of activities aimed at promoting and improving the functioning of the cooperation and consistency mechanisms provided by the GDPR (joint opinion 1/2023). The proposal – which takes into account the Vienna Declaration of April 28 and 29, 2022, during which the EDPS had addressed a letter to the European Commission to highlight certain procedural profiles (see Report 2022, p. 177) – aims to integrate the provisions of the GDPR, harmonizing certain aspects related, among others, to the admissibility or rejection of complaints in cross-border cases, procedural timelines, the status and rights of the parties, and the practical implementation of the cooperation procedure. In the opinion, the EDPS and the EDPB welcomed many provisions of the proposal but also suggested several amendments regarding certain procedural provisions, the mechanisms of cooperation and dispute resolution before the EDPB, and the procedural rights of the parties under investigation and the complainants. In particular, regarding the admissibility requirements for complaints, the EDPS and the EDPB urged the co-legislators to provide for a comprehensive harmonization of the admissibility requirements to overcome the currently existing differences in the various EEA countries and to clarify and integrate the proposal to allow all data protection authorities to proceed with amicable settlement of disputes, particularly in Member States that currently do not have national procedural rules to resolve complaints amicably.

Regarding the one-stop-shop mechanism, the opinion welcomed the introduction of new formal procedural phases requiring the lead supervisory authority (LSA) to share key information with the concerned supervisory authorities (CSAs) at an early stage, but requested the co-legislators to clarify that the LSA may adopt a proportionate approach to the case, modulating the information to be shared according to its complexity. The EDPS and the EDPB also requested the Commission to ensure greater and continuous involvement of the CSAs at every stage of the procedure, clarifying the obligation for the LSA to collaborate with the concerned supervisory authorities based on their observations in order to resolve any disagreement at an early stage. In the event of disagreement on the merits of the individual case, the opinion recommends that recourse to the cooperation procedures under Articles 61 and 62 of the GDPR (provided as mandatory by the proposal) be made optional to reduce processing times, and that the request for urgent resolution of such disputes to be addressed to the Committee under Article 65 of the GDPR at this preliminary stage of processing may also be initiated by the CSAs upon verifying the impossibility of reaching a consensus. The opinion also requested clarification on the effects of such an urgent decision made by the EDPS. Regarding the dispute resolution procedures before the EDPS following the formal submission of a decision proposal by the lead supervisory authority, the opinion welcomed the provisions aimed at their rationalization, albeit with some modifications that take into account the short timeframe provided by the GDPR for the adoption of binding decisions in these cases.

With a view to contributing to the correct application of the cooperation mechanisms, the EDPS has definitively adopted, after public consultation, some amendments to the guidelines for identifying the

lead supervisory authority (guidelines 8/2022, see Report 2022, p. 185) in order to ensure full consistency with the guidelines on the controller and processor. The final version of the guidelines confirmed the main clarifications introduced in the text, particularly excluding that the (necessary) agreement between joint controllers of processing entails the possibility of also defining the competent supervisory authority pursuant to Articles 55 and 56 GDPR or modifying in any way the ability of such authorities to exercise their tasks and powers under Articles 57 and 58 GDPR, and confirming that the main establishment of a data controller cannot be considered the main establishment of the joint controller – thus joint controllers cannot designate a common main establishment.**

****EDPS Guidelines on Cooperation Procedures****

****ACTIVITIES CARRIED OUT BY THE SUPERVISORY AUTHORITY****

****ACTIVITIES CARRIED OUT BY THE SUPERVISORY AUTHORITY****

Guidelines of the EDPB on

Consistency Procedures

Other EDPB Guidelines

In order to promote and support the efficient and harmonized functioning of the cooperation and consistency mechanism, the EDPB has also adopted a model for cross-border complaints from data subjects that supervisory authorities can use on a voluntary basis, in order to facilitate the cross-border exchange of information. The model is drafted in such a way as to allow all authorities to adopt it, adapting it to their respective national requirements. This model can be used both for cases where the complaint is submitted personally by the individual, and for cases where it is submitted by a legal representative, a person acting on behalf of the individual, or on their own initiative.

The EDPB has also adopted a model of ‘acknowledgment of receipt’ of the complaint – also to be used on a voluntary basis – which aims to provide the complainant with general information about the stages following the submission of the complaint and emphasizes the right to an effective judicial remedy against a legally binding decision made by a supervisory authority.

Furthermore, regarding cooperation and consistency among supervisory authorities, the guidelines on the resolution of disputes under Article 65, paragraph 1, letter a), of the GDPR (guidelines 3/2021) have been definitively adopted after public consultation. These guidelines concern the mechanism aimed at resolving conflicting opinions among authorities in cases of cross-border processing of personal data. The document includes a limited number of non-substantial modifications aimed at referencing the guidelines related to Article 60 (note 12), the provisions of the EDPB regulation concerning the translations of its binding decisions (point 46), and the order of the Court T-709/21 (notes 129 and 135).

Right of Access: In March 2023, the final version of the guidelines on the right of access was adopted, modified in light of the contributions received during the public consultation to which the preliminary version had been submitted. The final text presents few variations compared to the previous one (see 2022 Report, p. 176), particularly regarding the requirements for the identification and authentication of the data subject requesting access to their data and the completeness of the information provided following the access request. Additionally, through specific examples, clarifications are offered regarding the cases in which the controller, in the presence of a large volume of processed data, may ask the data subject to specify the request, as well as the possibility for the controller to retain personal data for an additional period for the purpose of responding to potential access requests.

Administrative Fines: In May 2023, the EDPB adopted the final version of the guidelines on the calculation of administrative fines, which had already been adopted on May 12, 2022, and subsequently subjected to public consultation (see 2022 Report, p. 179). The guidelines maintained the structure and content of the previous text and were supplemented with the introduction of additional examples or clarifications concerning substantive issues, such as the criteria for correlating the size of the business to an adjustment of the imposed fine. Two tables were added: one related to the definition of the starting amount for the calculation of the fine and the other illustrating the minimum and maximum values applicable in relation to the specific categorization of the violation, within which the actual imposed fine will be placed.

Data Breach Notification: In December 2023, the guidelines 9/2022 were definitively adopted after public consultation, updating the Article 29 Working Party guidelines on personal data breach notifications (WP250 rev.01). The update concerns only a reformulation of the data breach notification process for controllers not established in the EEA. In accordance with the guidelines 8/2022 on identifying the lead supervisory authority of the controller or processor, the revised guidelines now state that “the mere presence of a representative in a Member State does not activate the system of the single contact point.” In the event of a data breach, controllers without an establishment in the EU will therefore need to engage with local supervisory authorities in each Member State in which they operate, through their respective local representatives. The EDPB has decided to publish on its website a list of contacts for data breach notifications with relevant links and accepted languages for all EEA data protection authorities, in order to facilitate the notification process for breaches.

The EDPB adopted, in December 2023, definitively, after public consultation (26 contributions received), the guidelines on deceptive design patterns in social media platforms (guidelines 3/2022 already adopted by the EDPB on March 14, 2022 – see 2022 Report, p. 185). The guidelines – whose title was modified following the public consultation to avoid the original reference to so-called dark patterns – provide guidance for assessing and avoiding unfair techniques that lead users to take undesirable actions and make potentially harmful decisions regarding the processing of their data. The text now contains examples of best practices (such as privacy dashboards, contextual information, self-explanatory URLs for data protection settings, and forms for exercising the rights of the data subject), two new annexes related to use cases, and an introductory summary. The EDPB adopted, in April 2023, guidance on data protection to raise awareness among small and medium-sized enterprises regarding the GDPR and to provide them with practical information on GDPR compliance in an accessible and easily understandable format. The guidance covers various aspects of the GDPR, from the legal bases for data processing, to the rights of data subjects, to data breaches, and more. It includes videos, infographics, interactive flowcharts, and other practical materials to help SMEs comply with the GDPR. Additionally, the guidance contains an overview of useful materials developed for SMEs by national data protection authorities. The guidance, currently available in English, will be translated into other EU languages; it represents one of the EDPB's awareness-raising actions for the reference year and has been included as a key initiative in the Committee's 2021-2023 strategy.

In the aforementioned contribution to the review of the GDPR dated December 12, 2023 (see above), the EDPB reiterated the importance of continuing to work on adequacy decisions for third countries and international organizations regarding the transfer of data outside the European Union and, in 2023, addressed the topic twice with the opinion (Opinion No. 5/2023) on the draft decision on the adequacy of the "EU-US Data Privacy Framework" (hereinafter also referred to as DPF EU-US), presented by the European Commission on December 13, 2022 (see 2022 Report, p. 181), and with a statement regarding the review of the adequacy decision concerning Japan.

With Opinion 5/2023, the EDPB welcomed the substantial improvements of the DPF EU-US, which, like the Privacy Shield, is a self-certification system through which participating U.S. organizations commit to adhere to a series of privacy principles – the so-called Data Privacy Framework Principles (Annex I to the draft decision) – issued by the U.S. Department of Commerce. In particular, the EDPB appreciated both the introduction of the principles of necessity and proportionality for data collection for intelligence purposes and the greater guarantees provided regarding the independence of the Data Protection Review Court (DPRC) compared to the previous mechanism of the Ombudsperson, as well as the new appeal mechanism subject to review by the Privacy and Civil Liberties Oversight Board (PCLOB).

However, the EDPB also highlighted some critical points. Regarding the guarantees related to the commercial aspects of the agreement, it urged the Commission to provide clarifications on the guarantees concerning the right of access and the exemption for publicly accessible information, on the absence of certain key definitions, on the application of DPF principles to data controllers, and on the lack of specific rules regarding automated decision-making and profiling. The EDPB also reiterated

that the level of protection must not be compromised by subsequent transfers and urged the Commission to clarify that the guarantees imposed by the initial recipient on the importer in the third country must be effective in light of the legislation of a third country before proceeding with the subsequent transfer.

Regarding government access to data transferred to the United States, the EDPB acknowledged the significant improvements made by Executive Order (EO) 14086, which introduces the concepts of necessity and proportionality regarding data collection by U.S. intelligence, but emphasized the importance of waiting for U.S. intelligence agencies to adopt updated procedures to implement Executive Order 14086. The EDPB also expressed concern about the lack of a prior authorization requirement by an independent authority for bulk data collection under Executive Order 12333, as well as the lack of systematic independent ex post review by a court or an equivalently independent body.

The EDPB also urged the Commission to provide that, after the first review... same of the adequacy decision, subsequent reviews must take place at least every three years involving the same EDPB. In light of the critical issues highlighted above and the resolution of the European Parliament of May 11 (2023/2501(RSP)) – which shared the concerns and pointed out further aspects of the agreement that needed clarification – the Commission modified the originally presented draft and, following the introduction into the U.S. legal system of the anticipated internal procedural norms aimed at implementing the agreement (the so-called implementing acts), adopted the implementing decision 4745/2023 regarding the adequate level of protection of personal data within the EU-U.S. data privacy framework (which includes the EU-U.S. data privacy framework - DPF EU-U.S. as an annex). Following the adoption of the decision, the EDPB prepared an information note intended to provide some guidance on transfers to the United States. The note explains that the adequacy decision will cover all transfers made to self-certified companies listed in the Data Privacy Framework List (which can be carried out without the need to adopt any further protective measures) and that the guarantees introduced in the U.S. legal system are also applicable to transfers made, based on other instruments (such as SCCs or BCRs), to entities that do not fall under the DPF.

Also regarding the adequacy of third countries, in July 2023 the EDPB adopted a statement concerning the first report presented by the European Commission regarding the review of the adequacy decision for Japan already adopted on January 23, 2019. The statement focused on the assessment of recent changes to the Japanese legal framework that have only affected processing for commercial purposes. The EDPB welcomed the changes that seem to further align the two legal systems, particularly regarding the extension of the right to object to processing, the strengthening of the obligation to notify data breaches to the Japanese Data Protection Authority and individuals, as well as the expansion of the scope of the Japanese Personal Information Protection Act (which no longer excludes personal data that is "set to be deleted" within six months). At the same time, the EDPB agreed with the European Commission on the need to monitor the application of the new provisions regarding the new category of personal information "pseudonymized" and the use of consent in situations where there is a power imbalance between data subjects and data controllers.

During 2023, the EDPB defined some of the guidelines on data transfers already adopted in 2022 and then subjected to public consultation (see 2022 Report, p. 180 et seq.). The guidelines 7/2022 on certifications as tools for transferring data abroad, adopted on June 30, 2022, were definitively approved, after public consultation, in February 2023. These guidelines clarified, among other things, that the verification carried out by the certification body regarding the assessment of the importer concerning the legislation and practices of the third country in which it is established can be used as one of the elements by which the exporter can demonstrate compliance with the obligations under Chapter V of the GDPR. Furthermore, the same guidelines established that the "binding and enforceable commitments" that must accompany the use of certification for transfer purposes cannot be constituted by another instrument of Chapter V (such as, for example, SCCs - standard contractual clauses), as such commitments must ensure the importer's compliance with the certification criteria based on which it obtained its certificate.

After the public consultation that ended in January 2022, the guidelines on the interplay between

Article 3 and Chapter V of the GDPR (guidelines 7/2022, see 2022 Report, p. 181) were definitively adopted in February 2023. Also taking into account the contributions received during the public consultation (about sixty), the text was modified to provide further clarifications on various aspects. For this purpose, an additional 5 examples were introduced, which add to the 7 present in the first version. A clarification was added regarding responsibilities in cases of transfer made by a processor (on behalf of its controller). In this regard, it was specified that the processor must ensure compliance with the provisions of Chapter V of the GDPR in light of the instructions received from the data controller and that the latter, since the transfer is an activity of processing carried out on its own behalf, could also be responsible for violations of the same Chapter V as well as for the potential identification of a processor that does not provide sufficient guarantees under Article 28 of the GDPR. This also applies in cases where the processor located in the EU receives requests for access to data from public entities of third countries.

Additionally, a new section was included in the text regarding the guarantees that controllers and processors must ensure that personal data is processed outside the EEA, in the absence of any transfer. In short, the data controllers and/or processors whose processing activities are subject to the GDPR are responsible for the processing operations, regardless of where they take place, and processing in third countries may involve greater risks (also in relation to disproportionate access to data by public authorities in such countries and possible conflicts of law) that must be identified and addressed for the processing to be lawful under the GDPR. In June 2023, the recommendations 01/2022 (see 2022 Report, p. 181) on the approval request and on the elements and principles contained in the binding corporate rules (BCR) for data controllers (art. 47 of the GDPR) were definitively adopted following a public consultation (fifteen contributions received). The recommendations replace the working document WP 256, rev. 01 (see 2017 Report, p. 167) and contain guidance on the guarantees that the BCR must include to be approved and used as a transfer mechanism to third countries. An initial section also contains the model for submitting the BCR approval request to the lead authority. Based on WP 256, eighteen BCRs for controllers have also been approved (including the first BCR for which the Authority acted as the lead authority, see chap. 18). Nine BCRs for processors were adopted during the year.**

****216****

****THE ACTIVITIES CARRIED OUT BY THE AUTHORITY****

****Use of cloud services by public entities:** the EDPB adopted, in January 2023, the report prepared by the Coordinated Enforcement Framework (CEF) on the results of its first coordinated enforcement action, focused on the use of cloud-based services by the public sector (see 2022 Report, p. 179). There were 22 authorities (including the Authority) that, during 2022, initiated coordinated investigations into the use of cloud-based services by the public sector. Approximately 100 public entities (including European institutions) with competencies in various sectors (such as health, finance, taxation, education, buyers, and IT service providers) were consulted across the EEA, and it emerged that they often encounter difficulties in obtaining services and products compliant with the GDPR. The report, which focused on the most controversial aspects, emphasizes the need for public entities to act in full compliance with the GDPR and provides guidance for organizations intending to use cloud-based products or services. The report also includes an annex with the report of the activities carried out by each authority.**

****Data Protection Officer (DPO):** during 2023, 25 authorities including the EDPB initiated coordinated investigations on the role and functions of the DPO as part of the second coordinated action of the CEF. Various controllers and DPOs covering a wide range of sectors (both public and private) were contacted, and over 17,000 responses were received and analyzed, providing valuable information on the profile, position, and activities of DPOs five years after the full application of the GDPR. The Authority sent the questionnaire to approximately 60 DPOs from major companies operating in the private sector and large public entities. The aggregated responses were included in the appendix of the Committee's report containing statistics and graphs, while the outcomes of the action conducted by the Authority at the national level were briefly reported in the national report. The results of the

questionnaires sent by the Authority highlighted diversifications among the entities involved regarding, among other things, the possession of the necessary skills required by the Regulation and the actual involvement of the DPO in matters related to personal data protection as well as in the clear definition of the set of tasks assigned by the controller to the DPO.**

Also in 2023, several data protection authorities, recipients of 101 complaints filed by the NOYB association regarding data transfers made following the use of Google Analytics, Facebook Pixel, and Facebook Connect services, actively engaged within a specially established Task Force to enable the consistent application of the GDPR in the cases in question (see par. 18). The Task Force report, adopted in March 2023, contains a summary of the common position and, in particular, the determination regarding the need to suspend data flows abroad in cases where the appropriate guarantees provided for in Chapter V of the GDPR cannot be applied in light of the legislation of the destination country.

In 2023, the EDPB ensured a uniform approach among data protection authorities in defining and applying the accreditation requirements for monitoring bodies of codes of conduct. The GDPR does not set a single set of requirements for the accreditation of such bodies but delegates to the competent supervisory authority the drafting of the accreditation requirements for monitoring bodies based on Article 41, paragraph 2, of the GDPR. These are then adopted by each competent supervisory authority in line with the opinion expressed by the EDPB, in compliance with the consistency mechanism. During 2023, the EDPB specifically expressed its views on the draft accreditation requirements presented by the Swedish supervisory authority (Opinion 11/2023).

Requirements for the accreditation of certification bodies: equally important was the EDPB's activity aimed at ensuring consistency in the application of the GDPR regarding the definition of additional accreditation requirements for certification bodies by the competent supervisory authorities pursuant to Article 43, paragraph 3, of the GDPR (see EDPB Guidelines 4/2018 on the accreditation of certification bodies, 2018 Report, p. 145). In 2023, the EDPB issued the opinion required by Article 64, paragraph 1, letter c), of the GDPR regarding the draft additional accreditation requirements for certification bodies prepared by the Slovenian supervisory authority (Opinion 38/2023), Luxembourgish (Opinion 37/2023), Croatian (Opinion 13/2023), Cypriot (Opinion 12/2023), and Maltese (Opinion 4/2023) authorities.

Procedure for the adoption of EDPB opinions on certifications: the EDPB adopted (February 2023) a procedure for the adoption of opinions regarding national certification criteria and European data protection seals. The document is addressed to all certification scheme holders and aims to simplify and facilitate the adoption of EDPB opinions in this regard, clarifying the approval process for national and European certification criteria, as well as the certification criteria understood as tools for international transfers. To this end, the document outlines the procedural steps that supervisory authorities must undertake from the moment the criteria are submitted for their review by the certification scheme holders until they communicate to the President of the EDPB whether they intend to follow the latter's opinion.

Opinions on national data protection certification schemes: on September 19, 2023, the EDPB adopted, pursuant to Article 64 of the GDPR, Opinion 15/2023 on the decision of the Dutch Authority to approve the criteria of the national data protection certification scheme, Brand Compliance. The scheme, applicable to controllers, joint controllers, and processors, aims to demonstrate the compliance of the processing activities covered by the certification with the entirety of the GDPR rules and principles. The opinion aims to ensure consistency and correct application of the certification criteria among the various supervisory authorities in the EEA. To this end, the EDPB indicated a series of modifications to the draft certification criteria deemed necessary to ensure a consistent application of the GDPR, including the need to clarify the national scope of the certification scheme, the possibility of certifying sub-processors, as well as the criteria on international transfers. Following the final approval of the criteria by the Dutch supervisory authority, companies, public authorities, associations, and other organizations based in the Netherlands have the opportunity to demonstrate that their data processing activities comply with the GDPR.

****Letter to Accredia:** in the context of the approval of the certification criteria of Europrivacy, as a European seal for data protection, the EDPB, in response to Accredia, the Italian accreditation body, with a letter dated August 1, 2023, had the opportunity to express its views on the interpretation and application of the GDPR regarding certification and accreditation, clarifying, among other things, the roles and competencies of the various actors involved in the certification and accreditation procedures under the GDPR.**

****One of the cornerstones of the EDPB's work in the financial sector concerned the digital euro,** the preparatory phase of which, aimed at the development and testing of this currency, was initiated by the European Central Bank (ECB) in November 2023. The digital euro aims to provide citizens with an additional means of payment, alongside cash, that allows for electronic payments, both online and offline. The discussion, initiated in 2021, also through dialogue with the ECB, culminated in the adoption, on October 17, 2023, of the joint EDPB/EDPB Opinion 2/2023 on the proposal for a regulation establishing a digital euro. The EDPB and the EDPB recognize that the proposed regulation addresses many aspects concerning privacy, particularly the provision regarding offline mode to minimize the processing of personal data. The opinion also welcomes the fact that users of the digital euro will always have the option to choose whether to pay in digital euros or in cash. At the same time, it formulates several recommendations.**

****Recommendations to Ensure the Highest Standards of Personal Data Protection and Privacy and to Ensure that Only Necessary Personal Data of Users is Processed, Avoiding Excessive Centralization of Information by the ECB or National Central Banks.**** According to the proposed regulation, the ECB and national central banks may establish a single access point to verify that the amount of digital euros held by each user does not exceed the maximum allowed amount, through specific user identifiers. In this regard, the opinion advises evaluating whether the single access point established for this purpose is necessary and proportionate, emphasizing that, alternatively, technical measures that allow for decentralized storage of such identifiers are feasible. It is also recommended to introduce a "privacy threshold" below which neither offline nor online low-value transactions are tracked for anti-money laundering (AML) and combating the financing of terrorism (CFT) purposes. Finally, the opinion emphasizes the opportunity to further clarify in the proposed regulation the responsibilities regarding data protection of the ECB and payment service providers, defining the legal bases for their respective processing and the categories of personal data necessary for the issuance, distribution, and use of digital euros.

****Another Financial Topic that has Significantly Engaged the EDPB Concerns the Processing of Personal Data in the Context of Anti-Money Laundering and Counter-Terrorism Financing (AML/CFT) Provisions,**** a continuously evolving sector due to the succession of EU legislative initiatives and the subject of a specific action plan by the European Commission (May 7, 2020) and a package of four legislative proposals published by the Commission on July 20, 2021. In particular, in a letter dated March 28, 2023, the EDPB addressed a series of considerations to the Commission, the Council, and the EU Parliament regarding the Commission's proposal for a regulation of July 20, 2021, on preventing the use of the financial system for money laundering or terrorist financing. In light of the Council's introduction of amendments that provide for new rules on data sharing between obliged entities and public authorities, and among the obliged entities themselves, the letter highlights how the new proposals do not adhere to the principles of proportionality and necessity, nor to the quality of legislation, and recommends not including such proposals in the final legislative text.

****Application of Article 5, Paragraph 3, of the e-Privacy Directive:**** On November 15, 2023, the EDPB adopted guidelines on the technical scope of Article 5, Paragraph 3, of Directive 2002/58/EC, which aim to clarify which operations, particularly which new and emerging tracking techniques, are covered by current legislation, as well as to provide greater legal certainty to data controllers and data subjects. To clarify the operation of the article, the guidelines examine the concepts referred to therein such as "information," "terminal equipment of a subscriber or user," "electronic communication network," "access," and "access to stored information/storage." The guidelines also include a series of practical use cases that present common tracking techniques.

****Voluntary Cookie Pledge Initiative:**** The EDPB has drafted a letter addressed to the European Commission regarding the so-called voluntary cookie pledge initiative. The initiative—welcomed by the EDPB—was developed by the European Commission to address concerns related to the phenomenon of so-called cookie fatigue and consists of a voluntary commitment by businesses to simplify cookie management and personalized advertising choices for consumers. According to the principles of the initiative, users should be able to receive concrete information on how their data is processed, as well as the consequences of accepting different types of cookies, ensuring them greater control over the processing of their data. Always with the aim of reducing the fatigue caused by the...

****Guidelines on Facial Recognition in the Police and Justice Sector****

****Guidelines on Transfers Subject to Adequate Safeguards under the LED****

Cookies, consent should not be requested again in the year following the year in which it was refused. However, it remains clear that, as expressly indicated in the letter from the EDPS, adherence to the voluntary principles of the initiative does not equate to full compliance with the GDPR or the e-Privacy Directive, and that data protection authorities remain competent to exercise their powers when necessary.

On April 26, 2023, following the public consultation, the EDPS adopted the final version of the guidelines 5/2022 on facial recognition technology in the police and justice sector (see 2022 Report, p. 187 et seq.). The guidelines provide guidance to national and EU legislators, as well as law enforcement authorities, on the implementation and use of facial recognition technology systems. In particular, the guidelines emphasize that facial recognition tools should only be used in strict compliance with Directive 2016/680 (LED) where this is necessary and proportionate, as established in the Charter of Fundamental Rights. The guidelines reiterate the request to prohibit the use of facial recognition technology in publicly accessible spaces, as already requested in the opinion adopted jointly with the EDPS on the EU AI regulation proposal (see Chapter 16).

On September 19, 2023, the EDPS adopted the guidelines on Article 37 of the LED, which governs the transfer of personal data by the competent authorities of EU countries for judicial police activities to other competent authorities of third countries or international organizations. The guidelines, subject to public consultation, aim to provide practical guidance regarding the adequate safeguards that competent authorities must adopt in international transfers, with particular regard to the relevant factors for assessing the existence of such safeguards. In this regard, the guidelines serve as a reference point for EU countries wishing to establish or amend legally binding instruments for the transfers of data provided for in Article 37 of the LED, listing, among other things, the elements that such instruments should contain to provide adequate safeguards. At the same time, the guidelines offer guidance to supervisory authorities in case they are consulted or otherwise involved in the negotiation of such instruments, or where they subsequently verify their implementation. Furthermore, the guidelines clarify the role of data protection authorities concerning the accountability obligations incumbent on data controllers when they believe, after assessing the circumstances related to the transfers, that adequate safeguards for data protection exist, and also provide some useful examples for classifying and assessing such circumstances.

****21.2. Cooperation of Data Protection Authorities in the Area of Freedom, Security, and Justice****
The Authority has continued to actively participate in the meetings of European working groups on security and justice.

****21.2.1. Coordinated Supervisory Committee****

As is known, the Coordinated Supervisory Committee (CSC) deals with the coordination between national supervisory authorities and the EDPS for the supervision of large-scale IT systems used for police and judicial cooperation activities. During 2023, the transition within the Committee of the work of the previously autonomous subgroups concerning the supervision of the SIS, EUROPOL, EUROJUST, and EPPO systems was definitively implemented. In this regard, it is noted that, at a methodological level, starting from the meeting held in June 2023, the Committee initiated a dialogue with representatives of civil society and non-governmental authorities in order to implement an exchange of opinions and operational indications regarding the most critical aspects of the various

systems.

As anticipated, the handover of ongoing activities from the SIS SCG to the CSC has been completed, particularly concerning those related to the "Questionnaire on Article 36" (old SIS regulation). In April 2023, the so-called Schengen access guide was published (see A guide for exercising data subjects' rights: the right of access, rectification, and erasure, available on the EDPS website). Among the issues addressed, the presidency of the Committee highlighted that of the so-called new alerts, particularly those defined in Article 40 of Regulation 1862/2018 related to "Reports of unknown persons wanted for identification purposes in accordance with national law," regarding which the need to closely monitor the statistics provided by law enforcement authorities was noted in order to assess the manner of their use. Based on the report subsequently presented by the data protection officer of EU-LISA regarding the monitoring and control of the Schengen central system, the necessity for reflection on the opportunity to conduct a verification in each Member State regarding the eligibility criteria for the use of...

biometric data (fingerprints) for the aforementioned reports when referring to individuals suspected of committing serious crimes, also with regard to their legal basis. For its part, the European Commission illustrated during the year the statistics and innovations introduced by the new SIS system. In particular, regarding the inclusion of fingerprints, a high threshold is expected for the admissibility of an alert concerning them (e.g., seriousness of the crime, certainty about the perpetrator, etc.).

In anticipation of conducting inspections together with the EDPS at the EUROPOL headquarters, it was agreed on the necessity of a preliminary investigation at the national level, to be carried out by each authority – through requests for information and inspections at the competent national police authorities – aimed at verifying the methods by which the data sent to the EUROPOL system are processed. In particular, the checks should concern the procedures with which national police authorities carry out the risk assessment of the processing, the possible acquisition of irrelevant, excessive, or disproportionate information, and, more generally, the ways in which the data that subsequently flows into the system is acquired. The aforementioned checks should also focus on the methods of collecting data related to PNR and their use by national police authorities, with particular reference to those Member States that have been active in the process of collecting and transmitting such data to EUROPOL, indicating the categories of data that have been specifically collected and transmitted. Based on these checks, a list of best practices and critical points will be drafted for use in the scheduled inspections.

In a similar manner, it was agreed to operate concerning the FRONTEX information system, regarding which the authorities raised doubts and expressed the need to deepen the checks concerning its actual functioning and the contribution of national police authorities to it. In light of the information communicated about the technical evolution of the EUROPOL system architecture, which allows for the search for additional categories of data contained within the system, also through fully automated queries (see those using the NCMEC database - National Center for Missing and Exploited Children, cross-referencing its data with that from other archives), concerns and critical issues were shared among participants regarding the progressive interoperability of the EUROPOL system with other information systems, particularly regarding the need to sensitize national police authorities not to abuse these new capabilities.

The guide on the exercise of the rights of data subjects for access to the EUROPOL system was examined and then approved, which has been updated concerning the contact details for each Member State. The EDPS, which presented the results of the annual inspection carried out at EUROPOL, emphasized the importance of paying attention to the figure of the minor, who should always be considered a victim in the criminal scenario, and reiterated the importance of scheduling inspections by individual supervisory authorities at the so-called NCP (National Contact Point).

A possible coordinated action regarding PNR data and the classification of data subjects into different categories was also discussed. Specifically, attention was drawn to the "PNR request form" and its structure, emphasizing the importance of ensuring compliance with the requirements of necessity and proportionality, and a reflection was made on the criteria established for consulting PNR data.

Regarding complaints made against EUROPOL, the difficulty of complying with the three-month deadline set by the relevant regulation for responding to access requests was highlighted.

As for the EUROJUST information system, some critical issues were highlighted in the context of cooperation with the national EUROJUST structures (such as the lack of response to requests sent by mail) in view of the possible definition of a common approach within the group. Regarding Denmark's participation in the supervision of the EUROJUST and EUROPOL information systems, pursuant to Article 62 of Regulation (EU) 2018/1725 (EU-DPR), considering that it, while being a member of the European Union, has not implemented either Regulation (EU) 2016/794 (EUROPOL Regulation, ER) or Regulation (EU) 2018/1727 (EUROJUST Regulation, EJR), it was noted that from a formal point of view, the current regulatory framework prevents cooperation with States that have not implemented the two regulations ER and EJR into their national legal systems: therefore, various critical issues arise in the event of access by their respective police and judicial authorities to the two databases in question (e.g., in the case of viewing confidential documentation or in the case of voting on a decision of the Committee). The authorities were invited to conduct a thorough assessment of the issue at the national level. In other respects, the audit carried out by the EDPS indicated that most of the recommendations made have been implemented by EUROJUST. A memorandum of understanding with EPPO has been prepared by the EDPS, and audit activities have been planned during the course of 2023. A control activity was conducted at the Portuguese national office of the EPPO, with positive outcomes thanks to the integration of databases with national case files and a greater understanding of the role played by GEPD and national authorities in supervising the EPPO information systems.

21.2.2. EURODAC System Supervision Group

In the case of the EURODAC system, it is also necessary to highlight the expansion of technical data processing capabilities, while the adoption of the text of the new EURODAC regulation is expected in the early months of 2024. In this regard, a deepening of the interaction of its provisions with other sector regulations has been planned, particularly with the regulation establishing checks on citizens of third countries at the external borders of Member States (the so-called Screening Regulation), which is also to be adopted during the same period. A questionnaire has been developed regarding access to the EURODAC system by law enforcement authorities, with the aim of verifying the current use of the procedure and providing guidance in investigations of the most relevant crimes.

21.2.3. Customs Information System Supervision Coordination Group

The twenty-first meeting of the Customs Information System (SID) Supervision Group, the only one held in 2023, highlighted the gradual increase in the number of information systems that fall under the application of Article 62 of EU Regulation 2018/1725, resulting in an increased workload. It was therefore proposed to increase the number of meetings, also for the sake of greater continuity.

21.3. The Authority's Participation in the Council of Europe, OECD, and Other International Working Groups

The Authority's activities within the Council of Europe continued, particularly through participation in the Advisory Committee of Convention 108/1981, the so-called T-PD, and the restricted group T-PD Bureau responsible for preparing documents to be submitted to the plenary. 2023 was also marked by intense commitment from the Advisory Committee and the secretariat in promoting the modernized Convention 108 (the so-called Convention 108+). During the year, the amending protocol of the Convention, which updated its principles in a scenario significantly altered by new technologies and globalization, was ratified by a considerable number of countries and, as of December 31, 2023, has 15 signatures and 31 ratifications, including that of Italy. In both plenary sessions of the year (June 14-16 and November 15-17, 2023), a roundtable was held with all delegations from countries that have not yet ratified, and a certain optimism emerged regarding the timely achievement of the 38 ratifications necessary to ensure the entry into force of Convention 108+. During the June plenary, the model contractual clauses for the transfer of personal data to third countries, i.e., countries that are not parties to the Convention, were adopted. This is a very important document in light of the global vocation of Convention 108+. It offers a model of clauses that data controllers can use, based on Article 14(2.b) of the modernized Convention, to ensure an appropriate level of protection in the

transfers of personal data between controllers to third countries. One of the main objectives of Convention 108+ is indeed to facilitate the free flow of information both among the Parties and to third countries, ensuring an appropriate level of protection for personal data. Practice shows that such instruments provide a convenient and simple way for the cross-border transfer of data between data exporters and importers in the private sector. In addition to the clauses between controller and controller, during the June plenary, an additional model of clauses concerning transfers from controller to processor was adopted, and the Bureau was mandated to begin working on a model of clauses usable in transfers to third countries between processors.

During the June plenary, guidelines on the processing of personal data for anti-money laundering and counter-terrorism financing (AML/CFT) purposes were also adopted, aiming to provide guidance on how to integrate the requirements of Convention 108+ in the AML/CFT sector, ensuring an adequate level of data protection in cross-border data flows, as well as highlighting certain aspects concerning the application of AML/CFT principles in which data protection guarantees should be strengthened. The guidelines were adopted after extensive consultation with various stakeholders, including the FATF secretariat, and in close collaboration with the Committee of Experts on the Evaluation of Anti-Money Laundering Measures and the Financing of Terrorism (MONEYVAL) of the Council of Europe.

Advisory Committee of Convention 108/1981 (T-PD)

The Convention 108+

Model Contractual Clauses for the Transfer of Personal Data to Third Countries

Anti-Money Laundering and Counter-Terrorism Financing (AML/CFT)

REPORT 2023

****Art. 11 of the****

****Modernized Convention****

****Data Protection in the Context of Elections and Voting Procedures****

****Neurotechnologies****

****CAI - Ad Hoc Committee on AI****

****OECD - DGP (Data Governance and Privacy Working Party)****

****Analytical Report on Data Free Flow with Trust (DFFT)****

The Committee has also continued its in-depth activities aimed at drafting the additional documents provided for in the work program. Therefore, reflection on Art. 11 of Convention 108+, concerning the criteria that must accompany possible restrictions and exceptions to its principles to ensure respect for the right to data protection, has continued. The Committee has begun working on guidelines for the processing of data, particularly biometric data, in the context of elections and voting procedures, with the support of an external scientific expert.

The intent of the guidelines is to call for the utmost caution in the use of biometric systems in such a sensitive sector, in compliance with the principles of necessity and proportionality, and therefore evaluating the possibility that alternative and less intrusive processing methods may be employed. Work has been initiated on neurotechnologies and fundamental rights in view of the future development of specific guidelines. The evolution of such technologies and their combination with artificial intelligence systems are increasingly enhancing the possibility not only of "reading" the human brain but also of its alteration or manipulation. This necessitates reflection on the implications for fundamental rights, including the right to privacy (so-called mental privacy) and the free expression of thought. One of the first issues addressed was whether and to what extent existing regulatory tools can be relied upon to meet the new challenges posed by neurotechnologies and whether it is instead appropriate to promote the creation of "new rights" through regulation, as some legal systems (e.g., in Latin America) seem to wish to do.

Within the framework of the Council of Europe, the activities of the Ad Hoc Committee on AI - CAI have continued, which, following the work of the previous CAHAI committee (see 2021 Report, p. 235), has continued the development of a legal framework for the development, design, and application of AI,

based on the Council of Europe's standards on human rights, democracy, and the rule of law (see Chapter 16). The T-PD has followed the work of the CAI to ensure that the new Convention on AI maintains the protective framework guaranteed by Convention 108+, ensuring a consistent application of the two regulatory instruments.

The Authority's activities within the OECD have continued, particularly through participation in the DGP (Working Party on Data Governance and Privacy), of which the Authority has held the vice-presidency since 2012 (previously in the WPSPDE - Working Party on Security and Privacy in the Digital Economy) and has retained the vice-presidency for 2024 (confirmed in the plenary elections of November 2023). In addition to the activities reported below, the DGP has continued to monitor the implementation of documents and recommendations adopted by the OECD in previous years (among which we recall the recommendation on the protection of minors online).

During 2023, the Group completed its work on data free flow with trust, finalizing the related report that gathers the private sector's perspective in order to provide a more comprehensive understanding of the challenges and pathways to follow for the global political agenda on the subject. In particular, businesses indicate the need for consistent principles and rules that are transparent and predictable, provide a practical balance between certainty and flexibility, and offer solutions that correspond to business realities, all while respecting data protection. The report highlights the need for greater international regulatory cooperation and to leverage the full range of options to ensure the trust of parties in the challenging context of data flow. This work has also been conceived in coherence with what was done on the same topic in 2023 by the G7 of data protection authorities.

data to avoid duplication of efforts, analyzing areas of convergence and identifying possible concrete actions to facilitate global DFFT. During 2023, the Group worked on the theme of AI, aware of the significant opportunities but also the risks that its development is highlighting, and the need for greater international cooperation among multiple stakeholders in the governance of personal data and privacy.

In this context, during the plenary of the DGP in April 2023, recent advancements in generative AI were discussed, and the Italian authority reported on actions related to ChatGPT in light of the provision from the Authority dated April 11, 2023, no. 114, web document no. 9874702, which provided prescriptions on transparency, rights of data subjects, and the legal basis for the related processing. In light of the various presentations, it was deemed necessary to initiate joint activities with the OECD Working Group on AI Governance (AIGO). The first draft of an extended framework for a report titled "AI, Data, and Privacy: Preliminary Considerations on Synergies and Areas of Interest and International Cooperation at the OECD" was also presented, which aims to identify priority areas for necessary cooperation among different stakeholders to increase awareness of the scope of data protection rules and promote a shared understanding and consistent implementation.

To this end, a proposal was presented in the November plenary for the establishment of an OECD Expert Group on AI that, starting in 2024, will bring together various expertise in privacy and data protection as well as in the AI sector, in order to conduct in-depth analyses on the areas of intersection between the two fields and provide outputs on policy choices to be adopted in perspective and within the supranational framework.

The Group also focused its attention on the theme of "open finance," working on a draft report to which delegates from the DGP contributed along with other expert groups within the OECD. Since open finance allows for the sharing and access to data (including personal data) in the financial sector, it requires a particular focus on the protection of such data. The report analyzes the benefits, risks, and challenges associated with the implementation of open finance and provides recommendations for effective and proper data sharing in open finance. The document also examines other aspects related to consumer protection, particularly those concerning consent and liability, and contains a series of considerations on the possible creation of a technical infrastructure to promote data interoperability.

Throughout 2023, the DGP focused on the various intersections between the privacy sector and the competition/antitrust sector, a theme that is expected to become increasingly central in OECD discussions. The Group, starting from various national experiences, analyzed the impact of consumer

data on competition in online markets and questioned the possible creation of barriers to entry due to control over consumer data as well as possible remedies. The necessity to continue this work and evaluate (also through future documents to be developed in 2024) how to improve cooperation between competition authorities and those responsible for privacy and data protection was shared.

Another delicate and central theme was the implementation of the OECD declaration on trusted government access to data held by the private sector, adopted at the OECD ministerial meeting in Gran Canaria in December 2022 (see 2022 Report, p. 194). The declaration starts from the observation that cross-border data flows are an integral part of the global digital economy and an inevitable step to fully harness the benefits of digitalization. Therefore, adequate governance is necessary, along with effective guarantees regarding government access to personal data held by the private sector, in order to build trust and minimize obstacles to data flows. In the plenaries of 2023, the DGP acknowledged that the declaration represents a good step forward and that the international data protection community has begun to engage and provide feedback on its implementation; however, it was also noted that the declaration does not define further concrete steps for its implementation. Some delegations suggested creating a compendium of all relevant laws in OECD member countries, which could serve as a useful reference tool alongside the declaration.

21.4. International and European Conferences

The 45th annual conference of the Global Privacy Assembly (GPA), which brings together data protection authorities globally, was held in Hamilton (Bermuda) from October 16-20. As usual, the Conference was structured into an open session, involving various public and private actors, and a session reserved for data protection authorities only. The Authority participated in the panels of the open session dedicated to AI and emerging technologies with a presentation on the theme of personal data protection in

****Financial Sector.**** In the session reserved for data protection authorities, numerous resolutions were adopted on topics of great interest (notably those concerning AI in the workplace, for which the Authority was the proposing body; on the use of health data in scientific research; on achieving global data protection standards; and on the establishment of a working group on gender perspective in data protection). Furthermore, this session, a unique opportunity for dialogue among authorities at the global level, in 2023 was characterized by several "Capacity Building Workshops" dedicated to quantum technologies, the metaverse, technologies for environmental protection and data protection, and digitalization in the public sector. It is worth noting that the Philippine Authority has taken on the role of the first permanent secretariat of the GPA, for the first time funded by the authorities according to the criteria defined by the resolution on the future of the Conference adopted by the GPA in 2021. During the Conference, the dates for the next GPA were announced, which will take place in Jersey from October 28 to November 1, 2024. The Spring Conference of European data protection authorities, a traditional moment for exchange and best practices, was held in Budapest from May 10 to 12. During the event, discussions were held on the social and individual impact of new technologies, and an overview was provided on the jurisprudence of the European Court of Human Rights and the Court of Justice of the EU regarding data protection and privacy. A specific section examined the issues related to the role played by DPOs, also in light of the good practices developed by public and private entities and supervisory authorities. A concluding resolution was also adopted on the need to strengthen cooperation in the field of data protection and competition law, in which the unified commitment of the Authorities to protect fundamental rights was renewed and the exchange of information between privacy and competition authorities was encouraged, with a view to promoting equality in the markets in compliance with data protection regulations. Finally, on the occasion of the Spring Conference, on May 11, the Authority organized a workshop at the Italian Cultural Institute in Budapest titled "Vulnerable Persons: Online Protection Tools. Minors and Age Verification" (see par. 23.3).

****G7 of Data Protection Authorities****

****Preliminary References under Article 267 TFEU****

On June 20 and 21, the G7 of data protection authorities (Roundtable of G7 Data Protection

Authorities) was held in Tokyo. Reports from the three working groups established in 2022 during the G7 of DPAs held in Bonn were presented, which began to address three identified priority themes, namely:

- Free Data Flow with Trust;
- Emerging Technologies and Privacy-Enhancing Technologies (PET);
- International Cooperation in the Enforcement of the Regulatory Framework.

The G7 confirmed its intention to continue developing work on these themes for the coming year. The delegations then examined and approved the 2023-2024 Action Plan and the final press release, as well as a statement dedicated to generative AI, strongly advocated by the Japanese Authority, which recalled the ongoing initiatives by various data protection authorities, particularly regarding the activities undertaken by the Italian Authority concerning ChatGPT, urging the developing companies to pay due attention to the legal requirements and guidelines provided by data protection authorities on AI, ensuring privacy and other fundamental human rights. The Italian delegation presented and commented on a short video related to the upcoming G7 of data protection authorities, which will be organized and hosted in Rome from October 9 to 11, 2024.

****21.5. Preliminary Questions before the Court of Justice of the European Union****

The international activities of the Authority also involved the preliminary questions submitted to the CJEU by judges from Member States, pursuant to Article 267 of the TFEU, regarding the protection of personal data. In this regard, it should be noted that there has been a significant increase in the number of such cases during 2023, primarily related to the interpretation of provisions of the GDPR, although issues related to Directive 2016/680 and the long-standing topic of the prolonged retention of traffic data and access to electronic communications in light of Directive 2002/58/EC have not been lacking. The following judgments adopted by the CJEU during 2023 are particularly noteworthy, with further preliminary questions having received the conclusions of the Advocates General presented in the same year, which cannot be detailed here:

- Judgment of January 12, 2023, Case C-132/21, regarding remedies under the GDPR; art. 15 GDPR;
- judgment of January 12, 2023, case C-154/21, regarding the right of access under
- judgment of January 26, 2023, case C-205/21, concerning the limits on the processing of biometric and genetic data under Directive (EU) 2016/680;
- judgment of February 9, 2023, case C-453/21, regarding GDPR and the prerequisites for lawful removal under national legislation;
- judgment of February 9, 2023, case C-560/21, regarding GDPR and suspension from duties for reasons unrelated to tasks;
- judgment of February 16, 2023, case C-349/21, regarding access to data from electronic communications in judicial proceedings under Directive 2002/58/EC;
- judgment of March 2, 2023, case C-268/21, concerning the presentation of documentation containing personal data in civil proceedings and the related limits;
- judgment of March 30, 2023, case C-34/21, on the necessity of consent for distance learning via videoconference during the Covid-19 pandemic;

227

REPORT 2023IIII21

- judgment of May 4, 2023, case C-487/21, on the concept of "copy" of personal data in access requests under art. 15 GDPR;
- judgment of May 4, 2023, case C-60/22, on the notion of joint controllership of processing and the exercise of rights of data subjects under GDPR;
- judgment of May 4, 2023, case C-300/21, regarding the conditions for the right to compensation for damage from the processing of personal data and the notion of non-material damage;
- judgment of June 22, 2023, case C-579/21, on the scope (including in time) of the right of access under art. 15 GDPR and the notion of "recipients" of data;
- judgment of July 4, 2023, case C-252/21, on the fair cooperation between competition authorities and

data protection supervisory authorities in identifying non-compliance with GDPR;

- judgment of September 7, 2023, case C-162/22, on the prolonged retention of electronic communications data and their subsequent availability in other proceedings;
- judgment of October 5, 2023, case C-659/22, on the notion of "processing" of personal data in relation to the verification of the validity of "EU digital Covid certificates";
- judgment of October 26, 2023, case C-307/22, on the right of access under art. 15 GDPR and the justification of the related request;
- judgment of November 9, 2023, case C-319/22, on the notion of "personal data" in the context of services related to information on the repair and maintenance of motor vehicles;
- judgment of November 16, 2023, case C-333/22, on the exercise of the rights of the data subject through the supervisory authority under Directive (EU) 2016/680;
- judgment of December 5, 2023, case C-807/21, on the notion of "data controller" and the corrective powers of supervisory authorities against legal entities;
- judgment of December 5, 2023, case C-683/21, concerning the notion of "joint controllership" of processing and the scope of responsibility for the imposition of administrative monetary penalties;
- judgment of December 7, 2023, joined cases C-26/22 and C-64/22, on the scope of judicial review regarding a decision of a supervisory authority concerning a complaint in the case of unlawful processing of data;
- judgment of December 7, 2023, case C-634/21, concerning the notion of automated decision-making and the activities of companies providing commercial information;
- judgment of December 14, 2023, case C-340/21, regarding the liability of the data controller and the right to compensation for non-material damage in the event of a violation committed by third parties;
- judgment of December 14, 2023, case C-456/22, on the notion of "non-material damage" and the right to compensation in the case of online publication without the consent of the data subject;
- judgment of December 21, 2023, case C-667/21, regarding compensation for non-material damage, its compensatory function, and the impact of the fault of the data controller.

Project ARC II

21.6. Projects for the application of GDPR funded by the European Union

In the 2022 Report (see p. 197), it was reported that in September 2022, a project co-financed at 90% by the European Commission, called ARC II (<https://arc-rec-project.eu/about-the-arc-ii-project/>), was launched in partnership with the Croatian Personal Data Protection Authority (the lead partner of the project), the University of Florence (Department of Legal Sciences), the University of Zagreb (Faculty of Computer Science), and the University of Brussels (Vrije).

In this context, during 2023, an open-source digital tool called OLIVIA was developed, freely accessible, interoperable, and innovative, tailored to the specific needs of SMEs, to help them comply with GDPR. In Italy, staff from the Authority conducted five of the ten remote seminars on GDPR planned by the project, during which SMEs received direct support to address specific issues related to GDPR compliance. A campaign to raise awareness was also conducted on the Authority's social media channels, and a workshop was organized to verify the digital tool OLIVIA.

229

REPORT 2023IIII21

22

International and National Technical Standardization Activities

The Authority continued its collaboration on the development of international technical standards within Working Group 5 of Subcommittee SC27, which deals with information security within the JTC1 technical committee of the International Organization for Standardization (ISO). The working group addresses security aspects in identity management related to biometric technologies and the protection of personal data. By harmonizing its position with those of other data protection authorities through the European Data Protection Board (EDPB), which has a connection with ISO on this matter, the Authority has followed the development of the following technical standards:

- **ISO 27701:2019** - Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management - Requirements and guidelines, revised following the publication of ISO 27002:2022;

- ****ISO 27566**** - Information security, cybersecurity and privacy protection - Age assurance systems - Framework, which aims to establish key principles, including privacy, to enable decisions on the provision of goods, services, or content that depend on the age of the requesting individual by defining a framework of age confidence indicators or age range for natural persons, as well as, with Part 2, defining measures and testing of components for age verification with a view to use for conformity assessment and with Part 3 indicating elements for interoperability, technical architecture, and guidance on use;
- ****ISO TS 27006**** - Requirements for bodies providing audit and certification of privacy information management systems according to ISO/IEC 27701 in combination with ISO/IEC 27001, which defines additional requirements to ISO 17021 and 27006 for certification bodies conducting audits and issuing certifications according to the new ISO 27701 (Privacy Information Management System);
- ****PWI PII**** - Processing Record Structure, a new project that aims to reuse the data structures described by ISO/IEC 27560 - Consent Receipt and Record Standard for all possible legal bases for the processing of personal data;
- ****ISO TS 27561**** - Privacy operationalisation model and method for engineering (POMME), which, based on the OASIS-PMRM (Privacy Management Reference Model), provides elements and supports organizations in defining a model and standardized methods for privacy engineering of complex systems;
- ****ISO 29151:2017**** - Code of practice for personally identifiable information protection – systematic revision that will take into account the applicability of the identified controls in organizations (particularly SMEs) that do not implement management systems;
- ****ISO 27018:2019**** - Code of practice for protection of PII in public clouds acting as PII processors, revision of the technical standard – which identifies specific controls for cloud service providers that, processing personal data, act as data processors – for alignment with the new version of ISO 27002:2022;
- ****ISO 27562**** - Privacy guidelines for fintech services which proposes a guideline for privacy for fintech services identifying business models, roles of C2B, B2B relationships, risks and privacy requirements, and providing specific privacy controls for such services taking into account the context (legal) and roles;
- ****ISO 27091**** - Cybersecurity and privacy - Artificial intelligence – Privacy protection, which provides guidance to organizations that use or develop artificial intelligence systems and machine learning models to address privacy risks by identifying risks in the lifecycle of AI systems and establishing mechanisms to assess consequences and address such risks through mitigation measures.

The Authority also, within Working Group 5 of the JTC13 technical committee of CEN CENELEC, which deals with the development of technical standards concerning Data Protection, Privacy, and Identity Management, contributed to the development of the following technical standards:

- ****EN 17529**** - Privacy Protection by design and by default, which, in response to the mandate from the European Commission (Directorate-General for Security and Home Affairs), identifies objectives, data protection requirements, and guidelines to support developers, manufacturers, and service and product providers in implementing data protection principles from the design stage and by default in the development and production of products and services;
- ****EN 17799**** - Personal data protection requirements for processing activities, which, based on the reference practice UNI 43.2:2018 Guideline for personal data management within ICT according to Regulation EU 679/2016 (GDPR) - Requirements for the protection and conformity assessment of personal data within ICT, proposes requirements for the protection of personal data managed by information systems that can also be used for certifications pursuant to Article 42 of... RGPD;
- **EN 17740** - Requirements for professional profiles related to personal data processing and protection, which, based on the technical standard UNI 11697:2018, identifies harmonized requirements at the European level and in accordance with the European Qualifications Framework (EQF), certifiable, regarding the competencies, knowledge, and skills of professionals engaged in activities related to the processing and protection of personal data;

- EN 17926 - Privacy Information Management System for ISO/IEC 27701 - Refinements in European context, which adapts the international framework offered by ISO 27701 in the European context;
- JT013068 - Certification scheme as per ISO/IEC 17065 for certification against
- EN 17926 - Privacy Information Management System for ISO/IEC 27701 - Refinements in European context, which aims to define a certification scheme pursuant to Article 42 of the RGPD based on the technical standard EN 17926;
- JT013072 - Scheme for certification of personal data processing operations against EN 17799, which aims to define a certification scheme pursuant to Article 42 of the RGPD based on the technical standard EN 17799.

Similarly, collaboration with the various technical committees of UNINFO, the standardization body federated with UNI (Italian National Unification Body), has continued.

In the context of ENISA, the publication, on the occasion of the EU Data Protection Day at the end of January 2023, of the report on Data Protection Engineering, Scope and Application is noted, as well as the completion of the report on data protection engineering within the EU Data Spaces (particularly in the health sector), which will be published on the occasion of the EU Data Protection Day at the end of January 2024.

With reference to the so-called Berlin Group (International Working Group on Data Protection in Technology - see Chapter 23.1), the Authority has collaborated as lead rapporteur in drafting the opinion on data sharing, participated in defining the working documents on telemetry (text adopted during the meeting held in Rome on June 6-7, 2023), and contributed to the working document on digital currency (approved by the Group in November 2023) as well as to the initial drafting phases of the guidelines on large-scale language models and those related to the use of neurotechnologies.

Particularly significant, finally, has been the collaboration with the National Cybersecurity Agency to prepare guidelines on cryptographic functions for password storage (provision dated December 7, 2023, no. 594, web document no. 9962384), in order to provide guidance to data controllers and processors, and to producers of products, services, and applications, on technical measures capable of ensuring a level of security adequate to the risks presented by the processing of user passwords.

THE ACTIVITIES CARRIED OUT BY THE AUTHORITY

23.1. The Authority's Communication: General Profiles

In 2023, the Authority further promoted the right to data protection among citizens, institutions, businesses, and associations, also through innovative communication strategies. This communication activity primarily addressed the most invasive phenomena regarding individuals' privacy, such as telemarketing and, in relation to emerging technologies, biometric data collection systems and the use of facial recognition. Significant effort was also directed towards AI, particularly so-called generative AI, which materialized in an intervention—the first at the global level—against a platform like ChatGPT. Also on the AI front, extensive and accurate attention was dedicated to the exploratory investigation initiated by the Authority on public and private websites to verify the adoption of appropriate security measures aimed at preventing mass collection (web scraping) of personal data for the purpose of training AI algorithms by third parties.

Constant attention (see 12.7) has been given to initiatives for the protection of minors, particularly regarding the request made to the most frequented platforms to identify and adopt reliable age verification solutions, the stop to Replika (the chatbot, equipped with a written and vocal interface that generates a virtual friend based on artificial intelligence), as well as the awareness-raising activities for responsible use of the internet and new social media. Specific information activities have also been carried out towards the media to protect victims of violence.

In January, an institutional communication campaign titled "Finally a bit of privacy" was launched, funded by the Ministry of Enterprises and Made in Italy with the consumer benefit fund, aimed at raising awareness of the value of data and the importance of its protection, which developed through 9 radio and TV spots, social media products, and digital billboards. The radio and TV spots addressed various themes: from the use of apps to digital fraud, from cyberbullying to revenge porn, from wild telemarketing to digital assistants, from health data to profiling and the use of passwords. The final

claim "If you protect your data, you protect yourself" is an invitation to be increasingly aware of the "privacy value."

In January, the Authority also launched a competition aimed at students.

****Privacy Ambassador Initiative****

Students from classes I and II of upper secondary schools were called upon to create a video explaining to their peers what privacy means to them and how to protect it, with the aim of involving teachers and students in information and awareness projects related to data protection, especially in the digital realm. This initiative was titled "Become a Privacy Ambassador," and numerous schools from various Italian regions participated. To assist in the creation of the videos, the Authority provided schools with a dedicated educational kit to develop training paths on highly impactful topics, particularly for younger individuals: cyberbullying, identity theft, revenge porn, online profiling, digital assistants, wearable devices, and deepfakes.

****Strategic Communication Activities****

****2023 Report****

Monetary prizes designated for the purchase of technological products for teaching were awarded to the Liceo Scientifico Corradino D'Ascanio in Montesilvano, province of Pescara (first place), the Istituto Tecnico Commerciale e per Geometri Pareto in Pozzuoli, province of Naples (second place), and the Istituto Superiore di Istruzione Secondaria F. De Sanctis - O. D'Agostino in Domicella, province of Avellino (third place) for the videos they created, respectively. The awards were presented during the "Privacy Talks" event held on October 25 in Naples.

On March 10, the Authority participated in the "Didacta" Fair, the most important event dedicated to the education sector that takes place annually in Florence, and organized two seminars for teachers and school administrators on the theme "The School Tested for Privacy." On this occasion, the updated edition of the handbook dedicated to schools was presented.

The Authority also facilitated its participation in the 2023 edition of the Forum PA "Let's Start Again from People," an event dedicated to training and sharing best practices of public administration and innovative enterprises, which took place at the Palazzo dei Congressi in Rome from May 16 to 18. Members of the College, directors, and officials of the Authority participated in the event, discussing topics particularly related to the digitalization of public administration. At the Authority's stand, several seminars were organized, and documentary materials were distributed, including digital support such as the "Guide to the Application of the European Regulation on the Protection of Personal Data," the updated text of the Privacy Code, and the second volume of "Applying the GDPR. The European Guidelines 2019-2022."

Particular attention was given to the second edition of "State of Privacy," the dialogue event of the Authority that involves representatives from major public and private stakeholders with the goal of fostering an open and constructive discussion on the future of data protection and the issues raised by the development of the latest technologies. The meeting, held on September 18 at the National Etruscan Museum of Villa Giulia in Rome, organized in collaboration with the Universities of Roma Tre and Florence, brought together over 250 representatives from national and international institutions, public administrations, big tech, media, large companies, the financial world, as well as experts, scholars, and personalities from the academic and scientific community. The focus was on the work of 19 thematic tables dedicated to a series of relevant sectors: advertising, cloud, cybersecurity, human rights, DPO, enforcement, genetics, AI, IoT and smart cities, legal design, media and communication, minors, neuroscience, digital public administration, legislative process, health, financial services, sustainability, telemarketing.

During the event, conducted by Riccardo Luna, director of Italian Tech, the Undersecretary to the Presidency of the Council of Ministers with a mandate for technological innovation, Alessio Butti, and the Rectors of the two Universities of Roma Tre and Florence, Massimiliano Fiorucci and Alessandra Petrucci, spoke.

On this occasion, the Privacy Tour was launched, aimed at spreading the culture of personal data protection in the south and in small towns of our country where there is still limited awareness of their value, in order to avert the risk of new cultural divides between those who understand the opportunities and risks of the digital society and know how to defend themselves, and those who lack this knowledge. Those who have joined and will join the project commit to organizing events, initiatives, and training paths, including remote ones, throughout 2024, following a format designed by the Authority, addressing privacy issues and targeting individuals most exposed to online dangers, particularly children and non-digital natives. Among the first participants in the Privacy Tour, we note the Postal Police, the University of Rome.

pratiche in materia di protezione dei dati, e la promozione della cultura della privacy.

23.4. Collaborazioni e iniziative

L'Autorità ha collaborato con diverse istituzioni e organizzazioni per promuovere la cultura della privacy e la protezione dei dati. Tra le iniziative più significative, si segnala la partecipazione a eventi e conferenze nazionali e internazionali, dove sono stati discussi temi rilevanti per la protezione dei dati e la privacy.

23.5. Formazione e sensibilizzazione

Sono stati organizzati corsi di formazione e seminari per professionisti e operatori del settore, al fine di fornire aggiornamenti sulle normative vigenti e sulle best practices in materia di protezione dei dati. L'Autorità ha inoltre realizzato campagne di sensibilizzazione rivolte al pubblico, per aumentare la consapevolezza sui diritti dei cittadini in materia di privacy e protezione dei dati personali.

23.6. Monitoraggio e controllo

L'Autorità ha continuato a svolgere attività di monitoraggio e controllo per garantire il rispetto delle normative sulla protezione dei dati. Sono state effettuate ispezioni e audit presso enti pubblici e privati, con l'obiettivo di verificare la conformità alle disposizioni del Regolamento Generale sulla Protezione dei Dati (RGPD) e alle normative nazionali.

23.7. Conclusioni

In conclusione, l'Autorità ha lavorato attivamente nel 2023 per promuovere la cultura della privacy e garantire la protezione dei dati personali. Attraverso eventi, comunicazioni, collaborazioni e attività di monitoraggio, si è impegnata a sensibilizzare il pubblico e a garantire il rispetto dei diritti fondamentali in materia di privacy.

practices in the field of cybersecurity, AI, knowledge of rights, and the main obligations related to the regulations on personal data protection.

In 2023, video production significantly increased, both to account for new trends in digital consumption and to enhance the potential of social channels, particularly Instagram and YouTube. The latter, after a period of inactivity related to necessary legal-regulatory assessments, was revitalized, modernized, and populated with new content. During the year, 45 videos were produced, all in-house (with one exception), including interviews, teasers, tutorials, informational and promotional videos, montages, and reworking of events.

The Authority was also engaged in the development of integrated and multichannel informational campaigns that led to the creation of new thematic sections on the website, guides, and social content, including in particular, the fact sheet on misleading design patterns (Dark Patterns), the one on "Online Dating," and on "Apps and fitness tracker devices." Updated editions of the guides "Privacy-Proof School" and the "Guide to the Application of the European Regulation on Personal Data Protection" were also published.

There was a significant increase in the publication of content on the Authority's website (2,440 contents, +26% compared to 2022) and on the Authority's social media profiles on LinkedIn, YouTube, Telegram, Instagram, and Twitter (2,822 contents, +12% compared to 2022). The growth in the total number of followers on social media and messaging profiles was also important, reaching a total of 92,177 (+13.6% compared to 2022). On the Authority's website, 47 thematic pages were created from scratch or significantly updated.

On the editorial front, particular mention should be made of the production of several publications:

"Data Protection. For 25 Years the Compass of the Future" (proceedings of the Conference held in July 2022 on the occasion of the celebrations for the 25th anniversary of the Authority for the protection of personal data); "The Metaverse between Utopias and Dystopias" (proceedings of the conference for European Data Protection Day 2023); "Applying the GDPR. The European Guidelines - Volume 2"; "Vulnerable Persons: Online Protection Tools. Minors and Age Verification" (proceedings of the eponymous event organized by the Authority and linked to the Spring Conference 2023). The media, both national and foreign, have shown constant attention to the interventions carried out and the issues raised by the Authority. In particular, the ChatGPT case received extensive international coverage. Based on the daily press review produced, the pages of the major national and foreign newspapers and periodicals, the main local newspapers, online outlets, and blogs that addressed privacy-related issues totaled 7,312, while those related to the Authority's activities numbered 5,706. Articles concerning interviews, interventions, and statements by the Authority totaled 155 in print and online, while 56 were on radio and television. Finally, there were 1,931 articles related to press releases and 616 related to topics covered in the Newsletters.

23.4. Events and Conferences

Since 2007, promoted by the Council of Europe with the support of the European Commission and all European authorities for privacy and data protection, January 28 of each year is celebrated throughout Europe as "European Data Protection Day," aimed at raising awareness among citizens about rights related to the protection of privacy and fundamental freedoms.

The Authority dedicated European Day 2023 to the Metaverse. The Conference, titled "The Metaverse between Utopias and Dystopias: Horizons and Challenges of Data Protection," was held in person and streamed live at the Experience Europe space of the European Parliament in Italy - "David Sassoli." Through the interventions of the members of the College and renowned national and international experts, issues related to the impact that the new digital habitat will have on social relationships and individual behaviors, their freedoms and rights, as well as on the decision-making processes of the community were explored.

On February 22, at the same venue, the book "Privacy in the Digital Age - The Reports of the Presidents of the Authority 1997-2022," edited by the President of the Authority Pasquale Stanzione, was presented. The book, through the speeches of its presidents, retraced the twenty-five years of the Authority's history.

The right to personal data protection, the enhancement and monetization of data, artificial intelligence, and minors were the topics addressed by the College during the Italian session of the "Privacy Symposium," the international conference held in Venice in April. The goal of the event, which involved over 200 speakers in more than 80 sessions, was to promote international dialogue, cooperation, and knowledge sharing in the field of data protection. The progressive affirmation of the right to privacy as a tool for redistributing informational power was the subject of the opening speech of the day delivered by President Pasquale Stanzione. The need for quickly and collaboratively implement tools for verifying the age of minors accessing digital services was emphasized by the members of the Board, Guido Scorza and Agostino Ghiglia; the latter then addressed the relationship between artificial intelligence and privacy, reiterating the need for regulation of artificial intelligence and, therefore, for an acceleration of the approval process of the European AI Act. Regarding the monetization of data, which also requires governance, the Vice President of the Authority, Ginevra Cerrina Feroni, highlighted how the economic value of data has been recognized by both national and European jurisprudence but, at the same time, it is necessary to consider the vulnerability of those weak subjects who experience moments of vulnerability, including economic vulnerability.

In May, the Authority organized a workshop titled "Vulnerable People: Online Protection Tools. Minors and Age Verification" as part of the Spring Conference of European Data Protection Authorities held in Budapest. The Authority's goal was to raise awareness among participants to strengthen the protection of minors online with new technological tools and stronger regulations to safeguard their identity.

On July 6, at the parliamentary groups' hall, in the presence of representatives from the Chamber of

Deputies and the Senate, Ministers, institutional representatives, the business world, and trade associations, the ceremony for the presentation of the Annual Report for the year 2022 took place. The Report illustrated the various and delicate fronts on which the Authority has been engaged in enforcing the fundamental rights of individuals and the principles underlying privacy legislation. The entire event was broadcast live on television and streamed on the institutional website.

Finally, it should be noted that during the year, the President and the members of the Board participated in numerous events, conferences, and study days of national and international significance.

23.5. International Activity

The Authority has carried out significant activities through the group of communicators established at the European Data Protection Committee to implement coordinated communication activities, including the sharing of press releases and the joint management of cases with transnational relevance. The Authority has directly contributed to numerous communication activities of the Committee, such as, among others: production of enforcement news for the Italian section of the website; collaboration with specific working groups, particularly the "Support Expert Group," and in the implementation of activities related to the "Coordinated Implementation Framework"; contribution to the launch of the communication project dedicated to small and medium-sized enterprises; collaboration in updating statistics on activities carried out; collaboration in developing new shared guidelines for communication activities on cross-border cases. Also noteworthy are the communication activities related to the ARC II Project (see 21.6).

23.6. Public Assistance and Preparation of New Informational Tools

During 2023, the Authority continued to manage information on issues related to personal data protection through the Public Relations Service, including a telephone listening service and email; daily inquiries of various natures from public and private entities and citizens are presented, often of significant complexity and delicacy. In-person public reception has been reserved for the handling of more articulated and complex cases, while for the rest, the Service has primarily relied on telematic tools.

The Public Relations Service has continued to represent an essential point of contact for citizens with the Authority and has simultaneously performed a filtering function, taking care, where possible, to provide direct responses to incoming requests. During the period in question, there was a notable increase in requests for specific information related to the interpretation of the GDPR and the coordination between specific sector regulations and personal data protection, as well as the methods of protection.

at the Authority, received not only from interested citizens but also from lawyers and consultants, journalists, officials of public entities, DPOs, students/researchers particularly in the public and private sectors, healthcare, labor, and education. The interest of users regarding these topics is demonstrated by the numerical data related to contacts with the Service, which total 15,048, including 10,815 emails, 161 files, approximately 4,000 via phone, and 72 visitors on-site (see part IV, table 15).

For the purpose of enhancing the informational tools available to the public, in light of the most frequently reported issues and the evolution of the regulations, notes on various topics have been prepared to provide more in-depth responses to user requests (among others, e.g., regarding the processing of medical reports, the CIE, whistleblowing, the processing of minors' data, AI, the Disability card, as well as concerning Google Analytics 4 and the novelties of the FSE). The Service has also informed other organizational units of the Authority regarding the most sensitive and significant issues for users, including through quarterly reports.

Among the ordinary activities and support for users, assistance with requests concerning the online services active on the institutional website should be highlighted (in particular, the service for communicating the contact details of the DPO, the online service dedicated to data breaches, the reporting of unwanted communications, and the reporting to prevent the phenomenon of revenge porn), which involved constant coordination with other interested organizational units. For coordination

and collaboration purposes, reports of any anomalies found in the online forms and requests for the improvement/functioning of the official website have been effectively addressed. Such requests have been autonomously responded to in some cases related to the interpretation of the regulations, and in collaboration with the External Relations and Media Service as well as the Department of Digital Technologies and Cybersecurity in other cases concerning technical issues.

Finally, prompt responses have been provided to multiple requests regarding files assigned to other organizational units (for about 900 emails). Among the general topics of interest, those concerning forms of protection (approximately 1,195 emails received) and the obligations provided for by the GDPR (over 1,900 emails concerned the designation of the DPO and the online procedure carried out by the Authority for the communication of the DPO's contact details) are particularly noteworthy. Other ordinary issues of interest have concerned the processing of personal data in the public and private labor sectors (over 250 emails); video surveillance in public and private settings and in the workplace (almost 600 emails); the processing of personal data in the context of the internet and the use of Google Analytics, AI, as well as in journalism, with reference to requests for de-indexing personal data from search engines (over 650 emails).

In particular, starting from September 2023, several requests have been received from DPOs regarding the performance of their role (responsibilities, difficulties in exercising their functions, requests for a dedicated contact channel with the Authority, etc.). This topic has proven to be of interest as the EDPB, in its coordinated action for the implementation of the GDPR (Coordinated Enforcement Framework - CEF), has identified the role of DPOs as a focus for 2023 (see 21.1).

239

Topics of Interest

2023 REPORT

The Office of the Authority

ANNUAL REPORT

2023

III - The Office of the Authority

Study and Documentation Activities

The study and research activities have concerned multiple technical-legal issues on matters of interest, also subject to preliminary ruling before the Court of Justice of the European Union. Particular in-depth studies have been conducted, among other things, on digital inheritance, remote monitoring, whistleblowing, and generalized civic access. In continuity with a now consolidated study activity, an Observatory has been maintained for internal use on a monthly basis, serving as a summary documentation of the constant monitoring of national and EU data protection legislation, jurisprudence, and doctrine, along with in-depth studies on specific issues or sectors with profiles of interest related to the Authority's competencies.

Also through the aforementioned Observatory, thematic in-depth studies have been conducted, often in conjunction with the publication of judgments from European and national jurisdictions. In implementation of national and European regulations (see articles 154, paragraph 1, letter e), of the Code as well as 59 of the GDPR), the drafting of the Report has been managed, aimed at accounting, primarily to Parliament and the Government, for the activities carried out by the Authority. The structure of the Report, which traditionally presents a general part and multiple thematic sections (including those containing statistical data), allows for quick and concise consultation of specific information, particularly regarding the regulatory, sanctioning, and communicative activities of the Authority, as well as the European and international scope.

In accordance with the provisions of Article 22, Law Decree No. 90/2014 converted into law on August 11, 2014, No. 114, the annual report of the Authority (similarly to that of other independent administrative authorities) has also been transmitted to the Court of Auditors.

Study, Documentation, and Legal Support Activities

****Administrative Management and IT Systems****

25.1. **The Budget and Economic-Financial Management of the Authority**

The budget forecast for the fiscal year 2023 has been prepared in compliance with the current legislative provisions regarding the harmonization of public administration accounts and has taken into account the regulatory measures provided by the internal regulations of the Authority.

Regarding the formulation of forecasts, revenues have been quantified based on a general principle of prudence, while expenditures have been assessed considering the finalized contracts and the funding requests represented by the competent organizational units, ensuring compliance with specific budgetary constraints.

In terms of controls, the overall management has been subjected to review by the internal body responsible for verifying administrative-accounting regularity, which found no irregularities, while the management report has been transmitted to the Court of Auditors, in compliance with specific legislative provisions, for the relevant checks.

The sources of funding are exclusively represented by transfers made available by the legislator to ensure the functioning of the structure and the fulfillment of the multiple competencies assigned to the Authority by both national and EU regulations. For the year 2023, the budget law of December 29, 2022, no. 197, has provided for an allocation of 47,367,934 euros, to which have been added reimbursements of various nature provided by national administrations and EU bodies totaling 23,347 euros. It should be noted, however, that the burden placed on the state budget to ensure the proper functioning of the Authority is partially offset by the sums directly acquired by the state coffers resulting from the sanctioning activities of the Authority.

From a strictly accounting perspective, against the revenues acquired by the Authority in 2023 totaling 47.3 million euros, and net of the revolving funds amounting to 11.2 million euros, expenditure commitments of 38.2 million euros have been recorded. Therefore, the financial result of the fiscal year has recorded a budget surplus of 9.1 million euros, due to a management policy focused on enhancing and optimizing the use of public resources. For example, the procedures for the recruitment of new personnel, planned with the increase of the organizational structure, have been spread over multiple financial years, allowing for a better balance between expenditure needs and available resources, generating a positive effect in terms of financial management.

Compared to the previous fiscal year, the increase in total revenues recorded in 2023 was 2.1 million euros, with a positive variation of 4.59%.

Regarding expenditures, the costs recorded in the year, amounting to 38.2 million euros, show an increase of 4 million euros compared to 2022, with a negative deviation of about 12%. The total expenditure is mainly attributable to current management, amounting to 37.6 million euros, while the residual part represents the share of financial resources allocated to durable purchases consisting mainly of software products and IT equipment used to support institutional activities. Also for 2023, the structure of expenditure highlights, as in the past and in analogy with other independent administrative authorities, a significant incidence of personnel costs relative to the total expenditure for functioning. The remuneration recognized to the president and the members of the Authority's College has been defined within the limits and based on parameters specified by law, and the Office has provided for its payment in compliance with the existing constraints and prescriptions.

Finally, regarding the costs strictly related to management needs, the Authority has ensured compliance with legal limits. Reference is made to section IV, table 21, for a brief illustration of the financial management values divided between revenues and current expenditures, capital account, and mere transfers. The relevant amounts are compared with the corresponding values of the previous fiscal year to highlight the respective deviations, both in absolute value and in percentage terms.

25.2. ****Contractual Activity, Logistics, and Maintenance of the Property****

During 2023, the new public contracts code (Legislative Decree of March 31, 2023, no. 36) was approved, containing numerous and substantial innovations regarding the digitization of the contract lifecycle: use of telematic platforms, publicity of tender documents, transparency, access to documents, e-procurement, and compliance with the ANAC database. The adjustment to the new provisions has resulted in a significant increase in activities for the resources employed in the contracts sector, both in organizational terms and in learning new processes.

competences, also through

appropriate training activities (see below).

Consequently, the internal provisions, procedures, and forms have been updated. In this context, the approval of the new directive regarding works, services, and supplies, adopted in June 2023 by the determination of the Secretary General, has taken on particular importance.

In this case as well, the content and procedural innovations of the relevant provisions have been the subject of specific training activities during 2023.

These paths of administrative and managerial innovation have been added to the ongoing activities already initiated in 2022, aimed at qualifying the Office of the Guarantor as a contracting authority authorized by ANAC. As a result of this activity, concluded in June 2023, the Office has obtained this qualification for service and supply contracts for amounts less than 5 million euros, thus falling within the narrow group of qualified Italian contracting authorities (10%) that were qualified as of the effective date of the new qualification system (July 1, 2023).

Regarding public procurement, for the year in question, the Authority has continued to utilize, in full compliance with current regulations, awarding procedures based on comparisons, primarily using the purchase and negotiation tools provided by CONSIP S.p.A., where available. It should be noted that the Authority has continued to rigorously apply the fundamental principles of the public contracts code, particularly those of rotation among contractors and competition among them, as demonstrated by the wide diversification of the identities of contracting companies, even in the case of modest contracts, also due to the facilitated process provided by the use of the Electronic Market of public administration (MEPA) and its more streamlined procedures.

From an operational standpoint, the Authority has initiated in the current year the execution of two new contracts: the first related to software for managing tenders and the procurement cycle on a Platform certified by ANAC, the second related to managing transparency compliance (see par. 25.4).

****Programming****

****Award Procedures****

Regarding the biennial programming of requests for the purchase of goods and services, following the planned activities of dialogue with the organizational units for collecting needs and the related verification of financial coverage, the Purchasing Program for the biennium 2023-2024 has been approved by the Secretary General. In order to comply with publicity and transparency obligations, the publication of the Program on the website of the Ministry of Infrastructure and Transport and on the Authority's portal has been initiated at this stage.

From a procedural standpoint, the process of planning the purchases of goods and services has not undergone substantial changes due to the new public contracts code; however, some organizational adjustments will need to be made both regarding the changed frequency of programming (which shifts from biennial to triennial) and concerning the different threshold set by the code for services and supplies to be included in the programming document, amounting to 140,000 euros starting from 2024.

During 2023, the most significant contractual activity in terms of resource use—human and economic—has been the open procedure above the EU threshold for managing the 2023-2025 health plan, preceded by the necessary discussions with trade unions. The tender was awarded in relatively short time, through the signing of the relevant Agreement with a Health Assistance Fund for a duration of two years, subject to possible extension.

Regarding other commodity sectors, the Office's negotiation activity has primarily focused on the ICT sector (for about 25% of the procedures and nearly 60% of the amounts awarded), also due to the increase in the organizational structure and the simultaneous adoption of measures aimed at stabilizing the remote working modality, as well as the initiation of a new system for digitizing internal processes that has involved the acquisition of new application solutions dedicated to managing transparency obligations, internal training, and automating certain activities, in line with the more structural and strategic project of gradual transition to cloud-based digital services. In this context, the adherence to the national strategic hub, partially funded with community resources, has resulted in the reorganization of the purchasing program for additional goods and services related to the ICT sector.

In 2023, three requests for offers were awarded on the MEPA, concerning respectively: press review services;

printing services for the Authority's editorial products (Annual Report, brochures, manuals, books); the operational support service for processing the economic competencies of personnel.

In order to ensure the maximum possible competition, along with the speediness

****Office of the Guarantor****

****The Guarantor's Headquarters and Related Maintenance Contracts****

The portal Acquistinretepa.it managed by CONSIP, which includes the MEPA, continues to be the reference point in the contracts sector regarding adopted procedures: 56% of the number of contracts awarded below the EU threshold for the year in question has been concluded through it, representing 82% of the total value of these contracts. The CONSIP portal has thus continued to play a fundamental role, both due to the wide availability of purchasing initiatives and the effectiveness of price comparison tools, although during the reference period, the usability of the site experienced some service disruptions due to the need for updates to comply with new sector regulations.

The activity of constantly updating the list of independent lawyers that the Authority can resort to for legal representation in the interest of the Guarantor has also continued, in the rare cases where its defense cannot be assumed by the State Attorney's Office due to the public nature of the opposing party.

The Guarantor's offices are rented, and the Authority does not own properties designated for residential or guest accommodation. Considering the need to reorganize the logistics of its headquarters in light of the expected increase in personnel, various market surveys were conducted in 2023 aimed at acquiring expressions of interest regarding the sale or passive lease of a property suitable for office use as the institutional headquarters of the Guarantor. As a result of these procedures, no satisfactory allocation solutions were identified concerning the expected requirements and/or the financial availability of the Authority.

Regarding services related to the headquarters—cleaning, reception, ordinary maintenance, systems—in view of the contractual deadlines set for January 31, 2024, a detailed comparison process has been initiated, taking into account the available purchasing tools: the CONSIP "Facility Management 4" Agreement, the CONSIP "large properties" Framework Agreement, as well as the extension of the current contract, under the terms already provided in the tender conducted on the Dynamic System of the public administration of CONSIP. The ongoing uncertainties regarding the final arrangement of the headquarters ultimately led to this last solution, formalized at the beginning of 2024, with a reserve to proceed subsequently with adherence to one of the aforementioned purchasing tools.

Regarding the maintenance and logistical efficiency of the currently used property, optimization interventions have been carried out, also adopting open space furnishing solutions for setting up more functional and versatile work environments, always in compliance with the safety standards provided by Legislative Decree No. 81/2008 and subsequent amendments. The Guarantor has also initiated a study for the reorganization of office spaces according to the needs arising from the increasingly widespread use of agile work. Finally, in agreement with the property owner of the building housing the Guarantor's headquarters, a project has been developed for the adoption of measures to contain energy expenditure and for green certification, in full compliance with the directives and provisions, including local ones, issued in this regard.

****25.3. The Organization of the Office****

In the reference year, the process of implementing the Authority's strategic plan for the full achievement of the programmed objectives has continued, following a dual line of action that aims, on the internal side, to strengthen the workforce and re-engineer work processes, and on the external side, to enhance forms of collaboration with institutional and social stakeholders who participate in

their respective fields on issues of personal data protection (e.g., combating cyberbullying, impacts of artificial intelligence, etc.).

****Strengthening of the Authority****

****Agile Work****

****Trade Union Relations****

****Workplace Safety****

****Staff Training****

Regarding the recruitment of personnel, 2023 was also significantly impacted by the management of competitive procedures aimed at the gradual filling of positions in the organizational structure. In particular, in addition to the completion of some of the procedures related to the competitions announced in the previous year (including the hiring and integration phase of the new personnel hired), the competent offices of the Authority have been engaged in the preparation of the acts and actions necessary for the conduct of new competitive procedures aimed at the selection and recruitment of sixteen positions for officials with specific expertise in personal data protection, and one position for an official to perform the duties of a specialized linguistic translator for translation from Italian to English (joint announcement with AGCM). Furthermore, a comparative procedure was activated and defined for the assignment, pursuant to Article 7, paragraph 6, of Legislative Decree No. 165/2001, of four two-year assignments to consultants specialized in the field of artificial intelligence. The candidates who were successful in the procedure, however, declined the assignment.

Based on the experience gained during the emergency period, the Authority has redefined the institution of agile work as a regulated, structural, and flexible mode of performing work, concluding a shared process with the trade union organizations that led to the signing of an agreement consistent with the relevant regulations, including the legal provisions for the protection of vulnerable workers.

During 2023, the Office was also constantly engaged in managing the agreement on agile work signed in April 2022 and extended for the reference year, including the renewal of individual contracts for the participating personnel with all related administrative obligations.

Regarding the management of trade union relations, 2023 was also marked by ongoing discussions with trade union organizations on various negotiation issues, such as the adjustment of salary tables, the health plan for personnel, and the aforementioned agreement for conducting work activities in agile mode.

In terms of worker safety and health, activities continued to manage individual safety profiles, particularly concerning the execution of the medical examination plan to monitor the psychophysical health status of workers, according to the methods established by Legislative Decree No. 81/2008.

In particular, during 2023, the program of medical examinations related to the first cycle of health surveillance, which involved all personnel, was completed. Additionally, constant communication with the competent doctor continued to ensure a correct and fair application regarding the institutes of exceptional health surveillance and the extension of emergency agile work in favor of vulnerable workers, as well as concerning safety and health in the workplace, also with the collaboration of the Head of the Prevention and Protection Service. The Authority has increased the number of units comprising the first aid and fire-fighting teams to ensure the best safety conditions within its premises.

Also in 2023, the Authority engaged in identifying innovative training solutions for the growth of individual and group skills, consistently with the needs expressed by the respective Services and Departments. To this end, the collaborative relationship with the National School of Administration (SNA) was extended, whose catalog is constantly updated also thanks to the Club of Trainers of the same school. This is a project that also involves the Authority's representatives to improve the degree of coherence of the SNA's educational programming with the actual training needs of the administrations and the...

same Authority. At the same time, the Authority has joined the courses included in the initiative managed by INPS, called Valore PA, and the online platform Syllabus of the Department of Public Function, through which it is possible to participate in training courses available remotely, in e-learning

mode. Furthermore, taking into account the entry into force of the new public contracts code, the Authority organized, during 2023, various thematic deepening cycles related to the new provisions, intended for its staff, through online courses or self-training. Always in the area of public contracts, the Office has worked towards specific training, particularly concerning the unique project managers, also through training sessions provided remotely by a specialized company in the sector; these activities are also relevant for the qualification of the contracting authority with ANAC.

These multiple initiatives have been alongside the ordinary internal updating activities, ensured through the preparation of thematic documentation dossiers and the constant monitoring of regulatory changes as well as the relevant administrative decisions (primarily by ANAC) and judicial decisions made by the Studies and Documentation Service (see chapter 24). The recourse to the aforementioned training paths, which did not incur significant financial burdens on the Authority's budget, has allowed for considerable cost savings in light of a quantitative and qualitative increase in the training offer for the benefit of its staff. The search for innovative solutions has also led, after a careful experimentation and technological scouting process, to the acquisition of a cutting-edge digital solution aimed at converging a plurality of internal and external educational contents onto a single e-learning platform, accessible by staff as live events or in deferred and on-demand mode.

Finally, regarding the training and updating obligations of workers in the field of health and safety, as per Legislative Decree No. 81/2008, the individual paths "Medium Risk" have been completed for all staff. Specific training courses have also been provided for the staff identified for first aid, fire prevention, and use of defibrillators, adequately located at the Authority's headquarters. The management control at the Authority continues to focus on the periodic analysis of the affairs assigned to the various organizational units through the "Archiflow" protocol system and the consequent production of monthly statistical reports that focus on the progress of the handling of affairs, accounting for the flows related to the affairs assigned and resolved by the organizational units.

The Data Protection Officer has ensured both the usual support to the data controller and the supervisory activities provided for by Article 39 of the GDPR. The activities of the DPO during the year have intensified given the need to respond to an increasing number of issues of internal interest as well as requests from external parties. In particular, support has been provided to the network of DPOs of European data protection authorities, established within the European Data Protection Board (EDPB-DPO Network), in addressing the most common issues of mutual interest related to the application of national and EU legislation. Furthermore, at the national level, regarding the network established among the DPOs of independent authorities, contributions have been made to the organization of thematic meetings and in-depth seminars aimed at sharing knowledge and exchanging experiences related to the application of the regulations in the specific context of Italian authorities. The number of emails received at the dedicated inbox has also increased, to which timely responses have been provided.

25.4. "Transparent Administration" and compliance with anti-corruption regulations

At the Authority, the transparency regulations have continued to be implemented as well as the general measures aimed at preventing phenomena falling within the broad definition of "corruption"; a summary of the salient aspects of the activities carried out can be derived from the annual report of the Responsible for the Prevention of Corruption and Transparency (RPCT) referred to 2023, which is published in the "Transparent Administration" section (doc. web no. 9979018).

Within this general framework, the Authority, considering that independent administrative authorities are not required to adopt the Integrated Plan of Activities and Organization (PIAO) – as reiterated by ANAC in its "Guidelines for Anti-Corruption and Transparency Planning 2022" of February 2, 2022, particularly on pp. 3-4, and in the National Anti-Corruption Plan 2022, p. 26 – adopted, with resolution No. 78 of March 23, 2023, the Three-Year Plan for the Prevention of Corruption and Transparency 2023-2025 (doc. web no. 9870327).

Thanks to the contribution of the competent organizational units, the "Transparent Administration" section of the institutional website has been updated; based on ANAC resolution No. 203 of May 17,

2023, the detection grid has also been published (see doc. web no. 9929200) made available through the web application.

****Translated Document:****

Prepared by ANAC, whose drafting, in the absence of OIV or equivalent structures at the Authority, was managed by the RPCT; the latter also proceeded to publish the monitoring and certification sheet (doc. web no. 9961572).

Even following the aforementioned monitoring activities, in order to ensure the timely fulfillment of transparency obligations, the Authority has innovated the internal publication process by utilizing professional support provided by a software house specialized in SaaS solutions for public administration, consisting of an application solution transferred under the reuse formula pursuant to Articles 68-69 of the CAD. The adoption of professional software to more effectively comply with the provisions of Legislative Decree No. 33/2013 (specifically PAT - Transparent Administration Portal of AgID) indeed aims to streamline internal information flows, allowing individual organizational units to autonomously manage the functions of entering acts within their competence through a rapid, intuitive, and constantly updated procedure in line with the regulatory framework. This innovation will take effect with the full operation of the portal (scheduled for the first quarter of 2024). As an additional action aimed at improving the qualitative and quantitative aspects of previous publications, the timely recognition of recoverable data in open format should be mentioned.

From a prospective viewpoint (also for the purposes of preventing corruption and increasing the level of transparency), particular importance has been attributed to the design of the digital management system for work processes (Business Process Management) through the establishment of a team composed of personnel from various administrative functions (technological and organizational) (see par. 25.5). Following the introduction of Legislative Decree No. 24 of March 10, 2023 (Implementation of Directive (EU) 2019/1937 of the European Parliament and of the Council, of October 23, 2019, concerning the protection of persons who report breaches of Union law and containing provisions regarding the protection of persons who report breaches of national regulatory provisions), the procedure for reporting unlawful acts – already active at the Authority since 2018 – has been revised through specific instructions issued by the Secretary General with circular dated December 28, 2023, published on the intranet as well as in the "Transparent Administration" section of the website (doc. web no. 9967753).

****25.5. The IT-Technological Sector and Digital Transition****

The year 2023 was characterized by significant development and evolution activities of information systems in a cloud perspective in the application-functional components (online services) and in the infrastructural ones.

Regarding application-functional developments, numerous evolutionary activities and design aimed at the re-engineering of certain processes have been carried out.

Concerning online services, improvements have been made to the service reserved for the communication of the RPD's contact data, with the release of a new functionality for sending feedback to previous RPDs in the event of changes in communications.

Within the service reserved for reports of unwanted phone calls, the possibility of making reports has been activated, requiring authentication through SPID, CIE, and eIDAS systems.

For online reports regarding revenge porn, additional methods for the secure consultation of materials provided by reporters have been made available.

Using the same technological platform, the following functionalities have also been developed and made available to the relevant Departments/Services:

- For reports regarding revenge porn, a system has been created that allows for the management of assignments as well as the status of processing;
- For managing relations with the public, a system has been created that allows for a quicker and more

efficient response to requests for information regarding the communication of the RPD's contact data;
- For reports regarding unwanted phone calls, new functions have been implemented for the analysis of collected information.

As part of the re-engineering of internal processes, a new technological platform has been identified for the implementation of a Business Process Management system (and the related procurement procedure for goods and services) and the design of a first release of the new service aimed at external users for the transmission of complaints and reports.

Finally, in relation to enhancing resilience in the area of cybersecurity, the Authority has joined a specific initiative promoted by the National Cybersecurity Agency and funded by resources provided by the PNRR (see public notice no. 7/2023), which resulted in the recognition of substantial funding for the analysis of the Authority's security posture.

Regarding infrastructural aspects, the participation in the PNRR call published by the Department for Digital Transformation of the Presidency of the Council of Ministers has been particularly significant, allowing for the submission of a funding application for the migration of its IT infrastructure to the newly established National Strategic Hub.

As part of these activities, the Authority has been granted funding (by decree of the Head of the Department for Digital Transformation), the financial provision of which is covered by PNRR funds. Following the funding, activities have been initiated for the conclusion of a service contract with the National Strategic Hub S.p.A., which includes both services related to the provision of the web platform supporting the institutional website and those related to the establishment of a federated IaaS (Infrastructure as a Service) infrastructure with the current infrastructure, equipped with characteristics of resilience, reliability, performance, and security suitable for the challenges of digital transformation. To this end, the Authority has also joined the specific Agreement of the Presidency of the Council of Ministers - Department for Digital Transformation dated August 24, 2022.

During 2023, numerous other IT activities have also been completed, including the establishment of a new connection to the Public Connectivity System (SPC) via the Fastweb network, the reconfiguration and modernization of active network devices, the implementation of a new mail exchanger system with advanced security features, and the preparation of the Virtual Desktop Infrastructure to support internal mobility and remote work.

Finally, the contribution of technological analysis provided to the evaluation and decision-making activities of the Authority in multiple contexts has been relevant and fundamental, in light of the progress of digital administration and the implementation of the PNRR, as well as, obviously, the pervasive use of new technologies or already known technologies employed in innovative ways. In this regard, we highlight the establishment of the laboratory to support the verification activities related to the strategic case identified at the level of the CEPD concerning smart TVs (see par. 12.9).

IV - Statistical Data 2023

Summary of the main activities of the Authority

Total number of collegial measures adopted

Responses to acts of inspection and control

Hearings of the President of the Authority or written submissions sent to Parliament

Opinions on primary state regulations, regional regulations, and autonomy under art. 36, par. 4, GDPR

Opinions on regulatory and administrative acts under art. 36, par. 4, GDPR

Opinions pursuant to art. 36, par. 1, GDPR (data protection impact assessment)

Opinions pursuant to art. 110 of the Code for the implementation of a medical, biomedical, and epidemiological research project as well as under art. 36 of the GDPR

Opinions pursuant to art. 5, paragraph 7, Legislative Decree no. 33/2013

Authorizations of administrative agreements pursuant to arts. 46, par. 3, lett. b), 58, par. 3, lett. i) and 63, GDPR

Collegial measures following complaints, reports as well as following official investigations

Collegial measures following complaints, reports as well as following official investigations with simultaneous injunction orders

Collegial measures following notification of data breaches

Collegial measures following notification of data breaches with simultaneous injunction orders
Corrective and sanctioning measures (art. 58, par. 2, GDPR)

Corrective and sanctioning measures (Legislative Decree no. 51/2018)

Judicial appeals handled under art. 152, Legislative Decree no. 196/2003

Oppositions (handled) to measures of the Authority

Payments resulting from sanctioning activity

Communications of news of crime to the judicial authority

Management resolutions on revenge porn ratified by the Board

Measures approving codes of conduct

Notified personal data breaches

Investigations and inspections carried out on-site (arts. 157-158, Legislative Decree no. 196/2003)

Responses to reports and complaints (art. 11, Garante regulation no. 1/2019)

Responses to inquiries (art. 11, Garante regulation no. 1/2019)

Contacts Public Relations Service

IMI procedures for cooperation and consistency (Chapter VII GDPR)

Meetings of the European Data Protection Board

Participation in working subgroups of the EDPB

Meetings and inspections of joint control authorities/supervisory bodies (EUROPOL, SIS II, Customs, EURODAC, VIS)

Meetings at the CoE and the OECD

International conferences

Other conferences and meetings

634

1

8

6

53

6

****Table 1. Summary of the main activities of the Authority****

(*) also concerning matters received prior to 2023

****REPORT 2023IV****

****Table 2. Opinions pursuant to Article 36, paragraph 4, GDPR on primary state regulations, regional laws, and autonomous regulations****

****Table 3. Opinions pursuant to Article 36, paragraph 4, GDPR on regulatory and administrative acts submitted to the Government****

Opinions pursuant to Article 36, paragraph 4, GDPR on primary state regulations, regional laws, and autonomous regulations

****Topics****

Economic activities/tax assessment

Digitalization of public administration

Justice

Open data

****Total****

Responses provided in the year*

2

1

2

1

6

Opinions pursuant to Article 36, paragraph 4, GDPR on regulatory and administrative acts submitted to the Government

****Topics****

Digitalization of public administration

Taxation

Public interest functions

Justice

Businesses

Interceptions

Education

Health

Transport

****Total****

Responses provided in the year*

10

1

1

18

4

2

2

13

2

53

****Table 4. Opinions pursuant to Article 36, paragraph 4, GDPR on regulatory and administrative acts submitted to other institutions****

Opinions pursuant to Article 36, paragraph 4, GDPR on regulatory and administrative acts submitted to other institutions

****Topics****

Digitalization of public administration

Fundamental rights

Taxation

Public interest functions

Statistics

****Total****

Responses provided in the year*

3

2

6

1

1

13

****IV STATISTICAL DATA****

****Table 5. Opinions pursuant to Article 36, paragraph 1, GDPR (data protection impact assessment)****

****Table 6. Corrective and sanctioning measures (Article 58, paragraph 2, GDPR)****

Opinions pursuant to Article 36, paragraph 1, GDPR (data protection impact assessment)

****Topics****

Digitalization of public administration

Public interest functions

Statistics

****Total****

Responses provided in the year*

2

3
1
6

Corrective and sanctioning measures (Article 58, paragraph 2, GDPR)

Warnings to the data controller/processor regarding the fact that the proposed processing may likely violate the GDPR (Article 58, paragraph 2, letter a), GDPR)

Reprimands to the data controller/processor for GDPR violations (Article 58, paragraph 2, letter b), GDPR)

Injunctions to the data controller/processor to comply with requests from data subjects to exercise their rights under the GDPR (Article 58, paragraph 2, letter c), GDPR)

Injunctions to the data controller/processor to bring processing into compliance with the provisions of the GDPR (Article 58, paragraph 2, letter d), GDPR)

Injunctions to the data controller to notify the data subject of a personal data breach (Article 58, paragraph 2, letter e), GDPR)

Impositions of temporary or definitive restrictions on processing, including a ban on processing (Article 58, paragraph 2, letter f), GDPR)

Orders for rectification/deletion of personal data or limitation of processing pursuant to Articles 16, 17, and 18 and other measures provided for by Article 58, paragraph 2, letter g), GDPR)

Administrative monetary penalties pursuant to Article 83 (Article 58, paragraph 2, letter i), GDPR)

****Total****

8
65
25
46
3
62
21
166
396

****Payments resulting from sanctioning activity****

Voluntary payments by offenders

Coercive collection

****Total****

****Table 7. Payments resulting from sanctioning activity****

6,432,046.65
1,545,296.12
7,977,342.77

****Communications of criminal offenses to the judicial authority****

Unauthorized access to a computer or telematic system (Article 615-ter, Criminal Code)

Non-compliance with measures of the Guarantor (Article 170, Legislative Decree No. 196/2003)

Identity theft (Article 494, Criminal Code)

Illegal processing of data (Article 167, Legislative Decree No. 196/2003)

Violations regarding remote monitoring of workers (Article 171, Legislative Decree No. 196/2003)

****Total****

****Table 8. Communications of criminal offenses to the judicial authority****

*also related to violations reported in previous years

1
1
2
1
2

****Personal data breaches reported by type of data controller****

Public entities

Private entities

****Total****

****Notifications of personal data breaches received by type of notification****

Complete

Preliminary

Supplementary*

****Total****

753

1,284

2,037

734

1,303

1,403

3,440

****Table 9. Personal data breaches reported by type of data controller****

****Table 10. Notifications of personal data breaches received by type of notification****

****Graph 11. Notifications of personal data breaches received by nature of the breach****

(*) also concerning matters received prior to 2023

****IV STATISTICAL DATA****

****Table 12. Reports and complaints****

****Reports and complaints****

Inspection activities

Legal affairs and justice

Artificial intelligence

Freedom of expression and cyberbullying

Economic and productive realities

Public realities

Telematic networks and marketing

Health and research

Digital technologies and cybersecurity

Other Units

****Total****

Received in the year

0

170

1

1,335

3,232

1,284

113,829

255

44

161

120,311

Responses provided in the year (*)

20

130

0

999**

3,388

1,124

3,142

278

43

157

9,281

****Questions****

****Table 13. Questions****

Legal affairs and justice

Artificial intelligence

Freedom of expression and cyberbullying

Economic and productive realities

Public realities

Telematic networks and marketing

Health and research

Digital technologies and cybersecurity

Other Units

****Total****

Received in the year

6

3

12

87

113

48

38

1

73

381

Responses provided in the year (*)

9

0

16

157

179

27

33

0

85

506

(*) also concerning matters received prior to 2023

(**) of which 299 concerning revenge porn

****Table 14. Public relations service****

****Public relations service****

Emails examined

Phone contacts

Visitors to the SRP

Processing of cases related to files

****Total****

10,815

4,000

72

161

15,048

Chart 15. Subject of the emails examined by the Public Relations Service

Table 16. Cooperation between national data protection authorities - IMI procedures (Chapter VII GDPR)

Cooperation between national data protection authorities - IMI procedures (Chapter VII GDPR)

1) Final decisions adopted within the framework of cooperation activities in which the Authority acted as:

- a) "lead authority" (LSA)
- b) "concerned authority" (CSA)
- c) other

2) Preliminary procedures pursuant to Article 56 of the GDPR

- a) Preliminary procedures received in which the Authority declared itself as "concerned authority"
- b) Preliminary procedures received in which the Authority declared itself as "non-concerned authority"
- c) Preliminary procedures received in which the Authority assumed the role of "lead authority"
- d) Preliminary procedures received in which the Authority provided other feedback
- e) Preliminary procedures initiated by the Authority
- f) Preliminary procedures received and examined in which the Authority did not provide feedback
- g) other

3) Cooperation procedures with exclusively local impact pursuant to Article 56, paragraph 2, of the GDPR

301

575

7

285

9

295

177

11

4

7

10

71

1

(continued)→

261

REPORT 2023 IV

Cooperation between national data protection authorities - IMI procedures (Chapter VII GDPR)

←(continued)

4) Informal cooperation procedures pursuant to Article 60 of the GDPR in which the Authority participated as:

- a) "concerned authority"
- b) "lead authority"

5) Draft decisions pursuant to Article 60 of the GDPR in which the Authority cooperated as:

- a1) "concerned authority"
- a2) "concerned authority" and in which "relevant and reasoned objections" or comments were raised pursuant to Article 60, paragraph 4, of the GDPR
- b) "lead authority"
- c) other

6) Requests for mutual assistance pursuant to Article 61 of the GDPR

a) received from other authorities

b) sent to other authorities

7) Joint operations pursuant to Article 62 of the GDPR in which the Authority participated

****Table 17. Consistency mechanism - IMI procedures (Chapter VII GDPR)****

Consistency mechanism - IMI procedures (Chapter VII GDPR)

1) Procedures related to the advisory activity of the EDPB pursuant to Article 64 of the GDPR

2) Procedures related to the decision-making activity of the EDPB for the resolution of disputes pursuant to Article 65 of the GDPR with the participation of the Authority

3) Urgent procedures pursuant to Article 66 of the GDPR

87

-

321

15

2

5

247

31

87

343

278

3

1

4

2

****Table 18. Main areas affected by cooperation procedures and the consistency mechanism****

in relation to procedures received from 01/01/2023

Main areas affected by cooperation procedures and the consistency mechanism

Insurance

Associations

Biometrics

Licensees

Religious confessions

Credit

Cyberbullying

Data in the public domain

Data in the health sector

Right to be forgotten

Businesses

Deep fake

Labor

Freedom of expression and information

262

9

1

2

1

2

78

2

11

11

34

205

1

15

14

(continued)→

****IV STATISTICAL DATA****

Main areas affected by cooperation procedures and the consistency mechanism

←(continued)

Data breach notifications

Debt recovery

Telematic networks

GDPR

Research

Cybersecurity

Video surveillance

Total

63

1

1,129

6

1

2

7

1,595

****Authority's communication activities****

Press releases

Newsletters

Editorial products

Information campaigns

Informational video spots and teasers

Infographics and thematic pages

Staff in service (*)

Area

role (a)

out of role (b)

assigned to other administrations or on leave (c)

employed by the Office (a+b-c)

Secretary General

Managers

Officials

Operational

Executive

Total

0

17

107

23

2

149

1

0

5

0
0
6
Contract staff (Article 156, paragraphs 4 and 5 of the Code)

0
2
2
0
0
4

****Table 19. Communication activities of the Authority****

****Table 20. Staff in service****

(*) Situation as of 31/12/2023

62
17
10
4
45
71
1
15
110
23
2
151
14
263

****REPORT 2023 IV****

****Table 21. Financial management****

Financial management

Confirmed revenues

Year 2023

Year 2022

Variation

€

2,782,947

%

Current revenues

Other revenues, transfers, and reimbursements

Total revenues

Committed expenses

Operating expenses

Capital expenses

Transfers to administrations

Total expenses

47,367,934

44,584,987

23,347

726,554

-703,207

47,391,281

45,311,541

2,079,740
37,630,314
33,347,228
4,283,086
210,566
362,908
448,728
380,968
-238,162
-18,060
38,203,788
34,176,924
4,026,864
6.24
-96.79
4.59
12.84

-53.07

-4.74

11.78

****Table 22. International activities of the Authority****

European Union

Plenary sessions

Subgroup on strategic issues and advisory activities (SAESG)

Meetings of subgroups

Border Travel Law Enforcement (BTLE)

i

i

t

t

a

a

d

d

e

e

n

n

o

o

i

i

z

z

e

e

t

t

o

o

r

r

p
p
a
a
l
l
r
e
e
p
p
o
o
e
e
p
p
o
o
r
r
u
u
e
e
o
o
t
t
a
a
t
t
i
i
m
m
o
o
C
C

264

January 17

February 14 and 28

March 28

April 13 and 26

May 24 and 25

June 20

July 18

August 2

September 19

October 17 and 27

November 14
December 12 and 13
February 7 and 23
March 29
June 26
July 17
September 5 and 12
October 16, 19, and 24
November 10 and 20
January 26
February 10
March 23
May 4
June 15
September 19
October 26
November 30
(continued)→
IV STATISTICAL DATA

←(continued)

i
t
a
d
e
n
o
i
z
e
t
o
r
p
a
l
r
e
p
o
e
p
o
r
u
e
o
t
a
t
i
m

o
C
European Union
Cooperation
Compliance, E-Government, and Health
Financial Matters
Cookie Banner Task Force
Key Provisions
January 18
February 9
March 21
April 18 and 24
May 16
June 15
August 22 and 30
September 5 and 26
October 19
November 16
January 24
February 21
March 9 and 10 (workshop)
March 16
April 27
May 17
June 8, 19, and 26
July 11
September 21
October 20
November 7
November 22-24 (workshop)
December 19
January 19
February 20
March 6 and 13
April 4
May 3
June 6
July 7 and 11
September 1 and 21
November 28
October 11
November 15
January 25
March 1
April 18
May 30
July 6
September 26
October 26
November 21 and 22
(continues)→
265
REPORT 2023IV

European Union
International Transfers
Technology
IT Users
Enforcement
Fining Task Force
Task Force 101 Complaints
January 10, 11, and 31
February 1 and 10
March 14
April 11
May 31
June 1
July 4
September 5 and 6
October 4 and 5
November 7 and 8
November 22-24 (workshop)
December 5 and 6
January 18-19
February 16
March 22
April 19
May 10
June 12 and 13 (bootcamp)
June 14
July 13
September 13
October 18 and 19
November 16
December 4
March 13
June 16

October 9
December 4
February 8 and 17
March 2, 16, and 22
April 4 and 18
June 7, 19, and 27
July 4, 10, and 20
August 22 and 30
September 12
October 18
December 5
February 7
March 9
April 19
June 8
September 13
November 15
December 11
February 6

****March 6****

(continues)→

⇐(continues)

i
t
a
d

e
n
o
i
z
e
t
o
r
p
a
l

r
e
p
o
e
p
o
r
u
e

o
t
a
t
i

m
o
C
266

****IVSTATISTICAL DATA****

⇐(continues)

i
t
a
d

e
n
o
i
z
e

t
o
r
p
a
l
r
e
p
o
e
p
o
r
u
e
o
t
a
t
i

m
o
C

European Union

Task Force ChatGPT

Task Force Competition and Consumer Law

Task Force International Engagements

Social Media Working Group

Coordinated Enforcement Framework

EDPB DPO Network

EDPB Communications Network

Coordinators

April 18

May 3

July 12

September 6

October 20

November 8

December 1

April 28

June 21

September 6

November 15 and 23

December 15

May 22

July 10

September 18

November 27

January 23

February 23

May 23
June 29
September 7
October 10
December 7
January 9 and 26
February 16
March 4
October 12
November 7 and 17
December 4 and 8
September 25
January 11
February 9
March 22
April 20
May 17
June 15
July 12
September 13
October 11
November 9
December 6
January 30
February 7
March 27

267

REPORT 2023IV

European Union
VIS Supervision Coordination Group
June 13, November 28
EURODAC System Supervision Group
June 13, November 28
Customs Information System Supervision Coordination Group: SID
June 13
Coordinated Control Committee (CSC)
EUROPOL Data Protection Experts Network (EDEN)
High-level Group for the Digital Markets Act
CPC-DPA (Working Group on cooperation between data protection authorities and consumer protection authorities)
March 22, June 14, November 29
September 18 and 19
November 29
May 10
November 10
Meetings at OECD and CoE
DGP Committee

(**Data Governance and Privacy in the Digital Economy**)
DGP Bureau
Advisory Committee
Convention 108/1981
(T-PD)

****T-PD Bureau****
****Committee on Artificial Intelligence (CAI)****
****April 17-18****
****November 9-10****
****January 10****
****March 21****
****April 12****
****June 6****
****June 14-16****
****November 15-17****
****March 22-24****
****September 27-29****
****January 11-13****
****February 1-3****
****April 19-21****
****May 21-June 2****
****October 24-26****
****December 5-8****
****Organization for Economic Cooperation and Development (OECD)****
****Council of Europe****

268

****IVSTATISTICAL DATA****

****International Conferences****

(****International Conference of Data Protection Authorities****)

****GPA****

(****Spring Conference of Data Protection Authorities****)

****Spring Conference****

****Privacy Symposium 2022****

****G7 of Data Protection Authorities****

****IWGDPT****

(****Berlin Group****)

****October 15-20****

****May 10-12****

****April 17-21****

****June 20 and 21****

****June 5-7****

****December 6-8****

****Other Conferences and Meetings****

****Working group on data protection engineering****

****ENISA****

****Future of Data Protection. Effective enforcement in the digital world****

****EDPS****

****Privacy Hub - From Data Access to Data Transformations: How to Govern Data in the Age of Analytics and AI?****

****Regarding AI & Data Privacy Conference****

****PETs Network - Future of Privacy Forum****

****CEN JTC 13 WG 5****

****ENISA****

****Working group on data spaces****

****European Case Handling workshop****

****Synthetic Data Summit****

****May 30-31****

**** June 16-17****

**** June 23****

**** June 23****

**** June 26-27****

**** July 5****

**** October 2****

**** November 8-9****

**** November 30****

269

****REPORT 2023IV****

****GRAPHIC LAYOUT AND PRINTING****

****Solved S.R.L. ****

****Editorial Office****

****Data Protection Authority****

****Piazza Venezia, 11****

****00187 Rome****

****Tel. 06 696771****

****e-mail: protocollo@gpdp.it****

****www.gpdp.it****